27 安全配置

关于本章

27.1 ACL配置
设备为了对不同类的报文进行不同的处理，需要配置一系列的规则，以对报文进行分类，这些规则就是通过访问控制列表ACL定义的。

27.2 本机防攻击配置
本机防攻击特性针对的是上送CPU的报文，主要用于保护设备的自身安全，保证设备在受到攻击时已有业务可以正常运转。

27.3 攻击防范配置
攻击防范是一种重要的网络安全特性。通过配置攻击防范功能，设备能够检测出多种类型的网络攻击，并能采取相应的措施保护设备自身及其所连接的内部网络免受恶意攻击，保证内部网络及设备的正常运行。

27.4 流量抑制配置
流量抑制包括流量抑制的基础知识、配置方法、配置实例和常见配置错误。

27.5 ARP安全配置
介绍ARP安全的原理和配置方法，并给出配置举例。

27.6 DHCP Snooping配置

27.7 ND Snooping配置

27.8 IPSG配置
通过配置IPSG功能，可以对接口转发的报文进行过滤控制，防止非法报文通过接口。

27.9 SAVI配置

27.10 URPF配置
配置URPF可以用来防止基于源地址欺骗的网络攻击行为。

27.11 PKI配置

27.12 SSL配置

27.13 HTTPS配置
安全超文本传输协议HTTPS（Hypertext Transfer Protocol Secure）通过SSL提供的数据加密、身份验证和消息完整性验证等安全机制，为Web访问提供安全性保证。

27.14 Keychain配置
Keychain是一个集中控制认证算法和认证密钥的应用程序，广泛应用于应用协议的认证中。

27.15 URL过滤
URL（Uniform Resource Locator）过滤可以对用户访问的URL进行控制，允许或禁止用户访问某些网页资源，达到规范上网行为的目的。

27.16 升级特征库配置
介绍如何将特征库升级到指定版本。及时更新特征库的版本，可以提高网络安全设备的动态安全防御能力。

27.17 入侵防御配置
入侵防御是一种安全机制。设备通过分析网络流量来检测入侵，并通过一定的响应方式实时地中止入侵行为。

27.18 反病毒配置
反病毒特性用于保护内网的用户和服务器免受病毒威胁。

27.19 IAE全局配置
介绍IAE（Intelligent Awareness Engine，智能感知引擎）全局性的功能配置，包括国家码、文件解压缩功能和阻断文件断点续传功能等配置。

27.20 业务与管理隔离配置
通过配置业务与管理隔离，可以提高管理网络的安全性。

27.21 弱加密算法插件管理

27.1 ACL 配置

设备为了对不同类的报文进行不同的处理，需要配置一系列的规则，以对报文进行分类，这些规则就是通过访问控制列表ACL定义的。

27.1.1 ACL 简介

介绍ACL的定义和作用。

定义

访问控制列表ACL（Access Control List）是由一系列规则组成的集合，ACL通过这些规则对数据包进行分类，从而设备可以对不同类报文进行不同的处理。

目的

网络中的设备相互通信时，需要保障网络传输的安全可靠和性能稳定。例如：

- 防止对网络的攻击，例如IP（Internet Protocol）报文、TCP（Transmission Control Protocol）报文、ICMP（Internet Control Message Protocol）报文的攻击。
- 对网络访问行为进行控制，例如企业网中内、外网的通信，用户访问特定网络资源的控制，特定时间段内允许对网络的访问。
- 限制网络流量和提高网络性能，例如限定网络上行、下行流量的带宽，对用户申请的带宽进行收费，保证高带宽网络资源的充分利用。

ACL的出现，有效地解决了上述问题，切实保障了网络传输的稳定性和可靠性。

27.1.2 原理描述

介绍ACL的实现原理。

27.1.2.1 ACL 的基本原理

ACL负责管理用户配置的所有规则，并提供报文匹配规则的算法。

ACL 的规则管理

每个ACL作为一个规则组，可以包含多个规则。规则通过规则ID（rule-id）来标识，规则ID可以由用户进行配置，也可以由系统自动根据步长生成。一个ACL中所有规则均按照规则ID从小到大排序。

规则ID之间会留下一定的间隔。如果不指定规则ID时，具体间隔大小由“ACL的步长”来设定。例如步长设定为5，ACL规则ID分配是按照5、10、15……来分配的。如果步长值是2，自动生成的规则ID从2开始。用户可以根据规则ID方便地把新规则插入到规则组的某一位置。

ACL 的规则匹配

报文到达设备时，查找引擎从报文中取出信息组成查找键值，键值与ACL中的规则进行匹配，只要有一条规则和报文匹配，就停止查找，称为命中规则。查找完所有规则，如果没有符合条件的规则，称为未命中规则。

ACL的规则分为“permit”（允许）规则或者“deny”（拒绝）规则。

综上所述，ACL可以将报文分成三类：

- 命中“permit”规则的报文
- 命中“deny”规则的报文
- 未命中规则的报文

对于这三类报文的处理方式，各个特性不同，具体请参考各特性手册。

ACL 的实现方式

目前设备支持的ACL，有以下两种实现方式。

软件ACL：针对与本机交互的报文（必须上送CPU处理的报文），由软件实现来匹配报文的ACL，比如FTP、TFTP、Telnet、SNMP、HTTP、路由协议、组播协议中引用的ACL。

硬件ACL：针对所有报文（一般是针对转发的数据报文），通过下发硬件ACL资源来匹配报文的ACL，比如流策略、基于ACL的简化流策略和用户组。

两者主要区别在于：

- 处理不同的报文类型。
- 前者由软件实现；后者由硬件实现。通过前者匹配报文时，会消耗CPU资源，通过后者匹配报文时则会占用硬件资源。后者匹配报文的速度更快。

27.1.2.2 ACL 的分类

ACL的类型根据不同的划分规则可以有不同的分类。例如：

- 按照创建ACL时的命名方式分数字型ACL和命名型ACL：
  - 创建ACL时指定一个编号，称为数字型ACL。

    说明

    编号为ACL功能的标示。例如2000～2999为基本ACL，3000～3999为高级ACL。
  - 创建ACL时指定一个名称，称为命名型ACL。
- 按照ACL的功能分类，请参见表27-1：

表 27-1 ACL 的分类

分类	适用的IP版本	功能介绍	说明
基本ACL	IPv4	可使用IPv4报文的源IP地址、分片标记和时间段信息来定义规则。	基本IPv4 ACL简称基本ACL。编号范围为2000～2999。
高级ACL	IPv4	既可使用IPv4报文的源IP地址，也可使用目的地址、IP优先级、ToS、DSCP、IP协议类型、ICMP类型、TCP源端口/目的端口、UDP（User Datagram Protocol）源端口/目的端口号等来定义规则。	高级IPv4 ACL简称高级ACL。编号范围为3000～3999。
二层ACL	IPv4	可根据报文的以太网帧头信息来定义规则，如根据源MAC（Media Access Control）地址、目的MAC地址、以太帧协议类型等。	编号范围为4000～4999。
用户ACL	IPv4	既可使用IPv4报文的源IP地址或源用户组，也可使用目的地址或目的用户组、目的域名、IP优先级、ToS、DSCP、IP协议类型、ICMP类型、TCP源端口/目的端口、UDP源端口/目的端口号等来定义规则。	编号范围为6000～6999。
基本ACL6	IPv6	可使用IPV6报文的源IP地址、分片标记和时间段信息来定义规则。	基本IPv6 ACL简称基本ACL6。编号范围为2000～2999。
高级ACL6	IPv6	可以使用IPv6报文的源地址、目的地址、IP承载的协议类型、针对协议的特性（例如TCP的源端口、目的端口、ICMPv6协议的类型、ICMPv6 Code）等内容定义规则。	高级IPv6 ACL简称高级ACL6。编号范围为3000～3999。

分类	适用的IP版本	功能介绍	说明
用户ACL6	IPv6	可以使用IPv6报文的源地址、目的地址、目的域名、IP承载的协议类型、针对协议的特性（例如TCP的源端口、目的端口、ICMPv6协议的类型、ICMPv6 Code）等内容定义规则。	用户IPv6 ACL简称用户ACL6或UCL6。编号范围为6000～6999。

说明

基本ACL和基本ACL6、高级ACL和高级ACL6、用户ACL和用户ACL6对应的编号可以相同，二者互不影响。

27.1.2.3 ACL 的命名

用户在创建ACL时，可以为ACL指定一个名称。每个ACL最多只能有一个名称。命名型的ACL使用户可以通过名称唯一地确定一个ACL，并对其进行相应的操作。

在创建ACL时，用户可以选择是否配置名称。ACL创建后，不允许用户修改或者删除ACL名称，也不允许为未命名的ACL添加名称。

在指定命名型ACL时，也可以同时配置对应编号。如果没有配置对应编号，系统在记录此命名型ACL时会自动为其分配一个数字型ACL的编号。

说明

ACL的名称对于ACL全局唯一，但允许基本ACL与基本ACL6，高级ACL与高级ACL6，用户ACL和用户ACL6使用相同的名称。

27.1.2.4 ACL 的步长设定

步长的含义

步长的含义：设备自动为ACL规则分配编号的时候，每个相邻规则编号之间的差值。例如，如果将步长设定为5，规则编号分配是按照5、10、15…这样的规律分配的。

- 当步长改变后，ACL中的规则编号会自动从步长值开始重新排列。例如，原来规则编号为5、10、15、20，当通过命令把步长改为2后，则规则编号变成2、4、6、8。
- 当使用命令将步长恢复为缺省值后，设备将立刻按照缺省步长调整ACL规则的编号。例如：ACL 3001，步长为2，下面有4个规则，编号为2、4、6、8。如果此时使用命令将步长恢复为缺省值，则ACL规则编号变成5、10、15、20，步长为5。

步长的作用

通过设置步长，使规则之间留有一定的空间，用户可以在规则之间插入新的规则，以控制规则的匹配顺序。例如配置好了4个规则，规则编号为：5、10、15、20。此时如果用户希望能在第一条规则之后插入一条规则，则可以使用命令在5和10之间插入一条编号为7的规则。

另外，在定义一条ACL规则的时候，用户可以不指定规则编号，这时，系统会从步长值开始，按照步长，自动为规则分配一个大于现有最大编号的最小编号。假设现有规则的最大编号是25，步长是5，那么系统分配给新定义的规则的编号将是30。

27.1.2.5 ACL 的匹配顺序

一个ACL可以由多条“**deny | permit**”语句组成，每一条语句描述一条规则，这些规则可能存在重复或矛盾的地方（一条规则可以包含另一条规则，但两条规则不可能完全相同）。

设备支持两种匹配顺序，即配置顺序（**config**）和自动排序（**auto**）。当将一个数据包和访问控制列表的规则进行匹配的时候，由规则的匹配顺序决定规则的优先级，ACL通过设置规则的优先级来处理规则之间重复或矛盾的情形。

配置顺序

配置顺序按ACL规则编号（rule-id）从小到大的顺序进行匹配。

自动排序

自动排序（**auto**）使用“深度优先”的原则进行匹配。

“深度优先”即根据规则的精确度排序，匹配条件（如协议类型、源和目的IP地址范围等）限制越严格越精确。例如可以比较地址的通配符，通配符越小，则指定的主机的范围就越小，限制就越严格。

若“深度优先”的顺序相同，则匹配该规则时按rule-id从小到大排列。

说明

通配符掩码与反向掩码类似，以点分十进制表示，并用二进制的“0”表示“匹配”，“1”表示“不关心”，这恰好与子网掩码的表示方法相反，另外通配符1或者0可以不连续，掩码与反掩码必须连续。比如，IP地址192.168.1.169、通配符0.0.0.172表示的网址为192.168.1.x0x0xx01，其中x可以是0，也可以是1。

ACL规则按照“深度优先”顺序匹配的原则如**表27-2**所示。

表 27-2 “深度优先”匹配原则

ACL类型	匹配原则
基本ACL&ACL6	1. 比较源IP地址范围，源IP地址范围小（掩码中“1”位的数量多）的规则优先。 2. 如果源IP地址范围相同，则rule-id小的优先。
高级ACL&ACL6	1. 比较协议范围，指定了IP协议承载的协议类型的规则优先。 2. 如果协议范围相同，则比较源IP地址范围，源IP地址范围小（掩码中“1”位的数量多）的规则优先。 3. 如果协议范围、源IP地址范围相同，则比较目的IP地址范围，目的IP地址范围小（掩码中“1”位的数量多）的规则优先。 4. 如果协议范围、源IP地址范围、目的IP地址范围相同，则比较四层端口号（TCP/UDP端口号）范围，四层端口号范围小的规则优先。 5. 如果上述范围都相同，则rule-id小的优先。

ACL类型	匹配原则
二层ACL	1. 先比较二层协议类型通配符，通配符大（掩码中“1”位的数量多）的规则优先。 2. 如果二层协议类型通配符相同，则比较源MAC地址范围，源MAC地址范围小（掩码中“1”位的数量多）的规则优先。 3. 如果源MAC地址范围相同，则比较目的MAC地址范围，目的MAC地址范围小（掩码中“1”位的数量多）的规则优先。 4. 如果源MAC地址范围、目的MAC地址范围相同，则rule-id小的优先。
用户ACL&ACL6	1. 比较协议范围，指定了IP协议承载的协议类型的规则优先。 2. 如果协议范围相同，则比较源IP地址范围，源IP地址范围小（掩码中“1”位的数量多）的规则优先。 3. 如果协议范围、源IP地址范围相同，则比较目的IP地址范围，目的IP地址范围小（掩码中“1”位的数量多）的规则优先。 4. 如果协议范围、源IP地址范围、目的IP地址范围相同，则比较四层端口号（TCP/UDP端口号）范围，四层端口号范围小的规则优先。 5. 如果上述范围都相同，则rule-id小的优先。

27.1.2.6 ACL 对分片报文的支持

设备支持通过ACL对分片报文进行三层（IP层）匹配的包过滤功能。

- 对于不包含参数**fragment**的ACL规则，设备会匹配非分片报文和分片报文。
- 对于包含参数**fragment**的ACL规则，设备则仅匹配分片报文。

说明

AC6605的GE接口，对于包含参数**fragment**的ACL规则，设备则仅匹配非首片分片报文。

因此，针对网络攻击者构造分片报文进行流量攻击的情况，可以配置包含参数**fragment**的ACL规则，使设备仅过滤非首片分片报文，从而避免因过滤掉其他非分片报文而影响业务的正常运行。

27.1.2.7 ACL 生效时间段

时间段用于描述一个特殊的时间范围。用户可能有这样的需求，即一些ACL规则需要在某个或某些特定时间内生效，而在其他时间段则不生效。例如某单位严禁员工上班时间浏览非工作网站，而下班后则允许通过指定设备浏览娱乐网站，则可以对ACL规则约定生效时间段。这时，用户就可以先配置一个或多个时间段，然后通过配置规则引用该时间段，从而实现基于时间段的ACL过滤。

如果规则引用的时间段未配置，规则不能立即生效，直到用户配置了引用的时间段，并且系统时间在指定时间段范围内，ACL规则才能生效。

27.1.2.8 IPv6 ACL

IPv6 ACL对根据配置的规则对IPv6报文进行分类，其实现原理和ACL基本相同。

IPv6 ACL简称ACL6。

ACL6 的分类

按ACL6功能不同，分类有不同，具体请参见下表，

分类	对应编号范围	应用场景
基本ACL6	编号范围为2000～2999。	可以使用报文的源IP地址、分片标记和时间段信息来定义规则。
高级ACL6	编号范围为3000～3999。	可以使用报文的源地址、目的地址、IP承载的协议类型、针对协议的特性（例如TCP的源端口、目的端口和ICMPv6协议的类型、ICMPv6 Code）等内容定义规则。
用户ACL6	编号范围为6000～6999。	可以使用报文的源地址、目的地址、目的域名、IP承载的协议类型、针对协议的特性（例如TCP的源端口、目的端口和ICMPv6协议的类型、ICMPv6 Code）等内容定义规则。

说明

ACL6和ACL命令行不同，而对应的编号可以相同，二者互不影响。

27.1.3 缺省配置

介绍ACL缺省配置，实际应用的配置可以基于缺省配置进行修改。

ACL的缺省配置如表27-3所示。

表 27-3 ACL 缺省配置

参数	缺省值
规则步长	5
匹配顺序	配置顺序

27.1.4 配置 ACL

介绍ACL详细的配置过程。

27.1.4.1 配置基本 ACL

基本ACL可以根据源IP地址对IPv4报文进行分类定义。

27.1.4.1.1 （可选）配置规则生效时间段

背景信息

某些引用ACL的业务或功能需要限制在一定的时间范围内生效，比如，在流量高峰期时启动设备的QoS（Quality of Service）功能。用户可以为ACL创建生效时间段，通过在规则中引用时间段信息限制ACL生效的时间范围，从而达到该业务或功能在一定的时间范围内生效的目的。

须知

删除ACL生效时间段，可能会导致某些ACL不生效，请谨慎操作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**time-range** *time-name* { *start-time* **to** *end-time* { *days* } &<1-7> | **from** *time1 date1* [**to** *time2 date2*] }，创建一个时间段。

设备支持具有相同*time-name*的多个时间段共同描述某个时间范围，此时可以使用相同的*time-name*反复执行本步骤。

说明

使用同一*time-name*可以配置多条不同的时间段，以达到这样的效果：各周期时间段之间以及各绝对时间段之间分别取并集之后，再取二者的交集作为最终生效的时间范围。例如，时间段“test”配置了三个生效时段：

- 从2010年1月1日00:00起到2010年12月31日23:59生效，这是一个绝对时间段。
- 在周一到周五每天8:00到18:00生效，这是一个周期时间段。
- 在周六、周日下午14:00到18:00生效，这是一个周期时间段。

则时间段“test”最终描述的时间范围为：2010年的周一到周五每天8:00到18:00以及周六和周日下午14:00到18:00。

由于网络延迟等原因，可能造成网络上设备时间不同步，建议配置NTP（Network Time Protocol），以保证网络上时间的一致。NTP的配置，请参见**6.6.4.1 配置NTP基本功能**。

----结束

27.1.4.1.2 创建基本 ACL

背景信息

基本ACL可以根据报文自身的源IP地址、分片标记信息，以及时间段信息对IPv4报文进行分类。

配置基本ACL时，需要先创建一个基本ACL。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl** [**number**] *acl-number* [**match-order** { **auto** | **config** }]，使用编号创建一个数字型的基本ACL，并进入基本ACL视图；或者执行命令**acl name** *acl-name*

{ **basic** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的基本ACL，进入基本ACL视图。

基本ACL编号*acl-number*的范围是2000～2999。

缺省情况下，未创建ACL。

步骤3 （可选）执行命令**step** *step*，配置ACL步长。

缺省情况下，步长值为5。

步骤4 （可选）执行命令**description** *text*，配置ACL描述信息。

缺省情况下，未配置ACL的描述信息。

----结束

27.1.4.1.3 配置基本 ACL 的规则

背景信息

基本ACL通过rule（规则）匹配报文的信息，实现对报文的分类，因此创建基本ACL以后，需要配置基本ACL的规则。

在ACL中添加新的规则时，不会影响已经存在的规则；对已经存在的规则进行编辑时，如果新配置的规则内容与原规则内容存在冲突，则冲突的部分由新配置的规则内容代替，建议在编辑一个已存在的规则前，先将旧的规则删除，再创建新的规则，否则配置结果可能与预期的效果不同。此外，配置规则时，如果不同的规则之间存在矛盾或包含的关系，请注意规则的匹配顺序，防止出现错误配置。

说明

设备在收到报文时，会按照匹配顺序将报文与ACL规则进行逐条匹配，一旦匹配上某条规则，则停止匹配动作。之后，设备将依据匹配的规则对报文执行相应的动作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl** [**number**] *acl-number* [**match-order** { **auto** | **config** }]，使用编号创建一个数字型的基本ACL，并进入基本ACL视图；或者执行命令**acl name** *acl-name* { **basic** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的基本ACL，进入基本ACL视图。

基本ACL编号*acl-number*的范围是2000～2999。

缺省情况下，未创建ACL。

步骤3 执行命令**rule** [*rule-id*] { **deny** | **permit** } [**source** { *source-address source-wildcard* | **any** } | **fragment** | **time-range** *time-name*] *，配置基本ACL的规则。如果需要配置多个规则，可以反复执行本步骤。

说明

在ACL中配置首条规则时，如果未指定参数*rule-id*，设备使用步长值作为规则的起始编号。后续配置规则如仍未指定参数*rule-id*，设备则使用最后一个规则的rule-id的下一个步长的整数倍数值作为规则编号。例如ACL中包含规则rule 5和rule 7，ACL的步长为5，则系统分配给新配置的未指定*rule-id*的规则的编号为10。

当用户指定参数**time-range**引入ACL规则生效时间段时，如果*time-name*不存在，则该规则配置不生效。

步骤4 （可选）执行**rule** *rule-id* **description** *description*，配置基本ACL规则的描述信息。

设备仅允许对已存在*rule-id*的规则配置描述信息，不允许先配置规则的描述信息再配置具体的规则内容。

----结束

27.1.4.1.4 应用 ACL

背景信息

ACL本身只是一组规则，只能区分报文，无法实现对报文的区别处理。对不同种类报文的处理方法，需要由引用ACL的具体功能来决定。

操作步骤

- 应用ACL。

  ACL可以在很多特性中被应用。例如，当需要对不同类型的流量进行分类操作时，可以通过应用基本ACL、高级ACL、二层ACL、基本ACL6、高级ACL6、用户ACL6实现对满足过滤条件的流量进行流量监管、流量整形、流量分类。

  说明

  能应用ACL的特性较多，对ACL分类出来的报文的处理方式也不一致。此处未一一列出，具体描述请参考各特性的配置手册。

----结束

27.1.4.1.5 检查配置结果

操作步骤

- 执行命令**display acl** { *acl-number* | **name** *acl-name* | **all** }，查看ACL的配置信息。
- 执行命令**display time-range** { **all** | *time-name* }，查看时间段信息。

----结束

27.1.4.2 配置高级 ACL

当用户需要使用源IP地址、目的IP地址、源端口号、目的端口号、优先级、时间段等信息对IPv4报文进行过滤时，可以使用高级ACL。

27.1.4.2.1 （可选）配置规则生效时间段

背景信息

某些引用ACL的业务或功能需要限制在一定的时间范围内生效，比如，在流量高峰期时启动设备的QoS（Quality of Service）功能。用户可以为ACL创建生效时间段，通过在规则中引用时间段信息限制ACL生效的时间范围，从而达到该业务或功能在一定的时间范围内生效的目的。

须知

删除ACL生效时间段，可能会导致某些ACL不生效，请谨慎操作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**time-range** *time-name* { *start-time* **to** *end-time* { *days* } &<1-7> | **from** *time1 date1* [**to** *time2 date2*] }，创建一个时间段。

设备支持具有相同*time-name*的多个时间段共同描述某个时间范围，此时可以使用相同的*time-name*反复执行本步骤。

说明

使用同一*time-name*可以配置多条不同的时间段，以达到这样的效果：各周期时间段之间以及各绝对时间段之间分别取并集之后，再取二者的交集作为最终生效的时间范围。例如，时间段“test”配置了三个生效时段：

- 从2010年1月1日00:00起到2010年12月31日23:59生效，这是一个绝对时间段。
- 在周一到周五每天8:00到18:00生效，这是一个周期时间段。
- 在周六、周日下午14:00到18:00生效，这是一个周期时间段。

则时间段“test”最终描述的时间范围为：2010年的周一到周五每天8:00到18:00以及周六和周日下午14:00到18:00。

由于网络延迟等原因，可能造成网络上设备时间不同步，建议配置NTP（Network Time Protocol），以保证网络上时间的一致。NTP的配置，请参见**6.6.4.1 配置NTP基本功能**。

----结束

27.1.4.2.2 创建高级 ACL

背景信息

高级ACL可以根据源IP地址、目的IP地址、IP优先级、ToS、DSCP、IP协议类型、ICMP类型、TCP源端口/目的端口、UDP源端口/目的端口号等信息对IPv4报文进行分类。

配置高级ACL时，需要先创建一个高级ACL。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl** [**number**] *acl-number* [**match-order** { **auto** | **config** }]，使用编号创建一个数字型的高级ACL，并进入高级ACL视图；或者执行命令**acl name** *acl-name*

{ **advance** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的高级ACL，进入高级ACL视图。

高级ACL编号*acl-number*的范围是3000～3999。

缺省情况下，未创建ACL。

步骤3 （可选）执行命令**step** *step*，配置ACL步长。

缺省情况下，步长值为5。

步骤4 （可选）执行命令**description** *text*，配置ACL描述信息。

缺省情况下，未配置ACL的描述信息。

----结束

27.1.4.2.3 配置高级 ACL 的规则

背景信息

高级ACL通过rule（规则）匹配报文的信息，实现对报文的分类，因此创建高级ACL以后，需要配置高级ACL的规则。

在ACL中添加新的规则时，不会影响已经存在的规则；对已经存在的规则进行编辑时，如果新配置的规则内容与原规则内容存在冲突，则冲突的部分由新配置的规则内容代替，建议在编辑一个已存在的规则前，先将旧的规则删除，再创建新的规则，否则配置结果可能与预期的效果不同。此外，配置规则时，如果不同的规则之间存在矛盾或包含的关系，请注意规则的匹配顺序，防止出现错误配置。

说明

设备在收到报文时，会按照匹配顺序将报文与ACL规则进行逐条匹配，一旦匹配上某条规则，则停止匹配动作。之后，设备将依据匹配的规则对报文执行相应的动作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl** [**number**] *acl-number* [**match-order** { **auto** | **config** }]，使用编号创建一个数字型的高级ACL，并进入高级ACL视图；或者执行命令**acl name** *acl-name* { **advance** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的高级ACL，进入高级ACL视图。

高级ACL编号*acl-number*的范围是3000～3999。

缺省情况下，未创建ACL。

步骤3 根据报文的IP协议版本或IP承载的协议类型配置高级ACL规则。

- 根据IP协议版本配置高级ACL规则。当IP协议版本为IPv4时，高级访问控制列表的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } **ip** [**destination** { *destination-address destination-wildcard* | **any** } | **source** { *source-address source-wildcard* | **any** } | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *

- 根据报文中IP承载的协议类型配置高级ACL规则。

- 当IP承载的协议类型为ICMP时，高级访问控制列表的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **icmp** } [**destination** { *destination-address destination-wildcard* | **any** } | **icmp-type** { *icmp-name* | *icmp-type icmp-code* } | **source** { *source-address source-wildcard* | **any** } | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *

- 当IP承载的协议类型为TCP时，高级访问控制列表的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **tcp** } [**destination** { *destination-address destination-wildcard* | **any** } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **source** { *source-address source-wildcard* | **any** } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **tcp-flag** { **ack** | **fin** | **psh** | **rst** | **syn** | **urg** } * | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *

- 当IP承载的协议类型为UDP时，高级访问控制列表的命令格式为：

  rule [*rule-id*] { **deny** | **permit** }{ *protocol-number* | **udp** } [**destination** { *destination-address destination-wildcard* | **any** } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **source** { *source-address source-wildcard* | **any** } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *

- 当IP承载的协议类型为TCP、UDP和ICMP之外的其他协议时，高级访问控制列表的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **gre** | **igmp** | **ipinip** | **ospf** } [**destination** { *destination-address destination-wildcard* | **any** } | **source** { *source-address source-wildcard* | **any** } | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *

如果高级ACL需要配置多个规则，可以反复执行本步骤。

说明

如果要同时配置**precedence** *precedence*和**tos** *tos*参数，则需将**precedence** *precedence*和**tos** *tos*参数连续配置。

参数**dscp** *dscp*和**precedence** *precedence*不能同时配置。

参数**dscp** *dscp*和**tos** *tos*不能同时配置。

在ACL中配置首条规则时，如果未指定参数*rule-id*，设备使用步长值作为规则的起始编号。后续配置规则如仍未指定参数*rule-id*，设备则使用最后一个规则的rule-id的下一个步长的整数倍数值作为规则编号。例如ACL中包含规则rule 5和rule 7，ACL的步长为5，则系统分配给新配置的未指定*rule-id*的规则的编号为10。

当用户指定参数**time-range**引入ACL规则生效时间段时，如果*time-name*不存在，则该规则配置不生效。

编号为3000～3031的ACL会下发给AP生效。

步骤4 （可选）执行**rule** *rule-id* **description** *description*，配置高级ACL规则的描述信息。

----结束

27.1.4.2.4 应用 ACL

背景信息

ACL本身只是一组规则，只能区分报文，无法实现对报文的区别处理。对不同种类报文的处理方法，需要由引用ACL的具体功能来决定。

操作步骤

- 应用ACL。

  ACL可以在很多特性中被应用。例如，当需要对不同类型的流量进行分类操作时，可以通过应用基本ACL、高级ACL、二层ACL、基本ACL6、高级ACL6、用户ACL6实现对满足过滤条件的流量进行流量监管、流量整形、流量分类。

  说明

  能应用ACL的特性较多，对ACL分类出来的报文的处理方式也不一致。此处未一一列出，具体描述请参考各特性的配置手册。

----结束

27.1.4.2.5 检查配置结果

操作步骤

- 执行命令**display acl** { *acl-number* | **name** *acl-name* | **all** }，查看ACL的配置信息。
- 执行命令**display time-range** { **all** | *time-name* }，查看时间段信息。

----结束

27.1.4.3 配置二层 ACL

二层ACL可以根据源MAC地址、VLAN ID、二层协议类型、目的MAC地址等链路层信息制定规则，对数据进行相应处理。

27.1.4.3.1 （可选）配置规则生效时间段

背景信息

某些引用ACL的业务或功能需要限制在一定的时间范围内生效，比如，在流量高峰期时启动设备的QoS（Quality of Service）功能。用户可以为ACL创建生效时间段，通过在规则中引用时间段信息限制ACL生效的时间范围，从而达到该业务或功能在一定的时间范围内生效的目的。

须知

删除ACL生效时间段，可能会导致某些ACL不生效，请谨慎操作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**time-range** *time-name* { *start-time* **to** *end-time* { *days* } &<1-7> | **from** *time1 date1* [**to** *time2 date2*] }，创建一个时间段。

设备支持具有相同*time-name*的多个时间段共同描述某个时间范围，此时可以使用相同的*time-name*反复执行本步骤。

说明

使用同一*time-name*可以配置多条不同的时间段，以达到这样的效果：各周期时间段之间以及各绝对时间段之间分别取并集之后，再取二者的交集作为最终生效的时间范围。例如，时间段“test”配置了三个生效时段：

- 从2010年1月1日00:00起到2010年12月31日23:59生效，这是一个绝对时间段。
- 在周一到周五每天8:00到18:00生效，这是一个周期时间段。
- 在周六、周日下午14:00到18:00生效，这是一个周期时间段。

则时间段“test”最终描述的时间范围为：2010年的周一到周五每天8:00到18:00以及周六和周日下午14:00到18:00。

由于网络延迟等原因，可能造成网络上设备时间不同步，建议配置NTP（Network Time Protocol），以保证网络上时间的一致。NTP的配置，请参见**6.6.4.1 配置NTP基本功能**。

----结束

27.1.4.3.2 创建二层 ACL

背景信息

二层ACL可以根据报文二层ACL根据报文的源MAC地址、目的MAC地址、MAC承载的协议类型等信息对报文进行分类。

配置二层ACL时，需要先创建一个二层ACL。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl** [**number**] *acl-number* [**match-order** { **auto** | **config** }]，使用编号创建一个数字型的二层ACL，并进入二层ACL视图；或者执行命令**acl name** *acl-name* { **link** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的二层ACL，进入二层ACL视图。

二层ACL编号*acl-number*的范围是4000～4999。

缺省情况下，未创建ACL。

步骤3 （可选）执行命令**step** *step*，配置ACL步长。

缺省情况下，步长值为5。

步骤4 （可选）执行命令**description** *text*，配置ACL描述信息。

缺省情况下，未配置ACL的描述信息。

----结束

27.1.4.3.3 配置二层 ACL 的规则

背景信息

ACL通过rule（规则）匹配报文的信息，实现对报文的分类，因此创建ACL以后，需要配置ACL的规则。

在ACL中添加新的规则时，不会影响已经存在的规则；对已经存在的规则进行编辑时，如果新配置的规则内容与原规则内容存在冲突，则冲突的部分由新配置的规则内容代替，建议在编辑一个已存在的规则前，先将旧的规则删除，再创建新的规则，否则配置结果可能与预期的效果不同。此外，配置规则时，如果不同的规则之间存在矛盾或包含的关系，请注意规则的匹配顺序，防止出现错误配置。

说明

设备在收到报文时，会按照匹配顺序将报文与ACL规则进行逐条匹配，一旦匹配上某条规则，则停止匹配动作。之后，设备将依据匹配的规则对报文执行相应的动作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl** [**number**] *acl-number* [**match-order** { **auto** | **config** }]，使用编号创建一个数字型的二层ACL，并进入二层ACL视图；或者执行命令**acl name** *acl-name* { **link** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的二层ACL，进入二层ACL视图。

二层ACL编号*acl-number*的范围是4000～4999。

缺省情况下，未创建ACL。

步骤3 执行命令**rule** [*rule-id*] { **permit** | **deny** } [**l2-protocol** *type-value* [*type-mask*] | **destination-mac** *dest-mac-address* [*dest-mac-mask*] | **source-mac** *source-mac-address* [*source-mac-mask*] | **vlan-id** *vlan-id* [*vlan-id-mask*] | **8021p** *802.1p-value* | **time-range** *time-name*] *，配置二层ACL的规则。

如果二层ACL需要配置多个规则，可以反复执行本步骤。

说明

在ACL中配置首条规则时，如果未指定参数*rule-id*，设备使用步长值作为规则的起始编号。后续配置规则如仍未指定参数*rule-id*，设备则使用最后一个规则的rule-id的下一个步长的整数倍数值作为规则编号。例如ACL中包含规则rule 5和rule 7，ACL的步长为5，则系统分配给新配置的未指定*rule-id*的规则的编号为10。

当用户指定参数**time-range**引入ACL规则生效时间段时，如果*time-name*不存在，则该规则配置不生效。

编号为4000～4031的ACL会下发给AP生效。

步骤4 （可选）执行**rule** *rule-id* **description** *description*，配置二层ACL规则的描述信息。

设备仅允许对已存在*rule-id*的规则配置描述信息，不允许先配置规则的描述信息再配置具体的规则内容。

----结束

27.1.4.3.4 应用 ACL

背景信息

ACL本身只是一组规则，只能区分报文，无法实现对报文的区别处理。对不同种类报文的处理方法，需要由引用ACL的具体功能来决定。

操作步骤

- 应用ACL。

  ACL可以在很多特性中被应用。例如，当需要对不同类型的流量进行分类操作时，可以通过应用基本ACL、高级ACL、二层ACL、基本ACL6、高级ACL6、用户ACL6实现对满足过滤条件的流量进行流量监管、流量整形、流量分类。

  说明

  能应用ACL的特性较多，对ACL分类出来的报文的处理方式也不一致。此处未一一列出，具体描述请参考各特性的配置手册。

----结束

27.1.4.3.5 检查配置结果

操作步骤

- 执行命令**display acl** { *acl-number* | **name** *acl-name* | **all** }，查看ACL的配置信息。
- 执行命令**display time-range** { **all** | *time-name* }，查看时间段信息。

----结束

27.1.4.4 配置用户 ACL

当用户需要使用源IP地址或源用户组、目的IP地址或目的用户组、目的域名、源端口号、目的端口号、优先级、时间段等信息对IPv4报文进行过滤时，可以配置用户ACL。

27.1.4.4.1 （可选）配置规则生效时间段

背景信息

某些引用ACL的业务或功能需要限制在一定的时间范围内生效，比如，在流量高峰期时启动设备的QoS（Quality of Service）功能。用户可以为ACL创建生效时间段，通过在规则中引用时间段信息限制ACL生效的时间范围，从而达到该业务或功能在一定的时间范围内生效的目的。

须知

删除ACL生效时间段，可能会导致某些ACL不生效，请谨慎操作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**time-range** *time-name* { *start-time* **to** *end-time* { *days* } &<1-7> | **from** *time1 date1* [**to** *time2 date2*] }，创建一个时间段。

设备支持具有相同*time-name*的多个时间段共同描述某个时间范围，此时可以使用相同的*time-name*反复执行本步骤。

说明

使用同一*time-name*可以配置多条不同的时间段，以达到这样的效果：各周期时间段之间以及各绝对时间段之间分别取并集之后，再取二者的交集作为最终生效的时间范围。例如，时间段“test”配置了三个生效时段：

- 从2010年1月1日00:00起到2010年12月31日23:59生效，这是一个绝对时间段。
- 在周一到周五每天8:00到18:00生效，这是一个周期时间段。
- 在周六、周日下午14:00到18:00生效，这是一个周期时间段。

则时间段“test”最终描述的时间范围为：2010年的周一到周五每天8:00到18:00以及周六和周日下午14:00到18:00。

由于网络延迟等原因，可能造成网络上设备时间不同步，建议配置NTP（Network Time Protocol），以保证网络上时间的一致。NTP的配置，请参见**6.6.4.1 配置NTP基本功能**。

----结束

27.1.4.4.2 （可选）配置全局域名

背景信息

通过用户ACL可以为用户配置网络访问权限，如果管理员想要控制用户对一个域名的访问，可以通过查找该域名对应的IP地址，配置用户对该IP地址的访问权限。但如果该域名对应有多个IP地址，则会给管理员带来维护的困难，此时可以配置一条全局域名，然后在ACL规则中直接通过该全局域名控制访问权限。

仅用户ACL的6000～6031和用户ACL6的6000～6031，可以配置全局域名，该范围的ACL规则会下发给AP。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**passthrough-domain name** *domain-name* **id** *domain-id*，配置一个全局域名。

缺省情况下，未配置全局的域名。

域名不可与已配置的域名互相包含。

----结束

27.1.4.4.3 创建用户 ACL

背景信息

用户ACL可以根据源IP地址或源用户组、目的IP地址或目的用户组、IP优先级、ToS、DSCP、IP协议类型、ICMP类型、TCP源端口/目的端口、UDP源端口/目的端口号等信息对IPv4报文进行分类。

配置用户ACL时，需要先创建一个用户ACL。用户ACL编号*acl-number*的范围是6000～6999。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl** [**number**] *acl-number* [**match-order** { **auto** | **config** }]，使用编号创建一个数字型的用户ACL，并进入用户ACL视图；或者执行命令**acl name** *acl-name* { **ucl** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的用户ACL，进入用户ACL视图。

步骤3 （可选）执行命令**step** *step*，配置ACL步长。

步骤4 （可选）执行命令**description** *text*，配置ACL描述信息。

----结束

27.1.4.4.4 配置用户 ACL 的规则

背景信息

用户ACL通过rule（规则）匹配报文的信息，实现对报文的分类，因此创建用户ACL以后，需要配置用户ACL的规则。

在ACL中添加新的规则时，不会影响已经存在的规则；对已经存在的规则进行编辑时，如果新配置的规则内容与原规则内容存在冲突，则冲突的部分由新配置的规则内容代替，建议在编辑一个已存在的规则前，先将旧的规则删除，再创建新的规则，否则配置结果可能与预期的效果不同。此外，配置规则时，如果不同的规则之间存在矛盾或包含的关系，请注意规则的匹配顺序，防止出现错误配置。

说明

设备在收到报文时，会按照匹配顺序将报文与ACL规则进行逐条匹配，一旦匹配上某条规则，则停止匹配动作。之后，设备将依据匹配的规则对报文执行相应的动作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl** [**number**] *acl-number* [**match-order** { **auto** | **config** }]，使用编号创建一个数字型的用户ACL，并进入用户ACL视图；或者执行命令**acl name** *acl-name* { **ucl** | *acl-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的用户ACL，进入用户ACL视图。

步骤3 根据报文的IP协议版本或IP承载的协议类型配置用户ACL规则。

- 根据IP协议版本配置用户ACL规则。当IP协议版本为IPv4时，用户访问控制列表的命令格式为：

rule [*rule-id*] { **deny** | **permit** } **ip** [**destination** { { *destination-address destination-wildcard* | **any** } | **user-group** { **name** *destination-group-name* | **any** } | **passthrough-domain** *domain-name* } | **source** { { *source-address source-wildcard* | **any** } | **user-group** { **name** *source-group-name* | **any** } } | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *

- 根据报文中IP承载的协议类型配置用户ACL规则。
  - 当IP承载的协议类型为ICMP时，用户访问控制列表的命令格式为：

    rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **icmp** } [**destination** { { *destination-address destination-wildcard* | **any** } | **user-group** { **name** *destination-group-name* | **any** } | **passthrough-domain** *domain-name* } | **icmp-type** { *icmp-name* | *icmp-type icmp-code* } | **source** { { *source-address source-wildcard* | **any** } | **user-group** { **name** *source-group-name* | **any** } } | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *
  - 当IP承载的协议类型为TCP时，用户访问控制列表的命令格式为：

    rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **tcp** } [**destination** { { *destination-address destination-wildcard* | **any** } | **user-group** { **name** *destination-group-name* | **any** } | **passthrough-domain** *domain-name* } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **source** { { *source-address source-wildcard* | **any** } | **user-group** { **name** *source-group-name* | **any** } } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **tcp-flag** { **ack** | **fin** | **psh** | **rst** | **syn** | **urg** } * | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *
  - 当IP承载的协议类型为UDP时，用户访问控制列表的命令格式为：

    rule [*rule-id*] { **deny** | **permit** }{ *protocol-number* | **udp** } [**destination** { { *destination-address destination-wildcard* | **any** } | **user-group** { **name** *destination-group-name* | **any** } | **passthrough-domain** *domain-name* } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **source** { { *source-address source-wildcard* | **any** } | **user-group** { **name** *source-group-name* | **any** } } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *
  - 当IP承载的协议类型为TCP、UDP和ICMP之外的其他协议时，用户访问控制列表的命令格式为：

    rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **gre** | **igmp** | **ipinip** | **ospf** } [**destination** { { *destination-address destination-wildcard* | **any** } | **user-group** { **name** *destination-group-name* | **any** } | **passthrough-domain** *domain-name* } | **source** { { *source-address source-wildcard* | **any** } | **user-group** { **name** *source-group-name* | **any** } } | **time-range** *time-name* | [**dscp** *dscp* | [**tos** *tos* | **precedence** *precedence*] *] | **fragment**] *

如果用户ACL需要配置多个规则，可以反复执行本步骤。

说明

如果要同时配置**precedence** *precedence*和**tos** *tos*参数，则需将**precedence** *precedence*和**tos** *tos*参数连续配置。

参数**dscp** *dscp*和**precedence** *precedence*不能同时配置。

参数**dscp** *dscp*和**tos** *tos*不能同时配置。

仅规则的动作为**permit**时可以指定**passthrough-domain** *domain-name*。

在ACL中配置首条规则时，如果未指定参数*rule-id*，设备使用步长值作为规则的起始编号。后续配置规则如仍未指定参数*rule-id*，设备则使用最后一个规则的rule-id的下一个步长的整数倍数值作为规则编号。例如ACL中包含规则rule 5和rule 7，ACL的步长为5，则系统分配给新配置的未指定*rule-id*的规则的编号为10。

当用户指定参数**time-range**引入ACL规则生效时间段时，如果*time-name*不存在，则该规则配置不生效。

如果规则中指定了用户组信息，则不能使用命令**acl-id**（**用户组视图**）为该用户组绑定ACL。如果用户组已绑定ACL，则不能在用户ACL的规则中指定该用户组。

编号为6000～6031的ACL在创建时会自动下发给AP生效。

用户ACL规则中的域名配置仅应用在Portal认证免认证规则时生效。

步骤4 （可选）执行**rule** *rule-id* **description** *description*，配置用户ACL规则的描述信息。

----结束

27.1.4.4.5 应用 ACL

背景信息

ACL本身只是一组规则，只能区分报文，无法实现对报文的区别处理。对不同种类报文的处理方法，需要由引用ACL的具体功能来决定。

操作步骤

- 应用ACL。

  ACL可以在很多特性中被应用。例如，当需要对不同类型的流量进行分类操作时，可以通过应用基本ACL、高级ACL、二层ACL、基本ACL6、高级ACL6、用户ACL6实现对满足过滤条件的流量进行流量监管、流量整形、流量分类。

  说明

  能应用ACL的特性较多，对ACL分类出来的报文的处理方式也不一致。此处未一一列出，具体描述请参考各特性的配置手册。

----结束

27.1.4.4.6 检查配置结果

操作步骤

- 执行命令**display acl** { *acl-number* | **name** *acl-name* | **all** }，查看ACL的配置信息。
- 执行命令**display time-range** { **all** | *time-name* }，查看时间段信息。

----结束

27.1.4.5 配置基本 ACL6

基本ACL6可以根据源地址对报文进行分类。

27.1.4.5.1 （可选）配置规则生效时间段

背景信息

某些引用ACL的业务或功能需要限制在一定的时间范围内生效，比如，在流量高峰期时启动设备的QoS（Quality of Service）功能。用户可以为ACL创建生效时间段，通过在规则中引用时间段信息限制ACL生效的时间范围，从而达到该业务或功能在一定的时间范围内生效的目的。

须知

删除ACL生效时间段，可能会导致某些ACL不生效，请谨慎操作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**time-range** *time-name* { *start-time* **to** *end-time* { *days* } &<1-7> | **from** *time1 date1* [**to** *time2 date2*] }，创建一个时间段。

设备支持具有相同*time-name*的多个时间段共同描述某个时间范围，此时可以使用相同的*time-name*反复执行本步骤。

说明

使用同一*time-name*可以配置多条不同的时间段，以达到这样的效果：各周期时间段之间以及各绝对时间段之间分别取并集之后，再取二者的交集作为最终生效的时间范围。例如，时间段“test”配置了三个生效时段：

- 从2010年1月1日00:00起到2010年12月31日23:59生效，这是一个绝对时间段。
- 在周一到周五每天8:00到18:00生效，这是一个周期时间段。
- 在周六、周日下午14:00到18:00生效，这是一个周期时间段。

则时间段“test”最终描述的时间范围为：2010年的周一到周五每天8:00到18:00以及周六和周日下午14:00到18:00。

由于网络延迟等原因，可能造成网络上设备时间不同步，建议配置NTP（Network Time Protocol），以保证网络上时间的一致。NTP的配置，请参见**6.6.4.1 配置NTP基本功能**。

----结束

27.1.4.5.2 创建基本 ACL6

背景信息

基本ACL6可以根据报文源地址、分片标记和时间段信息对IPv6报文进行分类。

配置基本ACL6时，需要先创建一个基本ACL6。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl ipv6** [**number**] *acl6-number* [**match-order** { **auto** | **config** }]，使用编号创建一个基本ACL6，并进入基本ACL6视图；或者执行命令**acl ipv6 name** *acl6-name* { **basic** | *acl6-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的基本ACL6，进入基本ACL6视图。

基本ACL6编号*acl-number*的范围是2000～2999。

缺省情况下，未创建ACL6。

步骤3 （可选）执行命令**step** *step*，配置ACL6步长。

缺省情况下，步长值为5。

步骤4 （可选）执行命令**description** *text*，配置ACL6描述信息。

缺省情况下，未配置ACL6的描述信息。

----结束

27.1.4.5.3 配置基本 ACL6 的规则

背景信息

ACL6通过rule（规则）匹配报文的信息，实现对报文的分类，因此创建基本ACL6以后，需要配置ACL6的规则。

在ACL6中添加新的规则时，不会影响已经存在的规则；对已经存在的规则进行编辑时，如果新配置的规则内容与原规则内容存在冲突，则冲突的部分由新配置的规则内容代替，建议在编辑一个已存在的规则前，先将旧的规则删除，再创建新的规则，否则配置结果可能与预期的效果不同。此外，配置规则时，如果不同的规则之间存在矛盾或包含的关系，请注意规则的匹配顺序，防止出现错误配置。

说明

设备在收到报文时，会按照匹配顺序将报文与ACL规则进行逐条匹配，一旦匹配上某条规则，则停止匹配动作。之后，设备将依据匹配的规则对报文执行相应的动作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl ipv6** [**number**] *acl6-number* [**match-order** { **auto** | **config** }]，使用编号创建一个基本ACL6，并进入基本ACL6视图；或者执行命令**acl ipv6 name** *acl6-name* { **basic** | *acl6-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个命名型的基本ACL6，进入基本ACL6视图。

基本ACL6编号*acl-number*的范围是2000～2999。

缺省情况下，未创建ACL6。

步骤3 执行命令**rule** [*rule-id*] { **deny** | **permit** } [**fragment** | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **time-range** *time-name*] *，配置基本ACL6规则。

如果ACL6需要配置多个规则，可以反复执行本步骤。

说明

在ACL6中配置首条规则时，如果未指定参数*rule-id*，设备使用步长值作为规则的起始编号。后续配置规则如仍未指定参数*rule-id*，设备则使用最后一个规则的rule-id的下一个步长的整数倍数值作为规则编号。例如ACL6中包含规则rule 5和rule 7，ACL6的步长为5，则系统分配给新配置的未指定*rule-id*的规则的编号为10。

当用户指定参数**time-range**引入ACL规则生效时间段时，如果*time-name*不存在，则该规则配置不生效。

步骤4 （可选）执行**rule** *rule-id* **description** *description*，配置基本ACL6规则的描述信息。

设备仅允许对已存在*rule-id*的规则配置描述信息，不允许先配置规则的描述信息再配置具体的规则内容。

----结束

27.1.4.5.4 应用 ACL

背景信息

ACL本身只是一组规则，只能区分报文，无法实现对报文的区别处理。对不同种类报文的处理方法，需要由引用ACL的具体功能来决定。

操作步骤

- 应用ACL。

  ACL可以在很多特性中被应用。例如，当需要对不同类型的流量进行分类操作时，可以通过应用基本ACL、高级ACL、二层ACL、基本ACL6、高级ACL6、用户ACL6实现对满足过滤条件的流量进行流量监管、流量整形、流量分类。

  说明

  能应用ACL的特性较多，对ACL分类出来的报文的处理方式也不一致。此处未一一列出，具体描述请参考各特性的配置手册。

----结束

27.1.4.5.5 检查配置结果

操作步骤

- 执行命令**display acl ipv6** { *acl6-number* | **name** *acl6-name* | **all** }，查看ACL6的配置信息。
- 执行命令**display time-range** { **all** | *time-name* }，查看时间段信息。

----结束

27.1.4.6 配置高级 ACL6

高级ACL6可以根据源地址、目的地址、源端口号、目的端口号、协议类型等对报文进行更为细致的分类定义。

27.1.4.6.1 （可选）配置规则生效时间段

背景信息

某些引用ACL的业务或功能需要限制在一定的时间范围内生效，比如，在流量高峰期时启动设备的QoS（Quality of Service）功能。用户可以为ACL创建生效时间段，通过在规则中引用时间段信息限制ACL生效的时间范围，从而达到该业务或功能在一定的时间范围内生效的目的。

须知

删除ACL生效时间段，可能会导致某些ACL不生效，请谨慎操作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**time-range** *time-name* { *start-time* **to** *end-time* { *days* } &<1-7> | **from** *time1 date1* [**to** *time2 date2*] }，创建一个时间段。

设备支持具有相同*time-name*的多个时间段共同描述某个时间范围，此时可以使用相同的*time-name*反复执行本步骤。

说明

使用同一*time-name*可以配置多条不同的时间段，以达到这样的效果：各周期时间段之间以及各绝对时间段之间分别取并集之后，再取二者的交集作为最终生效的时间范围。例如，时间段“test”配置了三个生效时段：

- 从2010年1月1日00:00起到2010年12月31日23:59生效，这是一个绝对时间段。
- 在周一到周五每天8:00到18:00生效，这是一个周期时间段。
- 在周六、周日下午14:00到18:00生效，这是一个周期时间段。

则时间段“test”最终描述的时间范围为：2010年的周一到周五每天8:00到18:00以及周六和周日下午14:00到18:00。

由于网络延迟等原因，可能造成网络上设备时间不同步，建议配置NTP（Network Time Protocol），以保证网络上时间的一致。NTP的配置，请参见**6.6.4.1 配置NTP基本功能**。

----结束

27.1.4.6.2 创建高级 ACL6

背景信息

高级ACL6可以根据报文的源地址、目的地址、IP承载的协议类型、针对协议的特性（例如TCP的源端口、目的端口、ICMPv6协议的类型、ICMPv6 Code）等内容对IPv6报文进行分类。

配置高级ACL6时，需要先创建一个高级ACL6。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl ipv6** [**number**] *acl6-number* [**match-order** { **auto** | **config** }]，使用编号创建一个高级ACL6，并进入高级ACL6视图；或者执行命令**acl ipv6 name** *acl6-name* { **advance** | *acl6-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个高级ACL6，并进入高级ACL6视图。

高级ACL6编号*acl-number*的范围是3000～3999。

缺省情况下，未创建ACL6。

步骤3 （可选）执行命令**step** *step*，配置ACL6步长。

缺省情况下，步长值为5。

步骤4 （可选）执行命令**description** *text*，配置ACL6描述信息。

缺省情况下，未配置ACL6的描述信息。

----结束

27.1.4.6.3 配置高级 ACL6 的规则

背景信息

ACL6通过rule（规则）匹配报文的信息，实现对报文的分类，因此创建高级ACL6以后，需要配置ACL6的规则。

在ACL6中添加新的规则时，不会影响已经存在的规则；对已经存在的规则进行编辑时，如果新配置的规则内容与原规则内容存在冲突，则冲突的部分由新配置的规则内容代替，建议在编辑一个已存在的规则前，先将旧的规则删除，再创建新的规则，否则配置结果可能与预期的效果不同。此外，配置规则时，如果不同的规则之间存在矛盾或包含的关系，请注意规则的匹配顺序，防止出现错误配置。

说明

设备在收到报文时，会按照匹配顺序将报文与ACL规则进行逐条匹配，一旦匹配上某条规则，则停止匹配动作。之后，设备将依据匹配的规则对报文执行相应的动作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl ipv6** [**number**] *acl6-number* [**match-order** { **auto** | **config** }]，使用编号创建一个高级ACL6，并进入高级ACL6视图；或者执行命令**acl ipv6 name** *acl6-name* { **advance** | *acl6-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个高级ACL6，并进入高级ACL6视图。

高级ACL6编号*acl-number*的范围是3000～3999。

缺省情况下，未创建ACL6。

步骤3 请根据不同情况进行以下配置ACL6规则。

根据IP承载的协议类型不同，在设备上配置不同的高级ACL6。对于不同的协议类型，有不同的参数组合。

- 当参数protocol为TCP时，高级ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { **tcp** | *protocol-number* } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-*

length | **any** } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **dscp** *dscp* | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **tcp-flag** { **ack** | **fin** | **psh** | **rst** | **syn** | **urg** } * | **time-range** *time-name* | **tos** *tos*] *

- 当参数protocol为UDP时，高级ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { **udp** | *protocol-number* } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **dscp** *dscp* | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **time-range** *time-name* | **tos** *tos*] *

- 当参数protocol为ICMPv6时，高级ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { **icmpv6** | *protocol-number* } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** } | **dscp** *dscp* | **icmp6-type** { *icmp6-type-name* | *icmp6-type icmp6-code* } | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **time-range** *time-name* | **tos** *tos*] *

- 当protocol为IPv6时，高级ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **ipv6** } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** } | **dscp** *dscp* | **fragment** | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **time-range** *time-name* | **tos** *tos*] *

- 当protocol为其他协议时，高级ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **gre** | **ospf** } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** } | **dscp** *dscp* | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **time-range** *time-name* | **tos** *tos*] *

如果高级ACL6需要配置多个规则，可以反复执行本步骤。

说明

如果要同时配置**precedence** *precedence*和**tos** *tos*参数，则需将**precedence** *precedence*和**tos** *tos*参数连续配置。

参数**dscp** *dscp*和**precedence** *precedence*不能同时配置。

参数**dscp** *dscp*和**tos** *tos*不能同时配置。

当*protocol*不是IPv6时，不允许配置**fragment**参数。

在ACL6中配置首条规则时，如果未指定参数*rule-id*，设备使用步长值作为规则的起始编号。后续配置规则如仍未指定参数*rule-id*，设备则使用最后一个规则的rule-id的下一个步长的整数倍数值作为规则编号。例如ACL6中包含规则rule 5和rule 7，ACL6的步长为5，则系统分配给新配置的未指定*rule-id*的规则的编号为10。

当用户指定参数**time-range**引入ACL规则生效时间段时，如果*time-name*不存在，则该规则配置不生效。

编号为3000～3031的ACL会下发给AP生效。

步骤4 （可选）执行**rule** *rule-id* **description** *description*，配置高级ACL6规则的描述信息。

设备仅允许对已存在*rule-id*的规则配置描述信息，不允许先配置规则的描述信息再配置具体的规则内容。

----结束

27.1.4.6.4 应用 ACL

背景信息

ACL本身只是一组规则，只能区分报文，无法实现对报文的区别处理。对不同种类报文的处理方法，需要由引用ACL的具体功能来决定。

操作步骤

- 应用ACL。

  ACL可以在很多特性中被应用。例如，当需要对不同类型的流量进行分类操作时，可以通过应用基本ACL、高级ACL、二层ACL、基本ACL6、高级ACL6、用户ACL6实现对满足过滤条件的流量进行流量监管、流量整形、流量分类。

  说明

  能应用ACL的特性较多，对ACL分类出来的报文的处理方式也不一致。此处未一一列出，具体描述请参考各特性的配置手册。

----结束

27.1.4.6.5 检查配置结果

操作步骤

- 执行命令**display acl ipv6** { *acl6-number* | **name** *acl6-name* | **all** }，查看ACL6的配置信息。
- 执行命令**display time-range** { **all** | *time-name* }，查看时间段信息。

----结束

27.1.4.7 配置用户 ACL6

用户ACL6可以根据源地址、目的地址、目的域名、源端口号、目的端口号、协议类型等对报文进行更为细致的分类定义。

27.1.4.7.1 （可选）配置规则生效时间段

背景信息

某些引用ACL的业务或功能需要限制在一定的时间范围内生效，比如，在流量高峰期时启动设备的QoS（Quality of Service）功能。用户可以为ACL创建生效时间段，通过在规则中引用时间段信息限制ACL生效的时间范围，从而达到该业务或功能在一定的时间范围内生效的目的。

须知

删除ACL生效时间段，可能会导致某些ACL不生效，请谨慎操作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**time-range** *time-name* { *start-time* **to** *end-time* { *days* } &<1-7> | **from** *time1 date1* [**to** *time2 date2*] }，创建一个时间段。

设备支持具有相同*time-name*的多个时间段共同描述某个时间范围，此时可以使用相同的*time-name*反复执行本步骤。

说明

使用同一*time-name*可以配置多条不同的时间段，以达到这样的效果：各周期时间段之间以及各绝对时间段之间分别取并集之后，再取二者的交集作为最终生效的时间范围。例如，时间段“test”配置了三个生效时段：

- 从2010年1月1日00:00起到2010年12月31日23:59生效，这是一个绝对时间段。
- 在周一到周五每天8:00到18:00生效，这是一个周期时间段。
- 在周六、周日下午14:00到18:00生效，这是一个周期时间段。

则时间段“test”最终描述的时间范围为：2010年的周一到周五每天8:00到18:00以及周六和周日下午14:00到18:00。

由于网络延迟等原因，可能造成网络上设备时间不同步，建议配置NTP（Network Time Protocol），以保证网络上时间的一致。NTP的配置，请参见**6.6.4.1 配置NTP基本功能**。

----结束

27.1.4.7.2 （可选）配置全局域名

背景信息

通过用户ACL可以为用户配置网络访问权限，如果管理员想要控制用户对一个域名的访问，可以通过查找该域名对应的IP地址，配置用户对该IP地址的访问权限。但如果该域名对应有多个IP地址，则会给管理员带来维护的困难，此时可以配置一条全局域名，然后在ACL规则中直接通过该全局域名控制访问权限。

仅用户ACL的6000～6031和用户ACL6的6000～6031，可以配置全局域名，该范围的ACL规则会下发给AP。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**passthrough-domain name** *domain-name* **id** *domain-id*，配置一个全局域名。

缺省情况下，未配置全局的域名。

域名不可与已配置的域名互相包含。

----结束

27.1.4.7.3 创建用户 ACL6

背景信息

用户ACL6可以根据报文的源地址、目的地址、目的域名、IP承载的协议类型、针对协议的特性（例如TCP的源端口、目的端口、ICMPv6协议的类型、ICMPv6 Code）等内容对IPv6报文进行分类。

配置用户ACL6时，需要先创建一个用户ACL6。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl ipv6** [**number**] *acl6-number* [**match-order** { **auto** | **config** }]，使用编号创建一个用户ACL6，并进入用户ACL6视图；或者执行命令**acl ipv6 name** *acl6-name* { **advance** | *acl6-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个用户ACL6，并进入用户ACL6视图。

用户ACL6编号*acl-number*的范围是6000～6999。

缺省情况下，未创建ACL6。

步骤3 （可选）执行命令**step** *step*，配置ACL6步长。

缺省情况下，步长值为5。

步骤4 （可选）执行命令**description** *text*，配置ACL6描述信息。

缺省情况下，未配置ACL6的描述信息。

----结束

27.1.4.7.4 配置用户 ACL6 的规则

背景信息

ACL6通过rule（规则）匹配报文的信息，实现对报文的分类，因此创建用户ACL6以后，需要配置ACL6的规则。

在ACL6中添加新的规则时，不会影响已经存在的规则；对已经存在的规则进行编辑时，如果新配置的规则内容与原规则内容存在冲突，则冲突的部分由新配置的规则内容代替，建议在编辑一个已存在的规则前，先将旧的规则删除，再创建新的规则，否则配置结果可能与预期的效果不同。此外，配置规则时，如果不同的规则之间存在矛盾或包含的关系，请注意规则的匹配顺序，防止出现错误配置。

说明

设备在收到报文时，会按照匹配顺序将报文与ACL规则进行逐条匹配，一旦匹配上某条规则，则停止匹配动作。之后，设备将依据匹配的规则对报文执行相应的动作。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**acl ipv6** [**number**] *acl6-number* [**match-order** { **auto** | **config** }]，使用编号创建一个用户ACL6，并进入用户ACL6视图；或者执行命令**acl ipv6 name**

acl6-name { **advance** | *acl6-number* } [**match-order** { **auto** | **config** }]，使用名称创建一个用户ACL6，并进入用户ACL6视图。

用户ACL6编号*acl-number*的范围是6000～6999。

缺省情况下，未创建ACL6。

步骤3 请根据不同情况进行以下配置ACL6规则。

根据IP承载的协议类型不同，在设备上配置不同的用户ACL6。对于不同的协议类型，有不同的参数组合。

- 当参数protocol为TCP时，用户ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { **tcp** | *protocol-number* } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** | **passthrough-domain** *domain-name* } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **dscp** *dscp* | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **tcp-flag** { **ack** | **fin** | **psh** | **rst** | **syn** | **urg** } * | **time-range** *time-name* | **tos** *tos*] *

- 当参数protocol为UDP时，用户ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { **udp** | *protocol-number* } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** | **passthrough-domain** *domain-name* } | **destination-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **dscp** *dscp* | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **source-port** { **eq** *port* | **gt** *port* | **lt** *port* | **range** *port-start port-end* } | **time-range** *time-name* | **tos** *tos*] *

- 当参数protocol为ICMPv6时，用户ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { **icmpv6** | *protocol-number* } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** | **passthrough-domain** *domain-name* } | **dscp** *dscp* | **icmp6-type** { *icmp6-type-name* | *icmp6-type icmp6-code* } | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **time-range** *time-name* | **tos** *tos*] *

- 当protocol为IPv6时，用户ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **ipv6** } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** | **passthrough-domain** *domain-name* } | **dscp** *dscp* | **fragment** | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **time-range** *time-name* | **tos** *tos*] *

- 当protocol为其他协议时，用户ACL6的命令格式为：

  rule [*rule-id*] { **deny** | **permit** } { *protocol-number* | **gre** | **ospf** } [**destination** { *destination-ipv6-address prefix-length* | *destination-ipv6-address/prefix-length* | **any** | **passthrough-domain** *domain-name* } | **dscp** *dscp* | **precedence** *precedence* | **source** { *source-ipv6-address prefix-length* | *source-ipv6-address/prefix-length* | **any** } | **time-range** *time-name* | **tos** *tos*] *

如果用户ACL6需要配置多个规则，可以反复执行本步骤。

说明

如果要同时配置**precedence** *precedence*和**tos** *tos*参数，则需将**precedence** *precedence*和**tos** *tos*参数连续配置。

参数**dscp** *dscp*和**precedence** *precedence*不能同时配置。

参数**dscp** *dscp*和**tos** *tos*不能同时配置。

当*protocol*不是IPv6时，不允许配置**fragment**参数。

在ACL6中配置首条规则时，如果未指定参数*rule-id*，设备使用步长值作为规则的起始编号。后续配置规则如仍未指定参数*rule-id*，设备则使用最后一个规则的rule-id的下一个步长的整数倍数值作为规则编号。例如ACL6中包含规则rule 5和rule 7，ACL6的步长为5，则系统分配给新配置的未指定*rule-id*的规则的编号为10。

当用户指定参数**time-range**引入ACL规则生效时间段时，如果*time-name*不存在，则该规则配置不生效。

用户ACL规则中的域名配置仅应用在Portal认证免认证规则时生效。

步骤4 （可选）执行**rule** *rule-id* **description** *description*，配置用户ACL6规则的描述信息。

设备仅允许对已存在*rule-id*的规则配置描述信息，不允许先配置规则的描述信息再配置具体的规则内容。

----结束

27.1.4.7.5 应用 ACL

背景信息

ACL本身只是一组规则，只能区分报文，无法实现对报文的区别处理。对不同种类报文的处理方法，需要由引用ACL的具体功能来决定。

操作步骤

- 应用ACL。

  ACL可以在很多特性中被应用。例如，当需要对不同类型的流量进行分类操作时，可以通过应用基本ACL、高级ACL、二层ACL、基本ACL6、高级ACL6、用户ACL6实现对满足过滤条件的流量进行流量监管、流量整形、流量分类。

  说明

  能应用ACL的特性较多，对ACL分类出来的报文的处理方式也不一致。此处未一一列出，具体描述请参考各特性的配置手册。

----结束

27.1.4.7.6 检查配置结果

操作步骤

- 执行命令**display acl ipv6** { *acl6-number* | **name** *acl6-name* | **all** }，查看ACL6的配置信息。
- 执行命令**display time-range** { **all** | *time-name* }，查看时间段信息。

----结束

27.1.5 维护 ACL

维护ACL包括查看ACL的资源信息。

27.1.5.1 查看 ACL 的资源信息

背景信息

当用户发现ACL配置失败，原因之一可能是设备上的ACL规则分配完毕。

为了确认设备的ACL规则资源的分配情况，可以查看ACL规则资源信息。

操作步骤

- 在任意视图下执行**display acl resource**命令，查看ACL的资源信息。

----结束

27.1.6 配置举例

介绍ACL的配置举例。配置示例中包括组网需求、配置思路、操作步骤等。

27.1.6.1 应用基本 ACL 配置 FTP 服务器访问权限示例

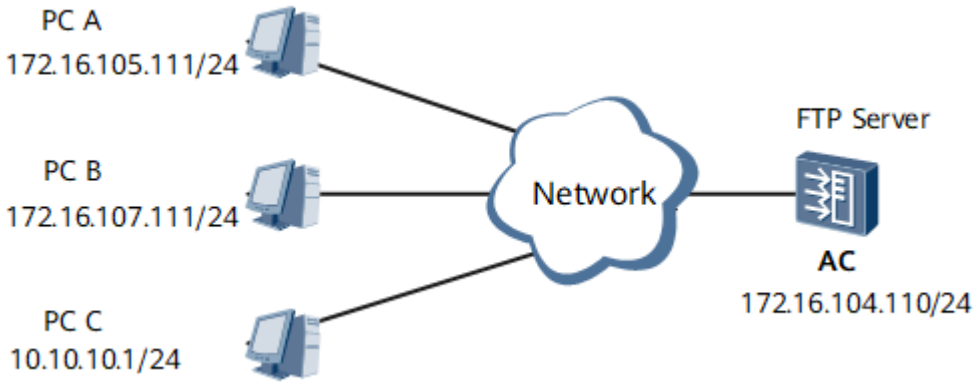
组网需求

如图27-1所示，AC作为FTP服务器（172.16.104.110/24）为网络中的不同用户设置不同的访问权限：

- 子网1（172.16.105.0/24）的所有用户在任意时间都可以访问FTP服务器。
- 子网2（172.16.107.0/24）的所有用户只能在某一个时间范围内访问FTP服务器。
- 其他用户不可以访问FTP服务器。

已知AC与各个子网之间路由可达，要求在AC上进行配置，实现FTP服务器对客户端访问权限的设置。

图 27-1 应用基本 ACL 配置 FTP 服务器访问权限组网图



配置思路

采用如下的配置思路：

- 在AC上创建基本ACL，并通过配置基本ACL规则对网络中不同用户进行分类。
- 在AC上配置FTP基本功能。
- 在AC应用基本ACL为网络中的不同用户设置不同的访问权限。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。
  - 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
  - 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

  配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击?**
- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 配置时间段

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] time-range ftp-access from 0:0 2009/1/1 to 23:59 2011/12/31
[AC] time-range ftp-access 14:00 to 18:00 off-day
```

步骤2 配置基本ACL

```
[AC] acl number 2001
[AC-acl-basic-2001] rule permit source 172.16.105.0 0.0.0.255
[AC-acl-basic-2001] rule permit source 172.16.107.0 0.0.0.255 time-range ftp-access
[AC-acl-basic-2001] rule deny source any
[AC-acl-basic-2001] quit
```

步骤3 配置FTP基本功能

```
[AC] ftp server enable
[AC] aaa
[AC-aaa] local-user huawei password irreversible-cipher SetUesrPasswd@123
[AC-aaa] local-user huawei privilege level 15
[AC-aaa] local-user huawei service-type ftp
[AC-aaa] local-user huawei ftp-directory flash:
[AC-aaa] quit
```

步骤4 配置FTP服务器访问权限

```
[AC] ftp acl 2001
```

步骤5 验证配置结果

在子网1的PC A（172.16.105.111/24）上执行**ftp 172.16.104.110**命令，可以连接FTP服务器。

2010年某个周一在子网2的PC B（172.16.107.111/24）上执行**ftp 172.16.104.110**命令，不能连接FTP服务器；2010年某个周六下午15:00在子网2的PC B（172.16.107.111/24）上执行**ftp 172.16.104.110**命令，可以连接FTP服务器。

在PC C（10.10.10.1/24）上执行**ftp 172.16.104.110**命令，不能连接FTP服务器。

----结束

配置文件

AC的配置文件

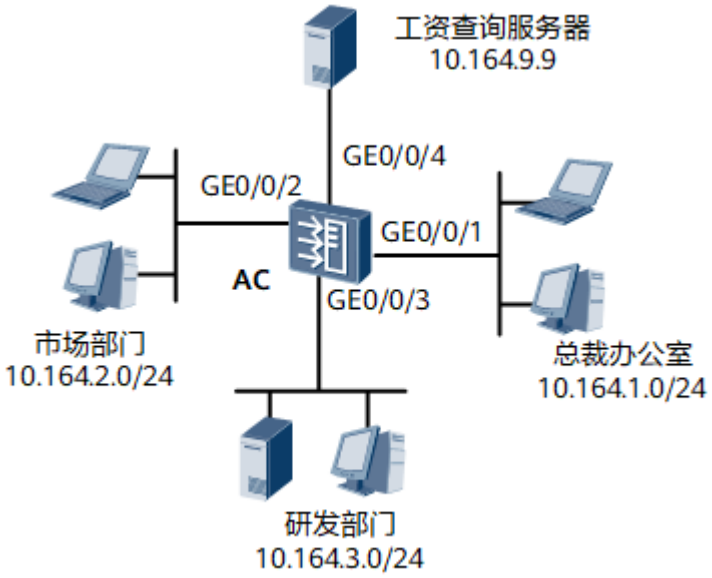
```
#
sysname AC
#
 ftp server enable
 ftp acl 2001
#
aaa
 local-user huawei password irreversible-cipher %$%$k$Xg7H;w4HZP5nE4-E4(FcZQ%$%$
 local-user huawei privilege level 15
 local-user huawei ftp-directory flash:/
 local-user huawei service-type ftp
#
time-range ftp-access 14:00 to 18:00 off-day
time-range ftp-access from 00:00 2009/1/1 to 23:59 2011/12/31
#
acl number 2001
 rule 5 permit source 172.16.105.0 0.0.0.255
 rule 10 permit source 172.16.107.0 0.0.0.255 time-range ftp-access
 rule 15 deny
#
return
```

27.1.6.2 应用高级 ACL 配置流分类示例

组网需求

如图27-2所示，公司企业网通过AC实现各部门之间的互连。要求正确配置ACL，禁止研发部门和市场部门在上班时间（8:00至17:30）访问工资查询服务器（IP地址为10.164.9.9），而总裁办公室不受限制，可以随时访问。

图 27-2 应用高级 ACL 配置流分类组网图



配置思路

采用如下的思路配置ACL：

1. 配置接口IP地址。
2. 配置时间段。
3. 配置ACL。
4. 配置流分类。
5. 配置流行为。
6. 配置流策略。
7. 在接口上应用流策略。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。
  - 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
  - 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

  配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击?**
- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。

- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 配置接口IP地址

配置接口加入VLAN，并配置VLANIF接口的IP地址。

规划GE0/0/1～GE0/0/3分别加入VLAN10、20、30，GE0/0/4加入VLAN100。VLANIF接口的地址取所在网段的第一个IP地址。下面配置以GE0/0/1接口为例，其他接口的配置与此类似，不再赘述。

```
<HUAWEI> system-view
[HUAWEI] vlan batch 10 20 30 100
[HUAWEI] interface gigabitethernet 0/0/1
[HUAWEI-GigabitEthernet0/0/1] port link-type access
[HUAWEI-GigabitEthernet0/0/1] port default vlan 10
[HUAWEI-GigabitEthernet0/0/1] quit
[HUAWEI] interface vlanif 10
[HUAWEI-Vlanif10] ip address 10.164.1.1 255.255.255.0
[HUAWEI-Vlanif10] quit
```

步骤2 配置时间段

配置8:00至17:30的周期时间段。

```
[HUAWEI] time-range satime 8:00 to 17:30 working-day
```

步骤3 配置ACL

配置市场部门到工资查询服务器的访问规则。

```
[HUAWEI] acl 3002
[HUAWEI-acl-adv-3002] rule deny ip source 10.164.2.0 0.0.0.255 destination 10.164.9.9 0.0.0.0 time-range satime
[HUAWEI-acl-adv-3002] quit
```

配置研发部门到工资查询服务器的访问规则。

```
[HUAWEI] acl 3003
[HUAWEI-acl-adv-3003] rule deny ip source 10.164.3.0 0.0.0.255 destination 10.164.9.9 0.0.0.0 time-range satime
[HUAWEI-acl-adv-3003] quit
```

步骤4 配置基于ACL的流分类

配置流分类c_market，对匹配ACL 3002的报文进行分类。

```
[HUAWEI] traffic classifier c_market
[HUAWEI-classifier-c_market] if-match acl 3002
[HUAWEI-classifier-c_market] quit
```

配置流分类c_rd，对匹配ACL 3003的报文进行分类。

```
[HUAWEI] traffic classifier c_rd
[HUAWEI-classifier-c_rd] if-match acl 3003
[HUAWEI-classifier-c_rd] quit
```

步骤5 配置流行为

配置流行为b_market，动作为拒绝报文通过。

```
[HUAWEI] traffic behavior b_market
[HUAWEI-behavior-b_market] deny
[HUAWEI-behavior-b_market] quit
```

配置流行为b_rd，动作为拒绝报文通过。

```
[HUAWEI] traffic behavior b_rd
[HUAWEI-behavior-b_rd] deny
[HUAWEI-behavior-b_rd] quit
```

步骤6 配置流策略

配置流策略p_market，将流分类c_market与流行为b_market关联。

```
[HUAWEI] traffic policy p_market
[HUAWEI-trafficpolicy-p_market] classifier c_market behavior b_market
[HUAWEI-trafficpolicy-p_market] quit
```

配置流策略p_rd，将流分类c_rd与流行为b_rd关联。

```
[HUAWEI] traffic policy p_rd
[HUAWEI-trafficpolicy-p_rd] classifier c_rd behavior b_rd
[HUAWEI-trafficpolicy-p_rd] quit
```

步骤7 应用流策略

将流策略p_market应用到GE0/0/2接口。

```
[HUAWEI] interface gigabitethernet 0/0/2
[HUAWEI-GigabitEthernet0/0/2] traffic-policy p_market inbound
[HUAWEI-GigabitEthernet0/0/2] quit
```

将流策略p_rd应用到GE0/0/3接口。

```
[HUAWEI] interface gigabitethernet 0/0/3
[HUAWEI-GigabitEthernet0/0/3] traffic-policy p_rd inbound
[HUAWEI-GigabitEthernet0/0/3] quit
```

步骤8 验证配置结果

查看ACL规则的配置信息。

```
[HUAWEI] display acl all
 Total quantity of nonempty ACL number is 2

Advanced ACL 3002, 1 rule
Acl's step is 5
 rule 5 deny ip source 10.164.2.0 0.0.0.255 destination 10.164.9.9 0 time-range satime(Active)

Advanced ACL 3003, 1 rule
Acl's step is 5
 rule 5 deny ip source 10.164.3.0 0.0.0.255 destination 10.164.9.9 0 time-range satime(Active)
```

查看流分类的配置信息。

```
[HUAWEI] display traffic classifier user-defined
  User Defined Classifier Information:
   Classifier: c_market
    Operator: OR
    Rule(s) :
      if-match acl 3002

   Classifier: c_rd
    Operator: OR
    Rule(s) :
      if-match acl 3003
```

查看流策略的配置信息。

```
[HUAWEI] display traffic policy user-defined
  User Defined Traffic Policy Information:
  Policy: p_market
   Classifier: c_market
    Operator: OR
```

```
    Behavior: b_market
     Deny

  Policy: p_rd
   Classifier: c_rd
    Operator: OR
     Behavior: b_rd
      Deny
```

----结束

配置文件

```
#
 time-range satime 08:00 to 17:30 working-day
#
 vlan batch 10 20 30 100
#
acl number 3002
 rule 5 deny ip source 10.164.2.0 0.0.0.255 destination 10.164.9.9 0 time-range satime
#
acl number 3003
 rule 5 deny ip source 10.164.3.0 0.0.0.255 destination 10.164.9.9 0 time-range satime
#
traffic classifier c_market operator or
 if-match acl 3002
traffic classifier c_rd operator or
 if-match acl 3003
#
traffic behavior b_market
 deny
traffic behavior b_rd
 deny
#
traffic policy p_market
 classifier c_market behavior b_market
traffic policy p_rd
 classifier c_rd behavior b_rd
#
interface Vlanif10
 ip address 10.164.1.1 255.255.255.0
#
interface Vlanif20
 ip address 10.164.2.1 255.255.255.0
#
interface Vlanif30
 ip address 10.164.3.1 255.255.255.0
#
interface Vlanif100
 ip address 10.164.9.1 255.255.255.0
#
interface GigabitEthernet0/0/1
 port link-type access
 port default vlan 10
#
interface GigabitEthernet0/0/2
 port link-type access
 port default vlan 20
 traffic-policy p_market inbound
#
interface GigabitEthernet0/0/3
 port link-type access
 port default vlan 30
 traffic-policy p_rd inbound
#
interface GigabitEthernet0/0/4
 port link-type access
 port default vlan 100
```

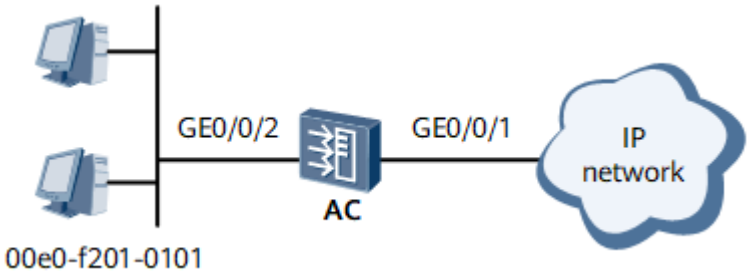
```
#
return
```

27.1.6.3 应用二层 ACL 配置流分类示例

组网需求

如图27-3所示，AC作为网关设备，下挂用户PC租户的Server。要求配置ACL，禁止源MAC地址为00e0-f201-0101、目的MAC地址为0260-e207-0002的报文通过。

图 27-3 应用二层 ACL 配置流分类组网图



配置思路

采用如下的思路配置二层ACL：

1. 配置ACL。
2. 配置流分类。
3. 配置流行为。
4. 配置流策略。
5. 在接口上应用流策略。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。
  - 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
  - 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

  配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击?**
- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 配置ACL

配置符合要求的二层ACL。

```
<HUAWEI> system-view
[HUAWEI] acl 4000
[HUAWEI-acl-L2-4000] rule deny source-mac 00e0-f201-0101 ffff-ffff-ffff destination-mac 0260-
e207-0002 ffff-ffff-ffff
[HUAWEI-acl-L2-4000] quit
```

步骤2 配置基于ACL的流分类

配置流分类tc1，对匹配ACL 4000的报文进行分类。

```
[HUAWEI] traffic classifier tc1
[HUAWEI-classifier-tc1] if-match acl 4000
[HUAWEI-classifier-tc1] quit
```

步骤3 配置流行为

配置流行为tb1，动作为拒绝报文通过。

```
[HUAWEI] traffic behavior tb1
[HUAWEI-behavior-tb1] deny
[HUAWEI-behavior-tb1] quit
```

步骤4 配置流策略

配置流策略tp1，将流分类tc1与流行为tb1关联。

```
[HUAWEI] traffic policy tp1
[HUAWEI-trafficpolicy-tp1] classifier tc1 behavior tb1
[HUAWEI-trafficpolicy-tp1] quit
```

步骤5 应用流策略

将流策略tp1应用到GE0/0/2接口。

```
[HUAWEI] interface gigabitethernet 0/0/2
[HUAWEI-GigabitEthernet0/0/2] traffic-policy tp1 inbound
[HUAWEI-GigabitEthernet0/0/2] quit
```

步骤6 验证配置结果

查看ACL规则的配置信息。

```
[HUAWEI] display acl 4000
L2 ACL 4000, 1 rule
Acl's step is 5
 rule 5 deny destination-mac 0260-e207-0002 source-mac 00e0-f201-0101
```

查看流分类的配置信息。

```
[HUAWEI] display traffic classifier user-defined
   User Defined Classifier Information:
   Classifier: tc1
    Operator: OR
    Rule(s) :
      if-match acl 4000
```

查看流策略的配置信息。

```
[HUAWEI] display traffic policy user-defined tp1
  User Defined Traffic Policy Information:
  Policy: tp1
   Classifier: tc1
    Operator: OR
```

```
  Behavior: tb1
   Deny
```

----结束

配置文件

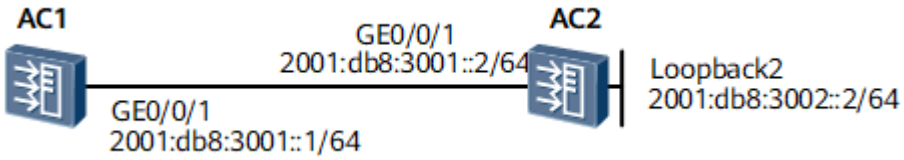
```
#
acl number 4000
 rule 5 deny destination-mac 0260-e207-0002 source-mac 00e0-f201-0101
#
traffic classifier tc1 operator or
 if-match acl 4000
#
traffic behavior tb1
 deny
#
traffic policy tp1
 classifier tc1 behavior tb1
#
interface GigabitEthernet0/0/2
 traffic-policy tp1 inbound
#
return
```

27.1.6.4 应用 ACL6 配置流分类示例

组网需求

如图27-4所示，AC1通过与AC2相连。在AC1上配置ACL6规则，禁止源地址为2001:db8:3001::2/64的IPv6报文进入AC1。

图 27-4 应用 ACL6 配置流分类示例组网图



配置思路

采用如下的思路配置ACL6：

1. 配置ACL6
2. 配置流分类
3. 配置流行为
4. 配置流策略
5. 在接口下应用流策略

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有

大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。

- 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
- 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击?**

- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 分别在AC1和AC2上使能IPv6转发能力，并配置接口参数

配置AC1。

```
<HUAWEI> system-view
[HUAWEI] sysname AC1
[AC1] ipv6
[AC1] vlan 100
[AC1-vlan100] quit
[AC1] interface gigabitethernet 0/0/1
[AC1-GigabitEthernet0/0/1] port hybrid tagged vlan 100
[AC1] quit
[AC1] interface vlanif 100
[AC1-Vlanif100] ipv6 enable
[AC1-Vlanif100] ipv6 address 2001:db8:3001::1 64
[AC1-Vlanif100] quit
```

配置AC1上的静态路由。

```
[AC1] ipv6 route-static 2001:db8:3002:: 64 2001:db8:3001::2
```

配置AC2。

```
<HUAWEI> system-view
[HUAWEI] sysname AC2
[AC2] ipv6
[AC2] vlan 100
[AC2-vlan100] quit
[AC2] interface gigabitethernet 0/0/1
[AC2-GigabitEthernet0/0/1] port hybrid tagged vlan 100
[AC2] quit
[AC2] interface vlanif 100
[AC2-Vlanif100] ipv6 enable
[AC2-Vlanif100] ipv6 address 2001:db8:3001::2 64
[AC2-Vlanif100] quit
```

步骤2 在AC1上配置一个ACL6规则，并在接口上应用该规则，用于拒绝来自2001:db8:3001::2的IPv6报文

配置AC1。

```
[AC1] acl ipv6 number 3001
[AC1-acl6-adv-3001] rule deny ipv6 source 2001:db8:3001::2/64
[AC1-acl6-adv-3001] quit
[AC1] traffic classifier class1
```

```
[AC1-classifier-class1] if-match ipv6 acl 3001
[AC1-classifier-class1] quit
[AC1] traffic behavior behav1
[AC1-behavior-behav1] deny
[AC1-behavior-behav1] quit
[AC1] traffic policy policy1
[AC1-trafficpolicy-policy1] classifier class1 behavior behav1
[AC1-trafficpolicy-policy1] quit
[AC1] interface vlanif 100
[AC1-Vlanif100] traffic-policy policy1 inbound
[AC1-Vlanif100] quit
```

步骤3 验证配置结果

查看ACL6的配置信息。

```
[AC1] display acl ipv6 3001

Advanced IPv6 ACL 3001, 1 rule
Acl's step is 5
 rule 5 deny ipv6 source 2001:db8:3001::2/64
```

查看流分类的配置信息。

```
[AC1] display traffic classifier user-defined
  User Defined Classifier Information:
   Classifier: class1
    Operator: OR
    Rule(s) :
      if-match ipv6 acl 3001
```

查看流策略的配置信息。

```
[AC1] display traffic policy user-defined
  User Defined Traffic Policy Information:
  Policy: policy1
   Classifier: class1
    Operator: OR
     Behavior: behav1
      Deny
```

查看流策略的应用信息。

```
[AC1] display traffic-policy applied-record
-----------------------------------------------
  Policy Name:   policy1
  Policy Index:  0
     Classifier:class1      Behavior:behav1
-----------------------------------------------
 *interface Vlanif100
    traffic-policy policy1 inbound
      slot 0    :  success
-----------------------------------------------
```

----结束

配置文件

- AC1的配置文件

```
#
 sysname AC1
#
acl ipv6 number 3001
 rule 5 deny ipv6 source 2001:db8:3001::2/64
#
ipv6
```

```
#
vlan batch 100
#
traffic classifier class1 operator or
 if-match ipv6 acl 3001
#
traffic behavior behav1
 deny
#
traffic policy policy1
 classifier class1 behavior behav1
#
interface Vlanif100
 ipv6 enable
 ipv6 address 2001:db8:3001::1/64
 traffic-policy policy1 inbound
#
interface GigabitEthernet0/0/1
 port  hybrid tagged vlan 100
#
ipv6 route-static 2001:db8:3002:: 64 2001:db8:3001::2
#
return
```

- AC2的配置文件

```
#
 sysname AC2
#
ipv6
#
vlan batch 100
#
interface Vlanif100
 ipv6 enable
 ipv6 address 2001:db8:3001::2/64
#
interface GigabitEthernet0/0/1
 port  hybrid tagged vlan 100
#
return
```

27.2 本机防攻击配置

本机防攻击特性针对的是上送CPU的报文，主要用于保护设备的自身安全，保证设备在受到攻击时已有业务可以正常运转。

27.2.1 本机防攻击简介

本机防攻击可保护CPU，解决CPU因处理大量正常上送CPU的报文或者恶意攻击报文造成的业务中断问题。

定义

在网络中，存在着大量针对CPU（Central Processing Unit）的恶意攻击报文以及需要正常上送CPU的各类报文。针对CPU的恶意攻击报文会导致CPU长时间繁忙的处理攻击报文，从而引发其他业务的断续甚至系统的中断；大量正常的报文也会导致CPU占用率过高，性能下降，从而影响正常的业务。

为了保护CPU，保证CPU对正常业务的处理和响应，设备提供了本机防攻击功能。本机防攻击针对的是上送CPU的报文，主要用于保护设备自身安全，保证已有业务在发生攻击时的正常运转，避免设备遭受攻击时各业务的相互影响。

基本原理

本机防攻击包括CPU防攻击和攻击溯源两部分。

CPU防攻击针对上送CPU的报文进行限制和约束，使单位时间内上送CPU报文的数量限制在一定的范围之内，从而保护CPU的安全，保证CPU对业务的正常处理。

- 多级安全机制，保证设备的安全，实现了对设备的分级保护。

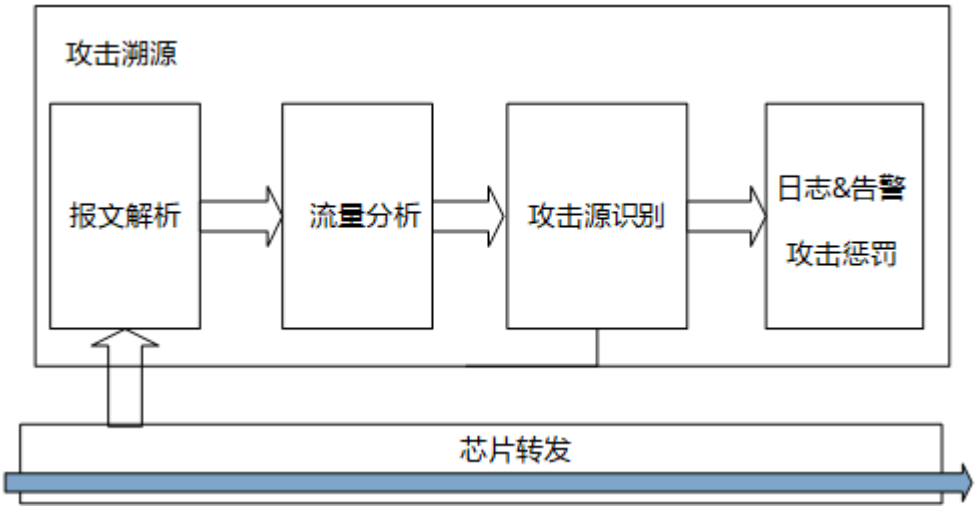
  设备通过以下策略实现对设备的分级保护：

  - 第一级：对上送CPU的报文按照协议类型进行速率限制，保证每种协议上送CPU的报文不会过多。
  - 第二级：对上送CPU的报文，按照协议优先级进行调度，保证优先级高的协议先得到处理。
  - 第三级：对上送CPU的报文统一限速，对超过统一限速值的报文随机丢弃，保证整体上送CPU的报文不会过多，保护CPU安全。
- 动态链路保护功能的CPU报文限速，是指当设备检测到SSH Session数据、Telnet Session数据、SSHv6 Session数据、Telnetv6 Session数据以及FTP Session数据建立时，会启动对此Session的动态链路保护功能，后续上送报文如匹配此Session特征信息，此类数据将会享受高速率上送的权利，由此保证了此Session相关业务的运行可靠性、稳定性。

攻击溯源针对DoS攻击进行防御。设备通过对上送CPU的报文进行分析统计，然后对统计的报文设置一定的阈值，将超过阈值的报文判定为攻击报文，再对这些攻击报文根据报文信息找出攻击源用户或者攻击源接口，最后通过日志、告警等方式提醒管理员以便管理员采用一定的措施来保护设备，或者直接丢弃攻击报文以对攻击源进行惩罚。

如图27-5所示，攻击溯源包括报文解析、流量分析、攻击源识别和发送日志告警通知管理员以及实施惩罚四个过程。

图 27-5 攻击溯源原理



通过图27-5所示的四个过程，找出攻击源，然后管理员通过ACL或配置黑名单的方式限制攻击源，以保护设备CPU。

27.2.2 缺省配置

介绍设备的本机防攻击缺省配置，实际应用的配置可以基于缺省配置进行修改。

本机防攻击的缺省配置如表27-4和表27-5所示。

表 27-4 CPU 防攻击缺省配置

参数	缺省值
防攻击策略	名称为**default**的防攻击策略
统一限速值	● AC6605、AC6508、AC6507S、AirEngine 9700S-S：4000pps ● AC6800V：200000pps ● AC6805、AirEngine 9700-M：85000pps ● ACU2：40000pps ● AC6003，AC6005：2000pps
动态链路保护功能的限制速率	当SSH、Telnet、SSHv6、Telnetv6、FTP协议连接建立时，如果用户没有配置**application-apperceive**的限制速率，那么协议报文使用**application-apperceive**命令缺省的限制速率上送，缺省值如下： ● SSH：512pps ● Telnet：512pps ● SSHv6：512pps ● Telnetv6：512pps ● FTP：1024pps
动态CPCAR	关闭

表 27-5 攻击溯源缺省配置

参数	缺省值
防攻击策略	名称为**default**的防攻击策略
攻击溯源功能	未使能
攻击溯源检查阈值	128pps
攻击溯源模式	基于源MAC地址、基于源IP地址和基于源接口+VLAN三种攻击溯源方式

参数	缺省值
攻击溯源防范的报文类型	HTTP、HTTPS、FTP、SSH、ARP、CAPWAP、DHCP、DHCPv6、ICMP、ICMPv6、ND、IGMP、Telnet、TCP和TTL-expired
攻击溯源告警功能	未使能
攻击溯源告警阈值	128pps
攻击溯源的惩罚功能	未使能

27.2.3 配置本机防攻击

介绍本机防攻击详细的配置过程。

27.2.3.1 配置 CPU 防攻击

通过配置CPU防攻击，设备可以对上送CPU的报文进行限制和约束，使单位时间内上送CPU报文的数量限制在一定的范围之内，从而保护CPU的安全，保证CPU对业务的正常处理。

前置任务

在配置CPU防攻击之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。

配置流程

在配置CPU防攻击任务中，必须首先创建防攻击策略，其余步骤是并列关系，无严格配置顺序，用户根据需要选择配置即可。防攻击策略在创建之后必须应用才能生效，但应用时机无严格限制。

27.2.3.1.1 创建防攻击策略

背景信息

用户需要先创建防攻击策略，然后在创建的防攻击策略中配置本机防攻击功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，创建防攻击策略并进入防攻击策略视图。

设备最多支持19个防攻击策略。其中名称为**default**的策略为系统自动生成的缺省策略，**default**策略默认应用到设备上，不允许删除，也不允许修改参数；其余18个允许用户创建、修改和删除。

步骤3 （可选）执行命令**description** *text*，配置防攻击策略的描述信息。

缺省情况下，防攻击策略没有配置描述信息。

----结束

27.2.3.1.2 配置速率限制

背景信息

设备可以通过对不同类型的报文设置不同的限制速率，也可以对报文设置为丢弃，从而减少上送CPU的报文数量，降低不同类型报文的相互影响，达到保护CPU的目的。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 配置速率限制。

- 执行命令**packet-type** *packet-type* **rate-limit** *rate-value* { **wired** | **wireless** }，配置对上送CPU的报文进行限速，并设置速率阈值。超过此速率限制的报文将会被丢弃。
- 执行命令**deny packet-type** *packet-type* { **wired** | **wireless** }，配置对上送CPU的报文进行丢弃。丢弃报文相当于将该类型报文的限速阈值设置为0。

缺省情况下，设备对上送CPU的报文按照**default**策略缺省的限速值进行限速。

----结束

27.2.3.1.3 配置协议优先级

背景信息

创建防攻击策略后，可以在防攻击策略中对上送CPU的报文按照协议优先级进行调度，保证优先级高的协议先得到处理。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**packet-type** *packet-type* **priority** *priority-level* { **wired** | **wireless** }，配置上送CPU报文的协议类型的优先级。

缺省情况下，使用**default**策略的缺省配置对上送CPU报文的协议类型区分优先级。

----结束

27.2.3.1.4 配置动态链路保护功能

背景信息

动态链路保护功能保护基于会话的应用层数据，包括SSH Session、Telnet Session、SSHv6 Session、Telnetv6 Session、FTP Session数据，保证这些业务在攻击发生时可以正常运行。

动态链路保护功能限制速率在防攻击策略视图下进行配置，而**cpu-defend application-apperceive enable**则是动态链路保护功能的开关。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**application-apperceive packet-type** { **ssh** | **telnet** | **sshv6** | **telnetv6** | **ftp** } **rate-limit** *rate-value*，配置SSH、Telnet、SSHv6、Telnetv6或FTP报文的动态链路保护功能的限制速率。

缺省情况下，SSH、Telnet、SSHv6、Telnetv6报文的动态链路保护功能的限制速率是512pps，FTP报文的动态链路保护功能的限制速率是1024pps。

说明

配置FTP协议的动态链路保护功能后，对TFTP协议也生效。

步骤4 执行命令**quit**，返回系统视图。

步骤5 执行命令**cpu-defend application-apperceive** [**ssh** | **telnet** | **sshv6** | **telnetv6** | **ftp**] **enable**，使能动态链路保护功能。

缺省情况下，对于SSH协议、Telnet协议、SSHv6协议、Telnetv6协议、FTP协议，已使能动态链路保护功能。

----结束

27.2.3.1.5 配置统一限速

背景信息

创建防攻击策略后，可以在防攻击策略中配置对所有上送CPU的报文进行统一限速。设备对超过统一限速值的报文随机丢弃，保证整体上送CPU的报文不会过多，保护CPU安全。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**rate-limit all-packets pps** *pps-value*，配置对所有上送CPU的报文进行统一限速。

缺省情况下，统一限速值为：

- AC6605、AC6508、AC6507S、AirEngine 9700S-S：4000pps
- AC6800V：200000pps
- AC6805、AirEngine 9700-M：85000pps
- ACU2：40000pps
- AC6003，AC6005：2000pps

----结束

27.2.3.1.6 配置动态 CPCAR 功能

背景信息

动态CPCAR是指当设备CPU占用率高于70%时，系统会自动降低部分协议报文上送CPU的速率，来降低CPU占用率。当CPU占用率降到70%及以下时，系统自动恢复这些协议报文上送CPU的速率。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**track system-load enable**，配置动态CPCAR功能。

缺省情况下，关闭动态调整CPCAR功能。

----结束

27.2.3.1.7 应用防攻击策略

背景信息

创建防攻击策略之后，必须将策略在系统视图下应用，否则防攻击策略不会生效。

设备上仅能应用一个防攻击策略。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend-policy** *policy-name*，应用防攻击策略。

----结束

27.2.3.1.8 检查配置结果

操作步骤

- 使用命令**display cpu-defend policy** [*policy-name*]，查看防攻击策略信息。
- 使用命令**display cpu-defend statistics** [**packet-type** *packet-type*] { **wired** | **wireless** }，查看上送CPU报文的统计信息。
- 使用命令**display cpu-defend configuration** [**packet-type** *packet-type*] { **wired** | **wireless** }，查看设备对协议报文限速的配置信息。

----结束

27.2.3.2 配置攻击溯源

通过配置攻击溯源，设备可以分析上送CPU的报文是否会对CPU造成攻击，对可能造成攻击的报文进行写日志或告警提醒网络管理员，以便管理员采用一定的措施来保护设备。

前置任务

在配置攻击溯源之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。

配置流程

在配置攻击溯源任务中，必须首先创建防攻击策略，其余步骤是并列关系，无严格配置顺序，用户根据需要选择配置即可。防攻击策略在创建之后必须应用才能生效，但应用时机无严格限制。

27.2.3.2.1 创建防攻击策略

背景信息

用户需要先创建防攻击策略，然后在创建的防攻击策略中配置本机防攻击功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，创建防攻击策略并进入防攻击策略视图。

设备最多支持19个防攻击策略。其中名称为**default**的策略为系统自动生成的缺省策略，**default**策略默认应用到设备上，不允许删除，也不允许修改参数；其余18个允许用户创建、修改和删除。

步骤3 （可选）执行命令**description** *text*，配置防攻击策略的描述信息。

缺省情况下，防攻击策略没有配置描述信息。

----结束

27.2.3.2.2 配置攻击溯源检查阈值

背景信息

网络上可能会出现大量攻击报文攻击设备的CPU。通过使能攻击溯源功能并配置攻击溯源检查阈值，设备可以分析上送CPU的报文是否会对CPU造成攻击。当可能的攻击源在单位时间内发送某种协议类型的报文超过检查阈值时，设备会将可能造成攻击的报文以日志方式通知网络管理员，以便网络管理员采取措施对攻击源进行防御部署。

说明

使能攻击溯源功能，如果有正常业务的协议报文超出设置的检查阈值，则可能会对这些业务造成影响，业务异常。此时可以尝试关闭攻击溯源功能，或者关闭对应协议的攻击溯源功能，使业务恢复正常。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**auto-defend enable**，使能攻击溯源功能。

缺省情况下，未使能攻击溯源功能。

步骤4 执行命令**auto-defend threshold** *threshold*，配置攻击溯源检查阈值。

缺省情况下，攻击溯源检查阈值为128pps。

----结束

27.2.3.2.3 配置攻击溯源的溯源模式

背景信息

当攻击溯源启动后，设备将根据配置的溯源模式进行溯源。目前，设备支持三种溯源模式，分别适用于以下场景：

- 针对三层报文的攻击，则配置基于源IP地址进行溯源。
- 针对固定源MAC地址报文的攻击，则配置基于源MAC地址进行溯源。
- 针对变换源MAC地址报文的攻击，则配置基于接口和VLAN进行溯源。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**auto-defend enable**，使能攻击溯源功能。

缺省情况下，未使能攻击溯源功能。

步骤4 执行命令**auto-defend trace-type** { **source-ip** | **source-mac** | **source-portvlan** } *，配置攻击溯源的溯源模式。

缺省情况下，攻击溯源的溯源模式为基于源MAC地址、基于源IP地址和基于源接口+VLAN。

----结束

27.2.3.2.4 配置攻击溯源防范的报文类型

背景信息

当攻击发生时，由于设备同时对多种类型的报文进行溯源，网络管理员无法区分攻击报文的具体类型。通过灵活配置攻击溯源防范的报文类型，设备将针对所配置的报文类型进行溯源。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**auto-defend enable**，使能攻击溯源功能。

缺省情况下，未使能攻击溯源功能。

步骤4 执行命令**auto-defend protocol** { **all** | { **http** | **https** | **ftp** | **ssh** | **arp** | **capwap** | **dhcp** | **dhcpv6** | **icmp** | **icmpv6** | **igmp** | **nd** | **tcp** | **telnet** | **ttl-expired** } * }，配置攻击溯源防范的报文类型。

缺省情况下，攻击溯源防范的报文类型为HTTP（Hyper Text Transport Protocol）、HTTPS（HTTP Secure）、FTP（File Transfer Protocol）、SSH（Secure Shell）、ARP（Address Resolution Protocol）、CAPWAP（Control And Provisioning of Wireless Access Points）、DHCP（Dynamic Host Configuration Protocol）、DHCPv6、ICMP（Internet Control Message Protocol）、ICMPv6、IGMP（Internet Group Management Protocol）、ND（Neighbor Discovery Protocol）、Telnet、TCP（Transmission Control Protocol）和TTL-expired（Time To Live-expired）。

----结束

27.2.3.2.5 配置攻击溯源告警功能

背景信息

当可能的攻击源在单位时间内发送某种协议类型的报文超过一定阈值时，如果希望设备能以告警的方式提醒网络管理员，以便管理员采取一定的措施来保护设备，则可以使能攻击溯源告警功能并配置攻击溯源告警阈值。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**auto-defend enable**，使能攻击溯源功能。

缺省情况下，未使能攻击溯源功能。

步骤4 配置攻击溯源告警功能

1. 执行命令**auto-defend alarm enable**，使能攻击溯源告警功能。

   缺省情况下，攻击溯源告警功能未使能。

2. 执行命令**auto-defend alarm threshold** *threshold*，配置攻击溯源告警阈值。

   缺省情况下，攻击溯源告警阈值为128pps。

----结束

27.2.3.2.6 配置攻击溯源惩罚功能

背景信息

配置对检测到的攻击源进行惩罚，设备将丢弃攻击源发送的攻击报文，从而避免攻击者继续攻击设备。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend policy** *policy-name*，进入防攻击策略视图。

步骤3 执行命令**auto-defend enable**，使能攻击溯源功能。

缺省情况下，未使能攻击溯源功能。

步骤4 执行命令**auto-defend action deny** [**timer** *time-length*]，使能攻击溯源的惩罚功能。

缺省情况下，未使能攻击溯源的惩罚功能。

----结束

27.2.3.2.7 应用防攻击策略

背景信息

创建防攻击策略之后，必须将策略在系统视图下应用，否则防攻击策略不会生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**cpu-defend-policy** *policy-name*，应用防攻击策略。

----结束

27.2.3.2.8 检查配置结果

操作步骤

- 执行命令**display auto-defend attack-source** [**detail**]，查看攻击源信息。
- 执行命令**display auto-defend configuration** [**cpu-defend policy** *policy-name*]，查看防攻击策略的攻击溯源配置信息。
- 执行命令**display cpu-defend policy** [*policy-name*]，查看防攻击策略的信息。

----结束

27.2.4 维护本机防攻击

维护本机防攻击包括清除攻击源信息和清除上送CPU报文统计信息，可以帮助您定位攻击源或者确认攻击是否消除。

27.2.4.1 清除攻击溯源信息

背景信息

当需要对攻击溯源信息重新进行统计时，可以在用户视图下执行以下命令，清除之前的统计信息。

须知

清除攻击溯源信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

步骤1 执行命令**reset auto-defend attack-source**，清除攻击溯源信息。

----结束

27.2.4.2 清除上送 CPU 报文统计信息

背景信息

当需要对上送CPU的报文重新进行统计时，可以在用户视图下执行以下命令，清除之前的统计信息。

须知

清除上送CPU报文统计信息后，以前的统计信息将无法恢复，请于清除之前仔细确认。

操作步骤

步骤1 执行命令**reset cpu-defend statistics** [**packet-type** *packet-type*] { **wired** | **wireless** }，清除上送CPU报文统计信息。

----结束

27.2.5 配置举例

介绍本机防攻击配置举例。配置示例中包括组网需求、配置思路等。

27.2.5.1 配置本机防攻击示例

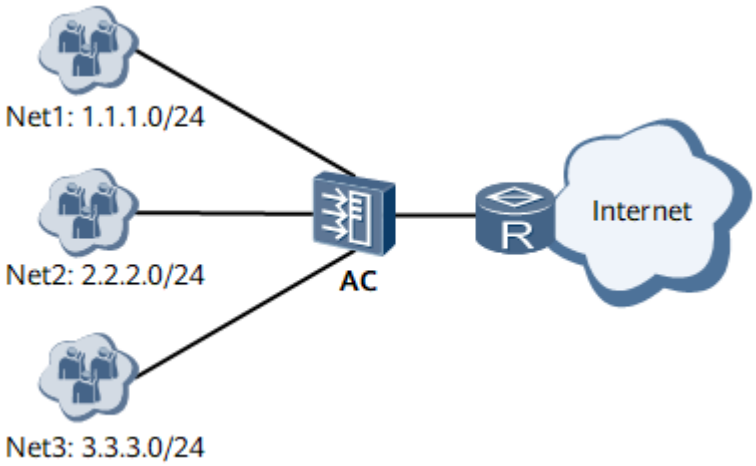
组网需求

如图27-6所示，位于不同局域网的用户通过AC访问Internet。管理员发现存在以下现象：

- 攻击者发送大量的ARP Request报文，影响CPU的正常工作。
- 管理员需要以FTP方式上传文件到AC，此时需要建立管理员主机与AC之间的数据连接。
- 大多数局域网用户通过DHCP方式动态获取IP地址，但AC不优先处理上送CPU的DHCP Client报文。

管理员希望通过在AC进行配置，以便解决上述问题。

图 27-6 配置本机防攻击组网图



配置思路

采用如下的思路配置本机防攻击：

1. 配置ARP Request报文上送CPU的速率限制，使ARP Request报文限制在一个较小的速率范围内，减少对CPU处理正常业务的影响。
2. 配置FTP协议的动态链路保护功能，保证文件数据可以在管理员主机与AC之间正常传输。
3. 配置协议优先级，对DHCP Client报文设置较高的优先级，保证AC优先处理上送CPU的DHCP Client报文。

配置注意事项

- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 创建防攻击策略

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] cpu-defend policy devicesafety
```

步骤2 配置ARP Request报文上送CPU的速率限制

```
[AC-cpu-defend-policy-devicesafety] packet-type arp-request rate-limit 80 wired
[AC-cpu-defend-policy-devicesafety] packet-type arp-request rate-limit 80 wireless
```

步骤3 配置FTP协议动态链路保护功能的速率限制值

```
[AC-cpu-defend-policy-devicesafety] application-apperceive packet-type ftp rate-limit 2000
```

步骤4 配置DHCP Client报文的优先级

```
[AC-cpu-defend-policy-devicesafety] packet-type dhcp-client priority 3 wired
[AC-cpu-defend-policy-devicesafety] packet-type dhcp-client priority 3 wireless
[AC-cpu-defend-policy-devicesafety] quit
```

步骤5 应用防攻击策略

使能FTP协议动态链路保护功能

```
[AC] cpu-defend application-apperceive ftp enable
```

应用防攻击策略

```
[AC] cpu-defend-policy devicesafety
```

步骤6 验证配置结果

查看配置的防攻击策略的信息。

```
[AC] display cpu-defend policy devicesafety
Related slot : <0>
 Configuration :
   Packet-type arp-request rate-limit : 80(pps) in wired
   Packet-type arp-request rate-limit : 80(pps) in wireless
   Packet-type dhcp-client priority : 3 in wired
   Packet-type dhcp-client priority : 3 in Wireless
   Rate-limit all-packets : 2000(pps)(default)
   Application-apperceive packet-type ftp : 2000(pps)
   Application-apperceive packet-type tftp : 2000(pps)
```

查看配置的限速信息，显示结果表明，对arp-request报文的限制速率和dhcp-client报文优先级的配置成功。

```
<AC> display cpu-defend configuration wired
Rate configurations on main board.
-----------------------------------------------------------------
Packet-type            Status       Rate-limit(PPS)  Priority
-----------------------------------------------------------------
8021X                  Enabled      128              2
arp-miss               Enabled      64               2
arp-reply              Enabled      128              2
arp-request            Enabled      80               2
bfd                    Disabled     128              4
bgp                    Disabled     256              3
capwap                 Enabled      1024             3
capwap-discovery       Enabled      64               2
capwap-echo            Enabled      1024             4
capwap-keepalive       Enabled      1024             4
dhcp-client            Enabled      256              3
dhcp-server            Enabled      256              2
dhcpv6-reply           Enabled      256              2
dhcpv6-request         Enabled      256              2
dns                    Enabled      64               3
eoam-3ah               Disabled     256              1
fib-hit                Enabled      64               2
ftp-client             Enabled      128              2
ftp-server             Enabled      256              2
gre-keepalive          Enabled      128              2
http-client            Enabled      256              2
http-server            Enabled      64               2
https-client           Enabled      512              2
https-server           Disabled     64               2
hw-tacacs              Enabled      64               2
icmp                   Enabled      128              2
icmpv6                 Enabled      128              2
igmp                   Disabled     128              2
ip-option              Enabled      256              2
ipsec-ike              Enabled      128              2
ipsec-isa              Enabled      128              2
ipsec-osa              Enabled      128              2
```

```
isis                    Disabled        256          3
lacp                    Disabled        128          1
lldp                    Enabled         128          3
mdns                    Disabled        256          3
mld                     Disabled        128          2
nat-debug               Enabled         16           2
nat-dns                 Enabled         128          2
nat-ftp                 Enabled         128          2
nat-pptp                Enabled         128          2
nat-rtsp                Enabled         128          2
nd                      Enabled         256          4
nd-miss                 Enabled         64           4
ntp                     Enabled         64           3
ospf                    Disabled        256          3
ospfv3                  Disabled        256          3
pim                     Disabled        128          3
radius                  Enabled         64           2
rarp-reply              Enabled         64           2
rarp-request            Enabled         64           2
rip                     Disabled        128          3
ripng                   Disabled        128          3
snmp                    Enabled         128          4
ssh-client              Disabled        128          4
ssh-server              Enabled         64           4
stp                     Disabled        64           3
tcp                     Enabled         64           2
telnet-client           Enabled         128          4
telnet-server           Enabled         256          4
ttl-expired             Enabled         64           1
unknown-multicast       Enabled         64           1
unknown-packet          Enabled         64           2
vrrp                    Disabled        64           3
vrrp6                   Disabled        64           3
wapi                    Enabled         128          2
-----------------------------------------------------------------
<AC> display cpu-defend configuration wireless
Rate configurations on main board.
-----------------------------------------------------------------
Packet-type             Status      Rate-limit(PPS)  Priority
-----------------------------------------------------------------
8021X                   Enabled     128              2
arp-miss                Enabled     64               2
arp-reply               Enabled     64               2
arp-request             Enabled     80               2
dhcp-client             Enabled     256              3
dhcp-server             Enabled     256              2
dhcpv6-reply            Enabled     256              2
dhcpv6-request          Enabled     256              2
dns                     Enabled     64               3
fib-hit                 Enabled     64               2
ftp-client              Enabled     128              2
ftp-server              Enabled     256              2
http-client             Enabled     256              2
http-server             Enabled     64               2
https-client            Enabled     512              2
https-server            Disabled    64               2
icmp                    Enabled     128              2
icmpv6                  Enabled     128              2
igmp                    Disabled    128              2
ip-option               Enabled     256              2
mdns                    Disabled    256              3
mld                     Disabled    128              2
nat-debug               Enabled     16               2
nat-dns                 Enabled     128              2
nat-ftp                 Enabled     128              2
nat-pptp                Enabled     128              2
nat-rtsp                Enabled     128              2
nd                      Enabled     256              4
nd-miss                 Enabled     64               4
```

```
rarp-reply              Enabled          64           2
rarp-request            Enabled          64           2
snmp                    Enabled         128           4
ssh-client              Disabled        128           4
ssh-server              Enabled          64           4
tcp                     Enabled          64           2
telnet-client           Enabled         128           4
telnet-server           Enabled         256           4
ttl-expired             Enabled          64           1
unknown-multicast       Enabled          64           1
unknown-packet          Enabled          64           2
wapi                    Enabled         128           2
-----------------------------------------------------------------
```

查看上送到CPU的报文的统计信息，丢弃的报文表明设备对arp-request进行了速率限制。

```
<AC> display cpu-defend statistics wired
-------------------------------------------------------------------------
Packet Type              Pass Packets        Drop Packets
-------------------------------------------------------------------------
8021X                          0                   0
arp-miss                       0                   0
arp-reply                     19                   0
arp-request                1446576              127773
capwap                        594                   0
capwap-discovery                0                   0
capwap-echo                     0                   0
capwap-keepalive              248                   0
dhcp-client                   108                   0
dhcp-server                     0                   0
dhcpv6-reply                    0                   0
dhcpv6-request                 17                   0
dns                             0                   0
fib-hit                         0                   0
ftp-client                      0                   0
ftp-server                      0                   0
gre-keepalive                   0                   0
http-client                     0                   0
http-server                     0                   0
https-client                    0                   0
hw-tacacs                       0                   0
icmp                           34                   0
icmpv6                         16                   0
ip-option                       0                   0
ipsec-ike                       0                   0
ipsec-isa                       0                   0
ipsec-osa                       0                   0
lldp                        12196                   0
nat-debug                       0                   0
nat-dns                         0                   0
nat-ftp                         0                   0
nat-pptp                        0                   0
nat-rtsp                        0                   0
nd                              0                   0
nd-miss                         0                   0
ntp                             0                   0
radius                          0                   0
rarp-reply                      0                   0
rarp-request                    0                   0
snmp                            0                   0
ssh-server                      0                   0
tcp                             0                   0
telnet-client                   0                   0
telnet-server                 649                   0
ttl-expired                     0                   0
unknown-multicast               0                   0
unknown-packet                  4                   0
wapi                            0                   0
-------------------------------------------------------------------------
```

```
<AC> display cpu-defend statistics wireless
-----------------------------------------------------------------------
Packet Type              Pass Packets        Drop Packets
-----------------------------------------------------------------------
8021X                          0                  0
arp-miss                       0                  0
arp-reply                      0                  0
arp-request                    0                  0
dhcp-client                    0                  0
dhcp-server                    0                  0
dhcpv6-reply                   0                  0
dhcpv6-request                 0                  0
dns                            0                  0
fib-hit                        0                  0
ftp-client                     0                  0
ftp-server                     0                  0
http-client                    0                  0
http-server                    0                  0
https-client                   0                  0
icmp                           0                  0
icmpv6                         0                  0
ip-option                      0                  0
nat-debug                      0                  0
nat-dns                        0                  0
nat-ftp                        0                  0
nat-pptp                       0                  0
nat-rtsp                       0                  0
nd                             0                  0
nd-miss                        0                  0
rarp-reply                     0                  0
rarp-request                   0                  0
snmp                           0                  0
ssh-server                     0                  0
tcp                            0                  0
telnet-client                  0                  0
telnet-server                  0                  0
ttl-expired                    0                  0
unknown-multicast              0                  0
unknown-packet                 0                  0
wapi                           0                  0
-----------------------------------------------------------------------
```

----结束

配置文件

```
#
sysname AC
#
cpu-defend policy devicesafety
 packet-type arp-request rate-limit 80 wired
 packet-type arp-request rate-limit 80 wireless
 packet-type dhcp-client priority 3 wired
 packet-type dhcp-client priority 3 wireless
 application-apperceive packet-type ftp rate-limit 2000
#
 cpu-defend-policy devicesafety
#
return
```

27.3 攻击防范配置

攻击防范是一种重要的网络安全特性。通过配置攻击防范功能，设备能够检测出多种类型的网络攻击，并能采取相应的措施保护设备自身及其所连接的内部网络免受恶意攻击，保证内部网络及设备的正常运行。

27.3.1 攻击防范简介

介绍攻击防范的定义和作用。

定义

攻击防范是一种重要的网络安全特性。它通过分析上送CPU处理的报文的内容和行为，判断报文是否具有攻击特性，并配置对具有攻击特性的报文执行一定的防范措施。

攻击防范主要分为畸形报文攻击防范、分片报文攻击防范和泛洪攻击防范。

目的

目前，网络的攻击日益增多，而通信协议本身的缺陷以及网络部署问题，导致网络攻击造成的影响越来越大。特别是对网络设备的攻击，将会导致设备或者网络瘫痪等严重后果。

攻击防范针对上送CPU的不同类型攻击报文，采用丢弃或者限速的手段，以保障设备不受攻击的影响，使业务正常运行。

27.3.2 原理描述

介绍攻击防范的实现原理。

27.3.2.1 畸形报文攻击防范

畸形报文攻击是通过向目标设备发送有缺陷的IP报文，使得目标设备在处理这样的IP报文时出错和崩溃，给目标设备带来损失。畸形报文攻击防范是指设备实时检测出畸形报文并予以丢弃，实现对本设备的保护。

畸形报文攻击主要分为以下几类：

没有 IP 载荷的泛洪

如果IP报文只有20字节的IP报文头，没有数据部分，就认为是没有IP载荷的报文。攻击者经常构造只有IP头部，没有携带任何高层数据的IP报文，目标设备在处理这些没有IP载荷的报文时会出错和崩溃，给设备带来损失。

启用畸形报文攻击防范后，设备在接收到没有载荷的IP报文时，直接将其丢弃。

IGMP 空报文

IGMP报文是20字节的IP头加上8字节的IGMP报文体，总长度小于28字节的IGMP报文称为IGMP空报文。设备在处理IGMP空报文时会出错和崩溃，给目标设备带来损失。

启用畸形报文攻击防范后，设备在接收到IGMP空报文时，直接将其丢弃。

LAND 攻击

LAND攻击是攻击者利用TCP连接三次握手机制中的缺陷，向目标主机发送一个源地址和目的地址均为目标主机、源端口和目的端口相同的SYN报文，目标主机接收到该报文后，将创建一个源地址和目的地址均为自己的TCP空连接，直至连接超时。在这种攻击方式下，目标主机将会创建大量无用的TCP空连接，耗费大量资源，直至设备瘫痪。

启用畸形报文攻击防范后，设备采用检测TCP SYN报文的源地址和目的地址的方法来避免LAND攻击。如果TCP SYN报文中的源地址和目的地址一致，则认为是畸形报文攻击，丢弃该报文。

Smurf 攻击

Smurf攻击是指攻击者向目标网络发送源地址为目标主机地址、目的地址为目标网络广播地址的ICMP请求报文，目标网络中的所有主机接收到该报文后，都会向目标主机发送ICMP响应报文，导致目标主机收到过多报文而消耗大量资源，甚至导致设备瘫痪或网络阻塞。

启用畸形报文攻击防范后，设备通过检测ICMP请求报文的目标地址是否是广播地址或子网广播地址来避免Smurf攻击。如果检测到此类报文，直接将其丢弃。

TCP 标志位非法攻击

TCP报文包含6个标志位：URG、ACK、PSH、RST、SYN、FIN，不同的系统对这些标志位组合的应答是不同的：

- 6个标志位全部为1，就是圣诞树攻击。设备在受到圣诞树攻击时，会造成系统崩溃。
- SYN和FIN同时为1，如果端口是关闭的，会使接收方应答一个RST | ACK消息；如果端口是打开的，会使接收方应答一个SYN | ACK消息，这可用于主机探测(主机在线或者下线)和端口探测（端口打开或者关闭）。
- 6个标志位全部为0：
  - 如果端口是关闭的，会使接收方应答一个RST | ACK消息，这可以用于探测主机；
  - 如果端口是开放的，Linux和UNIX系统不会应答，而Windows系统将回答RST | ACK消息，这可以探测操作系统类型（Windows系统，Linux和UNIX系统等）。

启用畸形报文攻击防范后，设备采用检查TCP的各个标志位避免TCP标志位非法攻击，如果符合下面条件之一，则将该TCP报文丢弃：

- 6个标志位全部为1；
- SYN和FIN位同时为1；
- 6个标志位全部为0。

27.3.2.2 分片报文攻击防范

分片报文攻击是通过向目标设备发送分片出错的报文，使得目标设备在处理分片错误的报文时崩溃、重启或消耗大量的CPU资源，给目标设备带来损失。分片报文攻击防范是指设备实时检测出分片报文并予以丢弃或者限速处理，实现对本设备的保护。

分片报文攻击主要分为以下几类：

分片数量巨大攻击

IP报文中的偏移量是以8字节为单位的。正常情况下，IP报文的头部有20个字节，IP报文的最大载荷为65515。对这些数据进行分片，分片个数最大可以达到8189片，对于超过8189的分片报文，设备在重组这些分片报文时会消耗大量的CPU资源。

启用分片报文攻击防范后，针对分片数量巨大攻击，如果同一报文的分片数目超过8189个，则设备认为是恶意报文，丢弃该报文的所有分片。

巨大 Offset 攻击

攻击者向目标设备发送一个Offset值超大的分片报文，从而导致目标设备分配巨大的内存空间来存放所有分片报文，消耗大量资源。

Offset字段的最大取值为65528，但是在正常情况下，Offset值不会超过8190（如果offset=8189*8，IP头部长度为20，最后一片报文最多只有3个字节IP载荷，所以正常Offset的最大值是8189），所以如果Offset值超过8190，则这种报文即为恶意攻击报文，设备直接丢弃。

启用分片报文攻击防范后，设备在收到分片报文时判断Offset*8是否大于65528，如果大于就当作恶意分片报文直接丢弃。

重复分片攻击

重复分片攻击就是把同样的分片报文多次向目标主机发送，存在两种情况：

- 多次发送的分片完全相同，这样会造成目标主机的CPU和内存使用不正常；
- 多次发送的分片报文不相同，但Offset相同，目标主机就会处于无法处理的状态：哪一个分片应该保留，哪一个分片应该丢弃，还是都丢弃。这样就会造成目标主机的CPU和内存使用不正常。

启用分片报文攻击防范后，对于重复分片类报文的攻击，设备实现对分片报文进行CAR（Committed Access Rate）限速，保留首片，丢弃其余所有相同的重复分片，保证不对CPU造成攻击。

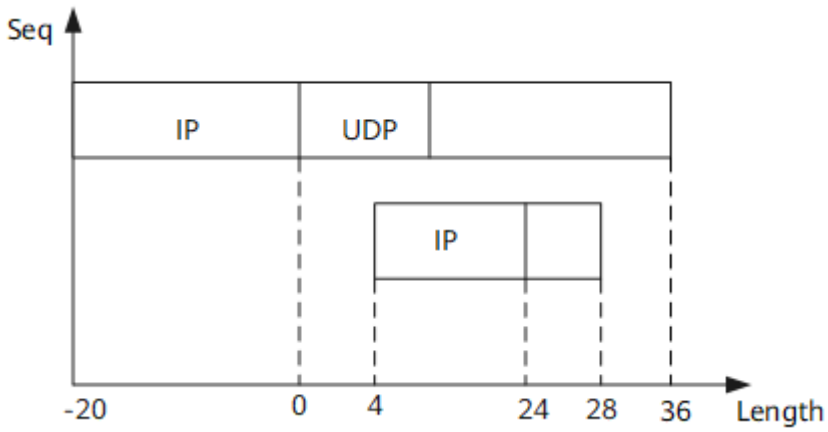
Tear Drop 攻击

Tear Drop攻击是最著名的IP分片攻击，原理是IP分片错误，第二片包含在第一片之中。即数据包中第二片IP包的偏移量小于第一片结束的位移，而且算上第二片IP包的Data，也未超过第一片的尾部。

如图27-7所示：

- 第一个分片IP载荷为36字节，总长度为56字节，protocol为UDP，UDP检验和为0（没有检验）；
- 第二片IP载荷为4字节，总长度为24字节，protocol为UDP，Offset=24（错误，正确应该为36）。

图 27-7 Tear Drop 攻击分片示意图



Tear Drop攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Tear Drop攻击，设备会直接丢弃所有分片报文。

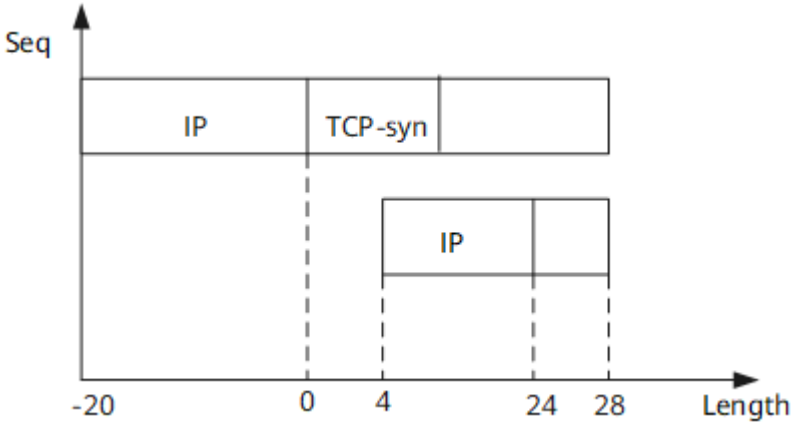
Syndrop 攻击

Syndrop攻击原理和Tear Drop原理一致，区别在于Syndrop攻击使用了TCP协议，Flag为SYN，而且带有载荷。

如图27-8所示：

- 第一片IP载荷为28字节，IP头部20字节；
- 第二片IP载荷为4字节，IP头部20字节，Offset=24（错误，正确应该是28）。

图 27-8 Syndrop 攻击分片示意图



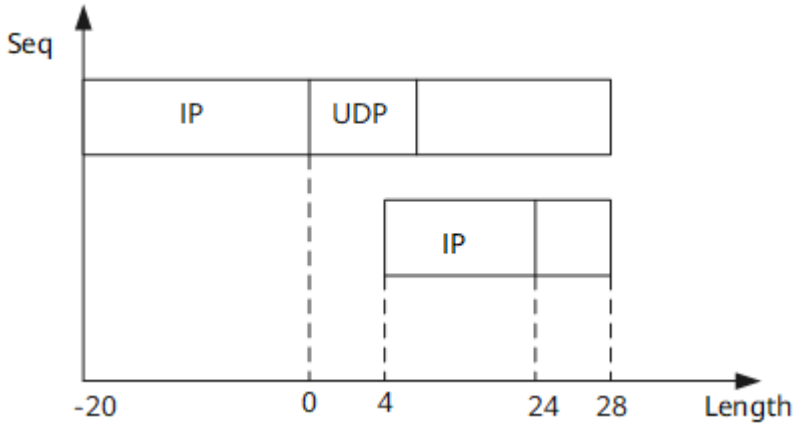
Syndrop攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Syndrop攻击，设备会直接丢弃所有分片报文。

NewTear 攻击

NewTear攻击是分片错误的攻击。如图27-9所示，protocol使用UDP。

- 第一片IP载荷28字节（包含UDP头部，UDP检验和为0）；
- 第二片IP载荷4字节，0ffset=24（错误，正确应该是28）。

图 27-9 NewTear 攻击分片示意图



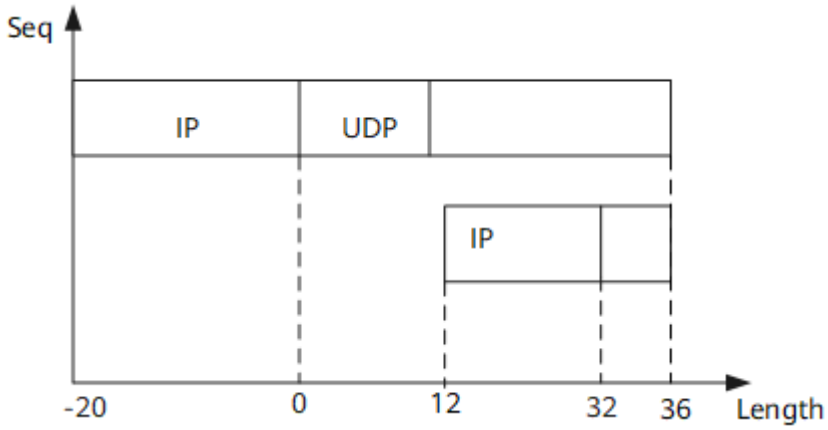
NewTear攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于NewTear攻击，设备会直接丢弃所有分片报文。

Bonk 攻击

Bonk攻击是分片错误的攻击。如图27-10所示，protocol使用UDP。

- 第一片IP载荷为36字节（包含UDP头部，UDP检验和为0）；
- 第二片IP载荷为4字节，offset=32（错误，正确应该是36）。

图 27-10 Bonk 攻击分片示意图



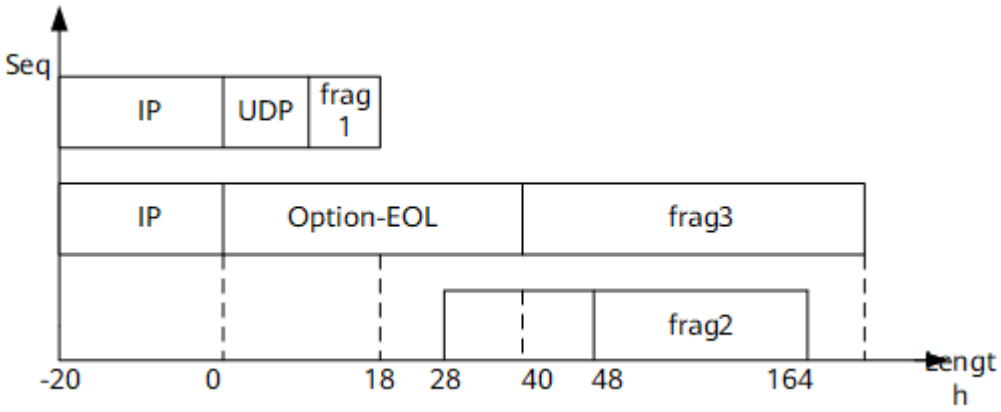
Bonk攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Bonk攻击，设备会直接丢弃所有分片报文。

Nesta 攻击

Nesta攻击是分片错误的攻击。如图27-11所示：

- 第一片IP载荷为18，protocol为UDP，检验和为0；
- 第二片offset为48，IP载荷为116字节；
- 第三片offset为0，more frag为1，也就是还有分片，40字节的IP option，都是EOL，IP载荷为224字节。

图 27-11 Nesta 攻击分片示意图



Nesta攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Nesta攻击，设备会直接丢弃所有分片报文。

Rose 攻击

IP protocol可以是UDP或TCP，可以选择。

如图27-12所示：

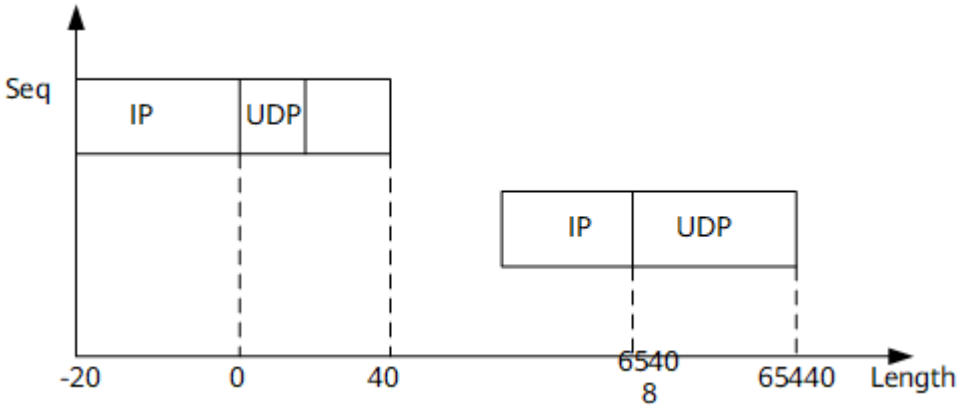
如果IP protocol是TCP：

- 第一片IP载荷为48字节（包含TCP头部），IP头部20字节；
- 第二片IP报文的载荷为32字节，但是offset=65408，more frag=0，即最后一片。

如果IP protocol是UDP：

- 第一片载荷长度40字节（包含UDP头部，UDP校验和为0），IP头部20字节；
- 第二片IP报文的载荷为32字节，但是offset＝65408，more frag＝0，即最后一片。

图 27-12 Rose 攻击分片示意图

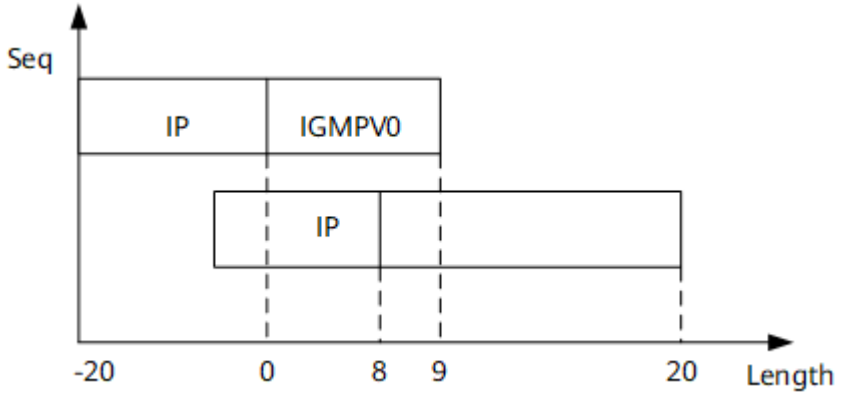


Rose攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Rose攻击，设备会直接丢弃所有分片报文。

Fawx 攻击

Fawx攻击是一种分片错误的IGMP报文。如图27-13，Fawx攻击的特征是：发送IGMP报文分片，一共两片，第一片9个字节，第二个分片offset＝8，载荷长度为16字节，没有结束分片。

图 27-13 Fawx 攻击分片示意图



Fawx攻击会导致系统崩溃或重启。启用分片报文攻击防范后，对于Fawx攻击，设备会直接丢弃所有分片报文。

Ping of Death 攻击

Ping of Death攻击原理是攻击者发送一些尺寸较大（数据部分长度超过65507字节）的ICMP报文对设备进行攻击。设备在收到这样一个尺寸较大的ICMP报文后，如果处理不当，会造成协议栈崩溃。

启用分片报文攻击防范后，设备在收到这种攻击报文后，直接丢弃该报文。

Jolt 攻击

Jolt攻击是攻击者发送总长度大于65535字节的报文对设备进行攻击。Jolt攻击报文一共173个分片，每个分片报文的IP载荷为380字节，因此总长度为：173*380+20＝65760，远远超过65535。设备在收到这样的报文时，如果处理不当，会造成设备崩溃、死机或重启。

启用分片报文攻击防范后，设备在收到Jolt攻击报文后，直接丢弃该报文。

27.3.2.3 泛洪攻击防范

泛洪攻击是指攻击者在短时间内向目标设备发送大量的虚假报文，导致目标设备忙于应付无用报文，而无法为用户提供正常服务。

泛洪攻击防范是指设备实时检测出泛洪报文并予以丢弃或者限速处理，实现对本设备的保护。

泛洪攻击主要分为TCP SYN泛洪攻击、UDP泛洪攻击和ICMP泛洪攻击。

TCP SYN 泛洪攻击

TCP SYN攻击利用了TCP三次握手的漏洞。在TCP的3次握手期间，当接收端收到来自发送端的初始SYN报文时，向发送端返回一个SYN+ACK报文。接收端在等待发送端的

最终ACK报文时，该连接一直处于半连接状态。如果接收端最终没有收到ACK报文包，则重新发送一个SYN+ACK到发送端。如果经过多次重试，发送端始终没有返回ACK报文，则接收端关闭会话并从内存中刷新会话，从传输第一个SYN+ACK到会话关闭大约需要30秒。

在这段时间内，攻击者可能将数十万个SYN报文发送到开放的端口，并且不回应接收端的SYN+ACK报文。接收端内存很快就会超过负荷，且无法再接受任何新的连接，并将现有的连接断开。

设备对TCP SYN攻击处理的方法是在使能了TCP SYN泛洪攻击防范后对TCP SYN报文进行速率限制，保证受到攻击时设备资源不被耗尽。

UDP 泛洪攻击

UDP泛洪攻击是指攻击者在短时间内向目标设备发送大量的UDP报文，导致目标设备负担过重而不能处理正常的业务。UDP泛洪攻击分为以下两类：

- Fraggle攻击

  Fraggle攻击的原理是攻击者发送源地址为目标主机地址，目的地址为广播地址，目的端口号为7的UDP报文。如果该广播网络中有很多主机都起用了UDP响应请求服务，目的主机将收到很多回复报文，造成系统繁忙，达到攻击效果。

  设备默认UDP端口号为7的报文是攻击报文，直接将其丢弃。

- UDP诊断端口攻击

  攻击者对UDP诊断端口（7-echo，13-daytime，19-Chargen等UDP端口）发送报文，如果同时发送的数据包数量很大，造成泛洪，可能影响网络设备的正常工作。

  设备将UDP端口为7、13和19的报文认为是攻击报文，直接丢弃。

ICMP 泛洪攻击

通常情况下，网络管理员会用Ping程序对网络进行监控和故障排除，大概过程如下：

- 源设备向接收设备发出ICMP响应请求报文；
- 接收设备接收到ICMP响应请求报文后，会向源设备回应一个ICMP应答报文。

如果攻击者向目标设备发送大量的ICMP响应请求报文，则目标设备会忙于处理这些请求，而无法继续处理其他的数据报文，造成对正常业务的冲击。

设备针对ICMP泛洪攻击进行CAR（Committed Access Rate）限速，保证CPU不被攻击，保证网络的正常运行。

27.3.3 缺省配置

介绍了攻击防范的缺省配置。

攻击防范的缺省配置如表27-6所示。

表 27-6 攻击防范缺省配置

参数	缺省值
畸形报文攻击防范功能	已使能

参数	缺省值
分片报文攻击防范功能	已使能
分片报文发送速率	155000000bit/s
TCP Syn攻击防范功能	已使能
TCP Syn泛洪报文发送速率	155000000bit/s
UDP泛洪攻击防范功能	已使能
ICMP泛洪攻击防范功能	已使能
ICMP泛洪报文发送速率	155000000bit/s

27.3.4 配置攻击防范

介绍攻击防范详细的配置过程。

27.3.4.1 配置畸形报文攻击防范

畸形报文攻击防范主要防止没有IP载荷的泛洪攻击、IGMP空报文攻击、LAND攻击、Smurf攻击和TCP标志位非法攻击。

背景信息

攻击者通过向目标设备发送畸形报文，使得目标设备在处理畸形报文时出错、崩溃，给目标设备带来损失，或者通过发送大量无用报文占用网络带宽等行为来造成攻击。

为了避免设备被畸形报文攻击的情况下瘫痪，保证正常的网络服务，可以配置畸形报文攻击防范。设备对畸形报文攻击防范的主要措施是判断是否是几种畸形报文攻击报文类型之一，若是，则直接丢弃畸形报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack abnormal enable**，使能畸形报文攻击防范功能。

缺省情况下，畸形报文攻击防范功能处于使能状态。

说明

在系统视图下，执行命令**anti-attack enable**可以使能所有的攻击防范功能（包括畸形报文攻击防范功能）。

----结束

检查配置结果

- 执行命令**display anti-attack statistics abnormal**，查看畸形报文防攻击的统计数据。

27.3.4.2 配置分片报文攻击防范

分片报文攻击主要包括分片数量巨大攻击、巨大offset攻击、重复分片攻击、Tear Drop攻击、Syndrop攻击、NewTear攻击、Bonk攻击、Nesta攻击、Rose攻击、Fawx攻击、Ping of Death攻击和Jolt攻击。

背景信息

攻击者通过向目标设备发送分片出错的报文，使得目标设备在处理分片错误的报文时消耗大量的CPU资源，给目标设备带来损失。

为了避免设备被分片报文攻击的情况下瘫痪，保证正常的网络服务，可以配置分片报文攻击防范。对分片报文攻击防范的主要措施是进行速率限制，防止大量的分片报文造成CPU繁忙，保证CPU在造成攻击的情况下正常运行。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack fragment enable**，使能分片报文攻击防范功能。

缺省情况下，分片报文攻击防范功能处于使能状态。

说明

在系统视图下，执行命令**anti-attack enable**可以使能所有的攻击防范功能（包括分片报文攻击防范功能）。

步骤3 执行命令**anti-attack fragment car cir** *cir*，限制分片报文接收的速率。

缺省情况下，分片报文的接收速率为155000000bit/s。

----结束

检查配置结果

- 执行命令**display anti-attack statistics fragment**，查看分片报文防攻击的统计数据。

27.3.4.3 配置泛洪攻击防范

泛洪攻击防范主要防止TCP Syn泛洪攻击、UDP泛洪攻击和ICMP泛洪攻击。

27.3.4.3.1 配置 TCP SYN 泛洪攻击防范

背景信息

攻击者向目标设备发送SYN报文，然后对于目标返回的SYN+ACK报文不作回应。目标设备如果没有收到攻击者的ACK回应，就会一直等待，形成半连接。攻击者利用这种方式，让目标设备上生成大量的半连接，迫使其大量资源浪费在这些半连接上。

为了避免TCP SYN泛洪攻击，可以在设备上配置TCP SYN泛洪攻击防范功能，通过限制TCP SYN报文的发送速率来防范TCP SYN泛洪攻击。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack tcp-syn enable**，使能TCP SYN泛洪攻击防范功能。

缺省情况下，TCP SYN泛洪攻击防范功能处于使能状态。

说明

在系统视图下，可以执行命令**anti-attack enable**使能所有的攻击防范功能（包括TCP SYN泛洪攻击防范功能）。

步骤3 执行命令**anti-attack tcp-syn car cir** *cir*，限制TCP SYN报文接收的速率。

缺省情况下，TCP SYN报文接收的速率为155000000bit/s。

----结束

27.3.4.3.2 配置 UDP 泛洪攻击防范

背景信息

如果攻击者在短时间内向特定目标发送特定目的端口号的UDP报文，会造成目标设备负担过重而不能处理正常的业务。为了避免UDP泛洪攻击，可以在设备上配置UDP泛洪攻击防范功能。

设备上配置UDP泛洪攻击防范功能，对于端口号为7、13和19的报文，直接丢弃。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack udp-flood enable**，使能UDP泛洪攻击防范功能。

缺省情况下，UDP泛洪攻击防范功能处于使能状态。

说明

在系统视图下，可以执行命令**anti-attack enable**使能所有的攻击防范功能（包括UDP泛洪攻击防范功能）。

----结束

27.3.4.3.3 配置 ICMP 泛洪攻击防范

背景信息

如果攻击者在短时间内向目标设备发送大量的ICMP响应请求报文，使目标设备忙于回复这些请求，会造成目标设备负担过重而不能处理正常的业务。为了避免ICMP泛洪攻击，可以在设备上配置ICMP泛洪攻击防范功能。

设备上配置ICMP泛洪攻击防范功能，通过限制ICMP报文的速率来防范ICMP泛洪攻击。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**anti-attack icmp-flood enable**，使能ICMP泛洪攻击防范功能。

缺省情况下，ICMP泛洪攻击防范功能处于使能状态。

说明

在系统视图下，可以执行命令**anti-attack enable**使能所有的攻击防范功能（包括ICMP泛洪攻击防范功能）。

步骤3 执行命令**anti-attack icmp-flood car cir** *cir*，限制ICMP泛洪攻击报文接收的速率。

缺省情况下，ICMP泛洪攻击报文接收的速率为155000000bit/s。

----结束

27.3.4.3.4 检查配置结果

操作步骤

- 执行**display anti-attack statistics** [**tcp-syn** | **udp-flood** | **icmp-flood**]命令，查看泛洪防攻击的统计数据。

----结束

27.3.5 维护攻击防范

维护攻击防范，包括清除攻击防范的统计信息。

27.3.5.1 清除攻击防范统计信息

背景信息

须知

清除信息后，以前的信息将无法恢复，务必仔细确认。

在确认需要清除攻击防范的统计信息时，请执行以下命令清除攻击防范的统计信息。

操作步骤

- 执行**reset anti-attack statistics** [**abnormal** | **fragment** | **tcp-syn** | **udp-flood** | **icmp-flood**]命令，清除攻击防范的报文统计信息。

----结束

27.3.6 配置举例

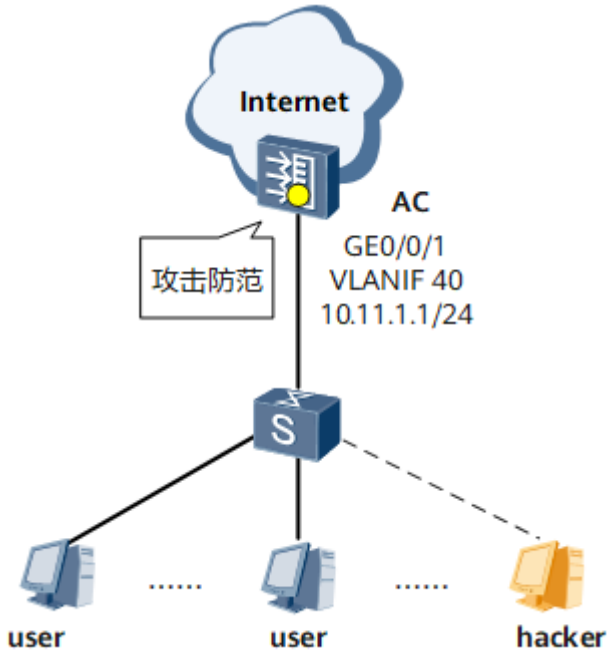
介绍攻击防范的配置举例。配置示例中包括组网图需求、配置思路、操作步骤等。

27.3.6.1 配置攻击防范示例

组网需求

如图27-14所示，如果局域网内存在Hacker向AC发起畸形报文攻击、分片报文攻击和泛洪攻击，将会造成AC瘫痪。为了预防这种情况，管理员希望通过在AC上部署各种攻击防范措施来为用户提供安全的网络环境，保障正常的网络服务。

图 27-14 配置攻击防范组网图



配置思路

采用如下思路在AC上配置攻击防范：

1. 使能畸形报文攻击防范功能，避免畸形报文攻击。
2. 使能分片报文攻击防范功能，避免分片报文攻击。
3. 使能泛洪攻击防范功能，避免泛洪攻击。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。
  - 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
  - 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击？**

- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 使能畸形报文攻击防范

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] anti-attack abnormal enable
```

步骤2 使能分片报文攻击防范，并限制分片报文接收的速率为15000bit/s

```
[AC] anti-attack fragment enable
[AC] anti-attack fragment car cir 15000
```

步骤3 使能泛洪攻击防范

使能TCP SYN攻击防范，并限制TCP SYN报文接收的速率为15000bit/s。

```
[AC] anti-attack tcp-syn enable
[AC] anti-attack tcp-syn car cir 15000
```

使能UDP泛洪攻击防范，对特定端口发送的UDP报文直接丢弃。

```
[AC] anti-attack udp-flood enable
```

使能ICMP泛洪攻击防范，并限制ICMP泛洪报文接收的速率为15000bit/s。

```
[AC] anti-attack icmp-flood enable
[AC] anti-attack icmp-flood car cir 15000
```

步骤4 检查配置结果

配置完成后，可以通过执行命令**display anti-attack statistics**查看报文攻击防范的统计数据。

```
<AC> display anti-attack statistics
Packets Statistic Information:
-------------------------------------------------------------------------------
AntiAtkType  TotalPacketNum        DropPacketNum        PassPacketNum
            (H)        (L)        (H)        (L)        (H)        (L)
-------------------------------------------------------------------------------
URPF         0          0          0          0          0          0
Abnormal     0          0          0          0          0          0
Fragment     0          0          0          0          0          0
Tcp-syn      0          34         0          28         0          6
Udp-flood    0          0          0          0          0          0
Icmp-flood   0          0          0          0          0          0
-------------------------------------------------------------------------------
```

由显示信息可知，AC上产生了TCP SYN报文的丢弃计数，表明攻击防范功能已经生效。

----结束

配置文件

AC的配置文件

```
#
sysname AC
#
anti-attack fragment car cir 15000
anti-attack tcp-syn car cir 15000
anti-attack icmp-flood car cir 15000
#
return
```

27.4 流量抑制配置

流量抑制包括流量抑制的基础知识、配置方法、配置实例和常见配置错误。

27.4.1 流量抑制简介

介绍流量抑制的定义和作用

定义

流量抑制是用于控制广播、组播以及未知单播报文，防止这三类报文引起广播风暴的安全技术。

流量抑制主要通过配置阈值来限制流量。

说明

未知单播报文是指目的MAC地址未被设备学习到的单播报文。

目的

当设备某个二层以太接口收到广播、组播或未知单播报文时，如果根据报文的目的MAC地址设备不能明确报文的出接口，设备会向同一VLAN内的其他二层以太接口转发这些报文，这样可能导致广播风暴，降低设备转发性能。

引入流量抑制特性，可以控制这三类报文流量，防范广播风暴。

27.4.2 原理描述

介绍流量抑制的实现原理。

27.4.2.1 流量抑制的基本原理

流量抑制特性按以下形式来限制广播、组播以及未知单播报文产生的广播风暴。

- 入方向上，设备支持分别对三类报文按包速率进行流量抑制。

  设备监控三类报文速率并和配置的阈值相比较，当入口流量超过配置的阈值时，设备会丢弃超额的流量。

27.4.3 配置注意事项

介绍了设备支持的流量抑制特性的相关配置注意事项。

设备支持情况

设备支持的流量抑制特性如表27-7所示。

表 27-7 设备支持情况

视图	设备支持的流量抑制特性
接口视图	• 对广播、组播和未知单播报文配置流量抑制。

27.4.4 缺省配置

介绍设备的流量抑制缺省值。

流量抑制缺省值如表27-8所示。

表 27-8 流量抑制缺省值

参数	缺省值
流量抑制	未使能
ICMP（Internet Control Message Protocol）报文流量抑制	未使能
ICMP报文流量抑制阈值	100pps

27.4.5 配置流量抑制

通过配置流量抑制，防范广播风暴，保障设备转发性能。

27.4.5.1 配置接口的流量抑制

背景信息

为了限制出入接口的广播、组播或未知单播类型报文的速率，防止广播风暴，可以在该接口上配置对应报文类型的流量抑制功能。

前置任务

在配置接口的流量抑制之前，需完成以下任务：

- 配置接口的链路层协议参数，使接口的链路协议状态为Up。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface** *interface-type interface-number*，进入接口视图。

步骤3 执行命令{ **broadcast-suppression** | **multicast-suppression** | **unicast-suppression** } **packets** *packets-per-second*，配置流量抑制。

----结束

27.4.5.2 配置 ICMP 报文限速

应用环境

网络中设备会收到大量的ICMP报文，对设备CPU造成冲击，设备可以对收到的ICMP报文进行速率限制，将超过限速阈值的报文丢弃，从而在一定程度上减轻CPU的负担。

说明

ICMP报文限速功能只能在一定程度上减轻大量ICMP报文对CPU的冲击，如果想要更好的对ICMP报文限速，需要与CPU防攻击功能结合使用，CPU防攻击功能的配置请参见**27.2.3.1 配置CPU防攻击**。

配置该功能后，会影响设备对PING报文的响应。

操作步骤

- 配置基于全局的ICMP报文限速。
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**icmp rate-limit enable**，使能全局ICMP报文的限速功能。

     缺省情况下，全局ICMP报文的限速功能不使能。
  c. （可选）执行命令**icmp rate-limit threshold** *threshold-value*，配置基于全局的ICMP报文限速的阈值。

     缺省情况下，全局的ICMP报文的限速阈值为100pps。
- 配置基于接口的ICMP报文限速。
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  c. 执行命令**icmp rate-limit enable**，使能接口ICMP报文的限速功能。

     缺省情况下，接口ICMP报文的限速功能不使能。
  d. （可选）执行命令**icmp rate-limit threshold** *threshold-value*，配置基于接口的ICMP报文限速的阈值。

     缺省情况下，接口的ICMP报文的限速阈值为100pps。

----结束

27.4.5.3 检查配置结果

操作步骤

- 使用命令**display flow-suppression interface** *interface-type interface-number* 查看流量抑制配置信息。

----结束

27.4.6 配置举例

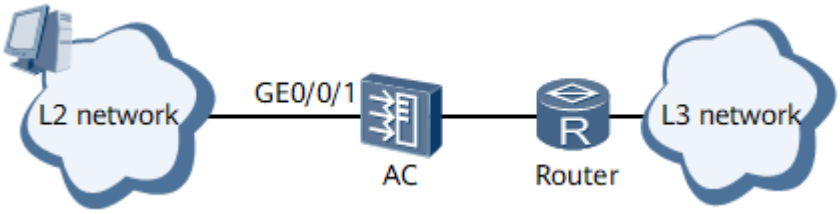
配置举例包括组网需求、配置思路、配置步骤和配置文件。

27.4.6.1 配置流量抑制示例

组网需求

如图27-15所示，AC作为二层网络到三层路由器Router的衔接点，当需要限制二层网络转发的来自用户的广播、组播或者未知单播报文时，可以通过在GigabitEthernet 0/0/1接口上配置以包模式进行流量抑制来实现。

图 27-15 配置以包模式进行流量抑制组网图



配置思路

采用如下的思路：

- 直接在GE0/0/1接口视图下配置以包模式进行流量抑制的功能。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。
  - 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
  - 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

  配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击?**
- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 进入接口视图

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] interface gigabitethernet 0/0/1
```

步骤2 配置广播报文以包模式进行流量抑制

```
[AC-GigabitEthernet0/0/1] broadcast-suppression packets 12600
```

步骤3 配置组播报文以包模式进行流量抑制

```
[AC-GigabitEthernet0/0/1] multicast-suppression packets 25200
```

步骤4 配置未知单播报文以包模式进行流量抑制

```
[AC-GigabitEthernet0/0/1] unicast-suppression packets 12600
```

步骤5 验证配置结果

执行命令**display flow-suppression interface**查看GigabitEthernet 0/0/1接口下的流量抑制配置情况。

```
[AC] display flow-suppression interface gigabitethernet 0/0/1
 storm type          rate mode   set rate value
--------------------------------------------------------------------------------
 unknown-unicast     pps          pps: 12600(packet/s)
 multicast           pps          pps: 25200(packet/s)
 broadcast           pps          pps: 12600(packet/s)
--------------------------------------------------------------------------------
```

----结束

配置文件

```
#
 sysname AC
#
interface GigabitEthernet0/0/1
 unicast-suppression packets 12600
 multicast-suppression packets 25200
 broadcast-suppression packets 12600
#
return
```

27.5 ARP 安全配置

介绍ARP安全的原理和配置方法，并给出配置举例。

27.5.1 ARP 安全简介

介绍ARP安全的定义和作用。

定义

ARP（Address Resolution Protocol）安全是针对ARP攻击的一种安全特性，它通过一系列对ARP表项学习和ARP报文处理的限制、检查等措施来保证网络设备的安全性。ARP安全特性不仅能够防范针对ARP协议的攻击，还可以防范网段扫描攻击等基于ARP协议的攻击。

目的

ARP协议有简单、易用的优点，但是也因为其没有任何安全机制，容易被攻击者利用。在网络中，常见的ARP攻击方式主要包括：

- ARP泛洪攻击，也叫拒绝服务攻击DoS（Denial of Service），主要存在这样两种场景：
  - 设备处理ARP报文和维护ARP表项都需要消耗系统资源，同时为了满足ARP表项查询效率的要求，一般设备都会对ARP表项规模有规格限制。攻击者就利用这一点，通过伪造大量源IP地址变化的ARP报文，使得设备ARP表资源被无效的ARP条目耗尽，合法用户的ARP报文不能继续生成ARP条目，导致正常通信中断。
  - 攻击者利用工具扫描本网段主机或者进行跨网段扫描时，会向设备发送大量目标IP地址不能解析的IP报文，导致设备触发大量ARP Miss消息，生成并下发大量临时ARP表项，并广播大量ARP请求报文以对目标IP地址进行解析，从而造成CPU（Central Processing Unit）负荷过重。
- ARP欺骗攻击，是指攻击者通过发送伪造的ARP报文，恶意修改设备或网络内其他用户主机的ARP表项，造成用户或网络的报文通信异常。

ARP攻击行为存在以下危害：

- 会造成网络连接不稳定，引发用户通信中断，导致严重的经济损失。
- 利用ARP欺骗截取用户报文，进而非法获取游戏、网银、文件服务等系统的帐号和口令，造成被攻击者重大利益损失。

为了避免上述ARP攻击行为造成的各种危害，ARP安全特性针对不同的攻击类型提供了多种解决方案，具体如表27-9所示：

表 27-9 ARP 安全针对泛洪和欺骗攻击的解决方案

攻击类型	防攻击功能	功能说明	部署设备
ARP泛洪	ARP报文限速	通过ARP报文限速功能，可以防止设备因处理大量ARP报文，导致CPU负荷过重而无法处理其他业务。	建议在网关设备上部署本功能
	ARP Miss消息限速	通过ARP Miss消息限速功能，可以防止设备因收到大量目的IP不能解析的IP报文，触发大量ARP Miss消息，导致CPU负荷过重而无法处理其他业务。	建议在网关设备上部署本功能
	ARP表项严格学习	使能ARP表项严格学习功能后，只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP。这可以防止设备收到大量ARP攻击报文时，ARP表被无效的ARP条目占满。	建议在网关设备上部署本功能

攻击类型	防攻击功能	功能说明	部署设备
	ARP表项限制	使能ARP表项限制功能后，设备接口只能学习到设定的最大动态ARP表项数目。这可以防止当一个接口所接入的某一台用户主机发起ARP攻击时整个设备的ARP表资源都被耗尽。	建议在网关设备上部署本功能
ARP欺骗	ARP表项固化	使能ARP表项固化功能后，设备在第一次学习到ARP之后，不再允许用户更新此ARP表项或只能更新此ARP表项的部分信息，或者通过发送ARP请求报文的方式进行确认，以防止攻击者伪造ARP报文修改正常用户的ARP表项内容。 设备提供三种ARP表项固化模式：fixed-all模式、fixed-mac模式和send-ack模式。	建议在网关设备上部署本功能
	动态ARP检测	使能动态ARP检测DAI（Dynamic ARP Inspection）功能后，当设备收到ARP报文时，将此ARP报文的源IP、源MAC、收到ARP报文的接口及VLAN信息和DHCP Snooping绑定表的信息进行比较，如果信息匹配，则认为是合法用户，允许此用户的ARP报文通过，否则认为是攻击，丢弃该ARP报文。 本功能仅适用于DHCP Snooping场景。 配置接入无线用户的AP的动态ARP检测功能，请参见**14.8.2 配置动态ARP检测功能**。	建议在接入设备上部署本功能
	ARP防网关冲突	通过ARP防网关冲突功能，可以防止用户仿冒网关发送ARP报文，非法修改网络内其他用户的ARP表项。 **说明** 仅AC6605支持该功能。	建议在网关设备上部署本功能

攻击类型	防攻击功能	功能说明	部署设备
	发送免费ARP报文	使能发送免费ARP报文功能后，设备作为网关，主动向用户发送以自己IP地址为目标IP地址的ARP请求报文，定时更新用户ARP表项的网关MAC地址，防止用户的报文不能正常的转发到网关或者被恶意攻击者窃听。	建议在网关设备上部署本功能
	ARP报文内MAC地址一致性检查	通过ARP报文内MAC地址一致性检查功能，可以防止以太网数据帧首部中的源、目的MAC地址和ARP报文数据区中的源、目的MAC地址不一致的ARP欺骗攻击。	建议在网关设备上部署本功能
	ARP报文合法性检查	使能ARP报文合法性检查功能后，设备会对以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址不一致的ARP报文进行过滤。	建议在网关设备或接入设备上部署本功能
	ARP表项严格学习	使能ARP表项严格学习功能后，只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP。这可以防止设备因收到伪造的ARP报文，错误地更新ARP表项，导致合法用户的通信流量发生中断。	建议在网关设备上部署本功能

受益

- 可以有效降低用户为保证网络正常运行和网络信息安全而产生的维护成本。
- 可以为用户提供更安全的网络环境和更稳定的网络服务。

27.5.2 原理描述

介绍ARP安全的实现原理。

27.5.2.1 ARP 报文限速

如果设备对收到的大量ARP报文全部进行处理，可能导致CPU负荷过重而无法处理其他业务。因此，在处理之前，设备需要对ARP报文进行限速，以保护CPU资源。

设备提供了如下几类针对ARP报文的限速功能：

- 根据源MAC地址或源IP地址进行ARP报文限速

  当设备检测到某一个用户在短时间内发送大量的ARP报文，可以针对该用户配置基于源MAC地址或源IP地址的ARP报文限速。在1秒时间内，如果该用户的ARP报文数目超过设定阈值（ARP报文限速值），则丢弃超出阈值部分的ARP报文。

  - 根据源MAC地址进行ARP报文限速：如果指定MAC地址，则针对指定源MAC地址的ARP报文根据限速值进行限速；如果不指定MAC地址，则针对每一个源MAC地址的ARP报文根据限速值进行限速。
  - 根据源IP地址进行ARP报文限速：如果指定IP地址，则针对指定源IP地址的ARP报文根据限速值进行限速；如果不指定IP地址，则针对每一个源IP地址的ARP报文根据限速值进行限速。

- 针对Super VLAN的VLANIF接口下的ARP报文限速

  当设备的VLANIF接口接收到触发ARP Miss消息的IP报文（关于ARP Miss消息的详细解释请参见**27.5.2.2 ARP Miss消息限速**）时，或者在设备的VLANIF接口上启用ARP代理功能之后，设备接收到目的IP符合代理条件且该IP对应的ARP条目不存在的ARP请求报文时，都会触发Super VLAN的VLANIF接口进行ARP学习。设备会将ARP请求报文在每个Sub VLAN下复制，如果该Super VLAN下配置了大量Sub VLAN，那么设备将产生大量的ARP请求报文。为了避免CPU因复制、发送大量ARP请求报文而负担过重，设备支持Super VLAN的VLANIF接口下的ARP报文限速功能，以对该场景下设备发送的ARP请求报文进行流量控制。

- 针对全局和接口的ARP报文限速

  设备支持在全局和接口下配置ARP报文的限速值和限速时间，有效顺序为接口优先，其次为全局。

  - 针对全局的ARP报文限速：在设备出现ARP攻击时，限制全局处理的ARP报文数量。
  - 针对接口的ARP报文限速：在某个接口出现ARP攻击时，限制处理该接口收到的ARP报文数量，配置本功能可以保证不影响其他接口的ARP学习。

27.5.2.2 ARP Miss 消息限速

如果网络中有用户向设备发送大量目标IP地址不能解析的IP报文（即路由表中存在该IP报文的目的IP对应的路由表项，但设备上没有该路由表项中下一跳对应的ARP表项），将导致设备触发大量的ARP Miss消息。这种触发ARP Miss消息的IP报文（即ARP Miss报文）会被上送到CPU进行处理，设备会根据ARP Miss消息生成和下发大量临时ARP表项并向目的网络发送大量ARP请求报文，这样就增加了设备CPU的负担，同时严重消耗目的网络的带宽资源。

为了避免这种IP报文攻击所带来的危害，设备提供了如下几类针对ARP Miss消息的限速功能：

- 根据源IP地址进行ARP Miss消息限速

  当设备检测到某一源IP地址的IP报文在1秒内触发的ARP Miss消息数量超过了ARP Miss消息限速值，就认为此源IP地址存在攻击。

  如果指定了IP地址，则针对指定源IP址的ARP Miss消息根据限速值进行限速；如果不指定IP地址，则针对每一个IP地址的ARP Miss消息根据限速值进行限速。

- 针对全局的ARP Miss消息限速

  设备支持对全局处理的ARP Miss消息数量，根据限速值进行限速。

- 通过设定临时ARP表项的老化时间控制ARP Miss消息的触发频率

  当IP报文触发ARP Miss消息时，设备会根据ARP Miss消息生成临时ARP表项，并且向目的网段发送ARP请求报文。

- 在临时ARP表项老化时间范围内：
  - 设备收到ARP应答报文前，匹配临时ARP表项的IP报文将被丢弃并且不会触发ARP Miss消息。
  - 设备收到ARP应答报文后，则生成正确的ARP表项来替换临时ARP表项。
- 当老化时间超时后，设备会清除临时ARP表项。此时如果设备转发IP报文匹配不到对应的ARP表项，则会重新触发ARP Miss消息并生成临时ARP表项，如此循环重复。

当判断设备受到攻击时，可以增大临时ARP表项的老化时间，减小设备ARP Miss消息的触发频率，从而减小攻击对设备的影响。

27.5.2.3 ARP 表项严格学习

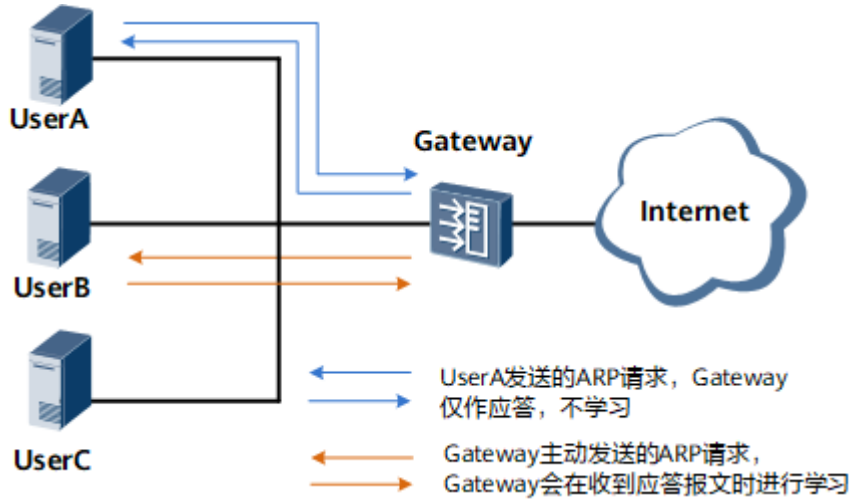
如果大量用户在同一时间段内向设备发送大量ARP报文，或者攻击者伪造正常用户的ARP报文发送给设备，则会造成下面的危害：

- 设备因处理大量ARP报文而导致CPU负荷过重，同时设备学习大量的ARP报文可能导致设备ARP表项资源被无效的ARP条目耗尽，造成合法用户的ARP报文不能继续生成ARP条目，进而导致用户无法正常通信。
- 伪造的ARP报文将错误地更新设备的ARP表项，导致用户无法正常通信。

为避免上述危害，可以在网关设备上部署ARP表项严格学习功能。

ARP表项严格学习是指只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP，这样，可以拒绝大部分的ARP报文攻击。

图 27-16 ARP 表项严格学习



如图27-16所示。通常情况下，当UserA向Gateway发送ARP请求报文后，Gateway会向UserA回应ARP应答报文，并且添加或更新UserA对应的ARP表项。当Gateway配置ARP表项严格学习功能以后：

- 对于Gateway收到UserA发送来的ARP请求报文，Gateway不添加也不更新UserA对应的ARP表项。如果该请求报文请求的是Gateway的MAC地址，那么Gateway会向UserA回应ARP应答报文。
- 如果Gateway向UserB发送ARP请求报文，待收到与该请求对应的ARP应答报文后，Gateway会添加或更新UserB对应的ARP表项。

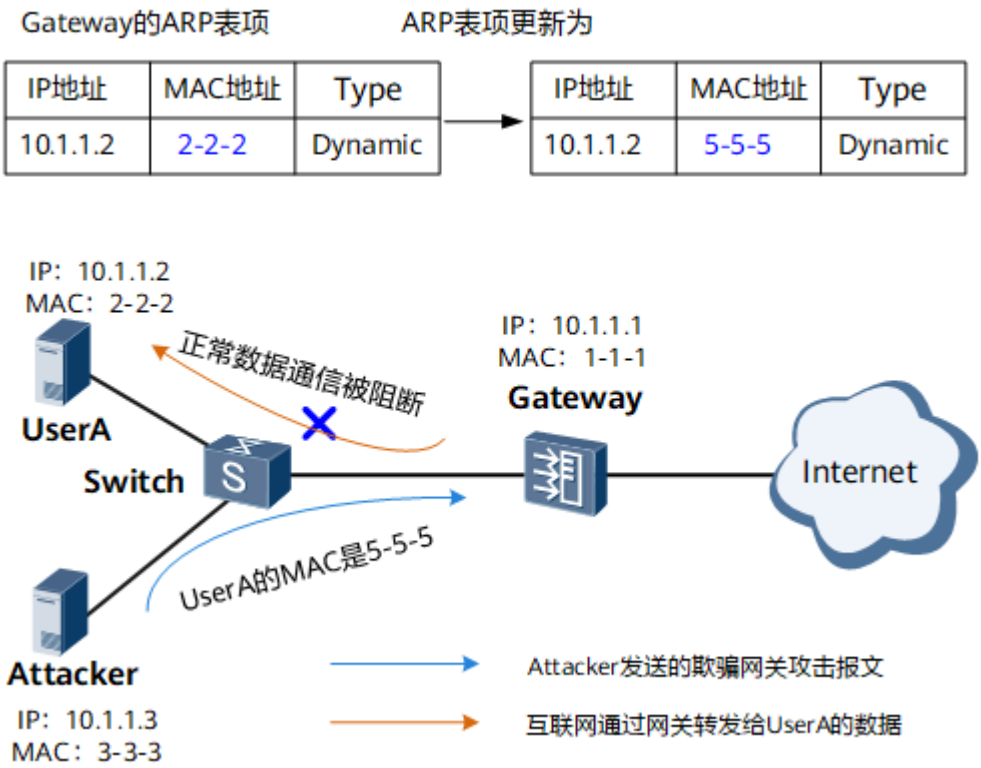
27.5.2.4 ARP 表项限制

ARP表项限制功能应用在网关设备上，可以限制设备的某个接口学习动态ARP表项的数目。默认状态下，接口可以学习的动态ARP表项数目规格与全局的ARP表项规格保持一致。当部署完ARP表项限制功能后，如果指定接口下的动态ARP表项达到了允许学习的最大数目，将不再允许该接口继续学习动态ARP表项，以保证当一个接口所接入的某一用户主机发起ARP攻击时不会导致整个设备的ARP表资源都被耗尽。

27.5.2.5 ARP 表项固化

如图27-17所示，Attacker仿冒UserA向Gateway发送伪造的ARP报文，导致Gateway的ARP表中记录了错误的UserA地址映射关系，造成UserA接收不到正常的数据报文。

图 27-17 欺骗网关攻击示意图



为了防御这种欺骗网关攻击，可以在网关设备上部署ARP表项固化功能。网关设备在第一次学习到ARP以后，不再允许用户更新此ARP表项或只能更新此ARP表项的部分信息，或者通过发送单播ARP请求报文的方式对更新ARP条目的报文进行合法性确认。

设备提供的三种ARP表项固化模式，如表27-10所示。

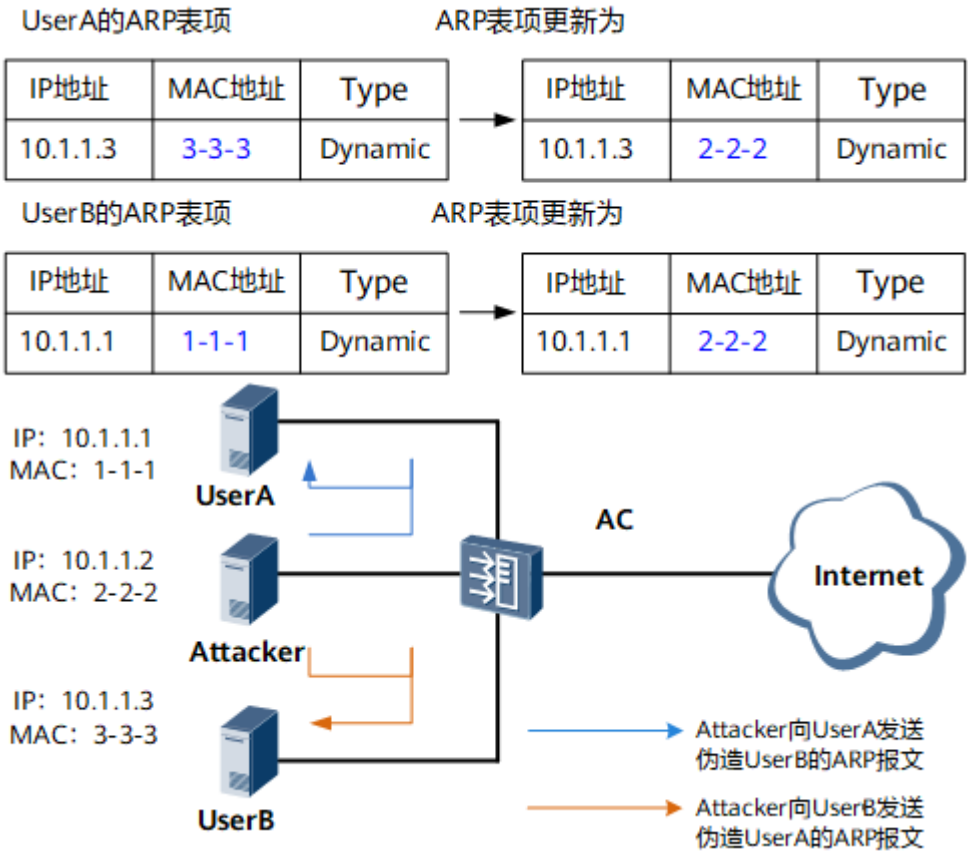
表 27-10 ARP 表项固化模式介绍

固化模式	功能
fixed-all模式	如果设备收到的ARP报文中的MAC地址、接口或VLAN信息和ARP表中的信息不匹配，则直接丢弃该ARP报文。此模式适用于静态配置IP地址，没有冗余链路的网络。
fixed-mac模式	如果设备收到的ARP报文中的MAC地址与ARP表中对应条目的MAC地址不匹配，则直接丢弃该ARP报文；如果匹配，但是收到报文的接口或VLAN信息与ARP表中对应条目不匹配，则可以更新对应ARP条目中的接口和VLAN信息。此模式主要应用于用户接口需要进行切换的场景。
send-ack模式	如果设备收到的ARP报文A涉及ARP表项MAC地址、接口或VLAN信息的修改，设备不会立即更新ARP表项，而是先向待更新的ARP表项现有MAC地址对应的用户发送一个单播的ARP请求报文进行确认。 ● 如果在随后的3秒内设备收到ARP应答报文B，且当前ARP条目中的IP地址、MAC地址、接口和VLAN信息与ARP应答报文B的一致，则认为ARP报文A为攻击报文，不更新该ARP条目。 ● 如果在随后的3秒内设备未收到ARP应答报文，或者收到ARP应答报文B与当前ARP条目中的IP地址、MAC地址、接口和VLAN信息不一致，设备会再向刚才收到的ARP报文A对应的源MAC发送一个单播ARP请求报文。 – 如果在随后的3秒内收到ARP应答报文C，且ARP报文A与ARP应答报文C的源IP地址、源MAC地址、接口和VLAN信息一致，则认为现有ARP条目已经无效且ARP报文A是可以更新该ARP条目的合法报文，并根据ARP报文A来更新该ARP条目。 – 如果在随后的3秒内未收到ARP应答报文，或者ARP报文A与收到的ARP应答报文C的源IP地址、源MAC地址、接口和VLAN信息不一致，则认为ARP报文A为攻击报文，设备会忽略收到的ARP报文A，ARP条目不会更新。 此模式适用于动态分配IP地址，有冗余链路的网络。

27.5.2.6 动态 ARP 检测

网络中针对ARP的攻击层出不穷，中间人攻击是常见的ARP欺骗攻击方式之一。

图 27-18 中间人攻击



如图27-18所示，是中间人攻击的一个场景。攻击者主动向UserA发送伪造UserB的ARP报文，导致UserA的ARP表中记录了错误的UserB地址映射关系，攻击者可以轻易获取到UserA原本要发往UserB的数据；同样，攻击者也可以轻易获取到UserB原本要发往UserA的数据。这样，UserA与UserB间的信息安全无法得到保障。

为了防御中间人攻击，可以在AC上部署动态ARP检测功能。

动态ARP检测DAI（Dynamic ARP Inspection）是利用绑定表来防御中间人攻击的。当设备收到ARP报文时，将此ARP报文对应的源IP、源MAC、VLAN以及接口信息和绑定表的信息进行比较，如果信息匹配，说明发送该ARP报文的用户是合法用户，允许此用户的ARP报文通过，否则就认为是攻击，丢弃该ARP报文。

说明

动态ARP检测功能仅适用于DHCP Snooping场景。设备使能DHCP Snooping功能后，当DHCP用户上线时，设备会自动生成DHCP Snooping绑定表；对于静态配置IP地址的用户，设备不会生成DHCP Snooping绑定表，所以需要手动添加静态绑定表。

关于DHCP Snooping的详细介绍，请参见**DHCP Snooping的基本原理**中的描述。

当AC上部署动态ARP检测功能后，如果攻击者连接到AC并试图发送伪造的ARP报文，AC会根据绑定表检测到这种攻击行为，对该ARP报文进行丢弃处理。

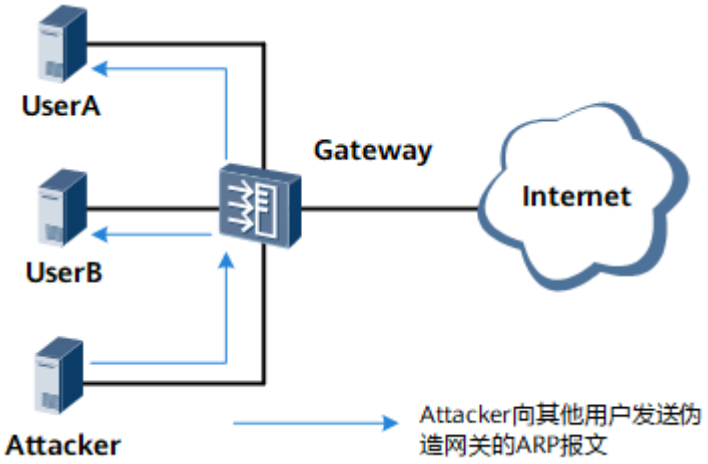
27.5.2.7 ARP 防网关冲突

说明

仅AC6605支持该功能。

如图27-19所示，用户主机直接接入网关，Attacker将伪造网关的ARP报文发送给UserA和UserB，使UserA和UserB误以为攻击者即为网关。UserA和UserB的ARP表中会记录错误的网关地址映射关系，这样就会把发往网关的流量均发送给了攻击者，攻击者可轻易窃听到UserA和UserB发送的数据内容。

图 27-19 ARP 网关冲突



为了防范攻击者仿冒网关，可以在网关设备上使能ARP防网关冲突功能。当设备收到的ARP报文存在下列情况之一：

- ARP报文的源IP地址与报文入接口对应的VLANIF接口的IP地址相同
- ARP报文的源IP地址是入接口的虚拟IP地址，但ARP报文源MAC地址不是VRRP虚MAC

说明

一个VRRP备份组，被当作一个共享局域网内主机的缺省网关，即虚拟交换机。一个虚拟交换机拥有一个VRRP虚MAC，VRRP虚MAC根据虚拟交换机ID生成，格式为：00-00-5E-00-01-{VRID}(VRRP)。当虚拟交换机回应ARP请求时，使用的是VRRP虚MAC地址，而不是接口的真实MAC地址。

关于VRRP的详细介绍，请参见“**VRRP基本概念**”的。

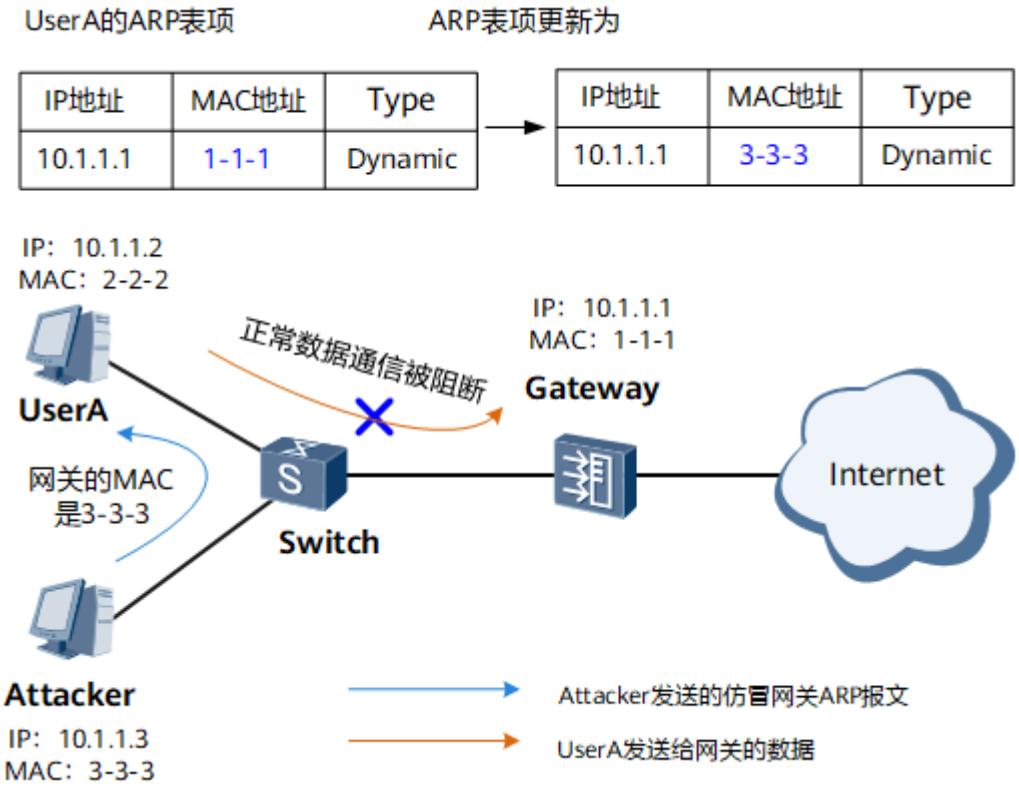
设备就认为该ARP报文是与网关地址冲突的ARP报文，设备将生成ARP防攻击表项，并在后续一段时间内丢弃该接口收到的同VLAN以及同源MAC地址的ARP报文，这样可以防止与网关地址冲突的ARP报文在VLAN内广播。

此时，还可以在设备上使能**发送免费ARP报文**功能，通过广播发送正确的免费ARP报文到所有用户，迅速将已经被攻击的用户记录的错误网关地址映射关系修改正确。

27.5.2.8 发送免费 ARP 报文

如图27-20所示，Attacker仿冒网关向UserA发送了伪造的ARP报文，导致UserA的ARP表中记录了错误的网关地址映射关系，从而正常的数据不能被网关接收。

图 27-20 仿冒网关攻击



为了避免上述危害，可以在网关设备上部署发送免费ARP报文功能，定期更新用户的ARP表项，使得用户ARP表项中记录的是正确的网关MAC地址。

27.5.2.9 ARP 报文内 MAC 地址一致性检查

ARP报文内MAC地址一致性检查功能主要应用于网关设备上，可以防御以太网数据帧首部中的源/目的MAC地址和ARP报文中的源/目的MAC地址不同的ARP攻击。

部署本功能后，网关设备在进行ARP学习前将对ARP报文进行检查。如果以太网数据帧首部中的源/目的MAC地址和ARP报文中的源/目的MAC地址不同，则认为是攻击报文，将其丢弃；否则，继续进行ARP学习。

27.5.2.10 ARP 报文合法性检查

设备在收到ARP报文时，会对ARP报文的有效性进行检查，检查的项目包含但不局限于：

- 检查报文的长度
- 以太网数据帧首部中的源MAC、目的MAC合法性检查
- ARP请求、回应类型检查
- MAC地址长度检查
- IP地址长度检查

- ARP帧格式是否为以太帧类型检查

这些检查是用来判断ARP报文的格式跟ARP协议的规定是否一致。其中以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址不一致的ARP报文是协议允许的报文，但是在实际的应用中，该类报文很可能是攻击报文。

在接入设备或网关设备上使能ARP报文合法性检查功能后，设备会对收到的ARP报文进行以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址的一致性检查，如果两者不一致，则直接丢弃该ARP报文，否则允许该ARP报文通过。

27.5.3 缺省配置

介绍设备的ARP安全缺省配置，实际应用的配置可以基于缺省配置进行修改。

ARP安全的缺省配置如表27-11所示。

表 27-11 ARP 安全缺省配置

参数	缺省值
ARP报文限速（根据源MAC地址）	对每一个源MAC地址的ARP报文速率限制为0，即不根据源MAC地址进行ARP报文限速
ARP报文限速（根据源IP地址）	设备允许1秒内最多只能有5个同一个源IP地址的ARP报文通过
ARP报文限速（针对全局和接口）	未使能
ARP报文的限速值、限速时间（针对全局和接口）	在1秒内设备最多允许100个ARP报文通过
ARP报文限速丢弃告警功能（针对全局和接口）	未使能
ARP报文限速丢弃告警阈值（针对全局和接口）	100
Super VLAN的VLANIF接口下ARP请求报文的广播发送限制速率	256pps
ARP Miss消息限速（根据源IP地址）	允许每秒最多处理同一个源IP地址触发的5个ARP Miss消息
ARP Miss消息限速（针对全局）	未使能
ARP Miss消息的限速值、限速时间（针对全局）	在1秒内设备最多允许处理100个ARP Miss消息
ARP Miss消息限速丢弃告警功能（针对全局）	未使能
ARP Miss消息限速丢弃告警阈值（针对全局）	100
临时ARP表项的老化时间	1秒
ARP表项严格学习功能	未使能

参数	缺省值
基于接口的ARP表项限制	在规格范围内，设备对接口能够学习到的最大动态ARP表项数目没有限制
ARP表项固化功能	未使能
动态ARP检测功能	未使能
ARP防网关冲突防攻击功能	未使能
发送免费ARP报文功能	未使能
发送免费ARP报文的时间间隔	90秒
ARP报文内MAC地址一致性检查功能	未使能
ARP报文合法性检查功能	未使能

27.5.4 配置 ARP 安全

介绍ARP安全详细的配置过程。

27.5.4.1 配置防 ARP 泛洪攻击

通过配置防ARP泛洪攻击功能，可以避免ARP泛洪攻击带来的ARP表项资源被无效ARP条目耗尽、CPU负荷过重造成用户无法正常通信等危害。

前置任务

在配置防ARP泛洪攻击之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。

配置流程

在配置防ARP泛洪攻击任务中，各配置步骤均是并列关系，无严格配置顺序，用户根据需要选择配置即可。

说明

当针对全局、接口的ARP报文限速以及根据源MAC地址、源IP地址进行ARP报文限速中的多个限速功能同时配置时，设备对同时满足这些限速条件的ARP报文以其中最小的限速值进行限速。

当针对全局的ARP Miss消息限速以及根据源IP地址进行ARP Miss消息限速中的多个限速功能同时配置时，设备对同时满足这些限速条件的ARP Miss消息以其中最小的限速值进行限速。

27.5.4.1.1 配置 ARP 报文限速（根据源 MAC 地址）

背景信息

设备处理大量源MAC地址相对固定的ARP报文会造成CPU繁忙，并且如果ARP报文的源IP地址同时不断变化，还会导致设备的ARP表资源被耗尽。

为了避免此问题，可以配置设备根据源MAC地址进行ARP报文限速。设备会对上送CPU的ARP报文根据源MAC地址进行统计，如果在1秒内收到的同一个源MAC地址的ARP报文超过设定阈值（ARP报文限速值），设备则丢弃超出阈值部分的ARP报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置根据源MAC地址进行ARP报文限速

- 执行命令**arp speed-limit source-mac maximum** *maximum*，配置根据源MAC地址进行ARP报文限速的限速值。
- 执行命令**arp speed-limit source-mac** *mac-address* **maximum** *maximum*，配置对指定MAC地址用户的ARP报文进行限速的限速值。

两种配置同时存在的情况下，当ARP报文源MAC地址匹配限速指定的MAC地址时，对该源MAC地址的ARP报文限速值为后一步骤中配置的*maximum*值；否则为前一步骤中配置的*maximum*值。

缺省情况下，设备对每一个源MAC地址的ARP报文速率限制为0，即不根据源MAC地址进行ARP报文限速。

----结束

27.5.4.1.2 配置 ARP 报文限速（根据源 IP 地址）

背景信息

设备处理大量源IP地址相对固定的ARP报文，会造成CPU繁忙，影响到正常业务的处理。

为了避免此问题，可以配置设备根据源IP地址进行ARP报文限速。设备会对上送CPU的ARP报文根据源IP地址进行统计，如果在1秒内收到的同一个源IP地址的ARP报文超过设定阈值（ARP报文限速值），设备则丢弃超出阈值部分的ARP报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置根据源IP地址进行ARP报文限速

- 执行命令**arp speed-limit source-ip maximum** *maximum*，配置根据源IP地址进行ARP报文限速的限速值。
- 执行命令**arp speed-limit source-ip** *ip-address* **maximum** *maximum*，配置对指定IP地址用户的ARP报文进行限速的限速值。

两种配置同时存在的情况下，当ARP报文源IP地址匹配限速指定的IP地址时，对该源IP地址的ARP报文限速值为后一步骤中配置的*maximum*值；否则为前一步骤中配置的*maximum*值。

缺省情况下，设备允许1秒内最多只能有同一个源IP地址的5个ARP报文通过。

----结束

27.5.4.1.3 配置 ARP 报文限速（针对全局和接口）

背景信息

如果设备对收到的大量ARP报文全部进行处理，可能导致CPU负荷过重而无法处理其他业务。因此，在处理之前，设备需要对ARP报文进行限速，以保护CPU资源。

使能ARP报文限速功能后，可以在全局或接口下配置ARP报文的限速值和限速时间。在ARP报文限速时间内，如果收到的ARP报文数目超过ARP报文限速值，设备会丢弃超出限速值的ARP报文。

- 针对全局的ARP报文限速：在设备出现ARP攻击时，限制全局处理的ARP报文数量。
- 针对接口的ARP报文限速：在某个接口出现ARP攻击时，限制处理该接口收到的ARP报文数量，配置本功能可以保证不影响其他接口的ARP学习。

当同时在全局或接口下配置ARP报文的限速值和限速时间时，有效的顺序为接口优先，其次为全局。

当设备丢弃的ARP报文数量较多时，如果希望设备能够以告警的方式提醒网络管理员，则可以使能ARP报文限速丢弃告警功能。当丢弃的ARP报文数超过告警阈值时，设备将产生告警。

说明

如果配置了ARP报文限速丢弃告警功能，则需使用命令**arp anti-attack log-trap-timer** *time*调整设备发送告警的时间间隔。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 （可选）执行命令**interface** *interface-type interface-number*，进入接口视图。

说明

在系统视图下配置ARP报文限速功能无需执行此步骤。

步骤3 执行命令**arp anti-attack rate-limit enable**，使能ARP报文限速功能。

缺省情况下，未使能ARP报文限速功能。

步骤4 执行命令**arp anti-attack rate-limit** *packet-number* [*interval-value*]，配置ARP报文的限速值、限速时间。

缺省情况下，在1秒内设备最多允许100个ARP报文通过。

步骤5 （可选）执行命令**arp anti-attack rate-limit alarm enable**，使能ARP报文限速丢弃告警功能。

缺省情况下，未使能ARP报文限速丢弃告警功能。

步骤6 （可选）执行命令**arp anti-attack rate-limit alarm threshold** *threshold*，配置ARP报文限速丢弃告警阈值。

缺省情况下，ARP报文限速丢弃告警阈值为100。

----结束

27.5.4.1.4 配置 ARP 报文限速（针对 Super VLAN 的 VLANIF 接口）

背景信息

以下两种情况会触发Super VLAN的VLANIF接口进行ARP学习：

- VLANIF接口接收到触发ARP Miss消息的IP报文
- VLANIF接口上启用ARP代理功能之后，设备接收到目的IP符合代理条件且该IP对应的ARP条目不存在的ARP请求报文

Super VLAN的VLANIF接口进行ARP学习时会将ARP请求报文在每个Sub VLAN下复制，如果该Super VLAN下配置了大量Sub VLAN，那么设备将产生大量的ARP请求报文。为了避免CPU因复制、发送大量ARP请求报文而负担过重，设备支持Super VLAN的VLANIF接口下的ARP报文限速功能，以对该场景下设备发送的ARP请求报文进行流量控制。

当设备CPU较为繁忙时，可适当调小ARP请求报文的广播发送限制速率；当设备CPU较为空闲时，且希望能够快速广播ARP请求报文，则可以适当调大该速率。请根据设备实际状况和实际网络环境进行调整。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp speed-limit flood-rate** *rate*，配置所有Super VLAN的VLANIF接口下ARP请求报文的广播发送限制速率。

缺省情况下，所有Super VLAN的VLANIF接口下ARP请求报文的广播发送限制速率为256pps。

----结束

27.5.4.1.5 配置 ARP Miss 消息限速（根据源 IP 地址）

背景信息

当设备检测到某一源IP地址的IP报文在1秒内触发的ARP Miss消息数量超过了限速值，就认为此源IP地址存在攻击。

管理员可以根据实际网络环境，对ARP Miss消息的限速值进行调整，限制设备在一定时间内只处理指定数目的ARP Miss消息，避免设备的资源浪费在处理ARP Miss消息上，保证用户的其他业务能够正常运行。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置根据源IP地址进行ARP Miss消息限速

- 执行命令**arp-miss speed-limit source-ip maximum** *maximum*，配置根据源IP地址进行ARP Miss消息限速的限速值。
- 执行命令**arp-miss speed-limit source-ip** *ip-address* **maximum** *maximum*，配置对指定IP地址用户的ARP Miss消息进行限速的限速值。

两种配置同时存在的情况下，当触发ARP Miss消息的IP报文的源IP地址匹配限速指定的IP地址时，对该源IP地址的IP报文触发的ARP Miss消息限速值为后一步骤中配置的*maximum*值；否则为前一步骤中配置的*maximum*值。

如果将限速值配置为0，则表示不根据源IP地址进行ARP Miss消息限速。缺省情况下，设备允许每秒最多处理同一个源IP地址触发的5个ARP Miss消息。

----结束

27.5.4.1.6 配置 ARP Miss 消息限速（针对全局）

背景信息

如果网络中有用户向设备发送大量目标IP地址不能解析的IP报文（即路由表中存在该IP报文的目的IP对应的路由表项，但设备上没有该路由表项中下一跳对应的ARP表项），将导致设备触发大量的ARP Miss消息。这种触发ARP Miss消息的IP报文会被上送到主控板进行处理，设备会根据ARP Miss消息生成和下发大量临时ARP表项并向目的网络发送大量ARP请求报文，这样就增加了设备CPU的负担，同时严重消耗目的网络的带宽资源。

为了避免这种IP报文攻击所带来的危害，需要配置ARP Miss消息限速功能。

当设备忽略的ARP Miss消息数量较多时，如果希望设备能够以告警的方式提醒网络管理员，则可以配置ARP Miss消息限速丢弃告警功能。当设备忽略处理的ARP Miss消息个数超过告警阈值时，设备将产生告警。

说明

如果配置了ARP Miss消息限速丢弃告警功能，则需使用命令**arp anti-attack log-trap-timer** *time*调整设备发送告警的时间间隔。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp-miss anti-attack rate-limit enable**，使能ARP Miss消息限速功能。

缺省情况下，未使能ARP Miss消息限速功能。

步骤3 执行命令**arp-miss anti-attack rate-limit** *packet-number* [*interval-value*]，配置ARP Miss消息的限速值和限速时间。

缺省情况下，在1秒内设备最多允许处理100个ARP Miss消息。

步骤4 （可选）执行命令**arp-miss anti-attack rate-limit alarm enable**，使能ARP Miss消息限速丢弃告警功能。

缺省情况下，未使能ARP Miss消息限速丢弃告警功能。

步骤5 （可选）执行命令**arp-miss anti-attack rate-limit alarm threshold** *threshold*，配置ARP Miss消息限速丢弃告警阈值。

缺省情况下，ARP Miss消息限速丢弃告警阈值为100。

----结束

27.5.4.1.7 配置临时 ARP 表项的老化时间

背景信息

当IP报文触发ARP Miss消息时，设备会根据ARP Miss消息生成临时ARP表项，并且向目的网段发送ARP请求报文。

- 在临时ARP表项老化时间范围内：
  - 设备收到ARP应答报文前，匹配临时ARP表项的IP报文将被丢弃并且不会触发ARP Miss消息。
  - 设备收到ARP应答报文后，则生成正确的ARP表项来替换临时ARP表项。
- 当老化时间超时后，设备会清除临时ARP表项。此时如果设备转发IP报文匹配不到对应的ARP表项，则会重新触发ARP Miss消息并生成临时ARP表项，如此循环重复。

故可以通过配置临时ARP表项的老化时间来控制ARP Miss消息的触发频率。当判断设备受到攻击时，可以调大该时间，减小设备ARP Miss消息的触发频率，从而减小攻击对设备的影响。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface** *interface-type interface-number*，进入接口视图。

步骤3 执行命令**arp-fake expire-time** *expire-time*，配置临时ARP表项的老化时间。

缺省情况下，临时ARP表项的老化时间是1秒。

----结束

27.5.4.1.8 配置 ARP 表项严格学习

背景信息

如果大量用户在同一时间段内向设备发送大量ARP报文，或者攻击者伪造正常用户的ARP报文发送给设备，则会造成如下危害：

- 设备因处理大量ARP报文而导致CPU负荷过重，同时设备学习大量的ARP报文可能导致设备ARP表项资源被无效的ARP条目耗尽，造成合法用户的ARP报文不能继续生成ARP条目，导致用户无法正常通信。
- 伪造的ARP报文将错误地更新设备ARP表项，导致合法用户无法正常通信。

为避免上述危害，可以在网关设备上配置ARP表项严格学习功能。配置该功能后，只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP，这样，可以拒绝大部分的ARP报文攻击。

ARP表项严格学习功能可在全局和接口视图下进行配置。

- 全局使能该功能，则设备的所有接口均进行ARP表项严格学习。
- 接口视图下使能该功能，则只有该接口进行ARP表项严格学习。

当同时在全局和接口视图下进行配置时，接口下配置的优先级高于全局配置的优先级。

说明

在全局使能ARP表项严格学习功能的前提下：

- 如果在指定接口下执行命令**arp learning strict force-disable**，则该接口将会被强制执行去使能ARP表项严格学习的功能。
- 如果在指定接口下执行命令**arp learning strict trust**时，则该接口的ARP表项严格学习功能和全局的配置保持一致。

操作步骤

- 配置全局ARP表项严格学习功能
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**arp learning strict**，配置全局ARP表项严格学习功能。

     缺省情况下，未使能ARP表项严格学习功能。
- 配置接口的ARP表项严格学习功能
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  c. 执行命令**arp learning strict** { **force-enable** | **force-disable** | **trust** }，配置接口的ARP表项严格学习功能。

     缺省情况下，未使能ARP表项严格学习功能。

----结束

27.5.4.1.9 配置基于接口的 ARP 表项限制

背景信息

为了防止当一个接口所接入的某一用户主机发起ARP攻击时导致整个设备的ARP表资源都被耗尽，可以在指定接口下配置接口能够学习到的最大动态ARP表项数目。当指定接口下的动态ARP表项达到允许学习的最大数目后，将不允许新增动态ARP表项。

操作步骤

- 配置以太网接口的ARP表项限制
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  c. 执行命令**arp-limit vlan** *vlan-id1* [**to** *vlan-id2*] **maximum** *maximum*，配置基于以太网接口的ARP表项限制。
- 配置VLANIF接口的ARP表项限制
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface vlanif** *vlan-id*，进入VLANIF接口视图。
  c. 执行命令**arp-limit maximum** *maximum* ，配置基于VLANIF接口的ARP表项限制。

----结束

27.5.4.1.10 检查配置结果

操作步骤

- 使用命令**display arp anti-attack configuration** { **arp-rate-limit** | **arpmiss-rate-limit** | **arp-speed-limit** | **arpmiss-speed-limit** | **entry-check** | **gateway-duplicate** | **packet-check** | **all** }，查看ARP防攻击配置。
- 使用命令**display arp-limit** [**interface** *interface-type interface-number*] [**vlan** *vlan-id*]，查看接口可以学习到的动态ARP表项数目的最大值。
- 使用命令**display arp learning strict**，查看全局和所有VLANIF接口上的ARP表项严格学习情况。

----结束

27.5.4.2 配置防 ARP 欺骗攻击

通过配置防ARP欺骗攻击功能，可以防止伪造的ARP报文恶意修改设备或网络内其他用户主机的ARP表项，造成网络中的报文转发异常。

前置任务

在配置防ARP欺骗攻击之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。

配置流程

在配置防ARP欺骗攻击任务中，各配置步骤均是并列关系，无严格配置顺序，用户根据需要选择配置即可。

27.5.4.2.1 配置 ARP 表项固化

背景信息

为了防止ARP地址欺骗攻击，可以配置ARP表项固化功能。三种ARP表项固化模式适用于不同的应用场景，且是互斥关系。

- **fixed-mac**方式：设备收到的ARP报文中的MAC地址与ARP表中对应条目的MAC地址不匹配，则直接丢弃该ARP报文；如果匹配，但是收到报文的接口或VLAN信息与ARP表中对应条目不匹配，则可以更新对应ARP条目中的接口和VLAN信息。此方式适用于静态配置IP地址，但网络存在冗余链路的情况。当链路切换时，ARP表项中的接口信息可以快速改变。
- **fixed-all**方式：只有当ARP报文对应的MAC地址、接口、VLAN信息和ARP表项中的信息完全匹配时，设备才可以更新ARP表项的其他内容。此方式适用于静态配置IP地址，网络没有冗余链路，同一IP地址用户不会从不同接口接入的情况。
- **send-ack**方式：设备收到一个涉及MAC地址、VLAN、接口修改的ARP报文时，不会立即更新ARP表项，而是先向待更新的ARP表项现有MAC地址对应的用户发送一个单播的ARP请求报文进行确认，根据确认结果再决定是否更新ARP表项中的MAC地址、VLAN和接口信息。此方式适用于动态分配IP地址，有冗余链路的网络。

操作步骤

- 全局使能ARP表项固化功能

a. 执行命令**system-view**，进入系统视图。

b. 执行命令**arp anti-attack entry-check** { **fixed-mac** | **fixed-all** | **send-ack** } **enable**，配置ARP表项固化功能。

缺省情况下，未配置ARP表项固化功能。

----结束

27.5.4.2.2 配置动态 ARP 检测

背景信息

为了防御中间人攻击，避免合法用户的数据被中间人窃取，可以使能动态ARP检测功能。设备会将ARP报文对应的源IP、源MAC、接口、VLAN信息和绑定表中的信息进行比较，如果信息匹配，说明发送该ARP报文的用户是合法用户，允许此用户的ARP报文通过，否则就认为是攻击，丢弃该ARP报文。

可在接口视图或VLAN视图下使能动态ARP检测功能。在接口视图下使能时，则对该接口收到的所有ARP报文进行绑定表匹配检查；在VLAN视图下使能时，则对加入该VLAN的接口收到的属于该VLAN的ARP报文进行绑定表匹配检查。

如果希望仅匹配绑定表某一项或某两项内容的特殊ARP报文也能够通过，则可以配置对ARP报文进行绑定表匹配检查时只检查某一项或某两项内容。

当设备丢弃的不匹配绑定表的ARP报文数量较多时，如果希望设备能够以告警的方式提醒网络管理员，则可以使能动态ARP检测丢弃报文告警功能。当丢弃的ARP报文数超过告警阈值时，设备将产生告警。

说明

本功能仅适用于DHCP Snooping场景。设备使能DHCP Snooping功能后，当DHCP用户上线时，设备会自动生成DHCP Snooping绑定表；对于静态配置IP地址的用户，设备不会生成DHCP Snooping绑定表，所以需要手动添加静态绑定表。

DHCP Snooping的配置，请参见**27.6 DHCP Snooping配置**。

静态绑定表的配置，请参见**27.8.4.1 配置绑定表**。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface** *interface-type interface-number*，进入接口视图；或者执行命令**vlan** *vlan-id*，进入VLAN视图。

步骤3 执行命令**arp anti-attack check user-bind enable**，使能动态ARP检测功能（即对ARP报文进行绑定表匹配检查功能）。

缺省情况下，未使能动态ARP检测功能。

步骤4 （可选）接口视图下执行命令**arp anti-attack check user-bind check-item** { **ip-address** | **mac-address** | **vlan** }*，或者VLAN视图下执行命令**arp anti-attack check user-bind check-item** { **ip-address** | **mac-address** | **interface** }*，配置对ARP报文进行绑定表匹配检查的检查项。

缺省情况下，对ARP报文的IP地址、MAC地址、VLAN和接口信息都进行检查。

说明

指定ARP报文绑定表匹配检查项对配置了静态绑定表的用户不起作用，即设备仍然按照静态绑定表的内容对ARP报文进行绑定表匹配检查。

步骤5 （可选）接口视图下执行命令**arp anti-attack check user-bind alarm enable**，使能动态ARP检测丢弃报文告警功能。

缺省情况下，未使能动态ARP检测丢弃报文告警功能。

须知

由于动态ARP检测丢弃报文告警功能针对的是接口下DAI功能丢弃的ARP报文数告警统计，因此建议不要同时在VLAN视图下配置命令**arp anti-attack check user-bind enable**以及在加入该VLAN的接口视图下配置命令**arp anti-attack check user-bind alarm enable**，避免VLAN下的DAI功能可能造成实际丢包数目和接口DAI告警统计值之间的偏差。

如果配置了动态ARP检测丢弃报文告警功能，则需使用命令**arp anti-attack log-trap-timer** *time*调整设备发送告警的时间间隔。

步骤6 （可选）接口视图下执行命令**arp anti-attack check user-bind alarm threshold** *threshold*，配置动态ARP检测丢弃报文告警阈值。

缺省情况下，动态ARP检测丢弃报文告警阈值为系统视图下**arp anti-attack check user-bind alarm threshold** *threshold*命令配置的值。如果系统视图下没有配置该值，则接口下缺省的告警阈值为100。

----结束

27.5.4.2.3 配置 ARP 防网关冲突

背景信息

如果有攻击者仿冒网关，在局域网内部发送源IP地址是网关IP地址的ARP报文，会导致局域网内其他用户主机的ARP表记录错误的网关地址映射关系。这样其他用户主机就会把发往网关的流量均发送给了攻击者，攻击者可轻易窃听到他们发送的数据内容，并且最终会造成这些用户主机无法访问网络。

为了防范攻击者仿冒网关，当用户主机直接接入网关时，可以在网关设备上使能ARP防网关冲突攻击功能。当设备收到的ARP报文存在下列情况之一：

- ARP报文的源IP地址与报文入接口对应的VLANIF接口的IP地址相同
- ARP报文的源IP地址是入接口的虚拟IP地址，但ARP报文源MAC地址不是**VRRP**虚MAC

设备就认为该ARP报文是与网关地址冲突的ARP报文，设备将生成ARP防攻击表项，并在后续一段时间内丢弃该接口收到的同VLAN以及同源MAC地址的ARP报文，这样就可以防止与网关地址冲突的ARP报文在VLAN内广播。

说明

仅AC6605支持该功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp anti-attack gateway-duplicate enable**，使能ARP防网关冲突攻击功能。

缺省情况下，未使能ARP防网关冲突攻击功能。

----结束

27.5.4.2.4 配置发送免费 ARP 报文

背景信息

如果有攻击者向其他用户发送仿冒网关的ARP报文，会导致其他用户的ARP表中记录错误的网关地址映射关系，造成其他用户的正常数据不能被网关接收。此时可以在网关设备上配置发送免费ARP报文的功能，用来定期更新合法用户的ARP表项，使得合法用户ARP表项中记录的是正确的网关地址映射关系。

可在全局或VLANIF接口下配置发送免费ARP报文功能。

- 全局配置该功能后，则默认设备上所有接口的发送免费ARP报文功能均已使能。
- 当全局和VLANIF接口下同时配置了该功能时，VLANIF接口下的配置优先生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 （可选）执行命令**interface vlanif** *vlan-id*，进入VLANIF接口视图。

说明

在系统视图下配置发送免费ARP报文功能无需执行此步骤。

步骤3 执行命令**arp gratuitous-arp send enable**，使能发送免费ARP报文的功能。

缺省情况下，未使能发送免费ARP报文的功能。

步骤4 （可选）执行命令**arp gratuitous-arp send interval** *interval-time*，配置发送免费ARP报文的时间间隔。

缺省情况下，发送免费ARP报文的时间间隔为90秒。

----结束

27.5.4.2.5 配置 ARP 报文内 MAC 地址一致性检查

背景信息

ARP报文内MAC地址一致性检查功能主要应用于网关设备上，可以防御以太网数据帧首部中的源/目的MAC地址和ARP报文数据区中的源/目的MAC地址不同的ARP攻击。

配置ARP报文内MAC地址一致性检查后，网关设备在进行ARP学习前将对ARP报文进行检查。如果以太网数据帧首部中的源/目的MAC地址和ARP报文数据区中的源/目的MAC地址不同，则认为是攻击报文，将其丢弃；否则，继续进行ARP学习。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface** *interface-type interface-number*，进入接口视图。

步骤3 执行命令**arp validate** { **source-mac** | **destination-mac** }*，使能ARP报文内MAC地址一致性检查功能，即设备对以太网数据帧首部中的源/目的MAC地址和ARP报文数据区中的源/目的MAC地址进行一致性检查的功能。

缺省情况下，设备不对以太网数据帧首部中的源/目的MAC地址和ARP报文数据区中的源/目的MAC地址进行一致性检查。

说明

本命令不支持在VLANIF接口上配置。当VLANIF接口收到ARP报文时，ARP报文内MAC地址一致性检查遵循成员口下的检查规则。

----结束

27.5.4.2.6 配置 ARP 报文合法性检查

背景信息

设备在收到ARP报文时，会对ARP报文的有效性进行检查，检查的项目包含但不局限于：

- 检查报文的长度
- 以太网数据帧首部中的源MAC、目的MAC合法性检查
- ARP请求、回应类型检查
- MAC地址长度检查
- IP地址长度检查
- ARP帧格式是否为以太帧类型检查

这些检查是用来判断ARP报文的格式跟ARP协议的规定是否一致。其中以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址不一致的ARP报文是协议允许的报文，但是在实际的应用中，该类报文很可能是攻击报文。

使能ARP报文合法性检查功能后，设备会对收到的ARP报文进行以太网数据帧首部中的源MAC地址和ARP报文数据区中的源MAC地址的一致性检查，如果两者不一致，则直接丢弃该ARP报文，否则允许该ARP报文通过。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp anti-attack packet-check sender-mac**，使能ARP报文合法性检查功能，即对ARP报文中的源MAC地址和以太网数据帧首部中的源MAC地址进行一致性检查的功能。

缺省情况下，未使能ARP报文合法性检查功能。

----结束

27.5.4.2.7 配置 ARP 表项严格学习

背景信息

如果大量用户在同一时间段内向设备发送大量ARP报文，或者攻击者伪造正常用户的ARP报文发送给设备，则会造成如下危害：

- 设备因处理大量ARP报文而导致CPU负荷过重，同时设备学习大量的ARP报文可能导致设备ARP表项资源被无效的ARP条目耗尽，造成合法用户的ARP报文不能继续生成ARP条目，导致用户无法正常通信。
- 伪造的ARP报文将错误地更新设备ARP表项，导致合法用户无法正常通信。

为避免上述危害，可以在网关设备上配置ARP表项严格学习功能。配置该功能后，只有本设备主动发送的ARP请求报文的应答报文才能触发本设备学习ARP，其他设备主动向本设备发送的ARP报文不能触发本设备学习ARP，这样，可以拒绝大部分的ARP报文攻击。

ARP表项严格学习功能可在全局和接口视图下进行配置。

- 全局使能该功能，则设备的所有接口均进行ARP表项严格学习。
- 接口视图下使能该功能，则只有该接口进行ARP表项严格学习。

当同时在全局和接口视图下进行配置时，接口下配置的优先级高于全局配置的优先级。

说明

在全局使能ARP表项严格学习功能的前提下：

- 如果在指定接口下执行命令**arp learning strict force-disable**，则该接口将会被强制执行去使能ARP表项严格学习的功能。
- 如果在指定接口下执行命令**arp learning strict trust**时，则该接口的ARP表项严格学习功能和全局的配置保持一致。

操作步骤

- 配置全局ARP表项严格学习功能
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**arp learning strict**，配置全局ARP表项严格学习功能。

     缺省情况下，未使能ARP表项严格学习功能。
- 配置接口的ARP表项严格学习功能
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  c. 执行命令**arp learning strict** { **force-enable** | **force-disable** | **trust** }，配置接口的ARP表项严格学习功能。

     缺省情况下，未使能ARP表项严格学习功能。

----结束

27.5.4.2.8 检查配置结果

操作步骤

- 使用命令**display arp anti-attack configuration** { **arp-rate-limit** | **arpmiss-rate-limit** | **arp-speed-limit** | **arpmiss-speed-limit** | **entry-check** | **gateway-duplicate** | **packet-check** | **all** }，查看ARP防攻击配置。

- 使用命令**display arp anti-attack check user-bind interface** *interface-type interface-number*，查看接口下ARP报文检查相关的配置。
- 使用命令**display arp learning strict**，查看全局和所有VLANIF接口上的ARP表项严格学习情况。
- 使用命令**display arp anti-attack gateway-duplicate item**，查看ARP防网关冲突攻击表项。

说明

仅AC6605支持该功能。

----结束

27.5.5 维护 ARP 安全

维护ARP安全包括监控ARP运行情况、清除ARP报文统计信息、清除ARP报文丢弃计数以及配置对潜在的ARP攻击行为发送日志和告警。

27.5.5.1 监控 ARP 安全运行情况

操作步骤

- 使用命令**display arp packet statistics**，查看ARP处理的报文统计数据。
- 使用命令**display arp flood statistics**，查看所有Super VLAN的VLANIF接口下ARP请求报文的发送统计信息。

----结束

27.5.5.2 清除 ARP 安全统计信息

背景信息

须知

清除统计信息后，以前的统计信息将无法恢复，务必仔细确认。

在确认需要清除运行信息后，请在用户视图下执行下列命令。

操作步骤

- 使用命令**reset arp packet statistics**，清除ARP报文的统计信息。
- 使用命令**reset arp flood statistics**，清除所有Super VLAN的VLANIF接口下ARP请求报文的发送统计信息。
- 使用命令**reset arp anti-attack statistics check user-bind interface** *interface-type interface-number*，清除由于不匹配绑定表而丢弃的ARP报文计数。
- 使用命令**reset arp anti-attack statistics rate-limit** { **global** | **interface** *interface-type interface-number* }，清除由于ARP报文超过速率限制阈值而被丢弃的计数。

----结束

27.5.5.3 配置对潜在的 ARP 攻击行为发送告警

背景信息

为了使管理员能够实时的了解设备上ARP运行情况，对潜在的攻击行为作出判断和应对措施，设备支持对潜在的攻击行为发送告警，实时记录ARP运行的异常情况。通过配置发送告警的时间间隔，可以减少告警发送的数量，以避免ARP攻击时造成海量告警信息。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp anti-attack log-trap-timer** *time*，配置对潜在的ARP攻击行为发送告警的时间间隔。

缺省情况下，发送ARP告警时间间隔为0，即设备不发送ARP告警信息。

----结束

27.5.6 配置举例

介绍ARP安全配置举例。配置示例中包括组网需求、配置思路、配置过程等。

27.5.6.1 配置 ARP 安全综合功能示例

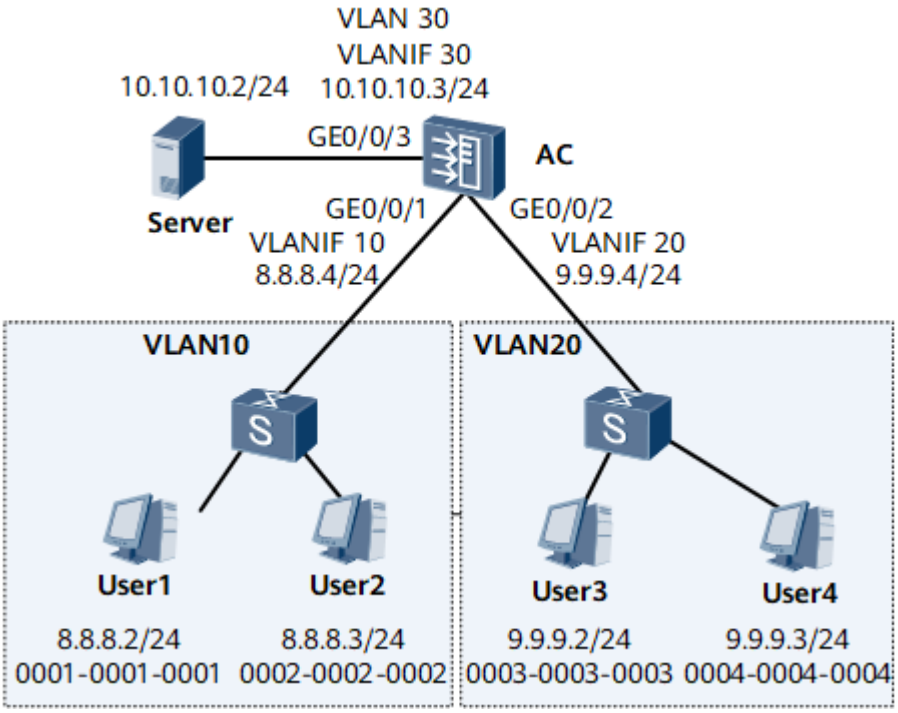
组网需求

如图27-21所示，AC通过接口GE0/0/3连接一台服务器，通过接口GE0/0/1、GE0/0/2连接VLAN10和VLAN20下的四个用户。网络中存在以下ARP威胁：

- 攻击者向AC发送伪造的ARP报文、伪造的免费ARP报文进行ARP欺骗攻击，恶意修改AC的ARP表项，造成其他用户无法正常接收数据报文。
- 攻击者发出大量目的IP地址不可达的IP报文进行ARP泛洪攻击，造成AC的CPU负荷过重。
- 用户User1构造大量源IP地址变化MAC地址固定的ARP报文进行ARP泛洪攻击，造成AC的ARP表资源被耗尽以及CPU进程繁忙，影响到正常业务的处理。
- 用户User3构造大量源IP地址固定的ARP报文进行ARP泛洪攻击，造成AC的CPU进程繁忙，影响到正常业务的处理。

管理员希望能够防止上述ARP攻击行为，为用户提供更安全的网络环境和更稳定的网络服务。

图 27-21 配置 ARP 安全功能组网图



配置思路

采用如下思路在AC上进行配置：

1. 配置ARP表项严格学习功能以及ARP表项固化功能，实现防止伪造的ARP报文错误地更新AC的ARP表项。
2. 配置根据源IP地址进行ARP Miss消息限速，实现防止用户侧存在攻击者发出大量目的IP地址不可达的IP报文触发大量ARP Miss消息，形成ARP泛洪攻击。同时需要保证AC可以正常处理服务器发出的大量此类报文，避免因丢弃服务器发出的大量此类报文而造成网络无法正常通信。
3. 配置基于接口的ARP表项限制以及根据源MAC地址进行ARP限速，实现防止User1发送的大量源IP地址变化MAC地址固定的ARP报文形成的ARP泛洪攻击，避免AC的ARP表资源被耗尽，并避免CPU进程繁忙。
4. 配置根据源IP地址进行ARP限速，实现防止User3发送的大量源IP地址固定的ARP报文形成的ARP泛洪攻击，避免AC的CPU进程繁忙。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。
  - 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
  - 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击?**

- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 创建VLAN，将接口加入到VLAN中，并配置VLANIF接口

创建VLAN10、VLAN20和VLAN30，并将接口GE0/0/1加入VLAN10中，接口GE0/0/2加入VLAN20中，接口GE0/0/3加入VLAN30中。

```
<HUAWEI> system-view
[HUAWEI] vlan batch 10 20 30
[HUAWEI] interface gigabitethernet 0/0/1
[HUAWEI-GigabitEthernet0/0/1] port link-type trunk
[HUAWEI-GigabitEthernet0/0/1] port trunk allow-pass vlan 10
[HUAWEI-GigabitEthernet0/0/1] quit
[HUAWEI] interface gigabitethernet 0/0/2
[HUAWEI-GigabitEthernet0/0/2] port link-type trunk
[HUAWEI-GigabitEthernet0/0/2] port trunk allow-pass vlan 20
[HUAWEI-GigabitEthernet0/0/2] quit
[HUAWEI] interface gigabitethernet 0/0/3
[HUAWEI-GigabitEthernet0/0/3] port link-type trunk
[HUAWEI-GigabitEthernet0/0/3] port trunk allow-pass vlan 30
[HUAWEI-GigabitEthernet0/0/3] quit
```

创建接口VLANIF10、VLANIF20、VLANIF30，配置各VLANIF接口的IP地址。

```
[HUAWEI] interface vlanif 10
[HUAWEI-Vlanif10] ip address 10.1.1.4 24
[HUAWEI-Vlanif10] quit
[HUAWEI] interface vlanif 20
[HUAWEI-Vlanif20] ip address 10.2.1.4 24
[HUAWEI-Vlanif20] quit
[HUAWEI] interface vlanif 30
[HUAWEI-Vlanif30] ip address 10.10.10.3 24
[HUAWEI-Vlanif30] quit
```

步骤2 配置ARP表项严格学习功能

```
[HUAWEI] arp learning strict
```

步骤3 配置ARP表项固化功能

配置ARP表项固化模式为**fixed-mac**方式。

```
[HUAWEI] arp anti-attack entry-check fixed-mac enable
```

步骤4 配置根据源IP地址进行ARP Miss消息限速

配置对Server（IP地址为10.10.10.2）的ARP Miss消息进行限速，允许AC每秒最多处理该IP地址触发的40个ARP Miss消息；对于其他用户，允许AC每秒最多处理同一个源IP地址触发的20个ARP Miss消息。

```
[HUAWEI] arp-miss speed-limit source-ip maximum 20
[HUAWEI] arp-miss speed-limit source-ip 10.10.10.2 maximum 40
```

步骤5 配置基于接口的ARP表项限制

配置接口GE0/0/1最多可以学习到20个动态ARP表项。

```
[HUAWEI] interface gigabitethernet 0/0/1
[HUAWEI-GigabitEthernet0/0/1] arp-limit vlan 10 maximum 20
[HUAWEI-GigabitEthernet0/0/1] quit
```

步骤6 配置根据源MAC地址进行ARP限速

配置对用户User1（MAC地址为0001-0001-0001）进行ARP报文限速，每秒最多只允许10个该MAC地址的ARP报文通过。

```
[HUAWEI] arp speed-limit source-mac 0001-0001-0001 maximum 10
```

步骤7 配置根据源IP地址进行ARP限速

配置对用户User3（IP地址为10.2.1.2）进行ARP报文限速，每秒最多只允许10个该IP地址的ARP报文通过。

```
[HUAWEI] arp speed-limit source-ip 10.2.1.2 maximum 10
```

步骤8 验证配置结果

执行命令**display arp learning strict**，可以看到全局已经配置ARP表项严格学习功能。

```
[HUAWEI] display arp learning strict
 The global configuration:arp learning strict
 Interface                        LearningStrictState
-------------------------------------------------------------
-------------------------------------------------------------
 Total:0
 Force-enable:0
 Force-disable:0
```

执行命令**display arp-limit**，查看接口可以学习到的动态ARP表项数目的最大值。

```
[HUAWEI] display arp-limit interface gigabitethernet 0/0/1
 Interface                    LimitNum   VlanID     LearnedNum(Mainboard)
-----------------------------------------------------------------------------
 GigabitEthernet0/0/1           20         10         0
-----------------------------------------------------------------------------
 Total:1
```

执行命令**display arp anti-attack configuration all**，查看当前ARP防攻击配置情况。

```
[HUAWEI] display arp anti-attack configuration all

 ARP anti-attack packet-check function: disable

 ARP anti-attack entry-check mode: fixed-mac

 ARP gateway-duplicate anti-attack function: disabled

 ARP rate-limit configuration:
-------------------------------------------------------------------------------
 Global configuration:
 Interface configuration:
-------------------------------------------------------------------------------

 ARP miss rate-limit configuration:
-------------------------------------------------------------------------------
 Global configuration:
-------------------------------------------------------------------------------

 ARP speed-limit for source-MAC configuration:
 MAC-address         suppress-rate(pps)(rate=0 means function disabled)
-------------------------------------------------------------------------------
 0001-0001-0001   10
 Others             0
```

```
-----------------------------------------------------------------------------
 1 specified MAC addresses are configured, spec is 256 items.

 ARP speed-limit for source-IP configuration:
 IP-address          suppress-rate(pps)(rate=0 means function disabled)
-----------------------------------------------------------------------------
 10.2.1.2          10
 Others             5
-----------------------------------------------------------------------------
 1 specified IP addresses are configured, spec is 256 items.

 ARP miss speed-limit for source-IP configuration:
 IP-address          suppress-rate(pps)(rate=0 means function disabled)
-----------------------------------------------------------------------------
 10.10.10.2         40
 Others             20
-----------------------------------------------------------------------------
 1 specified IP addresses are configured, spec is 256 items.
```

执行命令**display arp packet statistics**，查看ARP处理的报文统计数据。

```
[HUAWEI] display arp packet statistics
ARP Pkt Received:   sum   8678904
ARP Learnt Count:   sum     37
ARP Pkt Discard For Limit:   sum      146
ARP Pkt Discard For SpeedLimit:   sum      40529
ARP Pkt Discard For Proxy Suppress:   sum    0
ARP Pkt Discard For Other:   sum   8367601
```

由显示信息可知，AC上产生了ARP报文丢弃计数，表明ARP安全功能已经生效。

----结束

配置文件

```
#
vlan batch 10 20 30
#
arp-miss speed-limit source-ip maximum 20
#
arp learning strict
#
arp-miss speed-limit source-ip 10.10.10.2 maximum 40
arp speed-limit source-ip 10.2.1.2 maximum 10
arp speed-limit source-mac 0001-0001-0001 maximum 10
arp anti-attack entry-check fixed-mac enable
#
interface Vlanif10
 ip address 10.1.1.4 255.255.255.0
#
interface Vlanif20
 ip address 10.2.1.4 255.255.255.0
#
interface Vlanif30
 ip address 10.10.10.3 255.255.255.0
#
interface GigabitEthernet0/0/1
 port link-type trunk
 port trunk allow-pass vlan 10
 arp-limit vlan 10 maximum 20
#
interface GigabitEthernet0/0/2
 port link-type trunk
 port trunk allow-pass vlan 20
#
interface GigabitEthernet0/0/3
 port link-type trunk
 port trunk allow-pass vlan 30
#
return
```

27.6 DHCP Snooping 配置

27.6.1 DHCP Snooping 简介

定义

DHCP Snooping是DHCP（Dynamic Host Configuration Protocol）的一种安全特性，用于保证DHCP客户端从合法的DHCP服务器获取IP地址，并记录DHCP客户端IP地址与MAC地址等参数的对应关系，防止网络上针对DHCP攻击。

目的

目前DHCP协议（RFC2131）在应用的过程中遇到很多安全方面的问题，网络中存在一些针对DHCP的攻击，如DHCP Server仿冒者攻击、DHCP Server的拒绝服务攻击、仿冒DHCP报文攻击等。

为了保证网络通信业务的安全性，可引入DHCP Snooping技术，在DHCP Client和DHCP Server之间建立一道防火墙，以抵御网络中针对DHCP的各种攻击。

受益

- 设备具有防御网络上DHCP攻击的能力，增强了设备的可靠性，保障通信网络的正常运行。
- 为用户提供更安全的网络环境，更稳定的网络服务。

27.6.2 DHCP Snooping 原理描述

27.6.2.1 DHCP Snooping 的基本原理

DHCP Snooping能够实现如下基本功能：

信任功能

DHCP Snooping的信任功能，能够保证客户端从合法的服务器获取IP（Internet Protocol）地址。

网络中如果存在私自架设的DHCP Server仿冒者，则可能导致DHCP客户端获取错误的IP地址和网络配置参数，无法正常通信。DHCP Snooping信任功能可以控制DHCP服务器应答报文的来源，以防止网络中可能存在的DHCP Server仿冒者为DHCP客户端分配IP地址及其他配置信息。

DHCP Snooping信任功能将接口分为信任接口和非信任接口：

- 信任接口正常接收DHCP服务器响应的DHCP ACK、DHCP NAK和DHCP Offer报文。
- 非信任接口在接收到DHCP服务器响应的DHCP ACK、DHCP NAK和DHCP Offer报文后，丢弃该报文。

说明

管理员在部署网络时，一般将与合法DHCP服务器直接或间接连接的接口设置为信任接口，其他接口设置为非信任接口，从而保证DHCP客户端只能从合法的DHCP服务器获取IP地址，私自架设的DHCP Server仿冒者无法为DHCP客户端分配IP地址。

分析功能

开启DHCP Snooping功能后，设备能够通过分析DHCP的报文交互过程，生成DHCP Snooping绑定表，绑定表项包括客户端的MAC地址、获取到的IP地址、与DHCP客户端连接的接口及该接口所属的VLAN（Virtual Local Area Network）等信息。

DHCP Snooping绑定表根据DHCP租期进行老化或根据用户释放IP地址时发出的DHCP Release报文自动删除对应表项。

出于安全性的考虑，管理员需要记录用户上网时所用的IP地址，确认用户申请的IP地址和用户使用的主机的MAC地址的对应关系。在设备通过DHCP Snooping功能生成绑定表后，管理员可以方便的记录DHCP用户申请的IP地址与所用主机的MAC地址之间的对应关系。

由于DHCP Snooping绑定表记录了DHCP客户端IP地址与MAC地址等参数的对应关系，故通过对报文与DHCP Snooping绑定表进行匹配检查，能够有效防范非法用户的攻击。

为了保证设备在生成DHCP Snooping绑定表时能够获取到用户MAC等参数，DHCP Snooping功能需应用于二层网络中的接入设备或第一个DHCP Relay上。

27.6.2.2 DHCP Snooping 支持的 Option82 功能

概述

在传统的DHCP动态分配IP地址过程中，DHCP Server不能够根据DHCP请求报文感知到用户的具体物理位置，以致同一VLAN的用户得到的IP地址所拥有的权限是完全相同的。由于网络管理者不能对同一VLAN中特定的用户进行有效的控制，即不能够控制客户端对网络资源的访问，这将给网络的安全控制提出了严峻的挑战。

RFC 3046定义了DHCP Relay Agent Information Option（Option 82），该选项记录了DHCP Client的位置信息。DHCP Snooping设备或DHCP Relay通过在DHCP请求报文中添加Option82选项，将DHCP Client的精确物理位置信息传递给DHCP Server，从而使得DHCP Server能够为主机分配合适的IP地址和其他配置信息，实现对客户端的安全控制。

Option82包含两个常用子选项Circuit ID和Remote ID。其中Circuit ID子选项主要用来标识客户端所在的VLAN、接口等信息，Remote ID子选项主要用来标识客户端接入的设备，一般为设备的MAC地址。

设备作为DHCP Relay时，使能或未使能DHCP Snooping功能都可支持Option82选项功能，但若设备在二层网络作为接入设备，则必须使能DHCP Snooping功能方可支持Option82功能。

Option82选项仅记录了DHCP用户的精确物理位置信息并通过DHCP请求报文中将该信息发送给DHCP Server。而如果需要对不同的用户部署不同的地址分配或安全策略，则需DHCP Server支持Option82功能并在其上已配置了IP地址分配或安全策略。

Option82选项携带的用户位置信息与DHCP Snooping绑定表记录的用户参数是两个相互独立的概念，没有任何关联。Option82选项携带的用户位置信息是在DHCP用户申

请IP地址时（此时用户还未分配到IP地址），由设备添加到DHCP请求报文中。DHCP Snooping绑定表是在设备收到DHCP Server回应的DHCP Ack报文时（此时已为用户分配了IP地址），设备根据DHCP Ack报文信息自动生成。

实现

设备作为DHCP Relay或设备在二层网络作为接入设备并使能DHCP Snooping功能时均可支持Option82功能。使能设备的Option82功能有Insert和Rebuild两种方式，使能方式不同设备对DHCP请求报文的处理也不同。

- Insert方式：当设备收到DHCP请求报文时，若该报文中没有Option82选项，则插入Option82选项；若该报文中含有Option82选项，则判断Option82选项中是否包含remote-id，如果包含，则保持Option82选项不变，如果不包含，则插入remote-id。
- Rebuild方式：当设备收到DHCP请求报文时，若该报文中没有Option82选项，则插入Option82选项；若该报文中含有Option82选项，则删除该Option82选项并插入管理员自己在设备上配置的Option82选项。

对于Insert和Rebuild两种方式，当设备接收到DHCP服务器的响应报文时，处理方式一致。

- DHCP响应报文中有Option82选项：
  - 如果设备收到的DHCP请求报文中没有Option82选项，则设备将删除DHCP响应报文中的Option82选项，之后转发给DHCP Client。
  - 如果设备收到的DHCP请求报文中有Option82选项，则设备将DHCP响应报文中的Option82选项格式还原为DHCP请求报文中的Option82选项，之后转发给DHCP Client。
- DHCP响应报文不含有Option82选项：直接转发。

27.6.3 DHCP Snooping 应用场景

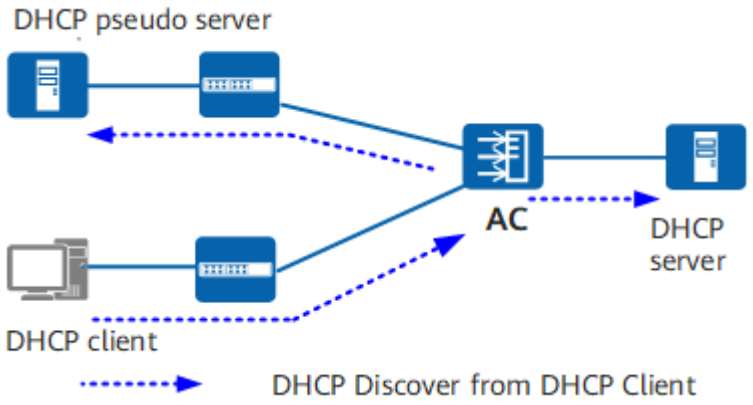
27.6.3.1 防止 DHCP Server 仿冒者攻击

攻击原理

由于DHCP Server和DHCP Client之间没有认证机制，所以如果在网络上随意添加一台DHCP服务器，它就可以为客户端分配IP地址以及其他网络参数。如果该DHCP服务器为用户分配错误的IP地址和其他网络参数，将会对网络造成非常大的危害。

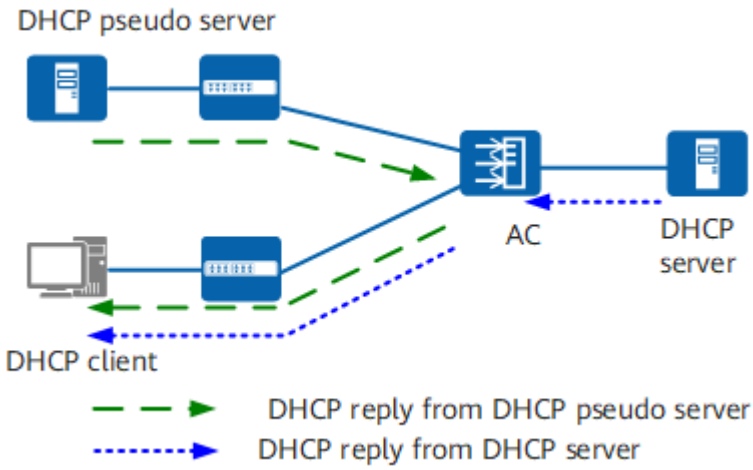
如图27-22所示，DHCP Discover报文是以广播形式发送，无论是合法的DHCP Server，还是非法的DHCP Server都可以接收到DHCP Client发送的DHCP Discover报文。

图 27-22 DHCP Client 发送 DHCP Discover 报文示意图



如果此时DHCP Server仿冒者回应给DHCP Client仿冒信息，如错误的网关地址、错误的DNS（Domain Name System）服务器、错误的IP等信息，如图27-23所示。DHCP Client将无法获取正确的IP地址和相关信息，导致合法客户无法正常访问网络或信息安全受到严重威胁。

图 27-23 DHCP Server 仿冒者攻击示意图

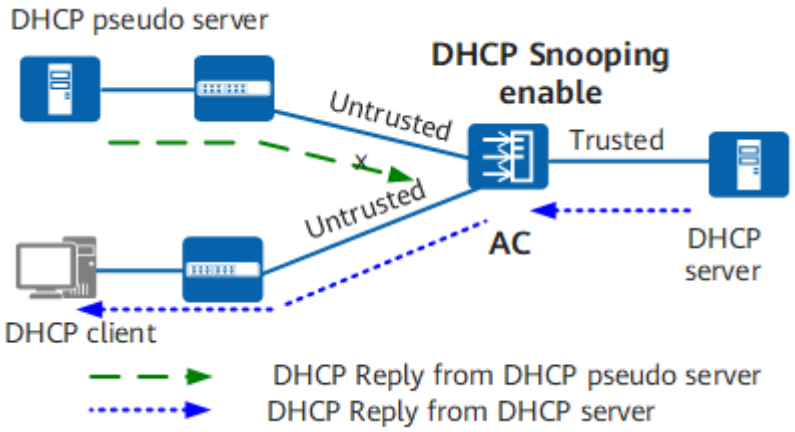


解决方法

为了防止DHCP Server仿冒者攻击，可配置设备接口的“信任（Trusted）/非信任（Untrusted）”工作模式。

将与合法DHCP服务器直接或间接连接的接口设置为信任接口，其他接口设置为非信任接口。此后，从“非信任（Untrusted）”接口上收到的DHCP回应报文将被直接丢弃，这样可以有效防止DHCP Server仿冒者的攻击。如图27-24所示。

图 27-24 Trusted/Untrusted 工作模式示意图



27.6.3.2 防止 DHCP 报文泛洪攻击

攻击原理

在DHCP网络环境中，若攻击者短时间内向设备发送大量的DHCP报文，将会对设备的性能造成巨大的冲击以致可能会导致设备无法正常工作。

解决方法

为了有效的防止DHCP报文泛洪攻击，在使能设备的DHCP Snooping功能时，可同时使能设备对DHCP报文上送DHCP报文处理单元的速率进行检测的功能。此后，设备将会检测DHCP报文的上送速率，并仅允许在规定速率内的报文上送至DHCP报文处理单元，而超过规定速率的报文将会被丢弃。

27.6.3.3 防止仿冒 DHCP 报文攻击

攻击原理

已获取到IP地址的合法用户通过向服务器发送DHCP Request或DHCP Release报文用以续租或释放IP地址。如果攻击者冒充合法用户不断向DHCP Server发送DHCP Request报文来续租IP地址，会导致这些到期的IP地址无法正常回收，以致一些合法用户不能获得IP地址；而若攻击者仿冒合法用户的DHCP Release报文发往DHCP Server，将会导致用户异常下线。

解决方法

为了有效的防止仿冒DHCP报文攻击，可利用DHCP Snooping绑定表的功能。设备通过将DHCP Request续租报文和DHCP Release报文与绑定表进行匹配操作能够有效的判别报文是否合法（主要是检查报文中的VLAN、IP、MAC、接口信息是否匹配动态绑定表），若匹配成功则转发该报文，匹配不成功则丢弃。

27.6.3.4 防止 DHCP Server 服务拒绝攻击

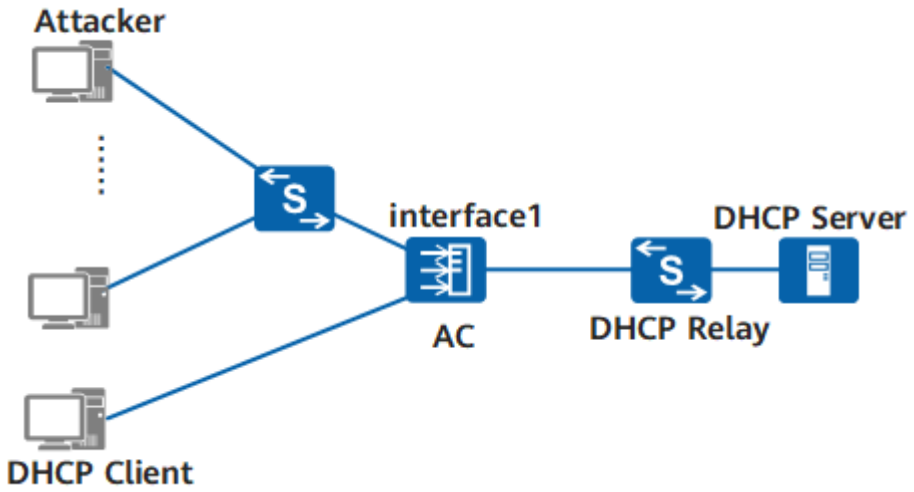
攻击原理

如图27-25所示，若设备接口interface1下存在大量攻击者恶意申请IP地址，会导致DHCP Server中IP地址快速耗尽而不能为其他合法用户提供IP地址分配服务。

另一方面，DHCP Server通常仅根据DHCP Request报文中的CHADDR（Client Hardware Address）字段来确认客户端的MAC地址。如果某一攻击者通过不断改变

CHADDR字段向DHCP Server申请IP地址，同样将会导致DHCP Server上的地址池被耗尽，从而无法为其他正常用户提供IP地址。

图 27-25 DHCP Server 服务拒绝攻击示意图



解决方法

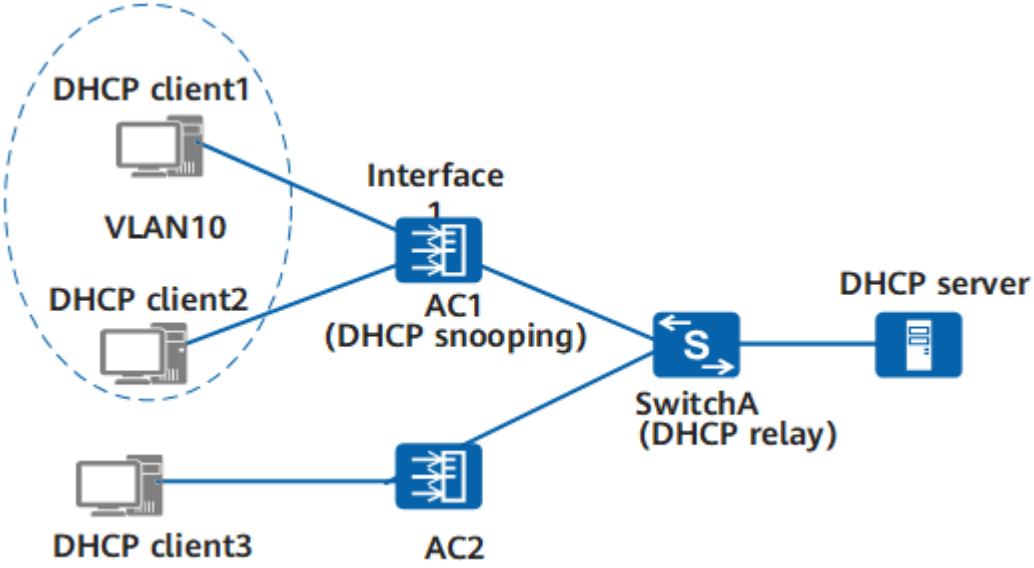
为了抑制大量DHCP用户恶意申请IP地址，在使能设备的DHCP Snooping功能后，可配置设备或接口允许接入的最大DHCP用户数，当接入的用户数达到该值时，则不再允许任何用户通过此设备或接口成功申请到IP地址。

而对通过改变DHCP Request报文中的CHADDR字段方式的攻击，可使能设备检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能，此后设备将检查上送的DHCP Request报文中的帧头MAC地址是否与CHADDR值相等，相等则转发，否则丢弃。

27.6.3.5 Option82 的典型应用

Option 82（DHCP Relay Agent Information Option）称为中继代理信息选项，该选项记录了DHCP Client的位置信息。DHCP Snooping设备或DHCP Relay通过在DHCP请求报文中添加Option82选项，将DHCP Client的位置信息传递给DHCP Server，从而使得DHCP Server能够为主机分配合适的IP地址和其他配置信息，并实现对客户端的安全控制。

图 27-26 Option82 应用组网图



如图27-26所示，用户通过DHCP方式获取IP地址。在管理员组建该网络时需要控制接口interface1下用户对网络资源的访问以提高网络的安全性。

在传统的DHCP动态分配IP地址过程中，DHCP Server是无法区分同一VLAN内的不同用户的，以致同一VLAN内的用户得到的IP地址所拥有的权限是完全相同的。

为实现上述目的，管理员在使能AC1的DHCP Snooping功能之后可使能其Option82功能。之后AC1在接收到用户申请IP地址发送的DHCP请求报文时，将会在报文中插入Option82选项，以标注用户的精确位置信息，譬如MAC地址、所属VLAN、所连接的接口号等参数。DHCP Server在接收到携带有Option82选项的DHCP请求报文后，即可通过Option82选项的内容获悉到用户的精确物理位置进而根据其上已部署的IP地址分配策略或其他安全策略为用户分配合适的IP地址和其他配置信息。

Option82选项仅记录了DHCP用户的精确物理位置信息并通过DHCP请求报文中将该信息发送给DHCP Server。而如果需要对不同的用户部署不同的地址分配或安全策略，则需DHCP Server支持Option82功能并在其上已配置了IP地址分配或安全策略。

27.6.4 DHCP Snooping 缺省配置

DHCP Snooping的缺省配置如表27-12所示：

表 27-12 DHCP Snooping 的缺省配置

参数	缺省值
DHCP Snooping功能	未使能
接口的信任状态	非信任
DHCP Snooping用户位置迁移功能	已使能
ARP与DHCP Snooping的联动功能	未使能
DHCP Snooping支持的Option82功能	未使能

参数	缺省值
DHCP报文上送DHCP报文处理单元的最大允许速率	100pps
对DHCP报文进行绑定表匹配检查的功能	未使能
检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能	未使能
检测DHCP Request报文中GIADDR字段是否非零的功能	未使能

27.6.5 配置 DHCP Snooping

为了提升隐私防护能力，部分主流智能终端（如安卓）支持使用随机MAC地址关联无线网络。由于终端在关联时使用的MAC可能不是真实的物理MAC，基于MAC地址的业务将无法生效。请了解如下建议。

MAC地址相关业务	业务建议
MAC认证	MAC认证一般用于哑终端接入。请勿对智能终端配置MAC认证业务。
PPSK认证	在配置PPSK业务时请勿绑定MAC地址，在使用时系统会动态绑定。
DHCP地址池静态绑定	请勿对智能终端配置静态IP-MAC绑定功能。
DHCP Snooping静态绑定	请勿对智能终端配置静态IP-MAC绑定功能。
MAC优先的Portal认证	在加密方式不变的情况下，终端会以固定的MAC接入相同SSID。一般情况下，MAC优先的Portal认证功能不受MAC随机化的影响。 如果在终端上手动忘记SSID，或者将终端恢复出厂设置，则此终端在下次接入该SSID时会以新的随机MAC接入、需要重新进行Portal认证。
STA黑白名单	请勿对智能终端配置黑白名单业务。

27.6.5.1 配置 DHCP Snooping 的基本功能

前置任务

在配置DHCP Snooping的基本功能之前，需要完成以下任务：

- 网络中已完成DHCP功能的部署。

本章节中，**使能DHCP Snooping功能**、**配置接口信任状态**同样适用于DHCPv6 Snooping。

说明

IPv4 DHCP Snooping功能可以在二层接入设备和第一跳DHCPv4 Relay设备上配置；IPv6 DHCP Snooping功能可以在二层接入设备和第一跳DHCPv6 Relay设备上配置。

配置流程

配置DHCP Snooping的基本功能需要在设备上进行以下配置。

27.6.5.1.1 使能 DHCP Snooping 功能

背景信息

DHCP Snooping是一种DHCP安全特性，在配置DHCP Snooping各安全功能之前需首先使能DHCP Snooping功能。

使能DHCP Snooping功能的顺序是先使能全局下的DHCP Snooping功能，再使能接口或VLAN下的DHCP Snooping功能。

说明

使能DHCP Snooping功能之前，必须已使用命令**dhcp enable**使能了设备的DHCP功能。

说明

DHCP Snooping不支持BOOTP协议，而无盘工作站使用BOOTP协议，所以无盘工作站不能通过DHCP Snooping生成动态绑定表。由于IPSG功能和DAI功能是基于绑定表实现的，如果无盘工作站要使用以上功能，需要执行命令**user-bind static**配置静态绑定表。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcp snooping enable** [**ipv4** | **ipv6**]，全局使能DHCP Snooping功能。

缺省情况下，设备全局未使能DHCP Snooping功能。

说明

系统视图下，**dhcp snooping enable**命令是DHCP Snooping相关功能的总开关。执行**undo dhcp snooping enable**命令后，设备上所有DHCP Snooping相关的配置会被删除；再次执行**dhcp snooping enable**命令使能DHCP Snooping功能后，设备上所有DHCP Snooping相关配置将被恢复为缺省配置。

步骤3 使能DHCP Snooping功能，可在系统视图、VLAN视图或接口视图下进行配置。

- 系统视图下：

1. 执行命令**dhcp snooping enable vlan** { *vlan-id1* [**to** *vlan-id2*] } &<1-10>，使能DHCP Snooping功能。

   缺省情况下，设备未使能DHCP Snooping功能。

- VLAN视图或接口视图下：

1. 执行命令**vlan** *vlan-id*，进入VLAN视图；或执行命令**interface** *interface-type interface-number*，进入连接用户的接口视图。

2. 执行命令**dhcp snooping enable**，使能接口或VLAN下的DHCP Snooping功能。

   缺省情况下，设备未使能DHCP Snooping功能。

   在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCP报文命令功能生效；在接口下执行该命令，则对该接口下的所有DHCP报文命令功能生效。

----结束

27.6.5.1.2 配置接口信任状态

背景信息

为使DHCP客户端能通过合法的DHCP服务器获取IP地址，需将与管理员信任的DHCP服务器直接或间接连接的设备接口设置为信任接口，其他接口设置为非信任接口。从而保证DHCP客户端只能从合法的DHCP服务器获取IP地址，私自架设的DHCP Server仿冒者无法为DHCP客户端分配IP地址。

在连接用户的接口或VLAN下使能DHCP Snooping功能之后，需将连接DHCP服务器的接口配置为“信任”模式，两者同时生效设备即能够生成DHCP Snooping动态绑定表。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置接口为“信任”状态，可在接口视图、VLAN视图下执行。

- 接口视图下：

1. 执行命令**interface** *interface-type interface-number*，进入接口视图。
2. 执行命令**dhcp snooping trusted**，配置接口为“信任”接口。

   缺省情况下，接口的状态为“非信任”状态。

- VLAN视图下：

1. 执行命令**vlan** *vlan-id*，进入VLAN视图。
2. 执行命令**dhcp snooping trusted interface** *interface-type interface-number*，配置接口为“信任”接口。

   缺省情况下，接口的状态为“非信任”状态。

   在VLAN视图下执行此命令，则命令功能仅对加入该VLAN的接口收到的属于此VLAN的DHCP报文生效；在接口下执行该命令，则命令功能对该接口接收到的所有DHCP报文生效。

----结束

27.6.5.1.3 配置接口不生成用户绑定表

背景信息

用户绑定表项记录了DHCP Client的关键信息（包括PC的MAC地址以及获取到的IP地址、地址租期），并且包含了与DHCP Client连接的使能了DHCP Snooping功能的接口信息（包括接口编号及该接口所属的VLAN）。缺省情况下，在使能DHCP Snooping功能后，接口自动生成用户绑定表。

由于接口允许学习的DHCP Snooping绑定表项的数目有限，在某些场景下，譬如使能DHCP Snooping后，当管理员确定DHCP网络中不存在非法用户，并且其仅希望设备能够记录用户详细的位置信息，可配置该功能以取消生成用户绑定表项，否则一旦设备上的绑定表项数目达到最大值，新用户将无法上线。

须知

执行本命令后，设备将删除对应VLAN或接口的用户绑定表项。

dhcp snooping enable no-user-binding命令不能与命令dhcp snooping check dhcp-request enable同时使用，否则可能会造成已在线用户无法下线。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置在使能DHCP Snooping功能后，接口不生成用户绑定表。

在接口视图下配置，对该接口下连接的所有DHCP用户，命令功能生效；在VLAN视图下配置，对该VLAN下所有接口连接的所有DHCP用户，命令功能生效；在系统视图下配置与在VLAN视图配置功能一致，区别在于系统视图下配置可同时对多个VLAN生效。

配置维度	操作步骤
基于VLAN配置	在系统视图下针对多个VLAN批量配置 ● 执行命令**dhcp snooping enable no-user-binding vlan** { *vlan-id1* [**to** *vlan-id2*] }&<1-10>，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 在VLAN视图下针对单个VLAN配置 1. 执行命令**vlan** *vlan-id*，进入VLAN视图。 2. 执行命令**dhcp snooping enable no-user-binding**，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 3. 执行命令**quit**，返回到系统视图。
基于接口配置	1. 执行命令**interface** *interface-type interface-number*，进入接口视图。 2. 执行命令**dhcp snooping enable no-user-binding**，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 3. 执行命令**quit**，返回到系统视图。

----结束

27.6.5.1.4 （可选）使能 DHCP Snooping 用户位置迁移功能

背景信息

在移动应用场景中，若某一用户由接口A上线后，然后切换到接口B，这时为了让用户能够上线，需要使能DHCP Snooping用户位置迁移功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcp snooping user-transfer enable**，使能DHCP Snooping用户位置迁移功能。

缺省情况下，已使能DHCP Snooping用户位置迁移功能。

----结束

27.6.5.1.5 （可选）配置 ARP 与 DHCP Snooping 的联动功能

背景信息

DHCP Snooping设备在收到DHCP用户发出的DHCP Release报文时将会删除该用户对应的绑定表项，但若用户发生了异常下线而无法发出DHCP Release报文时，DHCP Snooping设备将不能够及时的删除该DHCP用户对应的绑定表。

使能ARP与DHCP Snooping的联动功能，如果DHCP Snooping表项中的IP地址对应的ARP表项达到老化时间，则DHCP Snooping设备会对该IP地址进行ARP探测，如果在规定的探测次数内探测不到用户，设备将删除用户对应的ARP表项。之后，设备将会再次按规定的探测次数对该IP地址进行ARP探测，如果最后仍不能够探测到用户，则设备将会删除该用户对应的绑定表项。

说明

使用ARP与DHCP Snooping的联动功能之前，需要保证设备上具有与客户端同网段的IP地址用于ARP探测。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**arp dhcp-snooping-detect enable**，使能ARP与DHCP Snooping的联动功能。

缺省情况下，未使能ARP与DHCP Snooping的联动功能。

----结束

27.6.5.1.6 （可选）配置丢弃 GIADDR 字段非零的 DHCP 报文

背景信息

DHCP报文中的GIADDR（Gateway Ip Address）字段记录了DHCP报文经过的第一个DHCP Relay的IP地址，当客户端发出DHCP请求时，如果服务器和客户端不在同一个网段，那么第一个DHCP Relay在将DHCP请求报文转发给DHCP服务器时，会把自己的IP地址填入此字段，DHCP服务器会根据此字段来判断出客户端所在的网段地址，从而选择合适的地址池，为客户端分配该网段的IP地址。

在为了保证设备在生成DHCP Snooping绑定表时能够获取到用户MAC等参数，DHCP Snooping功能需应用于二层网络中的接入设备或第一个DHCP Relay上。故DHCP Snooping设备接收到的DHCP报文中GIADDR字段必然为零，若不为零则该报文为非法报文，设备需丢弃此类报文。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 使能检测DHCP Request报文中GIADDR字段是否非零的功能，可在系统视图、VLAN视图或接口视图下进行配置。

- 系统视图下：

1. 执行命令**dhcp snooping check dhcp-giaddr enable vlan** { *vlan-id1* [**to** *vlan-id2*] } &<1-10>，使能检测DHCP Request报文中GIADDR字段是否非零的功能。

   缺省情况下，未使能检测DHCP Request报文中GIADDR字段是否非零的功能。

- VLAN视图或接口视图下：

1. 执行命令**vlan** *vlan-id*，进入VLAN视图；或执行命令**interface** *interface-type interface-number*，进入接口视图。
2. 执行命令**dhcp snooping check dhcp-giaddr enable**，使能检测DHCP Request报文中GIADDR字段是否非零的功能。

   缺省情况下，未使能检测DHCP Request报文中GIADDR字段是否非零的功能。

在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCP报文命令功能生效；在接口下执行该命令，则对该接口下的所有DHCP报文命令功能生效。

----结束

27.6.5.1.7 （可选）配置 DHCPv6 报文限速功能和丢弃告警功能

背景信息

为了防止大量DHCPv6报文对设备造成冲击，设备支持对DHCPv6报文进行限速。

使能DHCPv6报文限速功能后，DHCPv6报文超过速率限制值时会被丢弃。使能DHCPv6报文限速丢弃告警功能后，当限速导致丢弃DHCPv6报文的数量超过一定阈值时，设备发出告警。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcpv6 packet-rate** *packet-rate*，使能DHCPv6报文限速功能，并配置速率抑制值。

缺省情况下，使能DHCPv6报文限速功能处于未使能状态。

步骤3 执行命令**dhcpv6 packet-rate drop-alarm enable**，使能DHCPv6报文限速丢弃告警功能。

缺省情况下，DHCPv6报文限速丢弃告警功能处于未使能状态。

步骤4 执行命令**dhcpv6 packet-rate drop-alarm threshold** *threshold*，配置DHCPv6报文限速丢弃告警的阈值。

缺省情况下，使能DHCPv6报文限速丢弃告警功能时，告警阈值为100包。

----结束

27.6.5.1.8 （可选）配置 DHCPv6 Snooping 探测 confirm-client 是否在线功能

背景信息

confirm-client指通过DHCPv6 Confirm报文生成绑定表的客户端，当客户端重新上线时，会发送DHCPv6 Confirm报文。

DHCPv6 Snooping在用户侧端口收到DHCPv6 Confirm报文会生成DHCPv6 Snooping绑定表。由于DHCPv6 Confirm报文没有携带有效租期，当confirm-client离线时，绑定表无法及时老化删除，占用了表项规格，可能导致新用户无法正常上线。

开启探测confirm-client是否在线功能后，DHCPv6 Snooping会周期性发送DAD类型的NS报文探测用户是否在线，及时删除下线的confirm-client的DHCPv6 Snooping表项。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcpv6 snooping user-bind detect confirm-client enable**，开启DHCPv6 Snooping探测confirm-client是否在线功能。

缺省情况下，DHCPv6 Snooping探测confirm-client是否在线功能处于关闭状态。

步骤3 执行命令**dhcpv6 snooping user-bind detect retransmit** *times* **interval** *interval*，配置DHCPv6 Snooping探测用户是否在线的DAD NS报文的发送次数和发送时间间隔。

缺省情况下，DHCPv6 Snooping探测用户是否在线的DAD NS报文发送次数为3次，发送时间间隔为180秒。

----结束

27.6.5.1.9 （可选）去使能接口 DHCP Snooping 功能

背景信息

若使能了某一VLAN的DHCP Snooping功能，则VLAN内所有的接口均使能了DHCP Snooping功能。此时如果需要去使能一特定接口的DHCP Snooping功能，可使用命令**dhcp snooping disable**去使能特定接口的DHCP Snooping功能。此后该接口下的用户将能正常上线，但是并不会生成DHCP动态绑定表。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface** *interface-type interface-number*，进入指定的接口视图。

步骤3 执行命令**dhcp snooping disable**，去使能接口的DHCP Snooping功能。

缺省情况下，接口的DHCP Snooping功能是否使能依赖于是否在该接口或者该接口所在的VLAN下使用**dhcp snooping enable**命令使能DHCP Snooping功能。

----结束

27.6.5.1.10 检查 DHCP Snooping 基本功能的配置结果

背景信息

在配置完成DHCP Snooping的基本功能后，可通过命令查看配置信息。

操作步骤

- 执行命令**display dhcp snooping** [**interface** *interface-type interface-number* | **vlan** *vlan-id*]，查看DHCP Snooping的运行信息。
- 执行命令**display dhcp snooping configuration** [**vlan** *vlan-id* | **interface** *interface-type interface-number*]，查看DHCP Snooping的配置信息。
- 执行命令**display dhcp snooping user-bind** { { **interface** *interface-type interface-number* | **ip-address** *ip-address* | **mac-address** *mac-address* | **vlan** *vlan-id* } * | **all** } [**verbose**]，查看DHCP Snooping绑定表信息。
- 执行命令**display dhcpv6 snooping user-bind** { { **interface** *interface-type interface-number* | **ipv6-address** *ipv6-address* | **mac-address** *mac-address* | **vlan** *vlan-id* } * | **confirm-client** | **all** } [**verbose**]，查看DHCPv6 Snooping绑定表信息。
- 执行命令**display dhcp snooping statistics** ，查看设备接收到的各类型DHCP报文的统计信息。
- 执行命令**display dhcpv6 snooping statistics**，查看DHCPv6 Snooping统计信息。

----结束

27.6.5.2 配置 DHCP Snooping 的攻击防范功能

说明

本章节中，**配置防止仿冒DHCP报文攻击**功能、**配置防止DHCP Server服务拒绝攻击**中的“步骤2”相关功能同样适用于DHCPv6 Snooping。

前提条件

配置DHCP Snooping的攻击防范功能之前，务必确保已完成DHCP Snooping的基本功能配置。

27.6.5.2.1 配置防止 DHCP Server 仿冒者攻击

背景信息

在使能DHCP Snooping功能并配置了接口的信任状态之后，设备将能够保证客户端从合法的服务器获取IP地址，这将能够有效的防止DHCP Server仿冒者攻击。但是此时却不能够定位DHCP Server仿冒者的位置，使得网络中仍然存在着安全隐患。

通过配置DHCP Server探测功能，DHCP Snooping设备将会检查并在日志中记录所有DHCP回应报文中携带的DHCP Server地址与接口等信息，此后网络管理员可根据日志来判定网络中是否存在伪DHCP Server进而对网络进行维护。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcp snooping enable**，使能了设备的DHCP Snooping功能。

步骤3 执行命令**dhcp server detect**，使能DHCP Server探测功能。

缺省情况下，未使能DHCP Server探测功能。

----结束

27.6.5.2.2 配置防止仿冒 DHCP 报文攻击

背景信息

在DHCP网络环境中，若攻击者仿冒合法用户的DHCP报文发往DHCP服务器，会导致合法用户无法使用该IP地址或异常下线。在生成DHCP Snooping绑定表后，设备可根据绑定表项，对DHCP报文进行匹配检查，只有匹配成功的报文设备才将其转发，否则将丢弃。这将能有效的防止非法用户通过发送伪造DHCP报文冒充合法用户进行续租或释放IP地址。

操作步骤

步骤1 开启对DHCP报文进行绑定表匹配检查的功能

在VLAN视图下执行以下命令，对属于该VLAN的所有接口都生效；在接口下执行该命令，仅对该接口生效。

- 系统视图下：

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**dhcp snooping check dhcp-request enable vlan** { *vlan-id1* [**to** *vlan-id2*] } &<1-10>，开启对从指定VLAN内上送的DHCP报文进行绑定表匹配检查的功能。

   缺省情况下，未开启对DHCP请求报文进行绑定表匹配检查的功能。
3. 执行命令**dhcp snooping check dhcp-chaddr enable vlan** { *vlan-id1* [**to** *vlan-id2*] } &<1-10>，开启检测DHCP Request报文帧头源MAC地址与CHADDR字段是否相同的功能。

   缺省情况下，未开启检测DHCP Request报文帧头源MAC地址与CHADDR字段是否相同的功能。

- VLAN视图或接口视图下：

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**vlan** *vlan-id*，进入VLAN视图；或执行命令**interface** *interface-type interface-number*，进入接口视图。
3. 执行命令**dhcp snooping check dhcp-request enable**，开启对DHCP报文进行绑定表匹配检查的功能。

   缺省情况下，未开启对DHCP报文进行绑定表匹配检查的功能。
4. 执行命令**dhcp snooping check dhcp-chaddr enable**，开启检测DHCP Request报文帧头源MAC地址与CHADDR字段是否相同的功能。

缺省情况下，未开启检测DHCP Request报文帧头源MAC地址与CHADDR字段是否相同的功能。

步骤2 （可选）开启DHCP Snooping告警功能

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**interface** *interface-type interface-number*，进入接口视图。
3. 执行命令**dhcp snooping alarm** { **dhcp-request** | **dhcp-chaddr** | **dhcp-reply** | **dhcpv6-request** } **enable**，开启DHCP Snooping告警功能。

   缺省情况下，未开启DHCP Snooping告警功能。

步骤3 （可选）配置告警阈值

若在系统视图、接口视图下同时进行了配置，则接口下DHCP Snooping丢弃报文数量的告警阈值以两者最小值为准。

- 系统视图下：

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**dhcp snooping alarm threshold** *threshold*，配置DHCP Snooping丢弃报文数量的告警阈值。

   在系统视图下执行该命令，则对设备所有的接口该命令功能生效。

   缺省情况下，DHCP Snooping丢弃报文数量的告警阈值为100packets。

- 接口视图下：

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**interface** *interface-type interface-number*，进入接口视图。
3. 执行命令**dhcp snooping alarm** { **dhcp-request** | **dhcp-chaddr** | **dhcp-reply** | **dhcpv6-request** } **threshold** *threshold*，配置DHCP Snooping丢弃报文数量的告警阈值。

   缺省情况下，全局DHCP Snooping丢弃报文数量的告警阈值为100packets，接口下DHCP Snooping丢弃报文数量的告警阈值为在系统视图下使用命令**dhcp snooping alarm threshold**配置的值。

----结束

27.6.5.2.3 配置防止 DHCP Server 服务拒绝攻击

背景信息

若在网络中存在DHCP用户恶意申请IP地址，将会导致IP地址池中的IP地址快速耗尽以致DHCP Server无法为其他合法用户分配IP地址。另一方面，DHCP Server通常仅根据CHADDR（client hardware address）字段来确认客户端的MAC地址。如果攻击者通过不断改变DHCP Request报文中的CHADDR字段向DHCP Server申请IP地址，将会导致DHCP Server上的地址池被耗尽，从而无法为其他正常用户提供IP地址。

为了防止某些端口的DHCP用户恶意申请IP地址，可配置接口允许学习的DHCP Snooping绑定表项的最大个数，当用户数达到该值时，则任何用户将无法通过此接口成功申请到IP地址。为了防止攻击者不断改变DHCP Request报文中的CHADDR字段进行攻击，可使能检测DHCP Request报文帧头MAC地址与DHCP数据区中CHADDR字段是否相同的功能，相同则转发报文，否则丢弃。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 配置接口允许学习的DHCP Snooping绑定表项的最大个数，可在系统视图、VLAN视图或接口视图下配置。

- 系统视图下：

1. 执行命令**dhcp snooping max-user-number** *max-user-number* **vlan** { *vlan-id1* [**to** *vlan-id2*] } &<1-10>，配置设备允许学习的DHCP Snooping绑定表项的最大个数。

   执行该命令后，设备所有的接口允许学习的DHCP Snooping绑定表项之和为该命令所配置的值。

2. （可选）执行命令**dhcp snooping user-alarm percentage** *percent-lower-value percent-upper-value*，配置DHCP Snooping绑定表的告警阈值百分比。

   缺省情况下，DHCP Snooping绑定表的下限告警阈值百分比为50，上限告警阈值百分比为100。

- VLAN视图或接口视图下：

1. 执行命令**vlan** *vlan-id*，进入VLAN视图；或执行命令**interface** *interface-type interface-number*，进入接口视图。
2. 执行命令**dhcp snooping max-user-number** *max-user-number* ，配置接口允许学习的DHCP Snooping绑定表项的最大个数。

   若在VLAN视图下执行该命令，则VLAN内所有的接口接入的用户最大数为该命令所配置的值。

   在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCP报文命令功能生效；在接口下执行该命令，则对该接口下的所有DHCP报文命令功能生效。

   若在系统视图、VLAN视图、接口视图下同时进行了配置，则接口下允许接入的最大用户数以三者最小值为准。

步骤3 使能对报文的CHADDR字段进行检查功能，可在系统视图、VLAN视图或接口视图下进行配置。

- 系统视图下：

1. 执行命令**dhcp snooping check dhcp-chaddr enable vlan** { *vlan-id1* [**to** *vlan-id2*] } &<1-10>，使能检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能。

   缺省情况下，未使能检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能。

- VLAN视图或接口视图下：

1. 执行命令**vlan** *vlan-id*，进入VLAN视图；或执行命令**interface** *interface-type interface-number*，进入接口视图。
2. 执行命令**dhcp snooping check dhcp-chaddr enable**，使能检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能。

   缺省情况下，未使能检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能。

在VLAN视图下执行此命令，则对设备所有接口接收到的属于该VLAN的DHCP报文命令功能生效；在接口下执行该命令，则仅对该接口接收到的所有DHCP报文命令功能生效。

3. 执行命令**quit**，返回到系统视图。

步骤4 （可选）配置DHCP Snooping丢弃报文数量的告警阈值，可在系统视图或接口视图下执行。

- 系统视图下：

1. 执行命令**dhcp snooping alarm threshold** *threshold*，配置全局DHCP Snooping丢弃报文数量的告警阈值。

   在系统视图下执行该命令，则设备所有的接口该命令功能生效。

   缺省情况下，全局DHCP Snooping丢弃报文数量的告警阈值为100packets。

- 接口视图下：

1. 执行命令**interface** *interface-type interface-number*，进入接口视图。
2. 执行命令**dhcp snooping alarm dhcp-chaddr threshold** *threshold*，配置帧头MAC地址与DHCP数据区中CHADDR字段不匹配而被丢弃的DHCP报文的告警阈值。

   缺省情况下，全局DHCP Snooping丢弃报文数量的告警阈值为100packets，接口下DHCP Snooping丢弃报文数量的告警阈值为在系统视图下使用命令**dhcp snooping alarm threshold**配置的值。

   说明

   若在系统视图、接口视图下同时进行了配置，则接口下DHCP Snooping丢弃报文数量的告警阈值以两者最小值为准。

----结束

27.6.5.2.4 检查 DHCP Snooping 攻击防范功能的配置结果

背景信息

DHCP Snooping的攻击防范功能配置完成后，可使用命令查看已配置的参数信息。

操作步骤

- 执行命令**display dhcp snooping** [**interface** *interface-type interface-number* | **vlan** *vlan-id*]，查看DHCP Snooping的运行信息。
- 执行命令**display dhcp snooping configuration** [**vlan** *vlan-id* | **interface** *interface-type interface-number*]，查看DHCP Snooping的配置信息。
- 执行命令**display dhcp snooping statistics** ，查看设备接收到的各类型DHCP报文的统计信息。

----结束

27.6.5.3 配置在 DHCP 报文中添加 Option82 字段

背景信息

Option82选项记录了DHCP Client的位置信息。设备通过在DHCP请求报文中添加Option82选项，可将DHCP Client的位置信息发送给DHCP Server，从而使得DHCP

Server能够根据Option82选项的内容为DHCP Client分配合适的IP地址和其他配置信息，并可以实现对客户端的安全控制。

说明

- DHCP Option82必须配置在设备的用户侧，否则设备向DHCP Server发出的DHCP报文不会携带Option82选项内容。
- 所有Option82选项共用1～255个字节长度，因此，所有Option82选项长度之和不能超过255个字节，否则会导致部分Option82选项信息丢失。
- 设备不限制配置多少个Option82选项，但是大量配置会占用很多内存，并延长设备处理时间。为保证设备性能，建议用户根据自身需要和设备内存大小来配置Option82选项。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 使能在DHCP报文中添加Option82选项功能，可在VLAN视图或接口视图下进行配置。

视图	操作步骤
VLAN视图	1. 执行命令**vlan** *vlan-id*，进入VLAN视图。 2. 执行命令**dhcp option82** { **insert** | **rebuild** } **enable interface** *interface-type interface-number1* [**to** *interface-number2*]，使能在DHCP报文中添加Option82选项功能。 缺省情况下，未使能在DHCP报文中添加Option82选项功能。 3. 执行命令**quit**，返回到系统视图。
接口视图	1. 执行命令**interface** *interface-type interface-number*，进入接口视图。 2. 执行命令**dhcp option82** { **insert** | **rebuild** } **enable**，使能在DHCP报文中添加Option82选项功能。 缺省情况下，未使能在DHCP报文中添加Option82选项功能。 3. 执行命令**quit**，返回到系统视图。

步骤3 （可选）配置Option82选项的格式，可在系统视图或接口视图下进行配置。在系统视图下进行配置，对设备所有的接口功能生效；在接口下进行配置，仅对指定的接口功能生效。

视图	操作步骤
系统视图	1. 执行命令**dhcp option82** [**vlan** *vlan-id*] [**ce-vlan** *ce-vlan-id*] [**circuit-id** | **remote-id**] **format** { **default** | **common** | **extend** | **user-defined** *text* }，配置在DHCP报文中添加的Option82选项的格式。 缺省情况下，在DHCP报文中添加的Option82选项的格式为**default**格式。

视图	操作步骤
接口视图	1. 执行命令**interface** *interface-type interface-number*，进入接口视图。 2. 执行命令**dhcp option82** [**vlan** *vlan-id*] [**ce-vlan** *ce-vlan-id*] [**circuit-id** | **remote-id**] **format** { **default** | **common** | **extend** | **user-defined** *text* }，配置在DHCP报文中添加的Option82选项的格式。 缺省情况下，在DHCP报文中添加的Option82选项的格式为**default**格式。 3. 执行命令**quit**，返回到系统视图。

步骤4 （可选）执行命令**dhcp option82 subscriber-id format** { **ascii** *ascii-text* \| **hex** *hex-text* }，配置在DHCP报文的Option82选项中插入Sub6子选项。

缺省情况下，未配置在DHCP报文的Option82选项中插入Sub6子选项。

步骤5 （可选）执行命令**dhcp option82 vendor-specific format vendor-sub-option** *sub-option-num* { **ascii** *ascii-text* \| **hex** *hex-text* \| **ip-address** *ip-address* &<1-8> \| **sysname** }，配置在DHCP报文中的Option82选项中插入Sub9子选项。

缺省情况下，未配置在DHCP报文的Option82选项中插入Sub9子选项。

步骤6 （可选）配置插入DHCP Option82选项中的子选项，可在系统视图、VLAN视图或接口视图下进行配置。在系统视图下进行配置，对设备所有的接口功能生效；在VLAN视图下进行配置，对设备所有接口接收到的属于该VLAN的DHCP报文功能生效；在接口下进行配置，仅对指定的接口功能生效。

视图	操作步骤
系统视图	1. 执行命令**dhcp option82 encapsulation** { **circuit-id** | **remote-id** | **subscriber-id** | **vendor-specific-id** } *，配置插入DHCP Option82选项中的子选项。 缺省情况下，插入DHCP Option82选项中的子选项为circuit-id（CID）子选项和remote-id（RID）子选项。
VLAN视图	1. 执行命令**vlan** *vlan-id*，进入VLAN视图。 2. 执行命令**dhcp option82 encapsulation** { **circuit-id** | **remote-id** | **subscriber-id** | **vendor-specific-id** } *，配置插入DHCP Option82选项中的子选项。 缺省情况下，插入DHCP Option82选项中的子选项为circuit-id（CID）子选项和remote-id（RID）子选项。 3. 执行命令**quit**，返回到系统视图。
接口视图	1. 执行命令**interface** *interface-type interface-number*，进入接口视图。 2. 执行命令**dhcp option82 encapsulation** { **circuit-id** | **remote-id** | **subscriber-id** | **vendor-specific-id** } *，配置插入DHCP Option82选项中的子选项。 缺省情况下，插入DHCP Option82选项中的子选项为circuit-id（CID）子选项和remote-id（RID）子选项。 3. 执行命令**quit**，返回到系统视图。

步骤7 （可选）配置在使能DHCP Snooping功能后，接口不生成用户绑定表。

基于VLAN进行配置，表示对设备所有接口下连接的属于该VLAN的DHCP用户，命令功能生效；基于接口进行配置，表示对设备该接口下连接的所有DHCP用户，命令功能生效。

缺省情况下，在使能DHCP Snooping功能后，接口生成用户绑定表。

配置维度	操作步骤
基于VLAN配置	在系统视图下针对多个VLAN批量配置 ● 执行命令**dhcp snooping enable no-user-binding vlan** { *vlan-id1* [**to** *vlan-id2*] }&<1-10>，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 在VLAN视图下针对单个VLAN配置 1. 执行命令**vlan** *vlan-id*，进入VLAN视图。 2. 执行命令**dhcp snooping enable no-user-binding**，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 3. 执行命令**quit**，返回到系统视图。
基于接口配置	1. 执行命令**interface** *interface-type interface-number*，进入接口视图。 2. 执行命令**dhcp snooping enable no-user-binding**，配置在使能DHCP Snooping功能后，接口不生成用户绑定表。 3. 执行命令**quit**，返回到系统视图。

----结束

检查配置结果

- 执行命令**display dhcp option82 configuration** [**vlan** *vlan-id* | **interface** *interface-type interface-number*]，查看DHCP Option82的配置信息。

27.6.6 维护 DHCP Snooping

27.6.6.1 查看 DHCP Snooping 统计信息

背景信息

通过查看DHCP Snooping统计信息，可以方便日常维护过程中的问题定位。

操作步骤

- 执行命令**display dhcp snooping statistics**，查看DHCP Snooping统计信息。
- 执行命令**display dhcpv6 snooping statistics**，查看DHCPv6 Snooping统计信息。

----结束

27.6.6.2 清除 DHCP Snooping 的统计信息

背景信息

须知

清除统计信息后，以前的统计信息将无法恢复，请慎重操作。

操作步骤

- 在用户视图下执行命令**reset dhcp snooping statistics global**，清除全局的报文丢弃统计计数。
- 在用户视图下执行命令**reset dhcpv6 snooping statistics**，清除DHCPv6 Snooping的统计信息。

----结束

27.6.6.3 清除 DHCP Snooping 绑定表

背景信息

由于在组网环境变化之后，DHCP Snooping绑定表不会立即老化，而DHCP Snooping绑定表匹配的如下信息可能会发生变化，导致报文转发错误。

- 用户所属VLAN信息。
- 用户所连接的接口信息。

所以，请在变更组网环境之前手动清除所有DHCP Snooping绑定表项，使得设备根据新的网络环境生成新的DHCP Snooping绑定表。

须知

清除DHCP Snooping绑定表后，设备下所连接的所有DHCP用户均需重新上线生成绑定表后方可恢复正常网络通信，请慎重操作。

操作步骤

- 在用户视图下执行命令**reset dhcp snooping user-bind** [[**vlan** *vlan-id* | **interface** *interface-type interface-number*] * | **ip-address** [*ip-address*] | **ipv6-address** [*ipv6-address*]]，清除DHCP Snooping绑定表。

----结束

27.6.6.4 备份 DHCP Snooping 绑定表

背景信息

如果没有备份绑定表，设备重启后DHCP Snooping绑定表将丢失，这将导致DHCP用户必须重新进行上线以生成DHCP Snooping绑定表项才能正常通信。在备份DHCP Snooping绑定表后，设备重启后恢复DHCP Snooping绑定表，即可避免上述问题。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**dhcp snooping user-bind autosave** *file-name* [**write-delay** *delay-time*]，使能DHCP Snooping绑定表的自动备份功能。

缺省情况下，未使能DHCP Snooping绑定表的自动备份功能。

----结束

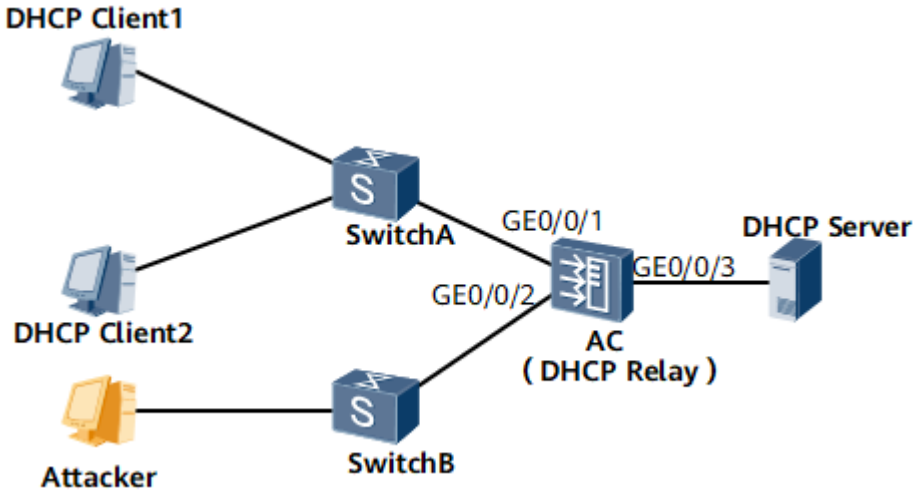
27.6.7 DHCP Snooping 配置举例

27.6.7.1 配置 DHCP Snooping 的攻击防范功能示例

组网需求

如图27-27所示，SwitchA与SwitchB为接入设备，AC为DHCP Relay。合法用户Client1与Client2通过SwitchA接入网络，并通过DHCP方式获取IP地址。网络中存在非法用户的攻击导致合法用户不能正常获取IP地址，管理员希望能够防止网络中针对DHCP的攻击，为DHCP用户提供更优质的服务。

图 27-27 配置 DHCP Snooping 的攻击防范功能组网图



配置思路

采用如下的思路在AC上进行配置。

1. 使能DHCP Snooping功能。
2. 配置接口的信任状态，以保证客户端从合法的服务器获取IP地址。
3. 使能ARP与DHCP Snooping的联动功能，保证DHCP用户在异常下线时实时更新绑定表。
4. 使能对DHCP报文进行绑定表匹配检查的功能，防止仿冒DHCP报文攻击。

5. 配置DHCP报文上送DHCP报文处理单元的最大允许速率，防止DHCP报文泛洪攻击。
6. 配置允许接入的最大用户数以及使能检测DHCP Request报文帧头MAC与DHCP数据区中CHADDR字段是否一致功能，防止DHCP Server服务拒绝攻击。

操作步骤

步骤1 使能DHCP Snooping功能。

使能全局DHCP Snooping功能。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] dhcp enable
[AC] dhcp snooping enable
```

使能用户侧接口的DHCP Snooping功能。以GE0/0/1接口为例，GE0/0/2的配置相同，此处省略。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] dhcp snooping enable
[AC-GigabitEthernet0/0/1] quit
```

步骤2 配置接口的信任状态：将连接DHCP Server的接口状态配置为“Trusted”。

```
[AC] interface gigabitethernet 0/0/3
[AC-GigabitEthernet0/0/3] dhcp snooping trusted
[AC-GigabitEthernet0/0/3] quit
```

步骤3 使能ARP与DHCP Snooping的联动功能。

```
[AC] arp dhcp-snooping-detect enable
```

步骤4 使能对DHCP报文进行绑定表匹配检查的功能。

在用户侧接口进行配置。以GE0/0/1接口为例，GE0/0/2的配置相同，此处省略。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] dhcp snooping check dhcp-request enable
[AC-GigabitEthernet0/0/1] quit
```

步骤5 配置DHCP报文上送DHCP报文处理单元的最大允许速率为90pps。

```
[AC] dhcp snooping check dhcp-rate enable
[AC] dhcp snooping check dhcp-rate 90
```

步骤6 使能检测DHCP Request报文中GIADDR字段是否非零的功能。

在用户侧接口进行配置。以GE0/0/1接口为例，GE0/0/2的配置相同，此处省略。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] dhcp snooping check dhcp-giaddr enable
[AC-GigabitEthernet0/0/1] quit
```

步骤7 配置接口允许接入的最大用户数并使能对CHADDR字段检查功能。

在用户侧接口进行配置。以GE0/0/1接口为例，GE0/0/2的配置相同，此处省略。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] dhcp snooping max-user-number 20
[AC-GigabitEthernet0/0/1] dhcp snooping check dhcp-chaddr enable
[AC-GigabitEthernet0/0/1] quit
```

步骤8 配置丢弃报文告警和报文限速告警功能。

使能丢弃报文告警功能，并配置丢弃报文告警阈值。以GE0/0/1接口为例，GE0/0/2的配置相同，此处省略。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] dhcp snooping alarm dhcp-chaddr enable
[AC-GigabitEthernet0/0/1] dhcp snooping alarm dhcp-request enable
[AC-GigabitEthernet0/0/1] dhcp snooping alarm dhcp-reply enable
[AC-GigabitEthernet0/0/1] dhcp snooping alarm dhcp-chaddr threshold 120
[AC-GigabitEthernet0/0/1] dhcp snooping alarm dhcp-request threshold 120
[AC-GigabitEthernet0/0/1] dhcp snooping alarm dhcp-reply threshold 120
[AC-GigabitEthernet0/0/1] quit
```

使能报文限速告警功能，并配置报文限速告警阈值。

```
[AC] dhcp snooping alarm dhcp-rate enable
[AC] dhcp snooping alarm dhcp-rate threshold 500
```

步骤9 验证配置结果

执行命令**display dhcp snooping configuration**查看DHCP Snooping的配置信息。

```
[AC] display dhcp snooping configuration
#
dhcp snooping enable
dhcp snooping check dhcp-rate enable
dhcp snooping check dhcp-rate 90
dhcp snooping alarm dhcp-rate enable
dhcp snooping alarm dhcp-rate threshold 500
arp dhcp-snooping-detect enable
#
interface GigabitEthernet0/0/1
 dhcp snooping enable
 dhcp snooping check dhcp-giaddr enable
 dhcp snooping check dhcp-request enable
 dhcp snooping alarm dhcp-request enable
 dhcp snooping alarm dhcp-request threshold 120
 dhcp snooping check dhcp-chaddr enable
 dhcp snooping alarm dhcp-chaddr enable
 dhcp snooping alarm dhcp-chaddr threshold 120
 dhcp snooping alarm dhcp-reply enable
 dhcp snooping alarm dhcp-reply threshold 120
 dhcp snooping max-user-number 20#
interface GigabitEthernet0/0/2
 dhcp snooping enable
 dhcp snooping check dhcp-giaddr enable
 dhcp snooping check dhcp-request enable
 dhcp snooping alarm dhcp-request enable
 dhcp snooping alarm dhcp-request threshold 120
 dhcp snooping check dhcp-chaddr enable
 dhcp snooping alarm dhcp-chaddr enable
 dhcp snooping alarm dhcp-chaddr threshold 120
 dhcp snooping alarm dhcp-reply enable
 dhcp snooping alarm dhcp-reply threshold 120
 dhcp snooping max-user-number 20
#
interface GigabitEthernet0/0/3
 dhcp snooping trusted
#
```

执行命令**display dhcp snooping interface**查看接口下的DHCP Snooping运行信息。

```
[AC] display dhcp snooping interface gigabitethernet 0/0/1
 DHCP snooping running information for interface GigabitEthernet0/0/1 :
 DHCP snooping                          : Enable
 Trusted interface                      : No
 Dhcp user max number                   : 20
 Current dhcp and nd user number        : 0
 Check dhcp-giaddr                      : Enable
 Check dhcp-chaddr                      : Enable
 Alarm dhcp-chaddr                      : Enable
 Alarm dhcp-chaddr threshold            : 120
```

```
 Discarded dhcp packets for check chaddr  : 0
 Check dhcp-request                       : Enable
 Alarm dhcp-request                       : Enable
 Alarm dhcp-request threshold             : 120
 Discarded dhcp packets for check request : 0
 Check dhcp-rate                          : Disable  (default)
 Alarm dhcp-rate                          : Disable  (default)
 Alarm dhcp-rate threshold                : 500
 Discarded dhcp packets for rate limit    : 0
 Alarm dhcp-reply                         : Enable
 Alarm dhcp-reply threshold               : 120
 Discarded dhcp packets for check reply   : 0
[AC] display dhcp snooping interface gigabitethernet 0/0/3
 DHCP snooping running information for interface GigabitEthernet0/0/3 :
 DHCP snooping                            : Disable  (default)
 Trusted interface                        : Yes
 Dhcp user max number                     : 1024     (default)
 Current dhcp and nd user number          : 0
 Check dhcp-giaddr                        : Disable  (default)
 Check dhcp-chaddr                        : Disable  (default)
 Alarm dhcp-chaddr                        : Disable  (default)
 Check dhcp-request                       : Disable  (default)
 Alarm dhcp-request                       : Disable  (default)
 Check dhcp-rate                          : Disable  (default)
 Alarm dhcp-rate                          : Disable  (default)
 Alarm dhcp-rate threshold                : 500
 Discarded dhcp packets for rate limit    : 0
 Alarm dhcp-reply                         : Disable  (default)
```

----结束

配置文件

AC的配置文件

```
#
 sysname AC
#
dhcp enable
#
dhcp snooping enable
dhcp snooping check dhcp-rate enable
dhcp snooping check dhcp-rate 90
dhcp snooping alarm dhcp-rate enable
dhcp snooping alarm dhcp-rate threshold 500
arp dhcp-snooping-detect enable
#
interface GigabitEthernet0/0/1
 dhcp snooping enable
 dhcp snooping check dhcp-giaddr enable
 dhcp snooping check dhcp-request enable
 dhcp snooping alarm dhcp-request enable
 dhcp snooping alarm dhcp-request threshold 120
 dhcp snooping check dhcp-chaddr enable
 dhcp snooping alarm dhcp-chaddr enable
 dhcp snooping alarm dhcp-chaddr threshold 120
 dhcp snooping alarm dhcp-reply enable
 dhcp snooping alarm dhcp-reply threshold 120
 dhcp snooping max-user-number 20
#
interface GigabitEthernet0/0/2
 dhcp snooping enable
 dhcp snooping check dhcp-request enable
 dhcp snooping alarm dhcp-request enable
 dhcp snooping alarm dhcp-request threshold 120
 dhcp snooping check dhcp-chaddr enable
 dhcp snooping alarm dhcp-chaddr enable
 dhcp snooping alarm dhcp-chaddr threshold 120
```

```
 dhcp snooping alarm dhcp-reply enable
 dhcp snooping alarm dhcp-reply threshold 120
 dhcp snooping max-user-number 20
#
interface GigabitEthernet0/0/3
 dhcp snooping trusted
#
return
```

27.6.8 DHCP Snooping 常见配置错误

27.6.8.1 DHCP Snooping 导致用户无法上线

故障现象

DHCP Snooping导致用户无法上线可能由以下原因造成：

- 连接DHCP Server的网络侧接口未配置为“信任”状态
- 用户侧接口下DHCP用户数达到配置的最大值

操作步骤

步骤1 查看接口状态是否配置错误。

1. 执行命令**display dhcp snooping configuration**查看在哪些VLAN下、哪些接口下使能了DHCP Snooping功能并查看网络侧接口下是否有“Trusted interface”信息。

   说明

   “Trusted”是接口信任状态的标识。接口使能了DHCP Snooping功能后，默认为“非信任”状态。对网络侧报文：设备只处理信任接口收到的DHCP Reply报文，非信任接口收到DHCP Reply报文会丢弃；对用户侧报文：设备收到用户的请求报文时，只会向信任接口转发。

2. 连接DHCP Server的网络侧接口应该配置为“Trusted”。如果网络侧接口不是信任接口，可在VLAN视图或接口视图下执行命令**dhcp snooping trusted**，配置接口为信任状态。

步骤2 如果接口信任状态配置正确，则查看DHCP上线用户数是否达到配置的最大值。

1. 执行命令**display dhcp snooping configuration**，查看全局、VLAN、以及用户侧接口下是否有“DHCP user max number: XX”信息。

   说明

   若没有“DHCP user max number: XX”信息，则接口允许接入的最大DHCP用户数取默认值。若配置了该信息则以配置值为准。

   如果在系统视图、VLAN视图、接口视图下均配置了该参数，则接口下允许接入的最大DHCP用户为三者中的最小值。

2. 执行命令**display dhcp snooping user-bind all**，查看当前设备使能DHCP Snooping功能的接口上一共生成多少DHCP用户动态绑定表项。如果表项数已经达到配置的限制值，后续用户无法接入不属于故障。

----结束

27.7 ND Snooping 配置

27.7.1 ND Snooping 简介

定义

ND Snooping是针对IPv6 ND（Neighbor Discovery，邻居发现）的一种安全特性，用于二层交换网络环境。通过侦听用户重复地址检测DAD（Duplicate Address Detection）过程的邻居请求报文NS（Neighbor Solicitation）来建立ND Snooping动态绑定表，从而记录下报文的源IPv6地址、源MAC地址、所属VLAN、入端口等信息，以防止后续仿冒用户、仿冒网关的ND报文攻击。

关于ND协议的详细介绍，请参见“邻居发现”。

目的

ND协议是IPv6的一个关键协议，它功能强大，但是因为其没有任何安全机制，所以容易被攻击者利用。在网络中，常见的ND攻击有如下两种情况。

- 地址欺骗攻击：攻击者仿冒其他用户的IP地址发送邻居请求报文NS（Neighbor Solicitation）/邻居通告报文NA（Neighbor Advertisement），会改写网关上或者其他用户的ND表项，导致被仿冒用户无法正常接收报文，从而无法正常通信。同时攻击者通过截获被仿冒用户的报文，可以非法获取用户的游戏、网银等帐号口令，会造成这些用户的重大利益损失。
- RA攻击：攻击者仿冒网关向其他用户发送路由器通告报文RA（Router Advertisement），会改写其他用户的ND表项或导致其它用户记录错误的IPv6配置参数，造成这些用户无法正常通信。

为了避免上述ND攻击带来的危害，设备提供了ND Snooping功能以对ND攻击进行防范。

受益

- 可以有效降低用户为保证网络正常运行和网络信息安全而产生的维护成本。
- 可以为用户提供更安全的网络环境和更稳定的网络服务。

27.7.2 ND Snooping 原理描述

ND Snooping是通过侦听**基于ICMPv6实现的ND报文**来建立**前缀管理表**和**ND Snooping动态绑定表**，使设备可以根据前缀管理表来管理接入用户的IPv6地址，并根据ND Snooping动态绑定表来过滤从**非信任接口**接收到的非法ND报文，从而可以防止ND攻击的一种安全技术。

基于 ICMPv6 实现的 ND 报文

ND协议定义的报文使用ICMP承载，其类型包括以下五种。

- 邻居请求报文NS（Neighbor Solicitation）：IPv6节点（使用IPv6协议的主机或网络设备）通过NS报文可以得到邻居的链路层地址，检查邻居是否可达，也可以进行重复地址检测DAD（Duplicate Address Detect）。
- 邻居通告报文NA（Neighbor Advertisement）：NA报文是IPv6节点对NS报文的响应，同时IPv6节点在链路层变化时也可以主动发送NA报文。

- 路由器请求报文RS（Router Solicitation）：IPv6节点启动后，向路由器发出RS报文，以请求网络前缀和其他配置信息，用于IPv6节点地址的自动配置。路由器则会以RA报文进行响应。
- 路由器通告报文RA（Router Advertisement）：路由器周期性的发布RA报文，其中包括网络前缀等网络配置的关键信息，或者路由器以RA报文响应RS报文。
- 重定向报文RR（Redirect）：路由器发现报文的入接口和出接口相同时，可以通过重定向报文通知主机选择另外一个更好的下一跳地址进行后续报文的发送。

ND Snooping 信任接口/非信任接口

为了区分可信任和不可信任的IPv6节点，ND Snooping将设备连接IPv6节点的接口区分为以下两种角色。

- ND Snooping信任接口：该类型接口用于连接可信任的IPv6节点，对于从该类型接口接收到的ND报文，设备正常转发，同时设备会根据接收到的RA报文建立前缀管理表。
- ND Snooping非信任接口：该类型接口用于连接不可信任的IPv6节点，对于从该类型接口接收到的RA报文，设备认为是非法报文直接丢弃。

前缀管理表

通过无状态地址自动配置方式获取IPv6地址的用户，其IPv6地址是根据路由器发送的RA报文中的网络前缀等配置信息来自动生成的。配置ND Snooping功能后，设备通过侦听从ND Snooping信任接口接收到的RA报文，可以生成前缀管理表（表项内容包括前缀、前缀长度、前缀老化租期等信息）供管理员查看，以方便灵活管理这些用户的IPv6地址。

ND Snooping 动态绑定表

ND Snooping动态绑定表的表项内容包括报文的源IPv6地址、源MAC地址、所属VLAN和入接口等信息，可用于设备对从非信任接口接收到的NA/NS/RS报文进行绑定表匹配检查，从而可以过滤非法的NA/NS/RS报文。

ND Snooping动态绑定表的新建、更新机制

配置ND Snooping功能后，设备通过检查DAD NS报文来建立ND Snooping动态绑定表；通过检查NS（包括DAD NS报文和普通NS报文）/NA报文来更新ND Snooping动态绑定表。

ND Snooping动态绑定表的新建、更新机制如下：

第一种情况：设备收到DAD NS报文

首先根据报文中的Target Address查找是否有对应的前缀管理表表项。

说明

Target Address表示请求目标的IP地址。不能是组播地址，可以是本地链路、本地站点、全局地址。

如果没有，则直接丢弃该报文。

如果有，则继续根据Target Address查找是否有对应ND Snooping动态绑定表表项。

- 如果没有，则新建ND Snooping动态绑定表表项，并且转发该报文。
- 如果有，则判断DAD NS报文的MAC地址、入端口、VLAN信息与现有该表项的MAC地址、入端口、VLAN信息是否一致。

  - 一致，则更新对应表项中用户的地址租期；
  - MAC地址一致、其他信息不一致，则删除原有表项，重新建立表项，并且转发该报文。
  - MAC地址不一致，则表项不变，并且转发该报文。

第二种情况：设备收到普通NS报文

首先根据报文中的Source Address查找是否有对应的ND Snooping动态绑定表表项。

如果没有，则检查是否开启ND协议报文合法性检查功能，如果有，则丢弃该报文，如果没有则转发该报文。

如果有，则判断NS报文的MAC地址、入端口、VLAN信息与现有该表项的MAC地址、入端口、VLAN信息是否一致。

- 一致，则更新对应表项中用户的地址租期；
- 不一致，则检查是否开启ND协议报文合法性检查功能，如果有，则丢弃该报文，如果没有则转发该报文。

第三种情况：设备收到NA报文

首先判断收到NA报文的接口是否为以下任一接口：配置了命令**dhcp snooping disable**的接口、配置了命令**dhcp snooping trust**或**nd snooping trust**的接口、未配置命令**nd snooping check na enable**的接口。

如果是以上任一接口，则直接转发该NA报文。

如果不是以上列举的接口，则继续根据NA报文的源IP地址和目的IP地址判断是否有对应的ND Snooping动态绑定表表项。

- 如果没有，则直接丢弃该NA报文。
- 如果有，则判断NA报文的端口信息与现有表项的是否一致。
  - 一致，则更新对应绑定表表项中用户地址租期；
  - 不一致，说明该NA报文与现有表项冲突，此时会触发设备发送NS报文探测用户是否在线。如果在表项生存时间内，设备从表项对应的端口上收到NA报文，说明该用户仍然在线，更新对应表项中用户的地址租期。如果在表项生存时间内，设备没有从表项对应的端口上收到NA报文，说明该用户已经下线，更新对应表项中用户的地址租期并将表项的端口更新为新端口。

    说明

    设备收到与绑定表冲突的NA报文后，触发用户在线状态探测功能时，用户在线状态的定时探测功能暂停。

ND Snooping动态绑定表的删除老化机制

ND Snooping动态绑定表的删除老化机制如下：

ND Snooping动态绑定表项的自动老化时间是由ND用户的地址租期决定的。

- 如果用户地址租期时间已到期，则ND Snooping动态绑定表项会自动老化。
- 在用户的地址租期未到期的情况下，存在以下两种删除ND Snooping动态绑定表项的情形：
  - 当设备收到用户的NS报文新建或更新ND Snooping动态绑定表项后，如果又收到了其他用户回应的通知该用户地址已被使用的NA报文，则设备会删除该ND Snooping动态绑定表项。
  - 当用户实际已经下线，该用户对应的ND Snooping动态绑定表项不会被及时删除。如果设备上使能了自动探测ND Snooping动态绑定表项对应用户的在

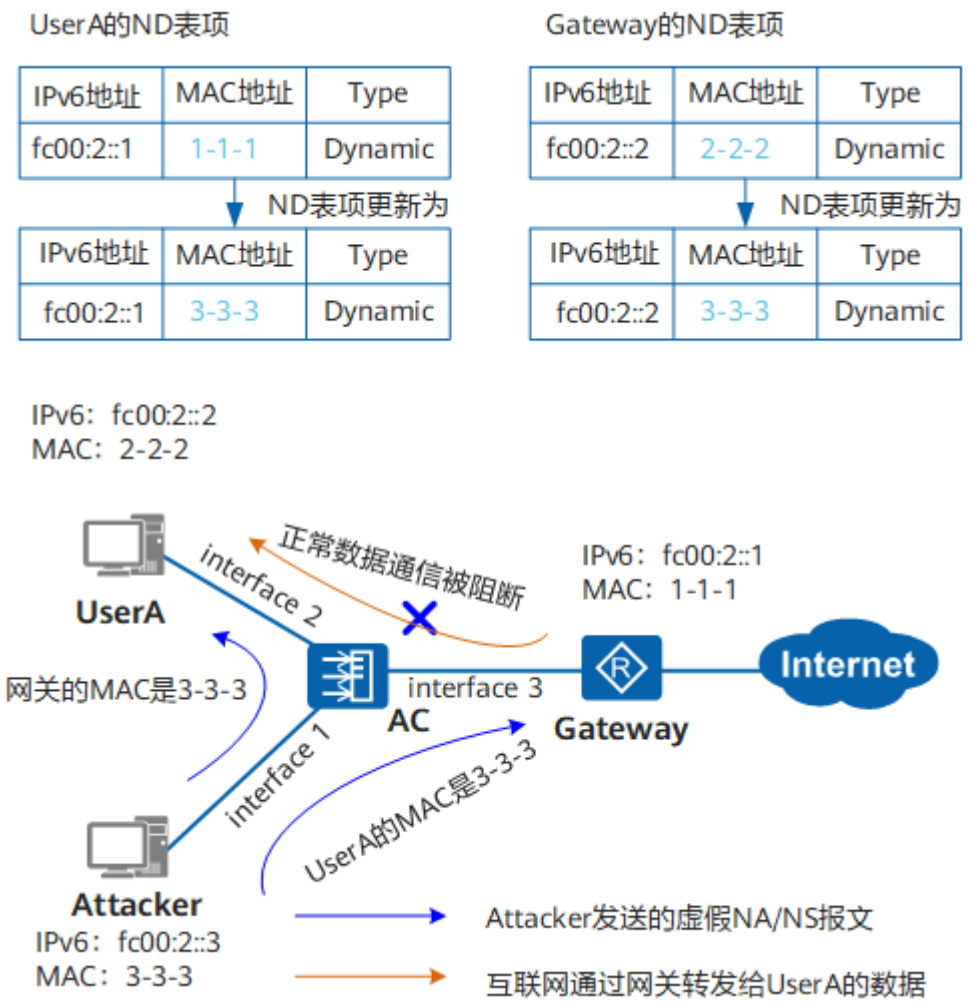
线状态功能，则设备会根据配置的探测次数和探测时间间隔向对应用户发送NS探测报文。在发出探测次数的NS探测报文后，用户仍然没有回应NA报文，设备则认为该用户不在线，删除该用户对应的ND Snooping动态绑定表项。

27.7.3 ND Snooping 应用场景

27.7.3.1 防地址欺骗攻击

如图27-28所示，Attacker仿冒UserA向网关发送伪造的NA/NS/RS报文，导致网关的ND表项中记录了错误的UserA地址映射关系，Attacker可以轻易获取到网关原来要发往UserA的数据；同时Attacker又仿冒网关向UserA发送伪造的NA/NS/RS报文，导致UserA的ND表中记录了错误的网关地址映射关系，Attacker可以轻易获取到UserA原来要发往网关的数据。这样不仅会造成UserA无法接收到正常的数据报文，还会使UserA的信息安全无法得到保障。

图 27-28 防地址欺骗攻击



版权所有 © 华为技术有限公司

为了防止上述地址欺骗攻击，建议在接入设备AC的**interface 1**和**interface 3**上部署ND Snooping功能，将AC与网关相连的接口**interface 3**配置为信任接口，并在用户侧接口**interface 1**上使能ND协议报文合法性检查功能。对于从**interface 1**接收到的NA/NS/RS报文，AC会根据生成的ND Snooping动态绑定表进行绑定表匹配检查，对于非法报文将直接丢弃，从而可以避免伪造的NA/NS/RS报文带来的危害。

27.7.3.2 防 RA 攻击

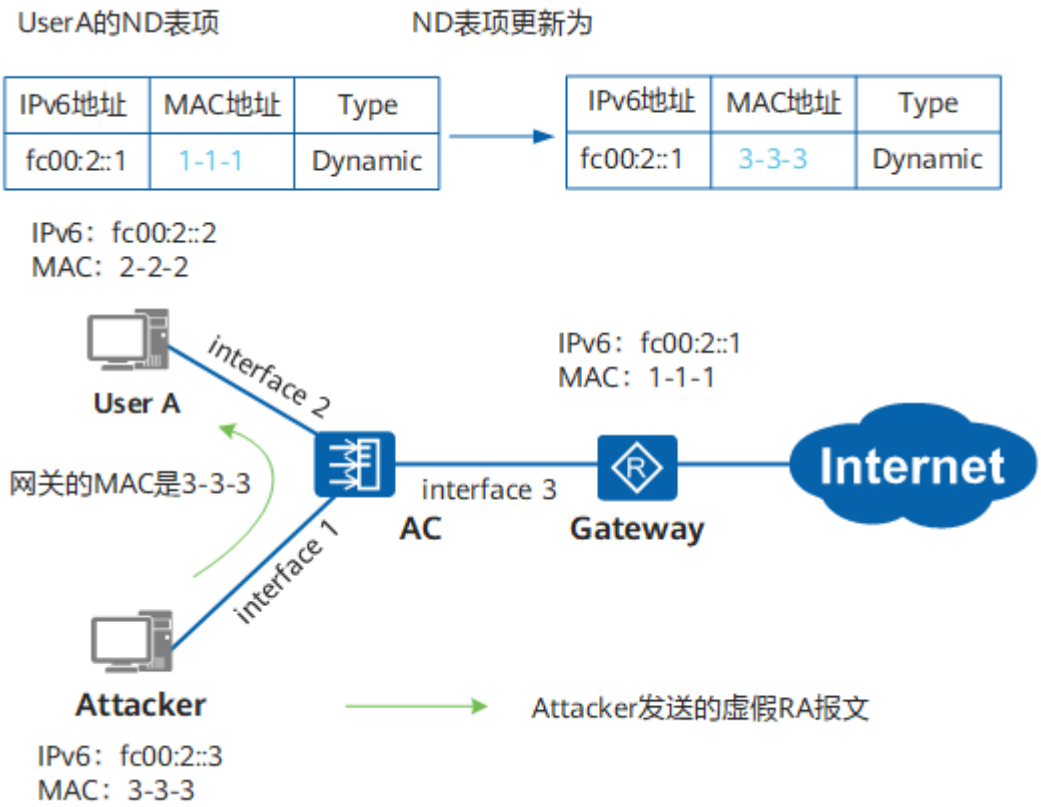
RA报文能够携带很多网络配置信息，包括默认路由器、网络前缀列表以及是否使用DHCPv6服务器进行有状态地址分配等网络配置的关键信息。如**图27-29**所示，攻击者通过发送伪造的RA报文，修改用户主机的网络配置，使合法用户无法进行正常通信。常见的RA报文攻击包括：

- 伪造不存在的前缀，修改合法用户主机的路由表。
- 伪造网关MAC地址，造成合法用户主机记录错误的网关地址映射关系；或者伪造RA报文中的Router Lifetime字段，造成合法用户主机的默认网关变为其他网关设备。
- 伪造DHCPv6服务器，同时伪造RA报文中的M标识位，造成合法用户主机使用DHCPv6服务器分配到的虚假地址。

Router Lifetime表示发送该RA报文的路由器使用该字段的值作为缺省路由器的生命周期。如果该字段为0，表示该路由器不能作为缺省路由器，但RA报文的其他信息仍然有效。

M表示管理地址配置标识（Managed address configuration），取值包括0和1。0表示无状态地址分配，客户端通过无状态协议（如ND）获得IPv6地址；1表示有状态地址分配，客户端通过有状态协议（如DHCPv6）获得IPv6地址。

图 27-29 防 RA 攻击



为了防止上述RA攻击，建议在接入设备AC的**interface 1**和**interface 3**上部署ND Snooping功能，并将AC与网关相连的接口**interface 3**配置为信任接口。这样AC就会直接丢弃用户侧接口**interface 1**（默认为非信任接口）收到的RA报文，仅处理信任接口收到的RA报文，从而可以避免伪造的RA报文带来的各种危害。

27.7.4 ND Snooping 缺省配置

ND Snooping的缺省配置如表27-13所示。

表 27-13 ND Snooping 缺省配置

参数	缺省值
ND Snooping功能	未使能。
ND Snooping信任接口	所有接口为非信任接口。
ND协议报文合法性检查功能	未使能。
自动探测ND Snooping动态绑定表项对应用户在线状态功能	未使能。
发送NS探测报文的探测次数和探测时间间隔	探测次数为2次，探测时间间隔为1000毫秒。

参数	缺省值
接口允许学习ND Snooping动态绑定表项的最大个数	在规格范围内，设备对接口能够学习到的最大ND Snooping动态绑定表项数目没有限制。
ND Snooping动态绑定表的告警阈值百分比	下限告警阈值百分比为50，上限告警阈值百分比为100。

27.7.5 配置 ND Snooping

前置任务

在配置ND Snooping之前，需完成以下任务：

- 连接接口并配置接口的物理参数，使接口的物理层状态为Up。

27.7.5.1 使能 ND Snooping 功能

背景信息

配置ND Snooping功能前必须先使能ND Snooping功能。

使能ND Snooping功能时，必须先全局使能ND Snooping功能，再在接口、VLAN下使能ND Snooping功能。

在接口视图下使能时，则对特定接口生效；在VLAN视图下使能时，则对加入该VLAN的所有接口生效。

如果配置了接口为**ND Snooping信任接口**，则该接口会自动使能ND Snooping功能，无需再在该接口、VLAN下使能ND Snooping功能。

操作步骤

- 在接口视图下使能
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**nd snooping enable**，全局使能ND Snooping功能。

     缺省情况下，全局未使能ND Snooping功能。
  c. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  d. 执行命令**nd snooping enable**，使能接口下的ND Snooping功能。

     缺省情况下，接口下未使能ND Snooping功能。
- 在接口视图下使能(DHCPv6 Only场景)
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**nd snooping enable**，全局使能ND Snooping功能。

     缺省情况下，全局未使能ND Snooping功能。
  c. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  d. 执行命令**nd snooping enable dhcpv6 only**，使能接口下的ND Snooping功能。

缺省情况下，接口下未使能ND Snooping功能。

- 在VLAN视图下使能
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**nd snooping enable**，全局使能ND Snooping功能。

     缺省情况下，全局未使能ND Snooping功能。
  c. 执行命令**vlan** *vlan-id*，进入VLAN视图。
  d. 执行命令**nd snooping enable**，使能VLAN下的ND Snooping功能。

     缺省情况下，VLAN下未使能ND Snooping功能。
- 在VLAN视图下使能(DHCPv6 Only场景)
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**nd snooping enable**，全局使能ND Snooping功能。

     缺省情况下，全局未使能ND Snooping功能。
  c. 执行命令**vlan** *vlan-id*，进入VLAN视图。
  d. 执行命令**nd snooping enable dhcpv6 only**，使能VLAN下的ND Snooping功能。

     缺省情况下，VLAN下未使能ND Snooping功能。

----结束

27.7.5.2 配置 ND Snooping 信任接口

背景信息

为了区分可信任和不可信任的IPv6节点，ND Snooping将设备连接IPv6节点的接口区分为信任接口和非信任接口两种角色。缺省情况下，设备的所有接口均为非信任接口。

- 对于可信任的IPv6节点，必须将连接此节点的接口配置为信任接口，使设备能够正常转发从该接口接收到的ND报文，同时能使设备根据接收到的RA报文建立前缀管理表，以方便管理员管理用户的IPv6地址。
- 对于不可信任的IPv6节点，连接此节点的接口必须为非信任接口。设备会直接丢弃从该接口接收到的RA报文，以防止攻击者发送伪造的RA报文进行RA攻击。

可在接口、VLAN视图下配置ND Snooping信任接口。在接口视图下配置时，对该接口收到的所有ND报文均生效；在VLAN视图下配置时，指定的接口必须属于此VLAN，此时仅对该接口收到的属于此VLAN的ND报文生效，故VLAN视图下的配置精度相对更高。

说明

一般将设备连接网关的接口配置成信任接口，其他接口均为非信任接口。

操作步骤

- 在接口视图下配置
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。

c. 执行命令**nd snooping trusted**，配置接口为ND Snooping信任接口。

缺省情况下，所有接口为非信任接口。

- 在接口视图下配置(DHCPv6 Only场景)
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  c. 执行命令**nd snooping trusted dhcpv6 only**，配置接口为ND Snooping信任接口。

  缺省情况下，所有接口为非信任接口。
- 在VLAN视图下配置
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**vlan** *vlan-id*，进入VLAN视图。
  c. 执行命令**nd snooping trusted interface** *interface-type interface-number*，配置加入该VLAN的接口为ND Snooping信任接口。

  缺省情况下，所有接口为非信任接口。
- 在VLAN视图下配置(DHCPv6 Only场景)
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**vlan** *vlan-id*，进入VLAN视图。
  c. 执行命令**nd snooping trusted interface** *interface-type interface-number* **dhcpv6 only**，配置加入该VLAN的接口为ND Snooping信任接口。

  缺省情况下，所有接口为非信任接口。

----结束

27.7.5.3 配置 ND 协议报文合法性检查

背景信息

为了防止攻击者发送伪造的NA/NS/RS报文进行地址欺骗攻击，可以开启ND协议报文合法性检查功能。

开启该功能后，设备将根据ND Snooping动态绑定表、DHCPv6动态绑定表或者IPv6静态绑定表，对从非信任接口接收到的NA/NS/RS报文进行绑定表匹配检查，检查该用户是否是报文收到端口所属VLAN上的合法用户。对于合法用户的NA/NS/RS报文进行正常转发，否则直接丢弃。

配置注意事项

配置ND协议报文合法性检查功能后，建议在系统视图下，通过命令**savi enable**，使能SAVI功能，使链路本地地址（前缀地址为FE80::/10的IPv6地址）能够自动生成ND Snooping绑定表。这是由于IPv6主机在邻居发现过程中，NA/NS/RS报文的源IPv6地址可能是链路本地地址，如果链路本地地址没有生成对应的ND Snooping绑定表，合法的NA/NS/RS报文会被丢弃，导致IPv6主机之间无法通信。

操作步骤

步骤1 开启ND协议报文合法性检查功能

可在接口、VLAN视图下配置ND协议报文合法性检查。在接口视图下配置时，则对该非信任接口收到的所有NA/NS/RS报文生效；在VLAN视图下配置时，则对加入该VLAN的所有非信任接口收到的属于此VLAN的NA/NS/RS报文生效。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**interface** *interface-type interface-number*，进入接口视图。

   或者，执行命令**vlan** *vlan-id*，进入VLAN视图。
3. 执行命令**nd snooping check** { **na** | **ns** | **rs** } **enable**，开启ND协议报文合法性检查功能。

   缺省情况下，未开启ND协议报文合法性检查功能。

----结束

27.7.5.4 （可选）配置自动探测 ND Snooping 动态绑定表项对应用户的在线状态

背景信息

设备在使能ND Snooping功能后会侦听用户用于重复地址检测的NS报文来建立ND Snooping动态绑定表。该表项的自动老化时间是由用户的IPv6地址租期决定的。如果用户的租期未到期，但是实际该用户已经下线，此时该用户对应的ND Snooping动态绑定表项不能被及时删除，会占用设备的绑定表资源。

为了解决该问题，可以在设备上使能自动探测ND Snooping动态绑定表项对应用户的在线状态功能。使能该功能后，设备会根据**nd user-bind detect**命令配置的探测次数（n）和探测时间间隔向对应的用户发送NS探测报文。在发出n次NS探测报文后，如果该用户仍然没有回应NA报文，设备则认为该用户不在线，删除该用户对应的ND Snooping动态绑定表项。

如果网络小且质量好，用户可以很快回应NA报文，此时可以将发送探测报文的时间间隔适当调小；如果网络大且质量不好，用户的回应NA报文较慢，为了避免在还没收到回应的NA报文时就开始发送下一个NS探测报文，可以将时间间隔适当调大。请根据实际网络环境进行调整。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**nd user-bind detect enable**，使能自动探测ND Snooping动态绑定表项对应用户的在线状态功能。

缺省情况下，未使能自动探测ND Snooping动态绑定表项对应用户的在线状态功能。

步骤3 （可选）执行命令**nd user-bind detect retransmit** *retransmit-times* **interval** *retransmit-interval*，配置发送NS探测报文的探测次数和探测时间间隔。

缺省情况下，探测次数为2次，探测时间间隔为1000毫秒。

----结束

27.7.5.5 （可选）配置用户在线状态探测功能

背景信息

设备在使能ND Snooping功能后通过检查NS报文来建立ND Snooping动态绑定表；通过检查NS/NA报文来更新ND Snooping动态绑定表。该表表项的自动老化时间是由用

户的IPv6地址租期决定的。如果用户的租期未到期，但是实际该用户已经下线，此时该用户对应的ND Snooping动态绑定表项不能被及时删除，一方面会占用设备的绑定表资源，另一方面会造成新的表项信息无法更新。

为了解决该问题，可以配置用户在线状态探测功能。探测方式分为两种：定时探测和由与现有表项IP地址相同、端口号不同的NA报文触发探测。

- 定时探测：

  设备根据**nd user-bind detect**命令配置的探测次数（n）和探测时间间隔向对应的用户发送NS探测报文。在发出n次NS探测报文后，如果该用户仍然没有回应NA报文，设备则认为该用户不在线，删除该用户对应的ND Snooping动态绑定表项。

  如果网络小且质量好，用户可以很快回应NA报文，此时可以将发送探测报文的时间间隔适当调小；如果网络大且质量不好，用户的回应NA报文较慢，为了避免在还没收到回应的NA报文时就开始发送下一个NS探测报文，可以将时间间隔适当调大。请根据实际网络环境进行调整。

- 由冲突的NA报文触发探测：

  设备收到与现有表项的IP地址相同、入端口不同的NA报文时，说明该NA报文与现有表项冲突，此时会触发设备发送NS报文来探测对应表项的用户在否在线。

  - 如果在表项生存时间内，设备从表项对应的端口上收到NA报文，说明该用户仍然在线，更新对应表项中用户的地址租期。
  - 如果在表项生存时间内，设备没有从表项对应的端口上收到NA报文，说明该用户已经下线，更新对应表项中用户的地址租期并将表项的端口更新为新端口。

说明

设备收到与绑定表冲突的NA报文后，触发用户在线状态探测功能时，用户在线状态的定时探测功能暂停。

操作步骤

- 定时探测：
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**nd user-bind detect enable**，使能定时探测ND Snooping动态绑定表项对应用户的在线状态功能。

     缺省情况下，未使能定时探测ND Snooping动态绑定表项对应用户的在线状态功能。
  c. 执行命令**nd user-bind detect retransmit** *retransmit-times* **interval** *retransmit-interval*，配置发送NS探测报文的探测次数和探测时间间隔。

     缺省情况下，探测次数为2次，探测时间间隔为1000毫秒。
- 冲突的NA报文触发探测：
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**nd snooping wait-time** *wait-time* **life-time** *life-time*，配置设备发送NS探测报文的等待时间和探测期间ND Snooping绑定表表项的生存时间。

     缺省情况下，设备发送NS探测报文的等待时间为250毫秒、探测期间ND Snooping绑定表表项的生存时间为500毫秒。

----结束

27.7.5.6 （可选）配置接口允许学习 ND Snooping 动态绑定表项的最大个数

背景信息

为了防止当一个接口下有大量用户上线，设备处理这些用户发送的大量NS报文会导致整个设备的ND Snooping动态绑定表资源都被耗尽，可以配置接口允许学习ND Snooping动态绑定表项的最大个数。如果指定接口下学习到的绑定表项数目达到了允许学习的最大个数，则不再新增与该接口相关的绑定表项。

可在系统视图或接口视图下配置接口允许学习ND Snooping动态绑定表项的最大个数，系统视图下的配置对所有接口都生效，接口视图下的配置仅对特定接口生效。如果同时在两个视图下进行了配置，则该接口允许学习的绑定表项最大个数以两个视图下配置的较小值为准。

操作步骤

- 在系统视图下配置
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**nd snooping max-user-number** *max-user-number*，配置接口允许学习ND Snooping动态绑定表项的最大个数。

     缺省情况下，在规格范围内，设备对接口能够学习到的最大ND Snooping动态绑定表项数目没有限制。
- 在接口视图下配置
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  c. 执行命令**nd snooping max-user-number** *max-user-number*，配置接口允许学习ND Snooping动态绑定表项的最大个数。

     缺省情况下，在规格范围内，设备对接口能够学习到的最大ND Snooping动态绑定表项数目没有限制。

----结束

27.7.5.7 （可选）配置 ND Snooping 动态绑定表的告警阈值百分比

背景信息

配置接口允许学习ND Snooping动态绑定表项的最大个数后，可以配置ND Snooping动态绑定表的告警阈值百分比。

当设备实际学习到的ND Snooping动态绑定表项数占设备允许学习的最大表项数的比例等于或高于上限告警阈值百分比时，设备将会发出超限告警。之后，如果该比例又等于或小于下限告警阈值百分比，设备会再次发出告警，表明之前的超限告警情况已经恢复正常。管理员通过这些告警信息，可实时掌握ND Snooping动态绑定表资源的使用状况。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**nd snooping user-alarm percentage** *percent-lower-value percent-upper-value*，配置ND Snooping动态绑定表的告警阈值百分比。

缺省情况下，下限告警阈值百分比为50，上限告警阈值百分比为100。

----结束

27.7.5.8 （可选）配置静态前缀管理表项

背景信息

设备根据收到的NS报文新建ND Snooping动态绑定表项之前，首先要求报文中的Target Address字段能够匹配用户的前缀管理表项。设备会截获从ND Snooping信任接口收到的RA报文，并根据RA报文自动生成前缀管理表项。但是，在网关设备不发送RA报文的情况下，前缀管理表项无法自动生成，进而无法新建对应的ND Snooping动态绑定表项，对业务造成影响。此时，可以通过以下步骤，手动配置前缀管理表项。

通过命令**display nd snooping prefix**可以查看设备上所有的前缀管理表项，包括静态配置的和动态生成的。静态配置的和动态生成的共享规格，超规格则无法配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**nd snooping static-prefix** *ipv6-address/prefix-length* [**vlan** *vlan-id* [**ce-vlan** *ce-vlan-id*]]，配置静态前缀管理表项。

缺省情况下，设备上没有配置静态前缀管理表项。

----结束

27.7.5.9 （可选）配置 DAD NS 报文重传速率检查功能

背景信息

设备非信任接口收到DAD NS报文时，会进行转发，用于重复地址检查和用户仿冒检查。在ND Snooping绑定表未建立的情况下，为避免因丢包等原因造成对端设备接收不到设备转发的报文，设备的非信任接口收到DAD NS报文时会进行重传。默认情况下，设备不对重传速率进行控制。在报文过多时，重传可能会影响网络业务正常运行。为解决该问题，可以配置DAD NS报文重传速率检查功能。配置该功能后，设备对重传报文进行限速，每秒钟重传的报文超过设置值时，超出部分直接丢弃，不会转发。

操作步骤

- 在系统视图下配置
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**nd snooping check dad-ns retransmit-rate enable**，使能DAD NS报文重传速率检查功能。

     缺省情况下，未使能DAD NS报文重传速率检查功能。
  c. 执行命令**nd snooping check dad-ns retransmit-rate rate** *rate-value*，配置DAD NS报文重传速率的最大值。

     缺省情况下，DAD NS报文重传速率的最大值50包/秒。
- 在VLAN视图下配置

a. 执行命令**system-view**，进入系统视图。
b. 执行命令**vlan** *vlan-id*，进入VLAN视图。
c. 执行命令**nd snooping check dad-ns retransmit-rate enable**，使能DAD NS报文重传速率检查功能。

   缺省情况下，未使能DAD NS报文重传速率检查功能。
d. 执行命令**nd snooping check dad-ns retransmit-rate rate** *rate-value*，配置DAD NS报文重传速率的最大值。

   缺省情况下，DAD NS报文重传速率的最大值50包/秒。

- 在接口视图下配置
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  c. 执行命令**nd snooping check dad-ns retransmit-rate enable**，使能DAD NS报文重传速率检查功能。

     缺省情况下，未使能DAD NS报文重传速率检查功能。
  d. 执行命令**nd snooping check dad-ns retransmit-rate rate** *rate-value*，配置DAD NS报文重传速率的最大值。

     缺省情况下，DAD NS报文重传速率的最大值50包/秒。

----结束

27.7.5.10 检查 ND Snooping 的配置结果

操作步骤

- 执行命令**display nd snooping** [**static** | **dynamic**] **prefix** [**verbose**]，查看ND用户的前缀管理表项。
- 执行命令**display nd snooping user-bind all** [**verbose**]或**display nd snooping user-bind** { **ipv6-address** *ipv6-address* | **mac-address** *mac-address* | **interface** *interface-type interface-number* | **vlan** *vlan-id* } * [**verbose**]，查看ND Snooping动态绑定表项。
- 执行命令**display nd snooping statistics**，查看设备接收与丢弃的ND Snooping用户报文统计信息。
- 执行命令**display nd snooping configuration**，查看ND Snooping的配置信息。

----结束

27.7.6 维护 ND Snooping

27.7.6.1 清除前缀管理表

背景信息

网关路由器会定时发送RA报文，通知用户更新网络前缀信息。交换机作为用户的接入设备会根据RA报文建立前缀管理表项，用来维护和管理用户的前缀信息。

一般情况下，不建议手工清除用户的前缀管理表项。当同时具备以下两种情况时，才需要手动进行清除：

- 用户的租期未到期，该用户的前缀管理表项不能自动老化。
- 确定该用户不再需要连接网络。

在确认需要手动清除前缀管理表项后，请在用户视图下执行以下命令。

操作步骤

- 使用命令**reset nd snooping prefix** [*ipv6-address*|*prefix-length*]，清除用户的前缀管理表项。

----结束

27.7.6.2 清除 ND Snooping 动态绑定表

背景信息

当同时具备以下几种情况时需要手动清除ND Snooping动态绑定表项:

- 因未到老化周期，ND Snooping动态绑定表项暂不能自动老化。
- 确认用户不再连接网络。
- 用户的VLAN或接口信息发生变化。

须知

由于组网环境变化之后，用户的VLAN或接口信息可能已经发生变化，然而用户对应的ND Snooping动态绑定表项却没有立即老化更新，此时会造成设备误将不匹配ND Snooping动态绑定表的合法ND报文丢弃。所以，请在变更组网环境之前手动清除所有ND Snooping动态绑定表项，使得设备根据新的网络环境生成新的ND Snooping动态绑定表。

在确认需要手动清除ND Snooping动态绑定表项后，请在用户视图下执行以下命令。

操作步骤

- 使用命令**reset nd snooping user-bind** [**interface** *interface-type interface-number* | **ipv6-address** *ipv6-address* | **mac-address** *mac-address* | **vlan** *vlan-id*]，清除ND Snooping动态绑定表项。

----结束

27.7.6.3 清除 ND Snooping 报文统计信息

背景信息

须知

清除统计信息后，以前的统计信息将无法恢复，请慎重操作。

操作步骤

- 在用户视图下执行命令**reset nd snooping statistics**，清除ND Snooping用户报文统计信息。

----结束

27.7.7 ND Snooping 配置举例

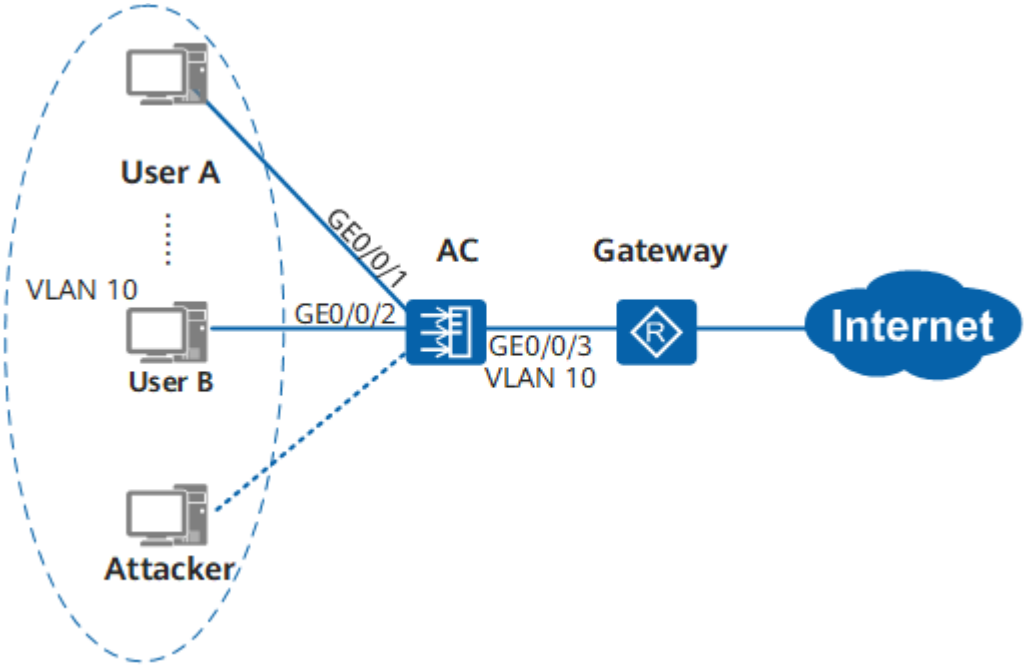
27.7.7.1 配置 ND Snooping 功能示例

组网需求

如图27-30所示，企业某部门使用AC作为用户主机连接网关的设备。网络中未部署DHCPv6服务器，该部门主机只能通过无状态地址自动配置方式获取IPv6地址。如果有攻击者发送非法的NA/NS/RS/RA报文，将会存在合法用户主机无法获取IPv6地址、通信过程中断、用户帐号口令被盗用等一系列安全隐患。

为了预防这种情况，管理员希望通过在AC上进行配置，对非法的NA/NS/RS/RA进行有效防范，为合法用户提供更安全的网络环境和更稳定的网络服务，并且希望能够掌握网关分配给用户的网络前缀信息，从而可以灵活管理接入用户的IPv6地址。

图 27-30 配置 ND Snooping 功能示例组网图



配置思路

采用如下的思路在AC上进行配置：

1. 使能ND Snooping功能，以便生成地址、VLAN和接口的绑定关系表，用于后续的ND报文合法性检查。

2. 将连接网关的接口配置为ND Snooping信任接口，以便AC可以根据从信任接口收到的RA报文生成前缀管理表，实现对接入用户地址的灵活管理。

   连接用户侧的接口缺省为ND Snooping非信任接口，AC会自动过滤非信任接口收到的RA报文。
3. 使能ND协议报文合法性检查功能，使AC根据绑定关系表对NA/NS/RS报文进行合法性检查，过滤非法NA/NS/RS报文。
4. 配置自动探测ND Snooping动态绑定表项对应用户的在线状态功能，保证ND用户下线时对应的ND Snooping动态绑定表项能够及时被删除，避免占用绑定表资源。
5. 配置接口允许学习ND Snooping动态绑定表项的最大个数，防止在配置ND Snooping功能后，由于某一接口下有大量用户上线，AC处理大量的NS报文会导致绑定表资源被耗尽，造成其他用户无法正常通信。

操作步骤

步骤1 创建VLAN并配置各接口

在AC上创建VLAN10。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] vlan batch 10
```

将接口GE0/0/1、GE0/0/2、GE0/0/3加入到VLAN10中。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] port link-type access
[AC-GigabitEthernet0/0/1] port default vlan 10
[AC-GigabitEthernet0/0/1] quit
[AC] interface gigabitethernet 0/0/2
[AC-GigabitEthernet0/0/2] port link-type access
[AC-GigabitEthernet0/0/2] port default vlan 10
[AC-GigabitEthernet0/0/2] quit
[AC] interface gigabitethernet 0/0/3
[AC-GigabitEthernet0/0/3] port link-type trunk
[AC-GigabitEthernet0/0/3] port trunk allow-pass vlan 10
[AC-GigabitEthernet0/0/3] quit
```

步骤2 使能ND Snooping功能

全局使能ND Snooping功能。

```
[AC] nd snooping enable
```

在VLAN10内使能ND Snooping功能。

```
[AC] vlan 10
[AC-vlan10] nd snooping enable
[AC-vlan10] quit
```

步骤3 配置接口GE0/0/3为ND Snooping信任接口

```
[AC] interface gigabitethernet 0/0/3
[AC-GigabitEthernet0/0/3] nd snooping trusted
[AC-GigabitEthernet0/0/3] quit
```

步骤4 使能ND协议报文合法性检查功能

```
[AC] vlan 10
[AC-vlan10] nd snooping check ns enable
[AC-vlan10] nd snooping check na enable
[AC-vlan10] nd snooping check rs enable
[AC-vlan10] quit
```

步骤5 配置自动探测ND Snooping动态绑定表项对应用户的在线状态功能

使能自动探测ND Snooping动态绑定表项对应用户的在线状态功能，并配置发送NS探测报文的探测次数和探测时间间隔。

```
[AC] nd user-bind detect enable
[AC] nd user-bind detect retransmit 5 interval 600
```

步骤6 配置接口允许学习ND Snooping动态绑定表项的最大个数

```
[AC] nd snooping max-user-number 20
```

步骤7 验证配置结果

在系统视图下执行命令**display this**可以看到全局下已经使能了ND Snooping功能和自动探测ND Snooping动态绑定表项对应用户的在线状态功能，并配置了接口允许学习ND Snooping动态绑定表项的最大个数。

```
[AC] display this
......
 nd snooping enable
 nd user-bind detect enable
 nd user-bind detect retransmit 5 interval 600
 nd snooping max-user-number 20
......
```

在VLAN视图下执行命令**display this**可以看到VLAN10下已经使能了ND Snooping功能和ND协议报文合法性检查功能。

```
[AC] vlan 10
[AC-vlan10] display this
#
vlan 10
 nd snooping enable
 nd snooping check ns enable
 nd snooping check na enable
 nd snooping check rs enable
#
return
[AC-vlan10] quit
```

在接口视图下执行命令**display this**可以看到接口GE0/0/3已经配置为信任接口。

```
[AC] interface gigabitethernet 0/0/3
[AC-GigabitEthernet0/0/3] display this
#
interface GigabitEthernet0/0/3
 port link-type trunk
 port trunk allow-pass vlan 10
 nd snooping trusted
#
return
[AC-GigabitEthernet0/0/3] quit
[AC] quit
```

执行命令**display nd snooping prefix**可以查看ND用户的前缀管理表。

```
<AC> display nd snooping prefix
prefix-table:
Prefix                          Length   Valid-Time  Preferred-Time
-------------------------------------------------------------------------------
FC00:1::                         64       100000      100000
-------------------------------------------------------------------------------
Prefix table total count:      1
```

执行命令**display nd snooping user-bind all**可以查看ND Snooping动态绑定表。

```
<AC> display nd snooping user-bind all
ND Dynamic Bind-table:
```

```
Flags:O - outer vlan ,I - inner vlan ,P - Vlan-mapping                    IP Address                MAC
Address     VSI/VLAN(O/I/P) Lease
--------------------------------------------------------------------------------
FC00:1::E58C:A2E7:AA4C:8E59     000e0-fc12-3456 10  /--  /--    2011.05.06-20:09
--------------------------------------------------------------------------------
print count:          1          total count:          1
```

如果AC上生成了前缀管理表和ND Snooping动态绑定表，则说明ND Snooping功能已配置成功。

----结束

配置文件

AC的配置文件

```
#
sysname AC
#
vlan batch 10
#
nd snooping enable
nd user-bind detect enable
nd user-bind detect retransmit 5 interval 600
nd snooping max-user-number 20
#
vlan 10
 nd snooping enable
 nd snooping check ns enable
 nd snooping check na enable
 nd snooping check rs enable
#
interface GigabitEthernet0/0/1
 port link-type access
 port default vlan 10
#
interface GigabitEthernet0/0/2
 port link-type access
 port default vlan 10
#
interface GigabitEthernet0/0/3
 port link-type trunk
 port trunk allow-pass vlan 10
 nd snooping trusted
#
return
```

27.8 IPSG 配置

通过配置IPSG功能，可以对接口转发的报文进行过滤控制，防止非法报文通过接口。

27.8.1 IPSG 简介

介绍IPSG的定义、由来和作用。

定义

IPSG是IP Source Guard的简称。IPSG可以防范针对源IP地址进行欺骗的攻击行为。

随着网络规模越来越大，基于源IP的攻击也逐渐增多。一些攻击者利用欺骗的手段获取到网络资源，取得合法使用网络资源的权限，甚至造成被欺骗者无法访问网络，或

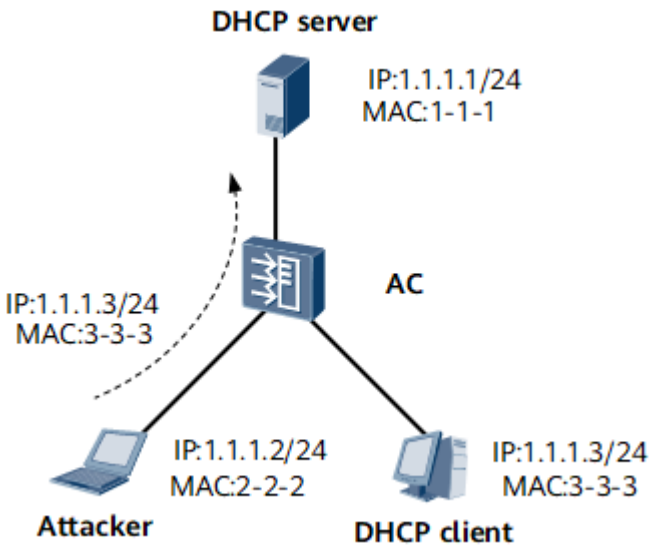
者信息泄露。IPSG针对基于源IP的攻击提供了一种防御机制，可以有效的防止基于源地址欺骗的网络攻击行为。

目的

IPSG功能是基于绑定表（DHCP动态和静态绑定表）对IP报文进行匹配检查。当设备在转发IP报文时，将此IP报文中的源IP、源MAC、接口、VLAN信息和绑定表的信息进行比较，如果信息匹配，表明是合法用户，则允许此报文正常转发，否则认为是攻击报文，并丢弃该IP报文。

如图27-31所示，攻击者伪造合法用户报文，篡改了AC上MAC表的出接口信息，使服务器回复的报文被发送给攻击者。

图 27-31 IP/MAC 欺骗攻击示意图



为了防止此类攻击，可以在AC上配置IPSG功能，对进入接口的IP报文进行绑定表匹配检查，合法用户发送报文的信息和绑定表一致，允许其通过；攻击者伪造的报文信息和绑定表不一致，AC将报文丢弃。

27.8.2 配置注意事项

介绍IPSG的相关配置注意事项。

IPSG功能是基于绑定表对IP报文进行检查，检查内容包括：源IP地址、源MAC地址、VLAN和接口。设备支持的IPSG可以对这几项的任意组合进行检查。

在接口视图下：

- 接口+IP
- 接口+MAC
- 接口+IP+MAC
- 接口+IP+VLAN
- 接口+MAC+VLAN

- 接口+IP+MAC+VLAN

说明

IP地址包括IPv4地址和IPv6地址，即使能IPSG功能后，设备将对用户IP报文的源IPv4地址和源IPv6地址都进行检查。

IPSG功能只对IP类型的报文有效。对其他类型的报文无法生效。

在VLAN视图下：

- VLAN+IP
- VLAN+MAC
- VLAN+IP+MAC
- VLAN+IP+接口
- VLAN+MAC+接口
- VLAN+IP+MAC+接口

27.8.3 缺省配置

介绍IPSG缺省配置，实际应用的配置可以基于缺省配置进行修改。

IPSG的缺省配置如表27-14所示。

表 27-14 IPSG 缺省配置

参数	缺省值
VLAN视图下的IP报文检查功能	未使能
接口视图下的IP报文检查功能	未使能
VLAN视图下IP报文检查选项	源IP地址、源MAC地址和接口
接口视图下的IP报文检查选项	源IP地址、源MAC地址和VLAN

27.8.4 配置 IPSG

配置IPSG功能，对接收到的IP报文进行绑定表匹配检查，可以有效的防止基于源地址欺骗的网络攻击行为。

前置任务

在配置IPSG之前，需完成以下任务：

- 配置接口IP地址，保证链路状态UP，通信正常。

配置流程

在配置IPSG任务中，必须先配置绑定表，接着配置IP报文检查功能。其余步骤无严格配置顺序，用户根据需要选择配置即可。

27.8.4.1 配置绑定表

背景信息

绑定表是IPSG进行IP报文检查的基础，绑定表包括动态绑定表和静态绑定表。

通过配置DHCP Snooping或ND Snooping功能生成动态绑定表，通常适用于局域网络中主机较多的情况。当主机采用DHCP方式获取IPv4或IPv6地址时，需要配置DHCP Snooping功能生成IPv4或IPv6动态绑定表项；当主机采用自动地址分配方式获取IPv6地址时，需要配置ND Snooping功能生成IPv6动态绑定表项。

- IPv4动态绑定表项：根据DHCP Snooping表项动态生成绑定表项来过滤接口收到的IPv4报文。
- IPv6动态绑定表项：根据DHCPv6 Snooping表项或ND Snooping表项动态生成绑定表项来过滤接口收到的IPv6报文。

通过手工配置产生绑定表项，适用于局域网络中主机数较少且主机使用静态配置IP地址的情况，比如在接入某重要服务器的接口上配置绑定表项，仅允许该接口接收或者发送与该服务器通信的报文。

- IPv4静态表项：使用手工配置的IPv4静态绑定表项来过滤接口收到的IPv4报文。
- IPv6静态表项：使用手工配置的IPv6静态绑定表项来过滤接口收到的IPv6报文。

操作步骤

- 对于DHCP动态分配IP地址的用户：
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**dhcp enable**，全局使能DHCP功能。
     缺省情况下，没有全局使能DHCP功能。
  c. 执行命令**dhcp snooping enable**，全局使能DHCP Snooping功能。
     缺省情况下，没有全局使能DHCP Snooping功能。
  d. 进入VLAN或者接口视图。
     - 执行命令**vlan** *vlan-id*，进入VLAN视图。
     - 执行命令**interface** *interface-type interface-number*，进入接口视图。
  e. 执行命令**dhcp snooping enable**，使能VLAN或者接口的DHCP Snooping功能。
     缺省情况下，VLAN和接口下没有使能DHCP Snooping功能。
  f. 配置信任接口。
     - 当配置基于VLAN内的信任接口时，执行命令**dhcp snooping trusted interface** *interface-type interface-number*，配置加入该VLAN的接口为信任状态。
     - 当配置基于接口的信任状态时，执行命令**dhcp snooping trusted**，配置接口为信任状态。

     缺省情况下，使能DHCP Snooping功能后，接口为非信任状态。

     说明

     一般将与服务器直接或间接相连的接口配置为信任接口。在使能DHCP Snooping功能并配置信任接口之后，用户侧接口根据DHCP Reply报文自动生成动态绑定表。
- 对于自动地址分配方式获取IPv6地址的用户：

a. 执行命令**system-view**，进入系统视图。
b. 执行命令**nd snooping enable**，全局使能ND Snooping功能。
缺省情况下，全局未使能ND Snooping功能。
c. 进入VLAN或者接口视图。
i. 执行命令**vlan** *vlan-id*，进入VLAN视图。
ii. 执行命令**interface** *interface-type interface-number*，进入接口视图。
d. 执行命令**nd snooping enable**，使能VLAN或者接口的ND Snooping功能。
缺省情况下，VLAN和接口下未使能ND Snooping功能。
e. 配置信任接口。
i. 当配置基于VLAN内的信任接口时，执行命令**nd snooping trusted interface** *interface-type interface-number*，配置加入该VLAN的接口为ND Snooping信任接口。
ii. 当配置基于接口的信任状态时，执行命令**nd snooping trusted**，配置接口为ND Snooping信任接口。
缺省情况下，使能ND Snooping功能后，所有接口为非信任状态。

说明

一般将设备连接网关的接口配置成信任接口，其他接口均为非信任接口。在使能ND Snooping功能并配置信任接口之后，设备将通过侦听用户DAD的NS报文来建立ND Snooping表项。

- 对于静态IP用户：
a. 执行命令**system-view**，进入系统视图。
b. 执行命令**user-bind static** { { **ip-address** | **ipv6-address** } *start-ip* [**to** *end-ip*] &<1-10> | **mac-address** *mac-address* } * [**interface** *interface-type interface-number*] [**vlan** *vlan-id* [**ce-vlan** *ce-vlan-id*]]，配置静态用户绑定表项。
缺省情况下，不存在静态绑定表。

说明

- 配置有线用户的静态绑定表，需要指定**interface** *interface-type interface-number*。
- 配置无线用户的静态绑定表，需要指定无线用户的**mac-address** *mac-address*，不需要绑定**interface**，表项会在AP上生效。

27.8.4.2 配置 IP 报文检查功能

背景信息

IPSG可以基于VLAN对IP报文进行检查，也可以基于接口对IP报文进行检查。

操作步骤

- 基于VLAN的IPSG：
a. 执行命令**system-view**，进入系统视图。
b. 执行命令**vlan** *vlan-id*，进入VLAN视图。
c. 执行命令**ip source check user-bind enable**，使能IP报文检查功能。

缺省情况下，VLAN内没有使能IP报文检查功能。

d. 执行命令**ip source check user-bind check-item** { **ip-address** | **mac-address** | **interface** }*，配置IP报文检查项。

缺省情况下，VLAN视图下的IP报文检查选项包括源IP地址、源MAC地址和接口。

说明

本命令只对动态绑定表生效，对静态绑定表不生效。对于静态绑定表，IPSG按照静态绑定表配置的表项进行完全匹配。

- 基于接口的IPSG：
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  c. 执行命令**ip source check user-bind enable**，使能IP报文检查功能。

     缺省情况下，接口下没有使能IP报文检查功能。
  d. 执行命令**ip source check user-bind check-item** { **ip-address** | **mac-address** | **vlan** }*，配置IP报文检查项。

     缺省情况下，接口视图下的IP报文检查选项包括源IP地址、源MAC地址和VLAN。

     说明

     本命令只对动态绑定表生效，对静态绑定表不生效。对于静态绑定表，IPSG按照静态绑定表配置的表项进行完全匹配。

27.8.4.3 检查配置结果

操作步骤

步骤1 执行命令**display dhcp static user-bind** { { **interface** *interface-type interface-number* | **ip-address** *ip-address* | **mac-address** *mac-address* | **vlan** *vlan-id* } * | **all** } [**verbose**]，查看静态绑定表信息。

步骤2 执行命令**display ip source check user-bind** { **vlan** *vlan-id* | **interface** *interface-type interface-number* }，查看VLAN和接口下的IPSG配置信息。

步骤3 执行命令**display dhcp snooping user-bind** { { **interface** *interface-type interface-number* | **ip-address** *ip-address* | **mac-address** *mac-address* | **vlan** *vlan-id* }* | **all** } [**verbose**]，查看DHCP Snooping动态绑定表的信息。

----结束

27.8.5 配置举例

通过示例介绍如何配置IPSG。配置示例中包括组网需求、配置思路等。

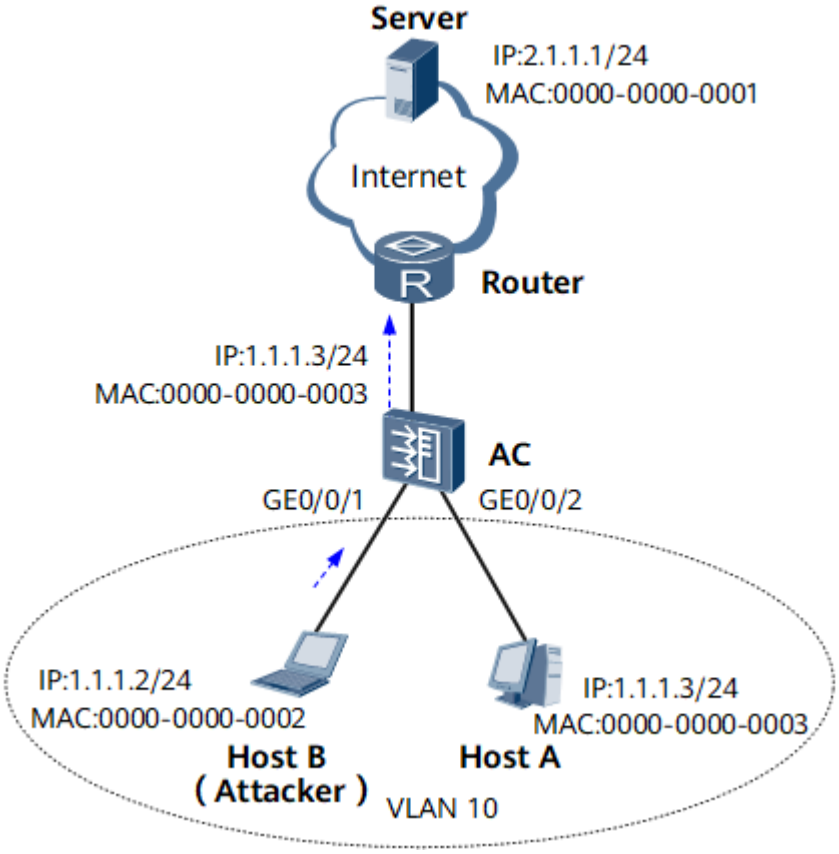
27.8.5.1 配置 IPSG 示例

组网需求

如图27-32所示，Host A和Host B是位于同一个部门的两台主机，该部门使用AC作为直接连接用户的设备。Host A和Host B通过DHCP动态分配到IP地址，并通过AC的不

同接口加入到相同的VLAN中。网络管理员发现Host B作为攻击者，经常仿冒Host A的IP地址和MAC地址与位于Internet的某个Server进行通信，导致Host A不能正常获取该Server的服务。网络管理员希望能够通过在AC进行配置，对Host B发送的攻击报文进行有效防范，使Host A可以正常获取Server的服务。

图 27-32 配置 IPSG 功能示意图



配置思路

该组网的配置思路如下：

- 确认AC已经使能DHCP Snooping功能后并生成动态绑定表。
- 在VLAN视图下配置基于绑定表的IP报文匹配检查功能，对用户的源IP地址、源MAC地址和接口进行绑定表匹配检查，这样设备将丢弃来自Host B的攻击报文。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。
  - 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。

– 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击?**

- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 全局使能DHCP Snooping功能。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] dhcp enable
[AC] dhcp snooping enable
```

步骤2 在VLAN10视图下配置IP报文匹配检查功能。

```
[AC] vlan 10
[AC-vlan10] dhcp snooping enable
[AC-vlan10] ip source check user-bind enable
[AC-vlan10] quit
```

----结束

配置文件

```
#
sysname AC
#
dhcp enable
dhcp snooping enable
#
vlan 10
 dhcp snooping enable
 ip source check user-bind enable
#
return
```

27.9 SAVI 配置

27.9.1 SAVI 概述

设备通过侦听（Snooping）各种地址分配方式的控制报文建立地址和端口的绑定关系表，对于从相应端口接收到的ND协议报文、DHCPv6协议报文和IPv6数据报文，根据其源地址是否能匹配绑定关系表来确定报文是否合法，合法报文则正常转发，非法报文则丢弃，从而防止非法报文形成攻击。

SAVI功能可以在下列地址分配场景下使用：

- DHCPv6-Only：和配置SAVI功能的设备连接的主机只能通过DHCPv6方式获取地址。
- SLAAC-Only（Stateless Address Autoconfiguration，无状态地址自动配置）：和配置SAVI功能的设备连接的主机只能通过自动地址分配方式获取地址。

- DHCPv6与SLAAC混合：和配置SAVI功能的设备连接的主机可以通过DHCPv6方式和自动地址分配方式获取地址。

27.9.2 SAVI 缺省配置

SAVI的缺省配置如表27-15所示。

表 27-15 SAVI 缺省配置

参数	缺省值
SAVI功能	未使能
侦听响应地址冲突的NA报文的时间	2秒
侦听DHCPv6客户端对获取地址作冲突检测的时间	2秒

27.9.3 配置 SAVI

前置任务

在配置SAVI功能之前，请使能ND Snooping和DHCPv6 snooping功能。

- 如果希望过滤非法IPv6数据报文，还需配置**IPSG**功能。
- 如果希望过滤非法ND协议报文，还需配置**ND协议报文合法性检查**功能。
- 如果希望过滤非法DHCPv6协议报文，还需**配置防止仿冒DHCP报文攻击**功能。

27.9.3.1 使能 SAVI 功能

背景信息

为了防止源地址非法的ND协议报文、DHCPv6协议报文和IPv6数据报文形成攻击，可以配置SAVI功能，设备将根据通过ND Snooping功能、DHCPv6 Snooping功能建立起的地址和端口的绑定关系表对ND协议报文、DHCPv6协议报文和IPv6数据报文的源地址进行合法性的过滤检查。

配置SAVI功能前必须先使能SAVI功能。

说明

使能SAVI功能后，前缀地址为FE80::/10的IPv6地址才能自动生成绑定表，但不会生成前缀表。

Fit AP上的SAVI功能默认开启，无需配置。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**savi enable**，使能SAVI功能。

缺省情况下，未使能SAVI功能。

----结束

27.9.3.2 （可选）配置接口允许学习 SAVI 绑定表项的最大个数

背景信息

SAVI绑定表是ND Snooping绑定表和DHCPv6 Snooping绑定表的集合，当接口下ND Snooping绑定表项和DHCPV6 Snooping绑定表项之和达到所配置的SAVI绑定表项最大数时，后续用户将无法接入。此功能可以有效避免设备处理用户发送的大量源地址非法的ND协议报文和DHCPv6协议报文，防止对设备造成攻击。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface** *interface-type interface-number*，进入接口视图。

步骤3 执行命令**savi max-binding-table** *max-number*，配置接口允许学习SAVI绑定表项的最大个数。

缺省情况下，在规格范围内，设备对接口能够学习到的最大SAVI绑定表项数目没有限制。

----结束

27.9.3.3 （可选）配置侦听响应地址冲突的 NA 报文的时间

背景信息

配置侦听响应地址冲突的NA报文的时间仅适用于SLAAC-Only场景或DHCPv6与SLAAC混合场景。

- SLAAC-Only场景下：

  客户端以无状态地址自动配置方式获取地址，客户端通过RA报文获取地址前缀并自动生成IPv6地址。生成地址后，客户端会发送DAD NS报文来检测网络中是否存在重复地址。当设备侦听到客户端的DAD NS报文后，会生成ND Snooping表项并将其置为detection状态，同时开始侦听相应的NA报文。

  - 如果在配置的侦听时间内侦听到NA报文，则说明该IPv6地址存在冲突，设备删除该ND Snooping表项。
  - 如果在配置的侦听时间内未侦听到NA报文，设备则将该ND Snooping表项置为bound状态，表明该IPv6地址不存在冲突，客户端可以使用该IPv6地址。直至ND Snooping表项老化时间到期，设备才将该ND Snooping表项删除；或者当设备配置了自动探测ND Snooping表项对应用户的在线状态功能（通过命令**nd user-bind detect enable**配置），在设备发出配置的探测次数（通过命令**nd user-bind detect retransmit** *retransmit-times* **interval** *retransmit-interval*配置）的NS探测报文之后，仍未收到用户回应的NA报文，使设备认为该用户已经下线，设备才将该ND Snooping表项删除。

- DHCPv6与SLAAC混合场景下：
  - 如果客户端以无状态地址自动配置方式获取地址，情况同SLAAC-Only场景。
  - 如果客户端通过DHCPv6方式获取地址，客户端在获取地址后，有可能会发送DAD NS报文来检测网络中是否存在重复地址。当设备侦听到客户端的DAD NS报文后，会将对应的DHCPv6 snooping表项置为detection状态，同时开始侦听相应的NA报文。

- 如果在配置的侦听时间内侦听到NA报文，则说明该IPv6地址存在冲突，设备删除该DHCPv6 Snooping表项。
- 如果在配置的侦听时间内未侦听到NA报文，设备则将该DHCPv6 Snooping表项置为bound状态，表明该IPv6地址不存在冲突，客户端可以使用该IPv6地址。直至侦听到DHCPv6客户端发送的DHCPv6 Decline或DHCPv6 Release报文，设备才将该DHCPv6 Snooping表项删除。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**savi max dad-delay** *value*，配置侦听响应地址冲突的NA报文的时间。

缺省情况下，侦听响应地址冲突的NA报文的时间为2秒。

----结束

27.9.3.4 （可选）配置侦听 DHCPv6 客户端对获取地址作冲突检测的时间

背景信息

配置侦听DHCPv6客户端对获取地址作冲突检测的时间仅适用于DHCPv6-Only场景或DHCPv6与SLAAC混合场景。

设备在侦听到DHCPv6客户端获取到IPv6地址后，还会侦听DHCPv6客户端是否会发送DAD NS报文对获取到的地址作冲突检测。

- DHCPv6-Only场景下：
  - 如果在配置的侦听时间内未侦听到DAD NS报文，设备则将对应的DHCPv6 Snooping表项置为bound状态，表明DHCPv6客户端未对获取到的地址作冲突检测，或者该IPv6地址不存在冲突，DHCPv6客户端可以使用该IPv6地址。
  - 如果在配置的侦听时间内侦听到DAD NS报文，设备不会改变对应的DHCPv6 Snooping表项状态。直至侦听时间到期，设备才会将该DHCPv6 Snooping表项置为bound状态。

  在DHCPv6-Only场景下，设备侦听到DHCPv6客户端发送的DHCPv6 Decline或DHCPv6 Release报文，会将对应的DHCPv6 Snooping表项删除。
- DHCPv6与SLAAC混合场景下：
  - 如果在配置的侦听时间内未侦听到DAD NS报文，设备则将对应的DHCPv6 Snooping或ND Snooping表项置为bound状态，表明客户端未对获取到的地址作冲突检测，或者该IPv6地址不存在冲突，客户端可以使用该IPv6地址。
  - 如果在配置的侦听时间内侦听到DAD NS报文，设备则将对应的DHCPv6 Snooping或ND Snooping表项置为detection状态，并继续侦听相应的NA报文。侦听方式请参见**（可选）配置侦听响应地址冲突的NA报文的时间**。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**savi max dad-prepare-delay** *value*，配置侦听DHCPv6客户端对获取地址作冲突检测的时间。

缺省情况下，侦听DHCPv6客户端对获取地址作冲突检测的时间为2秒。

----结束

27.9.3.5 检查 SAVI 的配置结果

操作步骤

- 系统视图和接口视图下执行命令**display this**，查看SAVI功能的配置信息。

----结束

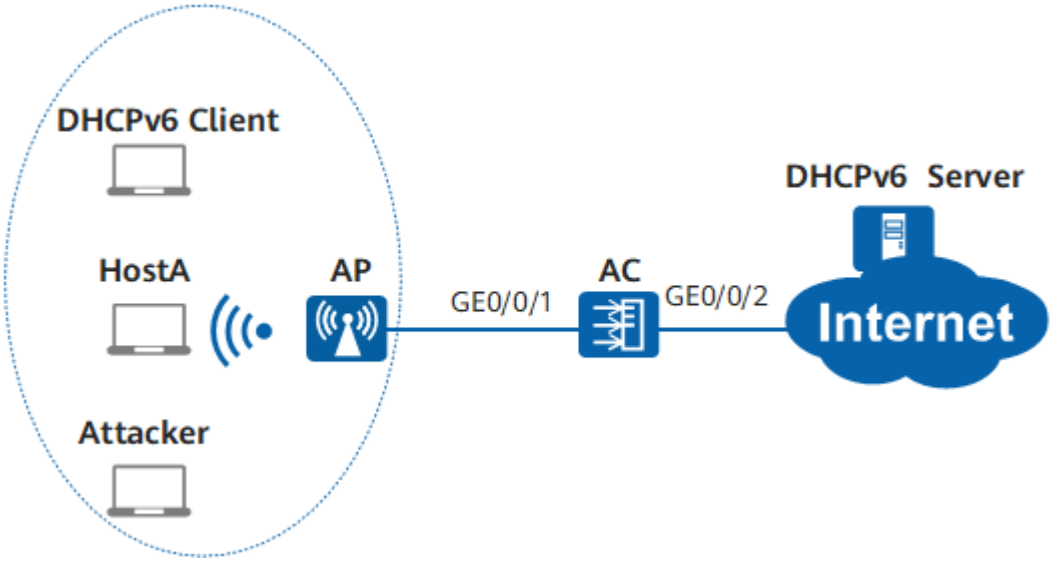
27.9.4 SAVI 配置举例

27.9.4.1 配置 SAVI 功能示例

组网需求

如图27-33所示，某企业部门AC直连AP，员工通过WLAN接入网络。该部门部分主机通过无状态地址自动配置方式获取IPv6地址，部分主机通过DHCPv6方式获取IPv6地址。如果存在攻击者发送大量非法的ND协议报文、DHCPv6协议报文或IPv6数据报文，将会存在合法用户主机通信中断、用户帐号口令被盗用等一系列安全隐患。为了预防这种情况，管理员希望通过在AC上进行配置，对非法的ND协议报文、DHCPv6协议报文和IPv6数据报文（源地址非法）进行有效防范，为合法用户提供更安全的网络环境和更稳定的网络服务。

图 27-33 配置 SAVI 功能示例组网图



配置思路

在AC上进行如下配置：

1. 配置DHCPv6 Snooping功能，以便生成地址和端口的绑定关系表，用于后续的DHCPv6报文源地址合法性检查。
2. 配置ND Snooping功能，以便生成地址和端口的绑定关系表，用于后续的ND协议报文源地址合法性检查。
3. 使能SAVI功能，使设备根据绑定关系表对DHCPv6协议报文和ND协议报文进行源地址合法性检查，过滤非法协议报文。
4. 使能IP Source Guard功能，使设备根据绑定关系表对IPv6数据报文进行源地址合法性检查，过滤非法IPv6数据报文。

操作步骤

步骤1 使能SAVI功能

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] savi enable
```

步骤2 配置DHCPv6 Snooping功能

全局使能DHCPv6 Snooping功能。

```
[AC] dhcp enable
[AC] dhcp snooping enable
```

在接口GE0/0/1上使能DHCPv6 Snooping功能。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] dhcp snooping enable
```

在接口GE0/0/1使能DHCPv6协议报文的绑定表匹配检查功能。

```
[AC-GigabitEthernet0/0/1] dhcp snooping check dhcp-request enable
[AC-GigabitEthernet0/0/1] quit
```

配置接口GE0/0/2为DHCP Snooping信任接口。

```
[AC] interface gigabitethernet 0/0/2
[AC-GigabitEthernet0/0/2] dhcp snooping trusted
[AC-GigabitEthernet0/0/2] quit
```

步骤3 配置ND Snooping功能

全局使能ND Snooping功能。

```
[AC] nd snooping enable
```

在接口GE0/0/1上使能ND Snooping功能。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] nd snooping enable
```

在接口GE0/0/1上使能对NA报文和NS报文进行合法性检查功能。

```
[AC-GigabitEthernet0/0/1] nd snooping check na enable
[AC-GigabitEthernet0/0/1] nd snooping check ns enable
[AC-GigabitEthernet0/0/1] quit
```

配置接口GE0/0/2为ND Snooping信任接口。

```
[AC] interface gigabitethernet 0/0/2
[AC-GigabitEthernet0/0/2] nd snooping trusted
[AC-GigabitEthernet0/0/2] quit
```

步骤4 在接口GE0/0/1上使能IP Source Guard功能

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] ip source check user-bind enable
[AC-GigabitEthernet0/0/1] quit
```

步骤5 验证配置结果

在系统视图下执行**display this**命令可以看到全局已经使能SAVI功能、DHCPv6 Snooping功能和ND Snooping功能。

```
[AC] display this
...
#
dhcp enable
#
dhcp snooping enable
#
nd snooping enable
savi enable
#
...
```

在接口GE0/0/1下执行**display this**命令可以看到接口GE0/0/1下已经使能DHCPv6 Snooping功能、DHCPv6协议报文绑定表匹配检查功能、ND Snooping功能、ND协议报文合法性检查功能以及IP Source Guard功能。

```
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] display this
#
interface GigabitEthernet0/0/1
 ip source check user-bind enable
 dhcp snooping enable
 dhcp snooping check dhcp-request enable
 nd snooping enable
 nd snooping check ns enable
 nd snooping check na enable
#
return
[AC-GigabitEthernet0/0/1] quit
```

在接口GE0/0/2下执行**display this**命令可以看到接口GE0/0/2已经配置为DHCP Snooping信任接口和ND Snooping信任接口。

```
[AC] interface gigabitethernet 0/0/2
[AC-GigabitEthernet0/0/2] display this
#
interface GigabitEthernet0/0/2
 dhcp snooping trusted
 nd snooping trusted
#
return
```

----结束

配置文件

AC的配置文件：

```
#
sysname AC
#
dhcp enable
#
dhcp snooping enable
#
nd snooping enable
savi enable
#
 interface GigabitEthernet0/0/1
 ip source check user-bind enable
 dhcp snooping enable
```

```
 dhcp snooping check dhcp-request enable
 nd snooping enable
 nd snooping check ns enable
 nd snooping check na enable
#
interface GigabitEthernet0/0/2
 dhcp snooping trusted
 nd snooping trusted
#
return
```

27.10 URPF 配置

配置URPF可以用来防止基于源地址欺骗的网络攻击行为。

27.10.1 URPF 简介

介绍URPF的定义、由来和作用。

定义

URPF（Unicast Reverse Path Forwarding）是单播逆向路径转发的简称，其主要功能是防止基于源IP地址欺骗的网络攻击行为。

目的

拒绝服务DoS（Denial of Service）攻击是一种阻止连接服务的网络攻击。DoS的攻击方式有很多种，最基本的DoS攻击就是利用合理的服务请求来占用过多的服务资源，从而使合法用户无法得到服务的响应。

URPF根据数据包的源IP地址在FIB表中查找对应的出接口，并判断该接口是否与数据包的来源接口相匹配。如果没有匹配表项则丢弃该数据包，从而预防IP欺骗，特别是针对伪造IP源地址的DoS攻击非常有效。

受益

- 帮助网络维护者防御网络上的IP源攻击，降低对IP源攻击的维护成本。
- 用户能获得更安全、稳定的网络环境，不用担心因IP源攻击带来的困扰。

27.10.2 原理描述

介绍URPF的实现原理。

工作模式

在复杂的网络环境中应用URPF时，会遇到路由不对称的情况，即对端设备记录的路由路径不一样，此时使能URPF的设备可能丢弃合法报文，造成设备不能正确转发。

为了解决以上复杂网络中应用URPF的问题，设备实现了URPF的两种工作模式：

- 严格模式

  严格模式下，设备不仅要求报文源地址在FIB表中存在相应表项，还要求接口匹配才能通过URPF检查。

  建议在路由对称的环境下使用URPF严格模式，例如两个网络边界设备之间只有一条路径的话，这时，使用严格模式能够最大限度的保证网络的安全性。

- 松散模式

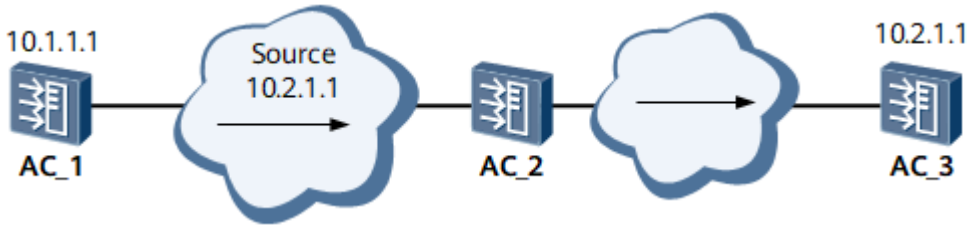
  松散模式下，设备不检查接口是否匹配，只要FIB表中存在该报文源地址的路由，报文就可以通过。

  建议在不能保证路由对称的环境下使用URPF的松散模式，例如两个网络边界设备之间如果有多条路径连接的话，路由的对称性就不能保证，在这种情况下，URPF的松散模式也可以保证较强的安全性。

工作原理

URPF通过获取报文的源地址和入接口，在FIB表中查找源地址对应的接口是否与入接口匹配。如果不匹配，则认为源地址是伪装的，丢弃该报文。通过这种工作方式，URPF能有效地防范网络中通过修改源地址而进行的恶意攻击行为。

图 27-34 URPF 原理



如图27-34所示，在AC_1上伪造源地址为10.2.1.1的报文向AC_2发起请求，AC_2响应请求时将向真正的“10.2.1.1”即AC_3发送报文。这种非法报文对AC_2和AC_3都造成了攻击。

如果在AC_2上启用URPF严格检查，则AC_2在收到源地址为10.2.1.1的报文时，URPF检查到以此报文源地址对应的接口与收到该报文的接口不匹配，报文会被丢弃。

说明

设备支持对入接口报文的源IPv4地址和源IPv6地址进行检查。

27.10.3 缺省配置

介绍URPF缺省配置，实际应用的配置可以基于缺省配置进行修改。

URPF的缺省配置如表27-16所示。

表 27-16 URPF 缺省配置

参数	缺省值
URPF检查功能	未使能

27.10.4 配置 URPF

介绍配置URPF具体命令和步骤。

前置任务

在配置URPF之前，需完成以下任务：

- 配置接口的链路层协议参数，使接口的链路协议状态为Up。

27.10.4.1 配置接口的 URPF 检查模式

背景信息

在复杂的网络环境中应用URPF时，会遇到路由不对称的情况，即对端设备记录的路由路径不一样，此时使能URPF的设备可能丢弃合法报文，造成设备不能正确转发。

为了解决以上复杂网络中应用URPF的问题，设备实现了URPF的两种工作模式：

- 严格模式

  严格模式下，设备不仅要求报文源地址在FIB（Forwarding Information Base）表中存在相应表项，还要求接口匹配才能通过URPF检查。

  建议在路由对称的环境下使用URPF严格模式，例如两个网络边界设备之间只有一条路径的话，这时，使用严格模式能够最大限度的保证网络的安全性。

- 松散模式

  松散模式下，设备不检查接口是否匹配，只要FIB表中存在该报文源地址的路由，报文就可以通过。

  建议在不能保证路由对称的环境下使用URPF的松散模式，例如两个网络边界设备之间如果有多条路径连接的话，路由的对称性就不能保证，在这种情况下，URPF的松散模式也可以保证较强的安全性。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface vlanif** *vlan-id*，进入VLANIF接口视图。

步骤3 配置对接口的报文进行URPF检查。

- 配置对接口的IPv4报文进行URPF检查的模式。

  执行命令**urpf** { **loose** | **strict** } [**allow-default-route**]，配置对接口的IPv4报文进行URPF检查的模式。

- 配置对接口的IPv6报文进行URPF检查的模式。

  执行命令**ipv6 urpf** { **loose** | **strict** } [**allow-default-route**]，配置对接口的IPv6报文进行URPF检查的模式。

  说明

  如果需要配置对接口的IPv6报文进行URPF检查的功能，需要先使能接口的IPv6功能。请先在系统视图下执行命令**ipv6**，然后在接口视图下执行命令**ipv6 enable**。

----结束

27.10.4.2 检查配置结果

操作步骤

步骤1 在VLANIF接口视图下使用命令**display this**查看当前接口下是否配置了URPF功能。

----结束

27.10.5 配置举例

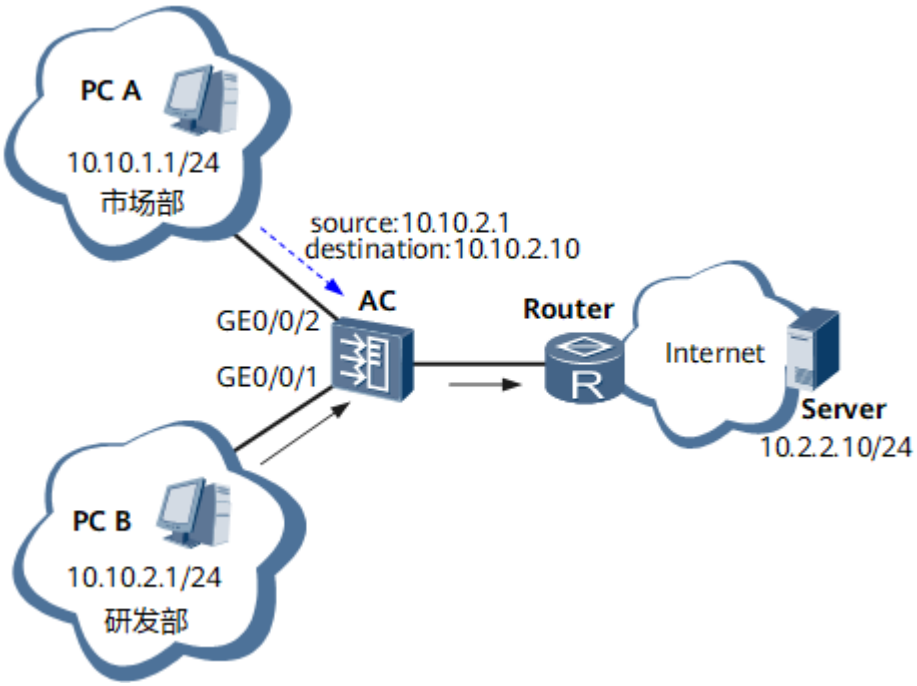
通过示例介绍如何配置URPF。配置示例中包括组网需求、配置思路等。

27.10.5.1 配置 URPF 功能示例

组网需求

如图27-35所示，某企业研发部和市场部通过接口GE0/0/1和接口GE0/0/2与AC连接，AC与外部的某个Server之间路由可达，研发部员工和市场部员工都可以通过AC访问该Server。公司希望在AC上进行配置，防止不同部门的员工利用源IP地址欺骗的方法超越权限，非法获取Server的服务。

图 27-35 配置 URPF 组网图



配置思路

该组网的配置思路如下：

在接口VLANIF10和接口VLANIF20配置URPF功能，并允许对缺省路由进行特殊处理。

配置注意事项

- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 配置接口的URPF检查模式。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] vlan batch 10 20
[AC] interface gigabitethernet 0/0/1
[AC-GigabitEthernet0/0/1] port hybrid pvid vlan 10
[AC-GigabitEthernet0/0/1] port hybrid  untagged vlan 10
[AC-GigabitEthernet0/0/1] quit
[AC] interface gigabitethernet 0/0/2
[AC-GigabitEthernet0/0/2] port hybrid pvid vlan 20
[AC-GigabitEthernet0/0/2] port hybrid  untagged vlan 20
[AC-GigabitEthernet0/0/2] quit
[AC] interface vlanif 10
[AC-Vlanif10] ip address 10.10.1.5 24
[AC-Vlanif10] urpf strict allow-default-route
[AC-Vlanif10] quit
[AC] interface vlanif 20
[AC-Vlanif20] ip address 10.10.2.5 24
[AC-Vlanif20] urpf strict allow-default-route
```

步骤2 验证配置结果。

在VLANIF 10接口视图下执行命令**display this**查看URPF配置。

```
[AC-Vlanif10] display this
#
interface Vlanif10
 ip address 10.10.1.5 255.255.255.0
 urpf strict allow-default-route
#
return
```

在VLANIF 20接口视图下执行命令**display this**查看URPF配置。

```
[AC-Vlanif20] display this
#
interface Vlanif20
 ip address 10.10.2.5 255.255.255.0
 urpf strict allow-default-route
#
return
```

----结束

配置文件

```
#
sysname AC
#
vlan batch 10 20
#
interface Vlanif10
 ip address 10.10.1.5 255.255.255.0
 urpf strict allow-default-route
#
```

```
interface Vlanif20
 ip address 10.10.2.5 255.255.255.0
 urpf strict allow-default-route
#
interface GigabitEthernet0/0/1
 port hybrid pvid vlan 10
 port hybrid  untagged vlan 10
#
interface GigabitEthernet0/0/2
 port hybrid pvid vlan 20
 port hybrid  untagged vlan 20
#
return
```

27.11 PKI 配置

27.11.1 PKI 简介

定义

公钥基础设施PKI（Public Key Infrastructure），是一种遵循既定标准的证书管理平台，它利用公钥技术能够为所有网络应用提供安全服务。PKI技术是信息安全技术的核心，也是电子商务的关键和基础技术。

目的

随着网络技术和信息技术的发展，电子商务已逐步被人们所接受，并得到不断普及。但通过网络进行电子商务交易时，存在如下问题：

- 交易双方并不现场交易，无法确认双方的合法身份。
- 通过网络传输时信息易被窃取和篡改，无法保证信息的安全性。
- 交易双方发生纠纷时没有凭证可依，无法提供仲裁。

为了解决上述问题，PKI技术应运而生，其利用公钥技术保证在交易过程中能够实现身份认证、保密、数据完整性和不可否认性。因而在网络通信和网络交易中，特别是电子政务和电子商务业务，PKI技术得到了广泛的应用。

受益

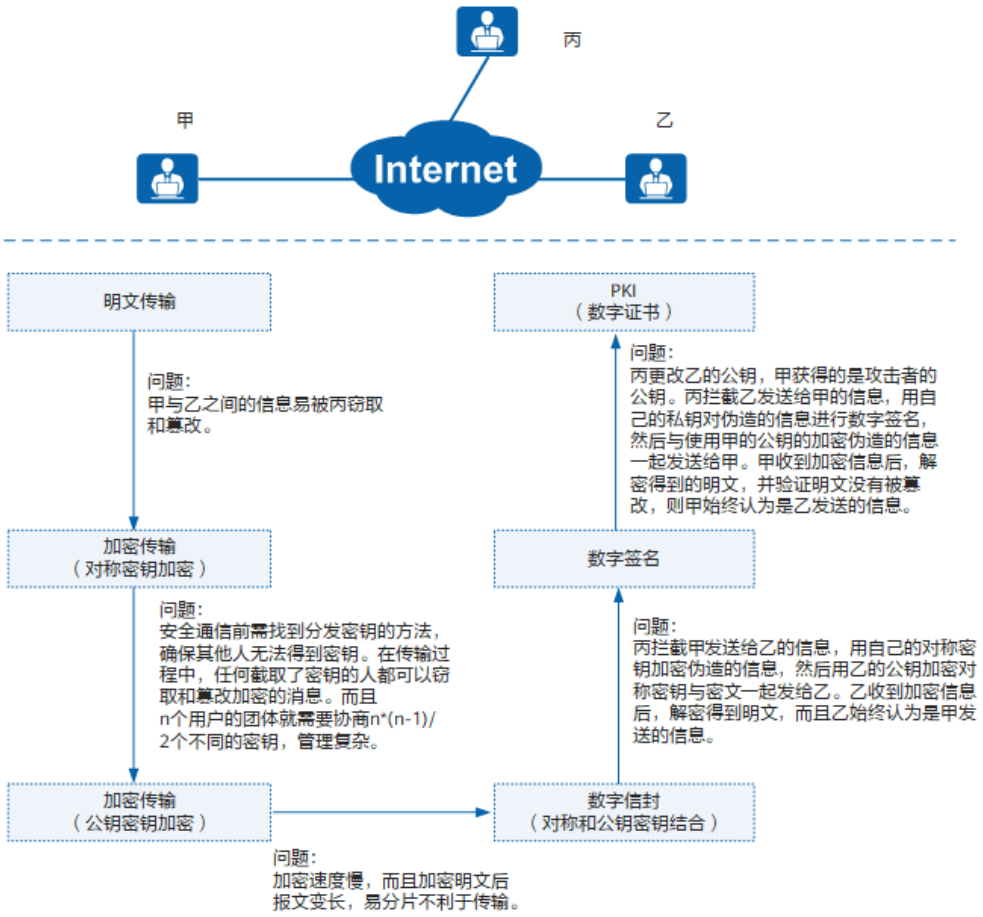
- 用户受益
  - 通过PKI证书认证技术，用户可以验证接入设备的合法性，从而可以保证用户接入安全、合法的网络中。
  - 通过PKI加密技术，可以保证网络中传输的数据的私密性，数据不会被篡改和窥探。
  - 通过PKI签名技术，可以保证数据的安全性，未授权的设备和用户无法查看该数据。
- 企业受益
  - 企业可以防止非法用户接入企业网络中。
  - 企业分支之间可以建立安全通道，保证企业数据的安全性。

27.11.2 PKI 原理描述

27.11.2.1 PKI 基本概念

PKI的核心技术就围绕着数字证书的申请、颁发和使用等整个生命周期进行展开，而在这整个生命周期过程中，PKI会使用到对称密钥加密、公钥加密、数字信封和数字签名技术。下面以图27-36为例介绍这些技术间的演进过程。甲和乙通过Internet进行通信，丙为攻击者专门破坏甲和乙间的通信。

图 27-36 演进示意图



对于这些概念的详细介绍请参见相应的章节。

27.11.2.1.1 加密

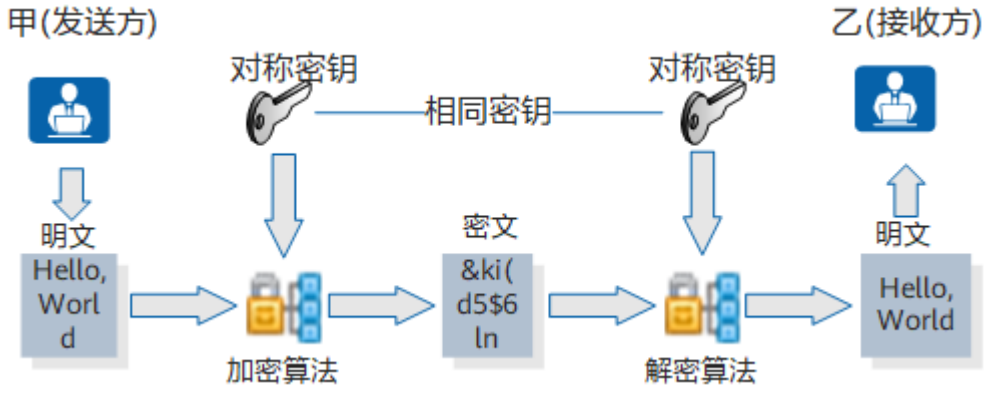
加密是通过网络传输信息的基础。通俗地讲，加密就是利用数学方法将明文(需要被隐蔽的数据)转换为密文（不可读的数据）从而达到保护数据的目的。

对称密钥加密

对称密钥加密又称为共享密钥加密，它使用同一个密钥对数据进行加密和解密。

对称密钥的加解密过程如图27-37所示。

图 27-37 对称密钥加解密过程示意图



甲与乙事先协商好对称密钥，具体加解密过程如下：

1. 甲使用对称密钥对明文加密，并将密文发送给乙。
2. 乙接收到密文后，使用对称密钥对密文解密，得到最初的明文。

对称密钥加密的优点是效率高，算法简单，系统开销小，适合加密大量数据。缺点是实现困难，扩展性差。实现困难原因在于进行安全通信前需要以安全方式进行密钥交换；扩展性差表现在每对通信用户之间都需要协商密钥，n个用户的团体就需要协商n*(n-1)/2个不同的密钥。

目前比较常用的对称密钥加密算法，主要包含DES（Data Encryption Standard）、3DES(Triple Data Encryption Standard)、AES（Advance Encrypt Standard）算法。其中，DES和3DES算法安全性低，存在安全风险，不推荐使用。

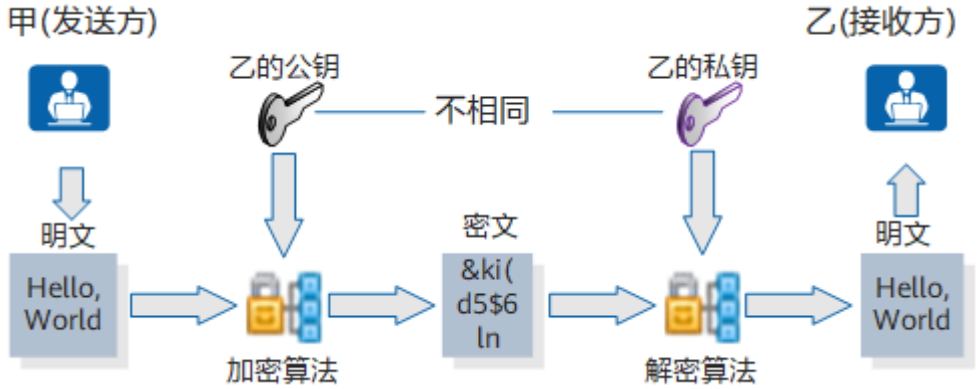
公钥加密

公钥加密又称为非对称密钥加密，它使用了两个不同的密钥：一个可对外界公开，称为“公钥”；一个只有所有者知道，称为“私钥”。

公钥加密解决了对称密钥的发布和管理问题，一个用于加密信息，另一个则用于解密信息，通信双方无需事先交换密钥就可进行保密通信。通常以公钥作为加密密钥，以私钥作为解密密钥。因为其他人没有对应的私钥，发送的加密信息仅该用户可以解读，从而实现通信的加密传输。

公钥加解密的过程如图27-38所示。

图 27-38 公钥加解密过程示意图



版权所有 © 华为技术有限公司

甲事先获得乙的公钥，具体加解密过程如下：

1. 甲使用乙的公钥对明文加密，并将密文发送给乙。
2. 乙收到密文后，使用自己的私钥对密文解密，得到最初的明文。

公钥加密的优点是无法从一个密钥推导出另一个密钥；公钥加密的信息只能用私钥进行解密。缺点是算法非常复杂，导致加密大量数据所用的时间较长，而且加密后的报文较长，不利于网络传输。

基于公钥加密的优缺点，公钥加密适合对密钥或身份信息等敏感信息加密，从而在安全性上满足用户的需求。

目前比较常用的公钥加密算法，主要包含DH（Diffie-Hellman）、RSA（Ron Rivest、Adi Shamirh、LenAdleman）和DSA（Digital Signature Algorithm）算法。

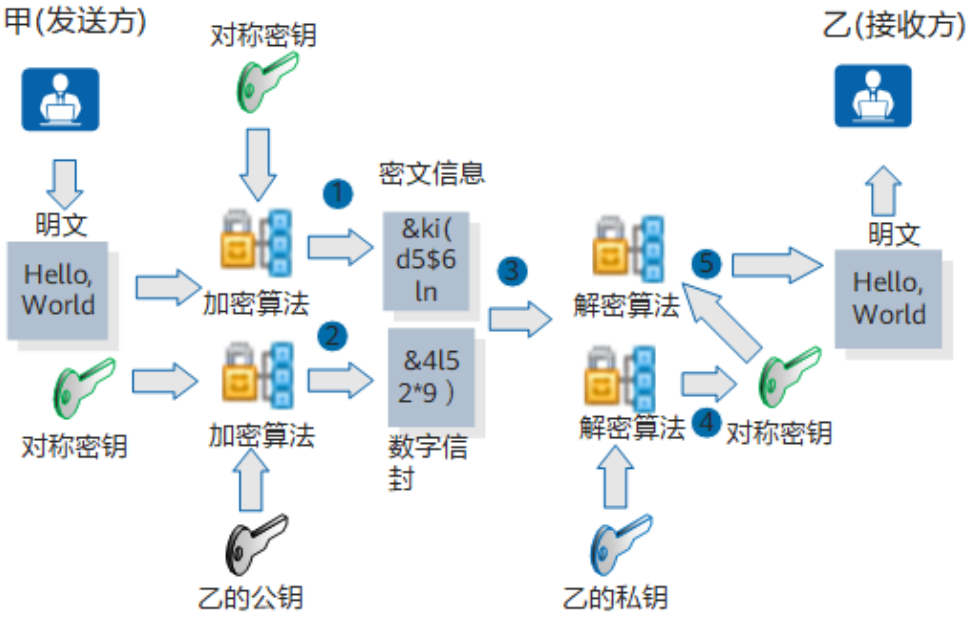
27.11.2.1.2 数字信封和数字签名

数字信封

数字信封是指发送方采用接收方的公钥来加密对称密钥后所得的数据。采用数字信封时，接收方需要使用自己的私钥才能打开数字信封得到对称密钥。

数字信封的加解密过程如图27-39所示。

图 27-39 数字信封的加解密过程示意图



甲事先获得乙的公钥，具体加解密过程如下：

1. 甲使用对称密钥对明文进行加密，生成密文信息。
2. 甲使用乙的公钥加密对称密钥，生成数字信封。
3. 甲将数字信封和密文信息一起发送给乙。

4. 乙接收到甲的加密信息后，使用自己的私钥打开数字信封，得到对称密钥。
5. 乙使用对称密钥对密文信息进行解密，得到最初的明文。

从加解密过程中，可以看出，数字信封技术结合了对称密钥加密和公钥加密的优点，解决了对称密钥的发布和公钥加密速度慢等问题，提高了安全性、扩展性和效率等。

但是，数字信封技术还有个问题，如果攻击者拦截甲的信息，用自己的对称密钥加密伪造的信息，并用乙的公钥加密自己的对称密钥，然后发送给乙。乙收到加密信息后，解密得到的明文，而且乙始终认为是甲发送的信息。此时，需要一种方法确保接收方收到的信息就是指定的发送方发送的。

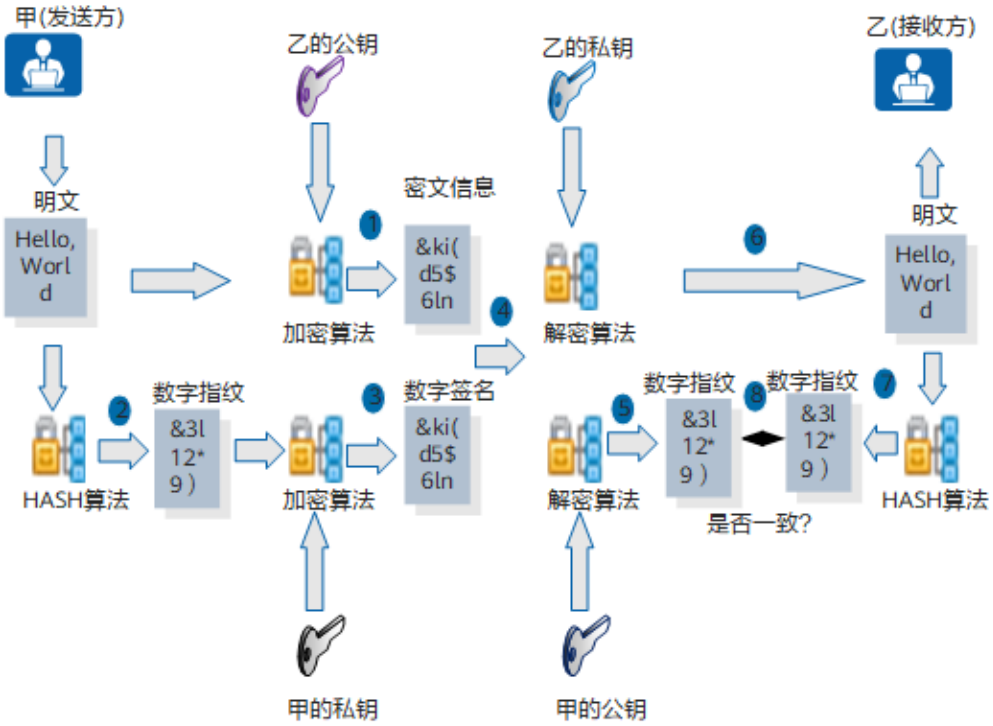
数字签名

数字签名是指发送方用自己的私钥对数字指纹进行加密后所得的数据。采用数字签名时，接收方需要使用发送方的公钥才能解开数字签名得到数字指纹。

数字指纹又称为信息摘要，它是指发送方通过HASH算法对明文信息计算后得出的数据。采用数字指纹时，发送方会将数字指纹和明文一起发送给接收方，接收方用同样的HASH算法对明文计算生成的数据指纹，与收到的数字指纹进行匹配，如果一致，便可确定明文信息没有被篡改。

数字签名的加解密过程如图27-40所示。

图 27-40 数字签名的加解密过程示意图



甲事先获得乙的公钥，具体加解密过程如下：

1. 甲使用乙的公钥对明文进行加密，生成密文信息。
2. 甲使用HASH算法对明文进行HASH运算，生成数字指纹。

3. 甲使用自己的私钥对数字指纹进行加密，生成数字签名。
4. 甲将密文信息和数字签名一起发送给乙。
5. 乙使用甲的公钥对数字签名进行解密，得到数字指纹。
6. 乙接收到甲的加密信息后，使用自己的私钥对密文信息进行解密，得到最初的明文。
7. 乙使用HASH算法对明文进行HASH运算，生成数字指纹。
8. 乙将生成的数字指纹与得到的数字指纹进行比较，如果一致，乙接受明文；如果不一致，乙丢弃明文。

从加解密过程中，可以看出，数字签名技术不但证明了信息未被篡改，还证明了发送方的身份。数字签名和数字信封技术也可以组合使用。

但是，数字签名技术还有个问题，如果攻击者更改乙的公钥，甲获得的是攻击者的公钥，攻击者拦截乙发送给甲的信息，用自己的私钥对伪造的信息进行数字签名，然后与使用甲的公钥的加密伪造的信息一起发送给甲。甲收到加密信息后，解密得到的明文，并验证明文没有被篡改，则甲始终认为是乙发送的信息。此时，需要一种方法确保一个特定的公钥属于一个特定的拥有者。

27.11.2.1.3 数字证书

数字证书简称证书，它是一个经证书授权中心（即在PKI中的**证书认证机构CA**）数字签名的文件，包含拥有者的公钥及相关身份信息。

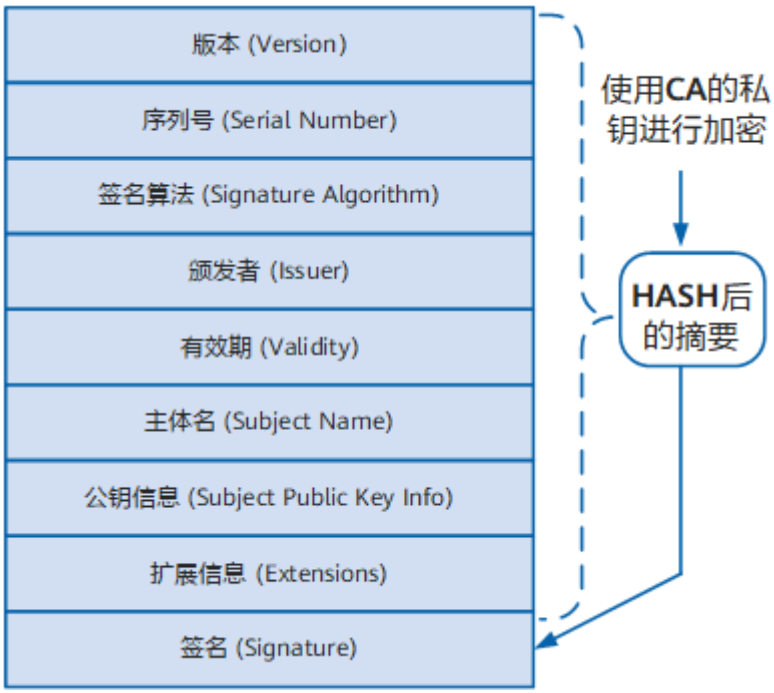
数字证书可以说是Internet上的安全护照或身份证。当人们到其他国家旅行时，用护照可以证实其身份，并被获准进入这个国家。数字证书提供的是网络上的身份证明。

数字证书技术解决了数字签名技术中无法确定公钥是指定拥有者的问题。

证书结构

最简单的证书包含一个公钥、名称以及证书授权中心的数字签名。一般情况下证书中还包括密钥的有效期，颁发者（证书授权中心）的名称，该证书的序列号等信息，证书的结构遵循X.509 v3版本的规范。**图27-41**展示了一个常见的证书结构。

图 27-41 证书结构示意图



证书的各字段解释：

- 版本：即使用X.509的版本，目前普遍使用的是v3版本（0x2）。
- 序列号：颁发者分配给证书的一个正整数，同一颁发者颁发的证书序列号各不相同，可用与颁发者名称一起作为证书唯一标识。
- 签名算法：颁发者颁发证书使用的签名算法。
- 颁发者：颁发该证书的设备名称，必须与颁发者证书中的主体名一致。通常为CA服务器的名称。
- 有效期：包含有效的起、止日期，不在有效期范围的证书为无效证书。
- 主体名：证书拥有者的名称，如果与颁发者相同则说明该证书是一个自签名证书。
- 公钥信息：用户对外公开的公钥以及公钥算法信息。
- 扩展信息：通常包含了证书的用法、CRL的发布地址等可选字段。
- 签名：颁发者用私钥对证书信息的签名。

证书分类

证书有四种类型，如**表27-17**所示。

表 27-17 证书类型

类型	描述	说明
自签名证书	自签名证书又称为根证书，是自己颁发给自己的证书，即证书中的颁发者和主体名相同。	申请者无法向CA申请本地证书时，可以通过设备生成自签名证书，可以实现简单证书颁发功能。 设备不支持对其生成的自签名证书进行生命周期管理（如证书更新、证书撤销等），为了确保设备和证书的安全，建议用户替换为自己的本地证书。
CA证书	CA自身的证书。如果PKI系统中没有多层级CA，CA证书就是自签名证书；如果有多层级CA，则会形成一个CA层次结构，最上层的CA是根CA，它拥有一个CA“自签名”的证书。	申请者通过验证CA的数字签名从而信任CA，任何申请者都可以得到CA的证书（含公钥），用以验证它所颁发的本地证书。
本地证书	CA颁发给申请者的证书。	-
设备本地证书	设备根据CA证书给自己颁发的证书，证书中的颁发者名称是CA服务器的名称。	申请者无法向CA申请本地证书时，可以通过设备生成设备本地证书，可以实现简单证书颁发功能。 **说明** ● 在关闭DNS服务器访问条件下，Chrome等浏览器打开内置Portal认证页面时，浏览器会有安全提示,可以访问认证页面成功。打开DNS服务器访问条件时，可能访问失败。这时候推荐用户尝试使用IE浏览器。 ● 部分终端在连接WIFI网络后，会主动向服务器发送HTTP探测请求报文，探测网络连通性。探测不通时，会校验证书是否为CA证书，导致Chrome等浏览器无法打开内置Portal认证页面。

证书格式

设备支持三种文件格式保存证书，如表27-18所示。

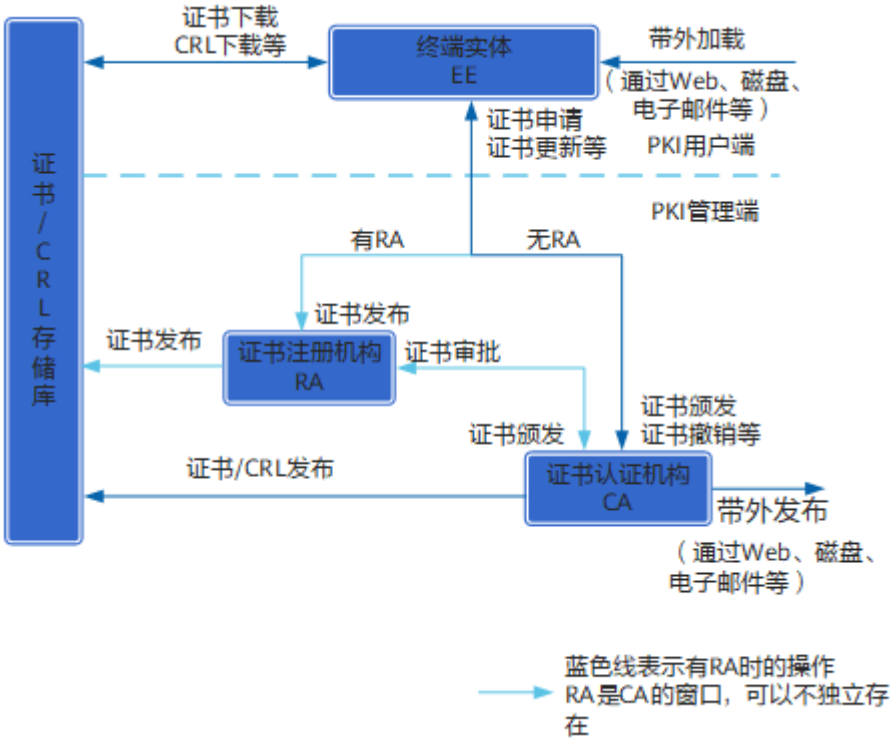
表 27-18 证书格式

格式	描述	说明
PKCS#12	以二进制格式保存证书，可以包含私钥，也可以不包含私钥。常用的后缀有：.P12和.PFX。	对于证书后缀为.CER或.CRT，可以用记事本打开证书，查看证书内容来区分证书格式。 ● 如果有类似 " -----BEGIN CERTIFICATE----- " 和 " -----END CERTIFICATE----- " 的头尾标记，则证书格式为PEM。 ● 如果是乱码，则证书格式为DER。
DER	以二进制格式保存证书，不包含私钥。常用的后缀有：.DER、.CER和.CRT。	
PEM	以ASCII码格式保存证书，可以包含私钥，也可以不包含私钥。常用的后缀有：.PEM、.CER和.CRT。	

27.11.2.2 PKI 体系架构

如图27-42所示，一个PKI体系由终端实体、证书认证机构、证书注册机构和证书/CRL存储库四部分共同组成。

图 27-42 PKI 体系架构



- 终端实体EE（End Entity）

  终端实体也称为PKI实体，它是PKI产品或服务的最终使用者，可以是个人、组织、设备（如路由器、防火墙）或计算机中运行的进程。

- 证书认证机构CA（Certificate Authority）

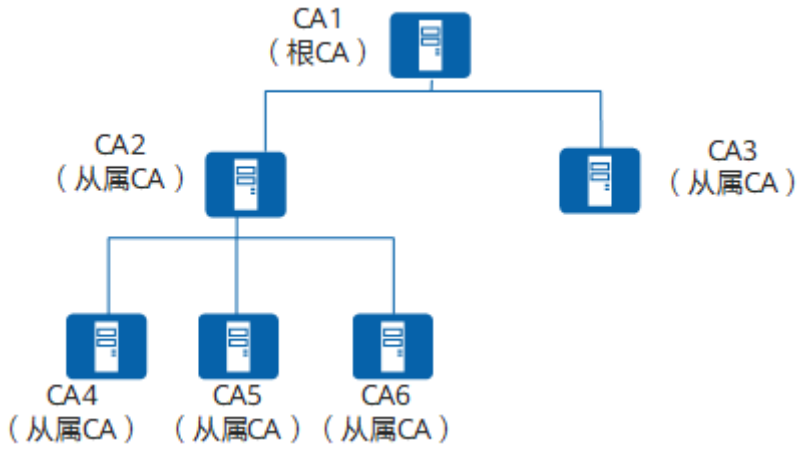
  CA是PKI的信任基础，是一个用于颁发并管理数字证书的可信实体。它是一种权威性、可信任性和公正性的第三方机构，通常由服务器充当，例如Windows Server 2008。

  如图27-43所示，CA通常采用多层次的分级结构，根据证书颁发机构的层次，可以划分为根CA和从属CA。

  - 根CA是公钥体系中第一个证书颁发机构，它是信任的起源。根CA可以为其它CA颁发证书，也可以为其它计算机、用户、服务颁发证书。对大多数基于证书的应用程序来说，使用证书的认证都可以通过证书链追溯到根CA。根CA通常持有一个自签名证书。
  - 从属CA必须从上级CA处获取证书。上级CA可以是根CA或者是一个已由根CA授权可颁发从属CA证书的从属CA。上级CA负责签发和管理下级CA的证书，最下一级的CA直接面向用户。例如，CA2和CA3是从属CA，持有CA1发行的CA证书；CA4、CA5和CA6是从属CA，持有CA2发行的CA证书。

  当某个PKI实体信任一个CA，则可以通过证书链来传递信任，证书链就是从用户的证书到根证书所经过的一系列证书的集合。当通信的PKI实体收到待验证的证书时，会沿着证书链依次验证其颁发者的合法性。

图 27-43 CA 层次示意图



CA的核心功能就是发放和管理数字证书，包括：证书的颁发、证书的更新、证书的撤销、证书的查询、证书的归档、证书废除列表CRL（Certificate Revocation List）的发布等。

- 证书注册机构RA（Registration Authority）

  RA是数字证书注册审批机构，RA是CA面对用户的窗口，是CA的证书发放、管理功能的延伸，它负责接受用户的证书注册和撤销申请，对用户的身份信息进行审查，并决定是否向CA提交签发或撤销数字证书的申请。

  RA作为CA功能的一部分，实际应用中，通常RA并不一定独立存在，而是和CA合并在一起。RA也可以独立出来，分担CA的一部分功能，减轻CA的压力，增强CA系统的安全性。

- 证书/CRL存储库

  由于用户名称的改变、私钥泄露或业务中止等原因，需要存在一种方法将现行的证书吊销，即撤销公钥及相关的PKI实体身份信息的绑定关系。在PKI中，所使用的这种方法为证书废除列表CRL。

  任何一个证书被撤销以后，CA就要发布CRL来声明该证书是无效的，并列出所有被废除的证书的序列号。因此，CRL提供了一种检验证书有效性的方式。

  证书/CRL存储库用于对证书和CRL等信息进行存储和管理，并提供查询功能。构建证书/CRL存储库可以采用FTP（File Transfer Protocol）服务器、HTTP（Hypertext Transfer Protocol）服务器或者数据库等等。

PKI的核心技术就围绕着本地证书的申请、颁发、存储、下载、安装、验证、更新和撤销的整个生命周期进行展开。

证书申请

证书申请即证书注册，就是一个PKI实体向CA自我介绍并获取证书的过程。通常情况下PKI实体会生成一对公私钥，公钥和自己的身份信息（包含在证书注册请求消息中）被发送给CA用来生成本地证书，私钥PKI实体自己保存用来数字签名和解密对端实体发送过来的密文。

PKI实体向CA申请本地证书有以下两种方式：

- 在线申请

PKI实体支持通过SCEP（Simple Certificate Enrollment Protocol）或CMPv2（Certificate Management Protocol version 2）协议向CA发送证书注册请求消息来申请本地证书。

- 离线申请（PKCS#10方式）

  离线申请是指PKI实体使用PKCS#10格式打印出本地的证书注册请求消息并保存到文件中，然后通过带外方式（如Web、磁盘、电子邮件等）将文件发送给CA进行证书申请。

还有种方式，PKI实体可以为自己颁发一个自签名证书或本地证书，实现简单的证书颁发功能。

证书颁发

PKI实体向CA申请本地证书时，如果有RA，则先由RA审核PKI实体的身份信息，审核通过后，RA将申请信息发送给CA。CA再根据PKI实体的公钥和身份信息生成本地证书，并将本地证书信息发送给RA。如果没有RA，则直接由CA审核PKI实体身份信息。

证书存储

CA生成本地证书后，CA/RA会将本地证书发布到证书/CRL存储库中，为用户提供下载服务和目录浏览服务。

证书下载

PKI实体通过SCEP或CMPv2协议向CA服务器下载已颁发的证书，或者通过HTTP或者带外方式，下载已颁发的证书。该证书可以是自己的本地证书，也可以是CA/RA证书或者其他PKI实体的本地证书。

证书安装

PKI实体下载证书后，还需安装证书，即将证书导入到设备的内存中，否则证书不生效。该证书可以是自己的本地证书，也可以是CA/RA证书，或其他PKI实体的本地证书。

证书验证

PKI实体获取对端实体的证书后，当需要使用对端实体的证书时，例如与对端建立安全隧道或安全连接，通常需要验证对端实体的本地证书和CA的合法性（证书是否有效或者是否属于同一个CA颁发等）。如果证书颁发者的证书无效，则由该CA颁发的所有证书都不再有效。但在CA证书过期前，设备会自动更新CA证书，异常情况下才会出现CA证书过期现象。

PKI实体可以使用CRL或者OCSP（Online Certificate Status Protocol）方式检查证书是否有效。使用CRL方式时，PKI实体先查找本地内存的CRL，如果本地内存没有CRL，则需下载CRL并安装到本地内存中，如果证书在CRL中，表示此证书已被撤销。使用OCSP方式时，PKI实体向OCSP服务器发送一个对于证书状态信息的请求，OCSP服务器会回复一个“有效”（证书没有被撤销）、“过期”（证书已被撤销）或“未知”（OCSP服务器不能判断请求的证书状态）的响应。

证书更新

当证书过期、密钥泄露时，PKI实体必须更换证书，可以通过重新申请来达到更新的目的，也可以使用SCEP或CMPv2协议自动进行更新。

设备在证书即将过期前，先申请一个证书作为“影子证书”，在当前证书过期后，影子证书成为当前证书，完成证书更新功能。

申请“影子证书”的过程，实质上是一个新的证书注册的过程。

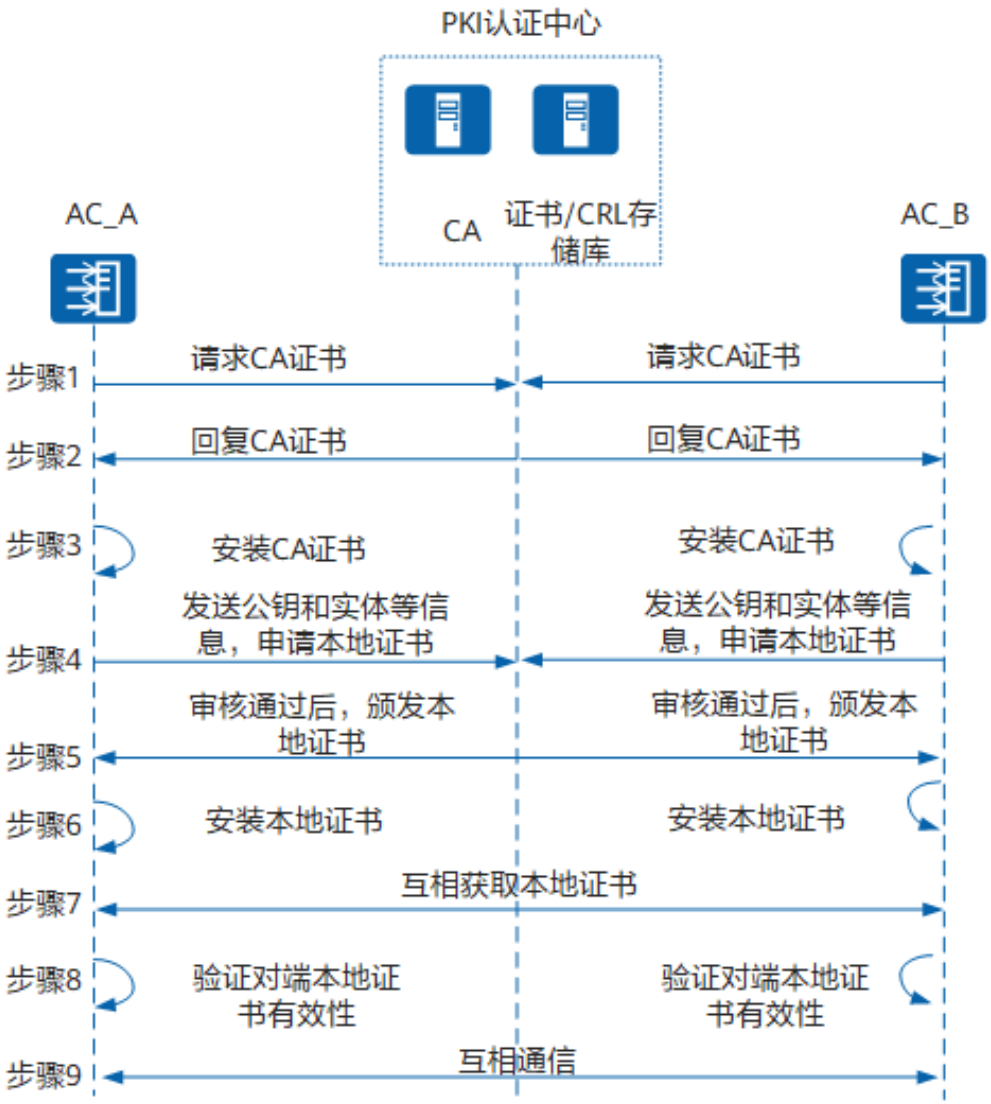
证书撤销

由于用户身份、用户信息或者用户公钥的改变、用户业务中止等原因，用户需要将自己的数字证书撤销，即撤销公钥与用户身份信息的绑定关系。在PKI中，CA主要采用CRL或OCSP协议撤销证书，而PKI实体撤销自己的证书是通过带外方式申请。

27.11.2.3 PKI 工作机制

针对一个使用PKI的网络，配置PKI的目的就是为指定的PKI实体向CA申请一个本地证书，并由设备对证书的有效性进行验证。PKI具体工作过程如图27-44所示。

图 27-44 PKI 工作过程示意图



1. PKI实体向CA请求CA证书，即CA服务器证书。
2. CA收到PKI实体的CA证书请求时，将自己的CA证书回复给PKI实体。
3. PKI实体收到CA证书后，安装CA证书。

   当PKI实体通过SCEP协议申请本地证书时，PKI实体会用配置的HASH算法对CA证书进行运算得到数字指纹，与提前配置的CA服务器的数字指纹进行比较，如果一致，则PKI实体接受CA证书，否则PKI实体丢弃CA证书。
4. PKI实体向CA发送证书注册请求消息（包括配置的密钥对中的公钥和PKI实体信息）。
   - 当PKI实体通过SCEP协议申请本地证书时，PKI实体对证书注册请求消息使用CA证书的公钥进行加密和自己的私钥进行数字签名。如果CA要求验证挑战密码，则证书注册请求消息必须携带挑战密码（与CA的挑战密码一致）。
   - 当PKI实体通过CMPv2协议申请本地证书时，PKI实体可以使用额外证书（其他CA颁发的本地证书）或者消息认证码方式进行身份认证。
     - 额外证书方式

       PKI实体对证书注册请求消息使用CA证书的公钥进行加密和PKI实体的额外证书相对应的私钥进行数字签名。
     - 消息认证码方式

       PKI实体对证书注册请求消息使用CA证书的公钥进行加密，而且证书注册请求消息必须包含消息认证码的参考值和秘密值（与CA的消息认证码的参考值和秘密值一致）。
5. CA收到PKI实体的证书注册请求消息。
   - 当PKI实体通过SCEP协议申请本地证书时，CA使用自己的私钥和PKI实体的公钥解密数字签名并验证数字指纹。数字指纹一致时，CA才会审核PKI实体身份等信息，审核通过后，同意PKI实体的申请，颁发本地证书。然后CA使用PKI实体的公钥进行加密和自己的私钥进行数字签名，将证书发送给PKI实体，也会发送到证书/CRL存储库。
   - 当PKI实体通过CMPv2协议申请本地证书时：
     - 额外证书方式

       CA使用自己的私钥解密和PKI实体的额外证书中的公钥解密数字签名并验证数字指纹。数字指纹一致时，CA才会审核PKI实体身份等信息，审核通过后，同意PKI实体的申请，颁发本地证书。然后CA使用PKI实体的额外证书中的公钥进行加密和自己的私钥进行数字签名，将证书发送给PKI实体，也会发送到证书/CRL存储库。
     - 消息认证码方式

       CA使用自己的私钥解密后，并验证消息认证码的参考值和秘密值。参考值和秘密值一致时，CA才会审核PKI实体身份等信息，审核通过后，同意PKI实体的申请，颁发本地证书。然后CA使用PKI实体的公钥进行加密，将证书发送给PKI实体，也会发送到证书/CRL存储库。
6. PKI实体收到CA发送的证书信息。
   - 当PKI实体通过SCEP协议申请本地证书时，PKI实体使用自己的私钥解密，并使用CA的公钥解密数字签名并验证数字指纹。数字指纹一致时，PKI实体接受证书信息，然后安装本地证书。
   - 当PKI实体通过CMPv2协议申请本地证书时：
     - 额外证书方式

PKI实体使用额外证书相对应的私钥解密，并使用CA的公钥解密数字签名并验证数字指纹。数字指纹一致时，PKI实体接受证书信息，然后安装本地证书。

- 消息认证码方式

  PKI实体使用自己的私钥解密，并验证消息认证码的参考值和秘密值。参考值和秘密值一致时，PKI实体接受证书信息，然后安装本地证书。

7. PKI实体间互相通信时，需各自获取并安装对端实体的本地证书。PKI实体可以通过HTTP/LDAP等方式下载对端的本地证书。
8. PKI实体安装对端实体的本地证书后，通过CRL或OCSP方式验证对端实体的本地证书的有效性。
9. 对端实体的本地证书有效时，PKI实体间才可以使用对端证书的公钥进行加密通信。

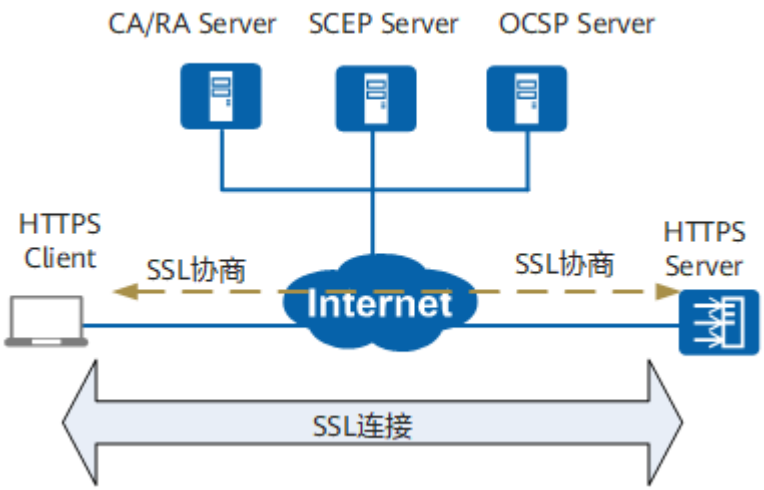
如果PKI认证中心有RA，则PKI实体也会下载RA证书。由RA审核PKI实体的本地证书申请，审核通过后将申请信息发送给CA来颁发本地证书。

27.11.3 PKI 应用场景

27.11.3.1 在 SSL 中的应用

SSL组网应用如图27-45所示。

图 27-45 SSL 应用组网图



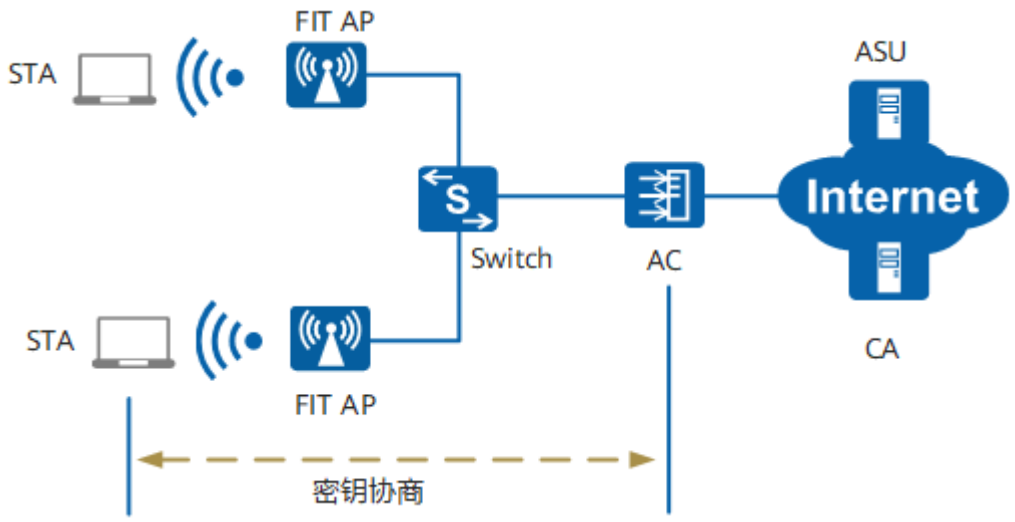
安全套接层SSL（Secure Sockets Layer）是一个安全协议，为基于TCP的应用层协议提供安全连接，如SSL可以为HTTP协议提供安全连接（即HTTPS）。SSL协议广泛应用于电子商务、网上银行等领域，为网络上数据的传输提供安全性保证。

SSL在连接建立的过程中，HTTPS客户端和HTTPS服务器可能需要通过交换和验证双方的证书来互相验证，其中证书申请、证书更新和证书验证功能由PKI特性完成。

27.11.3.2 在 WAPI 中的应用

WAPI组网应用如图27-46所示。

图 27-46 WAPI 应用组网图



WLAN用户STA通过WAPI-CERT方式进行WLAN认证接入网络中，认证服务器为ASU，CA为认证机构，一般情况下ASU和CA合二为一。

WAPI-CERT认证，是基于WLAN用户和WLAN设备双方的证书所进行的认证。认证前WLAN用户和WLAN设备必须预先拥有各自的证书，然后通过鉴别服务单元ASU（Authentication Service Unit）对双方的身份进行认证。

WLAN设备本身不需要验证证书，它只需要将WLAN设备和STA的证书通过WAPI协议报文发送给ASU，由ASU服务器负责验证证书。

WAPI应用需要的证书加载功能，即从设备存储器中读取证书文件并加载到内存中的功能由PKI特性完成。

27.11.4 PKI 缺省配置

表 27-19 PKI 的缺省配置

参数	缺省值
PKI实体	无
PKI域	default
RSA密钥对	default
设备保存证书请求、证书和CRL时的文件格式	PEM
证书状态检查方式	CRL方式

27.11.5 PKI 配置任务概览

PKI配置任务如表27-20所示。

表 27-20 PKI 配置任务概览

场景	描述	对应任务
在线申请本地证书	用户可以使用SCEP或CMPv2协议在线申请本地证书。使用SCEP或CMPv2协议都可以自动更新证书，SCEP比CMPv2协议维护更方便，但使用CMPv2协议可以为其他设备申请本地证书。	使用SCEP协议申请本地证书时，请按照如下顺序依次配置： 1. **27.11.6 申请本地证书的预配置** 2. **27.11.7 申请和更新本地证书**中的**27.11.7.1 配置通过SCEP协议为PKI实体申请和更新本地证书** 3. **27.11.10 验证CA证书和本地证书** 使用CMPv2协议申请本地证书时，请按照如下顺序依次配置： 1. **27.11.6 申请本地证书的预配置** 2. **27.11.7 申请和更新本地证书**中的**27.11.7.2 配置通过CMPv2协议为PKI实体申请和更新本地证书** 3. **27.11.9 （可选）安装本地证书** 4. **27.11.10 验证CA证书和本地证书**

版权所有 © 华为技术有限公司

场景	描述	对应任务
离线申请本地证书	如果受网络环境限制，设备无法访问CA服务器，可选择离线申请本地证书。 用户可以通过设备生成证书申请文件，然后通过带外方式（Web、磁盘、电子邮件等）将证书申请文件发送给CA申请本地证书;也可以无需通过设备生成证书申请文件，直接通过Web方式将申请证书信息发送给CA申请本地证书。	通过设备生成证书申请文件时，请按照如下顺序依次配置： 1. **27.11.6 申请本地证书的预配置** 2. **27.11.7 申请和更新本地证书**中的**27.11.7.3 配置为PKI实体离线申请本地证书** 3. **27.11.8 （可选）下载本地证书** 4. **27.11.9 （可选）安装本地证书** 5. **27.11.10 验证CA证书和本地证书** 未通过设备生成证书申请文件时，请按照如下顺序依次配置： 1. 直接通过Web方式将申请证书信息发送给CA申请本地证书 2. 下载CA提供的CA证书、本地证书和密钥对并上传至设备的存储介质中 3. 安装密钥对，请参考**27.11.6 申请本地证书的预配置**中的**27.11.6.2 配置RSA密钥对** 4. 安装CA证书，请参考**27.11.6 申请本地证书的预配置**中的**27.11.6.3.2 （可选）配置为PKI实体安装CA证书** 5. 安装本地证书，请参考**27.11.9 （可选）安装本地证书** 6. 验证证书，请参考**27.11.10 验证CA证书和本地证书**

27.11.6 申请本地证书的预配置

27.11.6.1 配置 PKI 实体信息

背景信息

本地证书是由CA进行数字签名并颁发的。它是公钥与PKI实体身份信息的绑定。PKI实体信息就是PKI实体的身份信息，CA根据PKI实体提供的身份信息来唯一标识证书申请

者。因此，申请本地证书时，PKI实体必须将包含PKI实体信息的证书注册请求消息发送给CA。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki entity** *entity-name*，创建PKI实体并进入PKI实体视图，或者直接进入PKI实体视图。

缺省情况下，系统未配置PKI实体。

说明

由于Windows Server 2003服务器处理能力有限，与该型号服务器对接时，设备上不能配置过多实体信息或携带密钥对位数过大的密钥对，否则可能导致设备与服务器对接失败。

步骤3 执行命令**common-name** *common-name*，配置PKI实体的通用名称。

缺省情况下，系统未配置PKI实体的通用名称。

为了更好的标识证书申请者的唯一身份，还需配置以下可选步骤的参数，作为PKI实体的一种别名。否则，当PKI实体间的通用名称相同时，会导致某PKI实体申请证书失败。

步骤4 （可选）执行命令**ip-address** { *ipv4-address* | *interface-type interface-number* }，配置PKI实体的IP地址。

缺省情况下，系统未配置PKI实体的IP地址。

步骤5 （可选）执行命令**fqdn** *fqdn-name*，配置PKI实体的FQDN名称。

缺省情况下，系统未配置PKI实体的FQDN名称。

步骤6 （可选）执行命令**email** *email-address*，配置PKI实体的电子邮箱地址。

缺省情况下，系统未配置PKI实体的电子邮箱地址。

步骤7 （可选）执行命令**country** *country-code*，配置PKI实体所属的国家代码。

缺省情况下，系统未配置PKI实体的国家代码。

步骤8 （可选）执行命令**locality** *locality-name*，配置PKI实体所在的地理区域名称。

缺省情况下，系统未配置PKI实体的地理区域名称。

步骤9 （可选）执行命令**state** *state-name*，配置PKI实体所属的州或省。

缺省情况下，系统未配置PKI实体所属的州或者省。

步骤10 （可选）执行命令**organization** *organization-name*，配置PKI实体所属的组织名称。

缺省情况下，系统未配置PKI实体的组织名称。

步骤11 （可选）执行命令**organization-unit** *organization-unit-name*，配置PKI实体所属的部门名称。

缺省情况下，系统未配置PKI实体所在的部门名称。

----结束

27.11.6.2 配置 RSA 密钥对

背景信息

本地证书是由CA进行数字签名并颁发的。它是公钥与PKI实体身份信息的绑定。因此，申请本地证书时，需先配置RSA密钥对生成公钥和私钥。公钥由PKI实体发送给CA，可以被对端用来加密明文；私钥由PKI实体保留，可以被用来数字签名和解密对端发送过来的密文。

配置RSA密钥对有以下两种方式：

- 创建RSA密钥对

  设备上可以直接创建密钥对，无需再导入密钥对到设备的内存中。

- 导入RSA密钥对

  当需要使用其他PKI实体产生的密钥对时，可以通过FTP/SFTP传到设备上，然后导入密钥对到设备的内存中，否则密钥对不生效。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 请根据实际情况选择配置。

- 创建RSA密钥对

  执行命令**pki rsa local-key-pair create** *key-name* [**modulus** *modulus-size*] [**exportable**]，创建证书申请时使用的RSA密钥对。

- 导入RSA密钥对

  执行命令**pki import rsa-key-pair** *key-name* [**include-cert realm** *realm-name*] { **pem** | **pkcs12** } *file-name* [**exportable**] [**password** *password*]或执行命令**pki import rsa-key-pair** *key-name* **der** *file-name* [**exportable**]，将RSA密钥对和证书导入设备的内存中。

  说明

  仅当配置**exportable**参数时，创建的RSA密钥对才可以被导出。

  由于Windows Server 2003服务器处理能力有限，与该型号服务器对接时，设备上不能配置过多实体信息或携带密钥对位数过大的密钥对，否则可能导致设备与服务器对接失败。

----结束

后续处理

- 当需要备份RSA密钥对或者RSA密钥对给其他设备使用时，可以执行命令**pki export rsa-key-pair** *key-name* [**and-certificate** *certificate-name*] { **pem** *file-name* [**3des** | **aes** | **des**] | **pkcs12** *file-name* } **password** *password*，将RSA密钥对导出到设备的存储介质中，同时支持导出与其关联的证书。然后用户可以通过FTP/SFTP获取RSA密钥对。
- RSA密钥对泄露、损坏、不用或丢失时，可以执行命令**pki rsa local-key-pair destroy** *key-name*，销毁指定的RSA密钥对。

  配置后，系统会销毁设备中对应名称的RSA密钥对，以及备设备中对应名称的RSA密钥对。

- 用户不知道证书所对应的RSA密钥对时，可以执行命令**pki match-rsa-key certificate-filename** *file-name*，查找证书所对应的RSA密钥对。

27.11.6.3 配置为 PKI 实体获取 CA 证书

背景信息

申请本地证书时，PKI实体会将证书注册请求消息发送给CA。为了提高传输过程中的安全性，PKI实体必须使用CA的公钥对证书注册请求消息进行加密保护。因此，PKI实体必须先获取到CA证书，并从CA证书中获取CA的公钥。

说明

设备出厂时已经在**default**域预置了CA和本地证书，可以执行命令**display pki certificate ca realm** *default*查看CA证书信息。

配置流程

PKI实体获取CA证书需要先下载CA证书，然后再安装CA证书。

27.11.6.3.1 配置为 PKI 实体下载 CA 证书

背景信息

下载CA证书有如下几种方式，请根据CA提供的服务方式选择。

- 通过SCEP协议从CA服务器下载CA证书，将CA证书下载到设备的存储介质中。
- 通过HTTP协议从Web服务器上下载CA证书，将CA证书下载到设备的存储介质中。
- 通过CMPv2协议从CMPv2服务器下载CA证书，将CA证书下载到设备的存储介质中。
- 通过带外方式（Web、磁盘、电子邮件等）获得CA证书后，上传到设备的存储介质中。

如果通过CMPv2协议申请本地证书时，这里下载的CA证书为CA服务器的根证书。

操作步骤

- 通过SCEP协议下载CA证书。

  通过SCEP协议下载CA证书的具体配置请参见**27.11.7.1 配置通过SCEP协议为PKI实体申请和更新本地证书**。
- 通过HTTP方式下载CA证书。
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**pki http** [**esc**] *url-address save-name*，配置通过HTTP方式下载CA证书。

     *url-address*必须包含完整的证书文件及扩展名，例如http://10.1.1.1:8080/cert.cer。如果设置为域名方式，必须保证该域名可以正常解析。
- 通过CMPv2协议下载CA证书。

  通过CMPv2协议下载CA证书的具体配置请参见**27.11.7.2 配置通过CMPv2协议为PKI实体申请和更新本地证书**。
- 通过带外方式下载CA证书。

用户通过Web、磁盘、电子邮件等方式获得CA证书后，需要手工上传到设备的存储介质中。也可以选择通过管理PC下载证书后，使用FTP/SFTP或Web方式上传到设备的存储介质中。

----结束

27.11.6.3.2 （可选）配置为 PKI 实体安装 CA 证书

背景信息

下载的CA证书只有导入到设备的内存中才可以正常生效，并且设备会将导入内存证书文件保存到缺省目录下的**ca_config.ini**文件中，在重启后可以自动加载文件中记录的证书文件。

说明

请确保CA证书文件不超过1M，避免安装失败。

配置通过SCEP协议申请本地证书时，设备会自动安装CA证书，无需手动安装CA证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki import-certificate ca realm** *realm-name* { **der** | **pkcs12** | **pem** } [**filename** *filename*] [**replace**] [**no-check-validate**] [**no-check-hash-alg**]或执行命令**pki import-certificate ca realm** *realm-name* **pkcs12 filename** *filename* [**no-check-validate**] [**no-check-hash-alg**] **password** *password*，将CA证书导入到设备的内存中。

步骤3 （可选）执行命令**pki set-certificate expire-prewarning** *day*，配置内存中的CA证书的过期预告警时间。

缺省情况下，内存中的CA证书的过期预告警时间为7天。

----结束

后续处理

- 如果需要把CA证书拷贝到其他设备上使用，可以执行命令**pki export-certificate ca realm** *realm-name* { **der** | **pem** | **pkcs12** } [**filename** *filename*]，将CA证书导出到设备存储介质中。然后，用户可以通过FTP/SFTP取出CA证书。
- 如果需要把系统缺省内置的CA证书拷贝到其他设备上使用，可以执行命令**pki export-certificate default ca filename** *filename*，将系统缺省内置的CA证书导出到设备存储介质中。然后，用户可以通过FTP/SFTP取出CA证书。
- 如果CA证书过期或者不用，可以执行命令**pki delete-certificate ca realm** *realm-name*，从内存中删除CA证书。

27.11.6.4 检查申请本地证书的预配置的配置结果

前提条件

已经完成配置PKI实体信息、RSA密钥对或者CA证书。

操作步骤

- 执行命令**display pki entity** [*entity-name*]，查看PKI实体信息。
- 执行命令**display pki rsa local-key-pair** { **pem** | **pkcs12** } *filename* [**password** *password*]，查看RSA密钥对信息。
- 执行命令**display pki rsa local-key-pair** [**name** *key-name*] **public** [**temporary**]，查看RSA公钥信息。
- 执行命令**display pki realm** [*realm-name*]，查看PKI域的信息。
- 执行命令**display pki certificate ca realm** *realm-name*，查看设备上已加载的CA证书的内容。
- 执行命令**display pki credential-storage-path**，查看证书的缺省保存路径。
- 执行命令**display pki ca-capability realm** *realm-name*，查看PKI域相对应的CA能力。

----结束

27.11.7 申请和更新本地证书

背景信息

说明

设备出厂时已经在**default**域预置了CA和本地证书，可以执行命令**display pki certificate local realm** *default*查看本地证书信息。

前置任务

在申请和更新本地证书之前，需完成**27.11.6 申请本地证书的预配置**。

配置流程

请根据CA提供的服务方式选择配置申请和更新本地证书的方式。

27.11.7.1 配置通过 SCEP 协议为 PKI 实体申请和更新本地证书

背景信息

配置通过SCEP协议为PKI实体申请本地证书，有两种方式：

- 自动触发申请和更新本地证书

  如果本地证书需要的配置信息齐全并且设备没有本地证书时，将自动触发设备通过SCEP协议申请本地证书；或者当证书即将过期、已经过期、已到达指定百分比时，自动触发设备通过SCEP协议申请并更新证书。
- 手动触发申请本地证书

  如果本地证书需要的配置信息齐全并且设备没有本地证书时，将手动触发设备通过SCEP协议申请本地证书，当证书即将过期、已经过期、已到达指定百分比时，不会自动触发设备通过SCEP协议申请并更新证书。

这两种方式申请本地证书时，设备都会先向CA获取CA证书保存到存储介质中并将CA证书自动导入设备的内存中，然后使用CA证书的公钥加密证书注册请求消息并发送给CA

来申请本地证书，获取本地证书保存到存储介质中并将本地证书自动导入设备的内存中。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki file-format** { **der** | **pem** }，配置设备保存证书时的文件格式。

缺省情况下，设备保存证书时的文件格式为PEM。

步骤3 执行命令**pki realm** *realm-name*，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

缺省情况下，设备存在名称为**default**的PKI域，且该域只能修改不能删除。

PKI域是一个本地概念，一个设备上配置的PKI域对CA和其他设备是不可见的，每一个PKI域有单独的参数配置信息。

步骤4 执行命令**ca id** *ca-name*，配置PKI域信任的CA。

缺省情况下，系统未配置PKI域信任的CA。

*ca-name*通常指的是CA服务器的名称。

步骤5 执行命令**entity** *entity-name*，指定申请证书的PKI实体。

缺省情况下，系统未指定申请证书的PKI实体。

*entity-name*是一个已经通过**pki entity**命令创建的PKI实体。

步骤6 执行命令**rsa local-key-pair** *key-name*，配置使用SCEP方式申请证书时使用的RSA密钥对。

缺省情况下，系统未配置使用SCEP方式申请证书时使用的RSA密钥对。

*key-name*是一个已经通过**pki rsa local-key-pair create**命令创建的RSA密钥对。

步骤7 （可选）执行命令**key-usage** { **ike** | **ssl-client** | **ssl-server** } *，配置证书公钥用途属性。

缺省情况下，系统未配置证书公钥用途属性。

步骤8 （可选）执行命令**source** { **interface** *interface-type interface-number* | *ip-address* }，配置建立TCP连接使用的源地址。

缺省情况下，设备使用出接口的IP地址作为建立TCP连接的源地址。

如果指定接口，请确保该接口为三层接口，且接口下已经配置了IP地址。

步骤9 执行命令**enrollment-url** [**esc**] *url* [**interval** *minutes*] [**times** *count*] [**ra**]，配置CA服务器的URL。

缺省情况下，系统未配置CA服务器的URL。

配置时，需注意：

- 未配置**esc**参数时，URL地址格式为**http://*server_location*/*ca_script_location***。

  其中，*server_location*目前支持IP地址和域名解析的表示方式。*ca_script_location*是在CA服务器主机上的应用程序脚本的路径。比如：服务器版本的Windows系统作为CA服务器时，URL的格式为**http://*host*:*port*/certsrv/mscep/mscep.dll**，其

中*host*为CA服务器的IP地址，*port*为CA服务器的端口号。服务器的IP为10.137.145.158，端口为8080时，URL为**http://10.137.145.158:8080/certsrv/mscep/mscep.dll**。

- 配置**esc**参数时，支持以ASCII码形式输入包含“?”的URL地址。

  关键字**esc**作用是支持以ASCII码形式输入包含“?”的URL地址，格式必须为“\x3f”，3f为字符“?”的16进制ASCII码。例如，如果用户想输入“http://***.com?page1”，则对应的URL为“http://***.com\x3fpage1”；如果用户想同时输入“?”和“\x3f”（http://www.***.com?page1\x3f），则对应的URL为“http://www.***.com\x3fpage1\\x3f”。

- 如果在CA服务器使用手工方式处理证书请求，证书发布可能需要较长时间。申请证书的PKI实体需要周期性发送查询，以便在证书颁发后能够及时获取到证书。此时，可以增大**interval**和**times**参数来调整注册证书状态查询的时间间隔和最大查询次数。
- 配置**ra**参数时，指定RA审核PKI实体申请本地证书时的身份信息。缺省情况下，CA审核PKI实体申请本地证书时的身份信息。

步骤10 执行命令**enrollment-request signature message-digest-method** { **md5** | **sha1** | **sha-256** | **sha-384** | **sha-512** }，配置签名证书注册请求消息使用的摘要算法。

缺省情况下，签名证书注册请求消息使用的摘要算法为**sha-256**。

md5和SHA1算法为不安全算法，建议使用SHA2算法。

PKI实体使用的摘要算法必须与CA服务器上的摘要算法一致。

步骤11 执行命令**password cipher** *password*，配置SCEP证书申请时使用的挑战密码，也是证书撤销密码。

缺省情况下，系统未配置SCEP证书申请时使用的挑战密码。

PKI实体使用的挑战密码必须与CA服务器上设置的密码一致。如果CA服务器不要求使用挑战密码，则不用配置挑战密码。

步骤12 执行命令**fingerprint** { **md5** | **sha1** | **sha256** } *fingerprint*，配置对CA证书进行验证时使用的CA证书数字指纹。

缺省情况下，系统未配置对CA证书进行验证时使用的CA证书数字指纹。

*fingerprint*参数需要通过离线的方式从CA服务器上获取。例如，当Windows Server 2008作为CA服务器时，可以通过登录网页http://host:port/certsrv/mscep_admin/获得CA证书指纹信息，其中host为CA服务器的IP地址，port为CA服务器的端口号。

步骤13 配置申请和更新本地证书的方式，请根据情况选择配置。

- 配置自动触发申请和更新本地证书。

  执行命令**auto-enroll** [*percent*] [**regenerate** [*key-bit*]] [**updated-effective**]，开启证书自动注册和更新功能。

  缺省情况下，证书自动注册和更新功能处于关闭状态。

- 配置手动触发申请本地证书。

  a. 执行命令**quit**，返回至系统视图。

  b. 执行命令**pki enroll-certificate realm** *realm-name* [**password** *password*]，配置手工触发设备申请证书。

如果配置了**password**命令，这里的**password**参数可以不用。如果都配置，这里配置的**password**优先级高。

----结束

27.11.7.2 配置通过 CMPv2 协议为 PKI 实体申请和更新本地证书

背景信息

当设备可以访问CA，并且CA支持CMPv2协议时，可选择此方式申请和更新本地证书。

通过CMPv2协议申请本地证书有两种情况：

- 首次申请本地证书IR（Initialization Request）

  首次证书申请适用于设备第一次向CA申请证书的情况。在这种情况下，设备提供以下两种向CMPv2服务器进行身份认证的方式。

  - 消息认证码方式：设备和CMPv2服务器共享一对消息认证码的参考值和秘密值。在进行首次证书申请的时候，设备会将这对参考值和秘密值加入到请求报文当中发送到CMPv2服务器，CMPv2服务器通过验证参考值和秘密值来鉴定设备的身份。
  - 签名方式：通过CMPv2协议的IR请求，向CA发起证书请求时，设备使用其他CA颁发的证书相对应的私钥来签名保护。

- 为其他设备申请本地证书CR（Certification Request）

  证书申请适用于当设备已经有了CA所颁发的本地证书，而需要申请额外的证书的情况。在这种情况下，设备会使用已经有的证书作为身份认证的手段。

通过CMPv2协议更新本地证书有两种方式：

- 手工更新证书，即密钥更新请求KUR（Key Update Request）

  密钥更新请求又称为证书更新请求，是对设备已有的证书（尚未过期且没有被吊销）进行更新操作。在更新过程中，使用现有的证书作为身份认证的手段。更新操作可以使用新的公钥，也可以使用原来的公钥。

  通过IR方式申请本地证书，安全性较低，建议通过KUR方式更新本地证书及密钥对。

- 自动更新证书

  为了避免业务的中断，在有效期截止前必须申请新的证书，而使用手工更新证书的方式容易出现忘记更新证书的情况。设备支持证书的自动更新功能，当系统检测到时间超过了设置的证书自动更新时间之后，会自动向CMPv2服务器发起证书的更新请求。申请的新证书会同时替换存储介质中的证书文件和内存中对应的证书，业务不会中断。

  此方式可以对IR方式申请的本地证书或KUR方式更新的本地证书进行自动更新。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki file-format** { **der** | **pem** }，配置设备保存证书时的文件格式。

缺省情况下，设备保存证书时的文件格式为PEM。

步骤3 执行命令**pki realm** *realm-name*，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

缺省情况下，系统未创建PKI域。

步骤4 执行命令**quit**，返回至系统视图。

步骤5 执行命令**pki cmp session** *session-name*，创建CMP会话并进入CMP会话视图，或者直接进入CMP会话视图。

缺省情况下，系统未创建CMP会话。

CMP会话是一个本地概念，一个设备上配置的CMP会话对CA和其他设备是不可见的。

步骤6 执行命令**cmp-request entity** *entity-name*，配置设备使用CMPv2方式申请证书时使用的PKI实体名称。

缺省情况下，系统未配置CMPv2方式申请证书时使用的PKI实体名称。

步骤7 执行命令**cmp-request ca-name** *ca-name*，为CMP会话配置CA的名称。

缺省情况下，系统未配置CMP会话下的CA名称。

配置的CA名称中各个字段的顺序必须要和实际CA证书中的顺序保持一致，否则CMPv2服务器会认为是错误的。

步骤8 执行命令**cmp-request server url** [**esc**] *url-addr*，配置CMPv2服务器的URL。

缺省情况下，系统未配置CMPv2服务器的URL。

*url-addr*可以设置为IP地址形式或域名形式，如果设置为域名形式，必须在PKI实体上正确配置DNS，使PKI实体可以通过DNS服务器解析域名。

步骤9 执行命令**cmp-request rsa local-key-pair** *key-name* [**regenerate** [*key-bit*]]，配置CMPv2方式申请证书时使用的RSA密钥对。

缺省情况下，系统未配置CMPv2方式申请证书时使用的RSA密钥对。

如果配置了**regenerate**参数，则证书自动更新时，系统会生成新的RSA密钥对去申请新证书，并且用新的证书和RSA密钥对替换原有的证书和RSA密钥对。否则证书自动更新时，系统会继续使用原来的RSA密钥对。

步骤10 执行命令**cmp-request realm** *realm-name*，配置使用CMPv2方式申请证书时使用的域名称。

缺省情况下，系统未配置CMPv2方式申请证书时使用的PKI域。

步骤11 （可选）执行命令**cmp-request verification-cert** *cert-file-name*，配置验证CA响应签名的证书文件。

缺省情况下，系统未配置验证CA响应签名的证书文件。

- 如果配置了此命令，并且服务器的响应报文是签名的方式时，则设备使用该命令行配置的证书来验证服务器的响应签名。此处配置的证书为CA证书，即CA自身的证书。
- 如果未配置此命令，并且服务器的响应报文是签名的方式时，则依据设备以及服务器响应中的证书构建证书链，验证服务器的响应签名；如果服务器使用消息认证码方式做保护时，则设备使用配置的消息认证码来验证服务器的响应报文，不受该命令配置影响。

步骤12 请根据实际情况选择配置来申请本地证书。

- 首次申请本地证书（IR）

a. 执行命令**cmp-request origin-authentication-method** { **message-authentication-code** | **signature** }，配置使用CMPv2协议进行首次证书申请（IR）的认证方式。

缺省情况下，使用CMPv2协议进行首次证书申请（IR）的认证方式为消息认证码方式。

- **message-authentication-code**表示消息认证码方式。选择此方式时请执行**步骤12.b**。
- **signature**表示签名方式。选择此方式时请执行**步骤12.c**。

b. 执行命令**cmp-request message-authentication-code** *reference-value secret-value*，配置消息认证码的参考值和秘密值。

缺省情况下，系统未配置消息认证码的参考值和秘密值。

消息认证码的参考值和秘密值，需要用户以带外方式从CMPv2服务器上获取。

c. 执行命令**cmp-request authentication-cert** *cert-name*，配置CMPv2请求中用于证明身份的证书。

缺省情况下，系统未配置CMPv2请求中用于证明身份的证书。

此证书是额外证书，并且必须由受CA信任的证书申请机构为设备颁发。

d. 执行命令**quit**，返回至系统视图。

e. 执行命令**pki cmp initial-request session** *session-name*，根据CMP会话的配置信息向CMPv2服务器进行首次证书申请（IR）。

配置后，系统首先会检查CMP会话中的配置是否可以进行证书申请。如果条件不满足，会给出错误的提示信息。如果条件满足，会依据配置内容发起首次证书请求。申请下来的证书将以文件的形式保存到存储介质中，不会执行导入内存的操作。同时，若服务器端在响应中给出CA证书，则CA证书也会以文件形式保存起来。

- 为其他设备申请本地证书（CR）

a. 执行命令**cmp-request authentication-cert** *cert-name*，配置CMPv2请求中用于证明身份的证书。

缺省情况下，系统未配置CMPv2请求中用于证明身份的证书。

此证书是CA已经颁发给设备的本地证书。

b. 执行命令**quit**，返回至系统视图。

c. 执行命令**pki cmp certificate-request session** *session-name*，根据CMP会话的配置信息向CMPv2服务器进行证书申请（CR）。

配置后，系统首先会检查CMP会话中的配置是否可以进行证书更新申请。如果条件不满足，会给出错误的提示信息。如果条件满足，会依据配置内容发起证书更新请求。申请下来的证书将以文件的形式保存到存储介质中，不会执行导入内存的操作。

步骤13 请根据实际情况选择配置来更新本地证书。

- 手工更新本地证书（KUR）

a. 执行命令**pki cmp session** *session-name*，直接进入CMP会话视图。

b. 执行命令**cmp-request authentication-cert** *cert-name*，配置CMPv2请求中用于证明身份的证书。

缺省情况下，系统未配置CMPv2请求中用于证明身份的证书。

此证书是CA已经颁发给设备的本地证书，同时也是将要被更新的本地证书。

c. 执行命令**quit**，返回至系统视图。

d. 执行命令**pki cmp keyupdate-request session** *session-name*，根据CMP会话的配置信息向CMPv2服务器进行密钥更新请求（KUR）。

向CMPv2服务器进行密钥更新请求时，同时也会重新申请本地证书。

配置后，系统首先会检查CMP会话中的配置是否可以进行证书更新申请。如果条件不满足，会给出错误的提示信息。如果条件满足，会依据配置内容发起证书更新请求。申请下来的证书将以文件的形式保存到存储介质中，不会执行导入内存的操作。

- 自动更新证书

a. 执行命令**pki cmp session** *session-name*，直接进入CMP会话视图。

b. 执行命令**cmp-request authentication-cert** *cert-name*，配置CMPv2请求中用于证明身份的证书。

缺省情况下，系统未配置CMPv2请求中用于证明身份的证书。

此证书是CA已经颁发给设备的本地证书，同时也是将要被更新的本地证书。

c. 执行命令**certificate auto-update enable**，开启使用CMPv2方式自动更新证书功能。

缺省情况下，使用CMPv2方式自动更新证书功能处于关闭状态。

d. 执行命令**certificate update expire-time** *valid-percent*，配置证书自动更新的时间，以当前使用证书有效期的百分比形式体现。

缺省情况下，证书更新时间的默认百分比是50%。

配置后，当系统检测到时间达到*valid-percent*时，会自动发起证书更新请求，并依据**cmp-request rsa local-key-pair**命令的配置决定是否创建新的RSA密钥对。申请到新的证书后，系统会使用新的证书和RSA密钥对替换原有的证书和RSA密钥对。

e. 执行命令**quit**，返回至系统视图。

步骤14 （可选）执行命令**undo pki cmp poll-request session** *session-name*，取消正在进行的CMP轮询请求。

当客户端发起证书相关的请求时，如果服务器不能够马上给出结果，服务器会让客户端每隔一段时间发起一次轮询请求，直到给出最终的结果为止。如果用户不想继续等待，可以取消正在进行的CMP轮询请求，从而取消本次的证书申请操作。

----结束

27.11.7.3 配置为 PKI 实体离线申请本地证书

背景信息

如果CA服务器不支持SCEP和CMPv2协议，可以配置离线申请本地证书。用户在设备上生成证书请求文件，然后通过Web、磁盘、电子邮件等带外方式将证书申请文件发送给CA，向CA申请本地证书。完成申请后，还需从存放本地证书的服务器上下载证书，保存到设备的存储介质中。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki realm** *realm-name*，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

缺省情况下，设备存在名称为**default**的PKI域，且该域只能修改不能删除。

PKI域是一个本地概念，一个设备上配置的PKI域对CA和其他设备是不可见的，每一个PKI域有单独的参数配置信息。

步骤3 执行命令**entity** *entity-name*，指定申请证书的PKI实体。

缺省情况下，系统未指定申请证书的PKI实体。

*entity-name*是一个已经通过**pki entity**命令创建的PKI实体。

步骤4 执行命令**rsa local-key-pair** *key-name*，配置使用离线方式申请证书时使用的RSA密钥对。

缺省情况下，系统未配置使用离线方式申请证书时使用的RSA密钥对。

步骤5 执行命令**enrollment-request signature message-digest-method** { **md5** | **sha1** | **sha-256** | **sha-384** | **sha-512** }，配置签名证书注册请求消息使用的摘要算法。

缺省情况下，签名证书注册请求消息使用的摘要算法为**sha-256**。

md5和SHA1算法为不安全算法，建议使用SHA2算法。

PKI实体使用的摘要算法必须与CA服务器上的摘要算法一致。

步骤6 （可选）执行命令**key-usage** { **ike** | **ssl-client** | **ssl-server** } *，配置证书公钥用途属性。

缺省情况下，系统未配置证书公钥用途属性。

步骤7 执行命令**quit**，返回至系统视图。

步骤8 执行命令**pki file-format** { **der** | **pem** }，配置设备保存证书和证书请求时的文件格式。

缺省情况下，设备保存证书和证书请求时的文件格式为PEM。

步骤9 执行命令**pki enroll-certificate realm** *realm-name* **pkcs10** [**filename** *filename*] [**password** *password*]，配置以PKCS#10格式保存证书申请信息到文件中。

PKI实体使用的挑战密码必须与CA服务器上设置的密码一致。如果CA服务器不要求使用挑战密码，则不用配置挑战密码。

步骤10 通过Web、磁盘、电子邮件等带外方式将证书申请文件发送给CA，向CA申请本地证书。

----结束

27.11.7.4 检查申请和更新本地证书的配置结果

前提条件

已经完成申请和更新本地证书的所有配置。

操作步骤

- 执行命令**display pki realm** [*realm-name*]，查看PKI域的信息。

- 执行命令**display pki credential-storage-path**，查看证书的缺省保存路径。
- 执行命令**display pki certificate enroll-status** [**realm** *realm-name*]，查看证书的注册状态。
- 执行命令**display pki cert-req filename** *file-name*，查看证书请求文件的内容。
- 执行命令**display pki cmp statistics** [**session** *session-name*]，查看CMP会话的统计信息。
- 执行命令**display pki certificate** { **ca** | **local** } **realm** *realm-name*，查看设备上已加载的CA证书和本地证书的内容。

----结束

27.11.8 （可选）下载本地证书

背景信息

通过SCEP或CMPv2协议申请本地证书时，设备会自动下载本地证书。仅当离线申请本地证书时，才需要下载本地证书。

通常采用以下方式获得本地证书，设备采用哪种方式下载证书，取决于CA服务器提供的服务方式：

- 通过HTTP协议从Web服务器上下载本地证书，将本地证书下载到设备的存储介质中。
- 通过带外方式（Web、磁盘、电子邮件等）获得本地证书后，上传到设备的存储介质中。

前置任务

已经完成本地证书的离线申请，本地证书已经在CA上注册成功。

操作步骤

- 通过HTTP方式下载本地证书。
  a. 执行命令**system-view**，进入系统视图。
  b. 执行命令**pki http** [**esc**] *url-address save-name*，配置通过HTTP方式下载本地证书。

     *url-address*必须包含完整的证书文件及扩展名，例如http://10.1.1.1:8080/cert.cer。如果设置为域名方式，必须保证该域名可以正常解析。
- 通过带外方式下载本地证书。

  用户通过Web、磁盘、电子邮件等方式获得本地证书后，需要手工上传到设备的存储介质中。也可以选择通过管理PC下载证书后，使用FTP/SFTP或Web方式上传到设备的存储介质中。

----结束

检查配置结果

- 执行命令**display pki credential-storage-path**，查看证书的缺省保存路径。
- 执行命令**dir（用户视图）**，查看存储器中的本地证书文件。

27.11.9 （可选）安装本地证书

背景信息

下载的本地证书只有导入到设备的内存中才可以正常生效，并且设备会将导入内存证书文件保存到缺省目录下的**ca_config.ini**文件中，在重启后可以自动加载文件中记录的证书文件。

前置任务

已经完成本地证书的下载，证书文件已经保存到设备的存储介质中。

说明

请确保本地证书文件不超过1M，避免安装失败。

当通过CMPv2协议或离线申请本地证书时，需要手动安装本地证书。设备通过SCEP协议申请本地证书会自动安装本地证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki import-certificate local realm** *realm-name* { **der** | **pkcs12** | **pem** } [**filename** *filename*] [**no-check-validate**] [**no-check-hash-alg**]或执行命令**pki import-certificate local realm** *realm-name* **pkcs12 filename** *filename* [**no-check-validate**] [**no-check-hash-alg**] **password** *password*，将本地证书导入到设备的内存中。

证书及其密钥对有两种存在形式，一种是证书文件中包含密钥对文件，两者以一个文件的形式存在；另一种是证书和密钥对相互独立以两个文件形式存在。不同形式下，将其导入内存所使用的方法不同。

- 证书文件中包含密钥对文件。

  执行命令**pki import rsa-key-pair**一次导入证书文件和密钥对文件。

  说明

  证书文件中包含密钥对文件时，执行命令**pki import-certificate**只能导入证书文件，密钥对文件不会被导入。如果需要导入密钥对文件，可执行命令**pki import rsa-key-pair**将密钥对继续导入。

- 证书文件和密钥对文件独立存在。

  a. 导入证书文件。

     执行命令**pki import-certificate**导入证书文件。

  b. 导入密钥对文件。

     执行命令**pki import rsa-key-pair**导入密钥对文件。

说明

若用户无法辨别待导入证书的格式，可依次配置不同格式并检查是否成功导入证书。若不指定待导入证书的格式，系统将自行识别导入。

步骤3 （可选）执行命令**pki set-certificate expire-prewarning** *day*，配置内存中的本地证书的过期预告警时间。

缺省情况下，内存中的本地证书的过期预告警时间为7天。

----结束

后续处理

- 如果需要把本地证书拷贝到其他设备上使用，可以执行命令**pki export-certificate local realm** *realm-name* { **pem** | **pkcs12** } [**filename** *filename* [**password** *password*]]或者**pki export-certificate local realm** *realm-name* **der** [**filename** *filename*]，将本地证书导出到设备的存储介质中。然后，用户可以通过FTP/SFTP取出本地证书。
- 如果需要把系统缺省内置的本地证书拷贝到其他设备上使用，可以执行命令**pki export-certificate default local filename** *filename*，将系统缺省内置的本地证书导出到设备存储介质中。然后，用户可以通过FTP/SFTP取出本地证书。

检查配置结果

执行命令**display pki certificate local realm** *realm-name*，查看设备上已加载的本地证书的内容。

27.11.10 验证 CA 证书和本地证书

前置任务

在验证证书之前，需完成**27.11.9 （可选）安装本地证书**。

配置流程

请按照以下顺序进行配置。对于可选步骤，请根据情况选择配置。

27.11.10.1 配置检查本地证书状态

背景信息

当验证对端实体的本地证书时，经常需要检查对端实体的本地证书是否有效，例如对端实体的本地证书是否过期、是否被加入CRL。通常检查证书状态的方式有三种：CRL方式、OCSP方式、None方式。

- CRL方式

  如果CA支持作为CRL发布点CDP（CRL Distribution Point），则当CA颁发证书时，在证书中会包含CDP信息，用以描述获取该证书CRL的途径和方式。PKI实体利用CDP中指定的机制（HTTP方式）和地址来下载CRL。

  如果PKI实体配置了CDP的URL地址，该地址将覆盖证书中携带的CDP信息，PKI实体使用配置的URL来获取CRL。如果CA不支持作为CDP，则PKI实体可以使用SCEP方式下载CRL。

  当PKI实体验证本地证书时，先查找本地内存的CRL，如果本地内存没有CRL，则需下载CRL并安装到本地内存中，如果对端实体的本地证书在CRL中，表示此证书已被撤销。
- OCSP方式

  在IPSec场景中，PKI实体间使用证书方式进行IPSec协商时，可以通过OCSP方式实时检查对端实体的证书状态。

OCSP克服了CRL的主要缺陷：PKI实体必须经常下载CRL以确保列表的更新。当PKI实体访问OCSP服务器时，会发送一个对于证书状态信息的请求。OCSP服务器会回复一个“有效”、“过期”或“未知”的响应。

- 有效表示证书没有被撤销。
- 过期表示证书已被撤销。
- 未知表示OCSP服务器不能判断请求的证书状态。

- None方式

  如果PKI实体没有可用的CRL和OCSP服务器，或者不需要检查PKI实体的本地证书状态，可以采用None方式，即不检查证书是否被撤销。

操作步骤

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**pki realm** *realm-name*，创建PKI域并进入PKI域视图，或者直接进入PKI域视图。

   缺省情况下，设备存在名称为**default**的PKI域，且该域只能修改不能删除。
3. 执行命令**certificate-check** { { **crl** | **ocsp** } * [**none**] | **none** }，配置PKI域中证书吊销状态的检查方式。

   缺省情况下，PKI域中证书吊销状态的检查方式为CRL。

   如果配置了多种吊销状态的检查方式，会按照配置的先后顺序执行，当前一种方式不可用（如服务器连接不上）时才会使用后边的方式。如果选用了不检查（none），当前面配置的方式均不可用时，认为证书有效。以配置了**certificate-check crl ocsp none**命令为例，先使用CRL方式检查证书是否有效，如果CRL方式不可用，使用OCSP方式，如果两种方式都不可用，则认为证书是有效的。
4. 请根据CA提供的服务方式选择配置检查对端实体本地证书状态的方式。
   - **自动更新CRL方式**
   - **手动更新CRL方式**
   - **OCSP方式**

自动更新 CRL 方式

1. 执行命令**quit**，返回至系统视图。
2. （可选）执行命令**pki file-format** { **der** | **pem** }，配置设备保存CRL时的文件格式。

   缺省情况下，设备保存CRL时的文件格式为PEM。
3. 执行命令**pki realm** *realm-name*，直接进入PKI域视图。
4. 执行命令**crl auto-update enable**，开启CRL自动更新功能。

   缺省情况下，CRL自动更新功能处于开启状态。
5. 执行命令**crl update-period** *interval*，配置CRL自动更新的时间间隔。

   缺省情况下，CRL自动更新的时间间隔为8小时。
6. 请根据CA提供的服务方式选择配置自动更新CRL方式。
   - 通过SCEP方式自动更新CRL。
     i. 执行命令**crl scep**，配置使用SCEP方式自动更新CRL。

        缺省情况下，使用HTTP方式自动更新CRL。

ii. 执行命令**cdp-url** [**esc**] *url-addr*，配置CRL发布点的URL。

缺省情况下，系统未配置CRL发布点的URL。

– 通过HTTP方式自动更新CRL。

i. 执行命令**crl http**，配置使用HTTP方式自动更新CRL。

缺省情况下，使用HTTP方式自动更新CRL。

ii. 执行命令**cdp-url** [**esc**] *url-addr*，配置CRL发布点的URL。或者执行命令**cdp-url from-ca**，配置从CA证书中获取CDP URL。

缺省情况下，系统未配置CRL发布点的URL。

7. 执行命令**crl cache**，配置允许PKI域使用缓存中的CRL。

缺省情况下，系统允许PKI域使用缓存中的CRL。

8. （可选）立即更新CRL。

a. 执行命令**quit**，返回至系统视图。

b. 执行命令**pki get-crl realm** *realm-name*，立即更新CRL。

立即更新CRL后，新的CRL会替换设备存储介质中原来的CRL，同时新的CRL也会被自动导入设备内存中替换原来的CRL。

手动更新 CRL 方式

1. 执行命令**quit**，返回至系统视图。
2. （可选）执行命令**pki file-format** { **der** | **pem** }，配置设备保存CRL时的文件格式。

缺省情况下，设备保存CRL时的文件格式为PEM。

3. 执行命令**pki http** [**esc**] *url-address save-name*，配置通过HTTP方式下载CRL。

*url-address*必须包含完整的证书文件及扩展名，例如http://10.1.1.1:8080/cert.cer。如果设置为域名方式，必须保证该域名可以正常解析。

4. 执行命令**pki import-crl realm** *realm-name* **filename** *file-name*，将CRL导入设备的内存中。

OCSP 方式

1. （可选）执行命令**source** { **interface** *interface-type interface-number* | *ip-address* }，配置建立TCP连接使用的源地址。

缺省情况下，设备使用出接口的IP地址作为建立TCP连接的源地址。

如果指定接口，请确保该接口为三层接口，且接口下已经配置了IP地址。

2. 执行命令**ocsp url** [**esc**] *url-address*，配置OCSP服务器的URL。或者执行命令**ocsp-url from-ca**，配置从CA证书的AIA选项中获取OCSP服务器的URL。

缺省情况下，系统未配置OCSP服务器的URL。

3. （可选）执行命令**ocsp nonce enable**，配置PKI实体发送OCSP请求时带有Nonce扩展。

缺省情况下，PKI实体发送OCSP请求时带有Nonce扩展。

通过该功能可以增强PKI实体与OCSP服务器通信时的安全性和可靠性。配置后，PKI实体与OCSP服务器通信时发送的OCSP请求中带有Nonce扩展，内容为随机数。对于OCSP服务器发出的响应报文，可以不包含Nonce扩展，但是如果包含了Nonce扩展，则必须与OCSP请求中的Nonce扩展一致。

4. （可选）执行命令**ocsp signature enable**，开启OCSP请求消息签名功能。

   缺省情况下，OCSP请求消息签名功能处于关闭状态。

   如果OCSP服务器要求对OCSP请求消息进行签名验证，设备需要配置本命令。
5. 执行命令**quit**，返回至系统视图。
6. 执行命令**pki import-certificate ocsp realm** *realm-name* { **der** | **pkcs12** | **pem** } [**filename** *filename*] 或执行命令**pki import-certificate ocsp realm** *realm-name* **pkcs12 filename** *filename* **password** *password*，将OCSP服务器证书导入到设备的存中。
7. 执行命令**pki validate ocsp-server-certificate enable**，开启OCSP证书校验OCSP服务器报文的功能。

   缺省情况下，OCSP证书校验OCSP服务器报文的功能处于关闭状态。
8. 执行命令**pki ocsp response cache enable**，开启PKI实体缓存OCSP响应的功能。

   缺省情况下，PKI实体缓存OCSP响应的功能处于关闭状态。

   开启缓存OCSP响应功能后，PKI实体在使用OCSP检查证书的吊销状态时，会先查找缓存，如果查找失败则再向OCSP服务器发起请求。同时，PKI实体会将有效的OCSP响应缓存起来，以便下次查找。

   OCSP响应是有生效期限的，开启缓存OCSP响应功能后，PKI实体会每隔1分钟刷新缓存的OCSP响应，清除其中过期的OCSP响应。
9. （可选）执行命令**pki ocsp response cache number** *number*，配置PKI实体可以缓存的OCSP响应的最大数量。

   缺省情况下，PKI实体可以缓存的OCSP响应的最大数量是2。
10. （可选）执行命令**pki ocsp response cache refresh interval** *interval*，配置PKI实体刷新OCSP响应缓存的周期。

    缺省情况下，PKI实体刷新OCSP响应缓存的周期为5分钟。

后续处理

- 如果需要把OCSP服务器证书拷贝到其他设备上使用时，可以执行命令**pki export-certificate ocsp realm** *realm-name* { **der** | **pem** | **pkcs12** } [**filename** *filename*]，将OCSP服务器证书导出到设备的存储介质中。然后，可以通过文件传输协议取出证书。
- 如果OCSP服务器证书过期或者不使用时，可以执行命令**pki delete-certificate ocsp realm** *realm-name*，从内存中删除OCSP服务器证书。
- 如果CRL过期或者不使用时，可以执行命令**pki delete-crl realm** *realm-name*，从内存中删除CRL。

27.11.10.2 配置检查 CA 证书和本地证书有效性

背景信息

在使用每一个证书之前，必须对证书进行验证以确保证书的合法性。证书验证包括对签发时间、签发者信息以及证书的有效性几方面进行验证。证书验证的核心是检查CA在证书上的签名，并确定证书仍在有效期内，而且未被撤销。

为完成证书验证，除了需要对端实体的本地证书外，本地设备需要下面的信息：CA证书、CRL、本地证书及其私钥及证书认证相关配置信息。

本地证书验证的主要过程如下：

1. 使用CA证书的公钥验证CA的签名是否正确。

   为验证一个证书的合法性，首先需要获得颁发这个证书的CA的公钥（即获得CA证书），以便检查该证书上CA的签名。一个CA可以让另一个更高层次的CA来证明其证书的合法性，这样顺着证书链，验证证书就变成了一个迭代过程，最终这个链必须在某个“信任点”（一般是持有自签名证书的根CA或者是PKI实体信任的中间CA）处结束。

   任何PKI实体，如果它们共享相同的根CA或子CA，并且已获取CA证书，都可以验证对端证书。一般情况下，当验证对端证书链时，验证过程在碰到第一个可信任的证书或CA机构时结束。

   证书链的验证过程是一个从目标证书（待验证的PKI实体证书）到信任点证书逐层验证的过程。

2. 根据证书的有效期，验证证书是否过期。
3. 检查证书的状态，即通过CRL和None方式检查证书是否被撤销。

当用户需要验证本地设备的CA证书和本地证书的有效性时，可以执行以下步骤。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki validate-certificate** { **ca** | **local** } **realm** *realm-name*，检查CA证书或本地证书的有效性。

pki validate-certificate ca命令只能验证根CA的CA证书有效性，不能验证从属CA的CA证书有效性。在多级CA的环境中，当设备上导入了多个CA证书时，只能使用**pki validate-certificate local**命令来验证从属CA的CA证书有效性。

----结束

27.11.10.3 检查验证 CA 证书和本地证书的配置结果

前提条件

已经完成验证CA证书和本地证书的所有配置。

操作步骤

- 执行命令**display pki realm** [*realm-name*]，查看PKI域的信息。
- 执行命令**display pki crl** { **realm** *realm-name* | **filename** *filename* }，查看设备中的CRL内容。
- 执行命令**display pki certificate ocsp realm** *realm-name*，查看设备上已加载的OCSP服务器证书的内容。
- 执行命令**display pki ocsp cache statistics**，查看OCSP响应缓存的统计信息。
- 执行命令**display pki ocsp server down-information**，查看设备上记录的OCSP服务器DOWN状态信息。

----结束

27.11.11 删除本地证书

背景信息

本地证书过期或者重新申请新的证书时，可以删除本地证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki delete-certificate local realm** *realm-name*，从内存中删除本地证书。

----结束

27.11.12 配置 PKI 扩展功能

27.11.12.1 配置获取证书

背景信息

当PKI实体通过SCEP协议申请本地证书时，PKI实体可以向CA服务器查询并获取已颁发的CA证书至设备存储介质中。

获取CA证书时，设备会自动将CA证书导入到设备内存中。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki get-certificate** { **ca** | **local** } **realm** *realm-name*，获取证书至设备的存储介质中。

如果设备中存在相同的证书，则需要删除设备中的证书，否则会导致获取证书失败。

----结束

27.11.12.2 配置自签名证书或设备本地证书

背景信息

如果设备无法向CA申请本地证书，可以通过设备生成自签名证书或设备本地证书后，生成的证书以文件形式保存在存储器中，实现简单的证书颁发功能。用户可以将证书导出供其他设备使用。

- 自签名证书是设备为自己颁发的证书，即证书颁发者和证书主体相同。
- 设备本地证书是设备根据CA证书给自己颁发的证书，证书颁发者是CA。

说明

设备不支持对其生成的自签名证书进行生命周期管理（如证书更新、证书撤销等），为了确保设备和证书的安全，建议用户替换为自己的本地证书。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**pki create-certificate** [**self-signed**] **filename** *file-name*，创建自签名证书或设备本地证书。

配置时，会提示用户输入证书的一些信息，比如PKI实体属性、证书文件名称、证书有效期和RSA密钥长度等。

指定**self-signed**参数时，创建自签名证书。不指定此参数时，创建设备本地证书。

创建的自签名证书或设备本地证书的文件格式为PEM。

----结束

27.11.13 维护 PKI

27.11.13.1 查看 PKI 信息

背景信息

在日常维护工作中，了解PKI相关信息时，可以在对应视图下选择执行以下命令查看证书等信息。

操作步骤

- 执行命令**display pki certificate enroll-status** [**realm** *realm-name*]，查看证书的注册状态。
- 执行命令**display pki cmp statistics** [**session** *session-name*]，查看CMP会话的统计信息。
- 执行命令**display pki ocsp cache statistics**，查看OCSP响应缓存的统计信息。
- 执行命令**display pki ocsp server down-information**，查看设备上记录的OCSP服务器DOWN状态信息。
- 执行命令**display pki certificate** { **ca** | **local** | **ocsp** } **realm** *realm-name*，查看设备上已加载的CA证书、本地证书或者OCSP服务器证书的内容。
- 执行命令**display pki certificate default** { **ca** | **local** }，查看设备上缺省的CA证书和本地证书的内容。
- 执行命令**display pki ocsp cache detail**，查看OCSP响应缓存的详细信息。

----结束

27.11.13.2 清除 PKI 信息

背景信息

清空PKI信息后，以前的信息将无法恢复，务必仔细确认。请在用户视图下执行以下命令。

操作步骤

- 执行命令**reset pki cmp statistics** [**session** *session-name*]，清除CMP会话的统计信息。
- 执行命令**reset pki ocsp response cache**，清除OCSP响应缓存。
- 执行命令**reset pki ocsp server down-information** [**url** [**esc**] *url-addr*]，清除设备上记录的OCSP服务器DOWN状态信息。

----结束

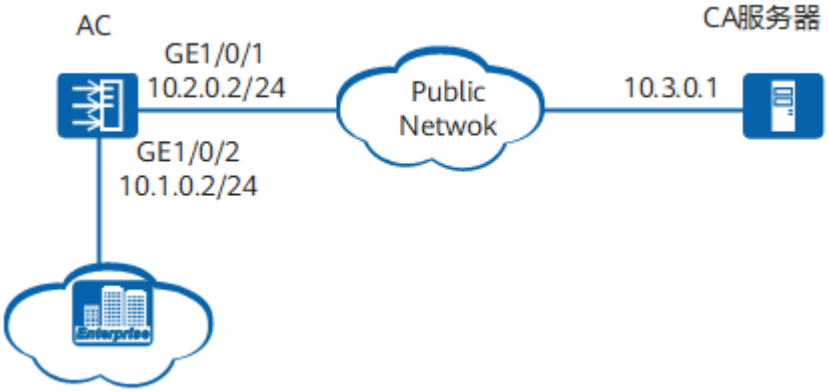
27.11.14 PKI 配置举例

27.11.14.1 配置通过 CMPv2 协议为 PKI 实体首次申请本地证书示例

组网需求

如图27-47所示，某企业在网络边界处部署了AC作为出口网关，AC使用CMPv2协议向公网上的CA服务器在线首次申请证书，申请成功后自动将本地证书下载到设备存储介质中。

图 27-47 配置通过 CMPv2 协议为 PKI 实体首次申请本地证书组网图



说明

本举例只列出了申请证书时AC侧的相关配置，CA服务器的部署和配置请参见相关产品手册。

配置思路

采用如下思路配置通过CMPv2协议为PKI实体首次申请本地证书：

1. 配置接口的IP地址及到CA服务器的静态路由，实现AC和CA服务器之间路由互通。
2. 创建RSA密钥对，实现申请本地证书时携带公钥。
3. 配置PKI实体，实现申请本地证书时携带PKI实体信息用来标识PKI实体的身份。
4. 通过CMPv2协议申请和自动更新证书，并使用消息认证码来验证消息，实现自动下载CA和本地证书。
5. 安装CA和本地证书，实现证书生效，即设备可以使用证书来保护通信。

数据准备

为完成此配置示例，需准备如下的数据：

- CA名称
  为CA证书的主题字段。
- 消息认证码的参考值和秘密值
  需要以带外方式从CMPv2服务器上获取消息认证码的参考值和秘密值。

操作步骤

步骤1 配置接口的IP地址及到CA服务器的静态路由。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] interface gigabitethernet 1/0/1
[AC-GigabitEthernet1/0/1] ip address 10.2.0.2 255.255.255.0
[AC-GigabitEthernet1/0/1] quit
[AC] interface gigabitethernet 1/0/2
[AC-GigabitEthernet1/0/2] ip address 10.1.0.2 255.255.255.0
[AC-GigabitEthernet1/0/2] quit
[AC] ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
```

步骤2 创建RSA密钥对。

创建一个2048位的RSA密钥对rsa_cmp，并设置为可以从设备上导出。

```
[AC] pki rsa local-key-pair create rsa_cmp exportable
 Info: The name of the new key-pair will be: rsa_cmp
 The size of the public key ranges from 2048 to 4096.
 Input the bits in the modules:2048
 Generating key-pairs...
...........+++
...........+++
```

步骤3 配置PKI实体，标识申请证书PKI实体的身份信息。

配置PKI实体为user01。

```
[AC] pki entity user01
[AC-pki-entity-user01] common-name hello
[AC-pki-entity-user01] country cn
[AC-pki-entity-user01] email user@test.abc.com
[AC-pki-entity-user01] fqdn test.abc.com
[AC-pki-entity-user01] ip-address 10.2.0.2
[AC-pki-entity-user01] state jiangsu
[AC-pki-entity-user01] organization
[AC-pki-entity-user01] organization-unit info
[AC-pki-entity-user01] quit
```

步骤4 创建PKI域。

```
[AC] pki realm abc
[AC-pki-realm-abc] quit
```

步骤5 配置CMP会话。

创建CMP会话cmp。

```
[AC] pki cmp session cmp
```

指定CMP会话引用的PKI实体名称。

```
[AC-pki-cmp-session-cmp] cmp-request entity user01
```

配置CA的名称，举例中假设为“C=cn,ST=beijing,L=SD,O=BB,OU=BB,CN=BB”。

说明

配置的CA名称中各个字段的顺序必须要和实际CA证书中的顺序保持一致，否则服务器端会认为是错误的。

```
[AC-pki-cmp-session-cmp] cmp-request ca-name "C=cn,ST=beijing,L=SD,O=BB,OU=BB,CN=BB"
```

配置申请证书的URL。

```
[AC-pki-cmp-session-cmp] cmp-request server url http://10.3.0.1:8080
```

指定申请证书时使用的RSA密钥对，并设置为证书自动更新时同时更新RSA密钥对。

```
[AC-pki-cmp-session-cmp] cmp-request rsa local-key-pair rsa_cmp regenerate
```

指定CMP服务器证书所属的PKI域，并设置CMP服务器证书所属的域名称为abc。

```
[AC-pki-cmp-session-cmp] cmp-request realm abc
```

首次申请证书时，使用消息认证码认证。配置消息认证码的参考值和秘密值，举例中假设分别为“1234”和“123456”。

```
[AC-pki-cmp-session-cmp] cmp-request message-authentication-code 1234 123456
[AC-pki-cmp-session-cmp] quit
[AC] pki cmp initial-request session cmp
[AC]
 Info: Initializing configuration.
 Info: Creatting initial request packet.
 Info: Connectting to CMPv2 server.
 Info: Sending initial request packet.
 Info: Waitting for initial response packet.
 Info: Creatting confirm packet.
 Info: Connectting to CMPv2 server.
 Info: Sending confirm packet.
 Info: Waitting for confirm packet from server.
 Info: CMPv2 operation finish.
```

获取到的CA、本地证书将会分别被命名为cmp_ca1.cer和cmp_ir.cer保存在设备存储介质中。

步骤6 安装证书。

导入CA证书到PKI域。

```
[AC] pki import-certificate ca realm abc pem filename cmp_ca1.cer
 The CA's Subject is /C=cn/ST=beijing/L=BB/O=BB/OU=BB/CN=BB
 The CA's fingerprint is:
   MD5  fingerprint:3AC7 54FD E272 09BE 9008 84EE D1FC 118E
   SHA1 fingerprint:492A 8E0B BED2 BE10 C097 9039 99FE F7E1 9AA5 B658
 Is the fingerprint correct?(Y/N):y
 Info: Succeeded in importing file.
```

导入本地证书到PKI域。

```
[AC] pki import-certificate local realm abc pem filename cmp_ir.cer
 Info: Succeeded in importing file.
```

步骤7 配置证书自动更新功能。

配置设备用于证明自己身份的证书，也是待更新的证书cmp_ir.cer。

```
[AC] pki cmp session cmp
[AC-pki-cmp-session-cmp] cmp-request authentication-cert cmp_ir.cer
```

开启证书自动更新的功能。

```
[AC-pki-cmp-session-cmp] certificate auto-update enable
```

配置当前系统时间超过证书有效期的60%时开始更新证书。

```
[AC-pki-cmp-session-cmp] certificate update expire-time 60
[AC-pki-cmp-session-cmp] quit
```

步骤8 验证配置结果。

1. 证书申请成功后，可执行命令**display pki certificate**查看已经导入内存的本地证书的内容。

```
[AC] display pki certificate filename cmp_ir.cer
 The  x509_obj type is Cert:
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number: 1144733510 (0x443b3f46)
        Signature Algorithm: sha1WithRSAEncryption
        Issuer: C=cn, ST=beijing, L=BB, O=BB, OU=BB, CN=BB
        Validity
            Not Before: Jun 12 09:33:10 2012 GMT
            Not After : Aug 13 02:38:27 2016 GMT
        Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (2048 bit)
                Modulus:
                    00:d3:12:fe:57:48:c6:a5:10:12:e9:2f:f9:2a:ff:
                    7b:2a:d8:45:69:11:c4:85:30:c4:9a:4d:0f:ad:58:
                    e7:56:cd:5c:f0:18:e1:c3:6d:44:c2:c3:5e:64:22:
                    d1:28:c9:c3:37:3c:34:ed:28:04:7f:62:9e:8b:94:
                    af:bc:72:de:f6:72:7f:e4:d8:45:31:fd:f9:ac:ce:
                    5a:b9:c7:1b:23:53:00:28:a6:3b:f5:61:69:5d:ab:
                    67:cb:bb:e8:96:2f:ce:ab:2c:6b:91:5b:26:91:86:
                    8f:80:a9:b0:66:c1:16:3d:31:55:a2:d4:b5:5a:af:
                    85:88:6e:99:f8:f8:53:58:77:26:91:ed:0e:94:ad:
                    c5:8d:53:67:67:55:08:8d:90:38:e0:5e:96:37:b9:
                    64:0e:36:e7:cf:9a:d2:77:e4:b0:24:05:a6:eb:03:
                    6e:ff:f7:ab:be:93:9e:8c:66:7d:31:66:be:6d:c8:
                    f3:17:9d:86:19:88:21:2d:d9:69:86:5f:b2:55:a4:
                    db:bc:d7:d0:6b:ac:66:ac:e4:63:9c:66:79:9c:42:
                    5c:83:b8:9e:4b:6e:67:85:a2:47:19:f1:5c:c0:3c:
                    c9:a3:47:02:a8:53:69:59:9e:d9:c7:5e:90:83:8d:
                    ac:cd:21:3c:d5:31:39:49:84:e6:f8:f4:e0:44:dd:
                    5d:7b
                Exponent: 65537 (0x10001)
        X509v3 extensions:
            X509v3 Subject Alternative Name:
                IP Address:10.2.0.2, DNS:test.abc.com, email:user@test.abc.com
    Signature Algorithm: sha1WithRSAEncryption
        53:d5:79:31:7b:40:52:aa:ec:a9:35:ed:07:62:32:c4:ce:22:
        d3:37:0e:83:0c:4c:fa:61:dd:8c:db:a8:d3:fd:6a:ca:0e:3c:
        91:2c:91:ab:92:31:34:b5:87:1e:30:a4:ff:94:9c:d2:71:3c:
        6b:1f:4f:be:a7:20:f2:e1:c2:ad:71:8b:c2:79:0f:50:1f:3c:
        f9:87:df:1d:ee:3d:38:8c:f3:30:b7:3b:00:9b:72:38:b0:68:
        e1:c0:08:f4:02:91:81:a8:fa:51:9e:53:0d:03:b3:6b:0e:e2:
        62:80:ef:2a:a0:cb:9b:9b:91:21:7c:df:fe:6a:38:cc:03:36:
        9c:fc

Pki realm name: abc
Certificate file name: cmp_ir.cer
Certificate peer name: -
```

2. 证书申请成功后，可执行命令**display pki certificate**查看已经导入内存的CA证书的内容。

```
[AC] display pki certificate filename cmp_ca1.cer
 The x509 object  type is certificate:
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number: 2 (0x2)
        Signature Algorithm: sha1WithRSAEncryption
        Issuer: C=cn, ST=beijing, L=BB, O=BB, OU=BB, CN=BB
        Validity
            Not Before: Aug 15 02:38:27 2011 GMT
            Not After : Aug 13 02:38:27 2016 GMT
```

```
        Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (1024 bit)
                Modulus:
                    00:b7:3e:65:7f:3b:3c:18:b8:87:34:39:76:3c:87:
                    39:f7:a9:b3:35:9b:e0:e0:5b:c7:4f:3c:bb:fa:dd:
                    da:93:0b:55:6e:eb:ba:52:c8:86:d1:cf:14:1e:1c:
                    35:c6:53:68:f3:51:e7:2c:d4:b8:fa:0f:b3:04:ef:
                    3f:a0:b3:4d:78:c1:26:88:26:15:41:3d:14:7f:67:
                    3e:2f:35:32:ce:c7:73:73:43:5c:12:d3:0f:a0:ec:
                    96:ae:55:61:27:32:39:a4:f8:32:a1:68:50:e6:3d:
                    2b:39:6d:42:e8:09:5d:4f:98:46:6e:fc:80:87:0e:
                    36:ca:09:7a:ca:2f:dd:ad:d3
                Exponent: 65537 (0x10001)
        X509v3 extensions:
            X509v3 Basic Constraints: critical
                CA:TRUE
            X509v3 Subject Key Identifier:
                4F:67:F4:CB:F4:C3:F7:61:2C:BD:FF:1D:D1:29:FD:39:28:9F:3B:8B
            X509v3 Key Usage:
                Certificate Sign, CRL Sign
            Netscape Cert Type:
                SSL CA, S/MIME CA, Object Signing CA
            Netscape Comment:
                xca certificate
    Signature Algorithm: sha1WithRSAEncryption
        75:43:24:eb:db:ee:7d:05:30:88:b8:1b:d5:32:ca:51:49:74:
        04:94:fe:d0:31:29:6f:72:c7:4a:86:ac:2a:4c:45:24:9d:3c:
        b4:30:b5:d1:43:88:29:f7:b4:88:b8:37:dc:dd:f4:fa:42:34:
        1c:e6:a5:bc:bb:0b:37:ef:db:8c:b2:b0:bd:97:7f:15:ae:6c:
        71:1b:ff:f1:90:13:74:a4:1f:7c:f7:4e:80:5b:42:aa:6b:22:
        2a:cf:04:48:29:20:c0:b2:95:38:11:06:be:76:f0:cb:8d:4a:
        c6:1a:50:af:31:81:58:ac:14:fe:89:f2:e0:bb:95:3c:94:d0:
        54:96

Pki realm name: abc
Certificate file name: cmp_ca1.cer
Certificate peer name: -
```

3. 配置证书自动更新功能后，当系统检测到时间已经超过了配置的当前证书有效期的60%之后，就会向CMPv2服务器发起证书的更新请求。

   由于配置命令**cmp-request rsa local-key-pair**时选择了**regenerate**参数，更新时系统会生成新的RSA密钥对去申请新证书，申请下来的新证书会同时替换设备存储介质中的证书文件和内存中对应的证书。

----结束

配置文件

AC的配置文件

```
#
sysname AC
#
pki entity user01
 country CN
 state jiangsu
 organization
 organization-unit info
 common-name hello
 fqdn user@test.abc.com
 ip-address 10.2.0.2
 email user@user@test.abc.com
#
pki realm abc
#
```

```
interface GigabitEthernet0/0/1
 ip address 10.2.0.2 255.255.255.0
interface GigabitEthernet1/0/2
 ip address 10.1.0.2 255.255.255.0
#
pki cmp session cmp
 cmp-request ca-name "C=cn,ST=beijing,L=SD,O=BB,OU=BB,CN=BB"
 cmp-request authentication-cert cmp_ir.cer
 cmp-request entity user01
 cmp-request server url http://10.3.0.1:8080
 cmp-request rsa local-key-pair rsa_cmp regenerate
 cmp-request realm abc
 cmp-request message-authentication-code 1234 %$%$DO<zV;5|h,-E`1#||f`(4~UJ%$%$
 certificate auto-update enable
 certificate update expire-time 60
#
ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
#
return
```

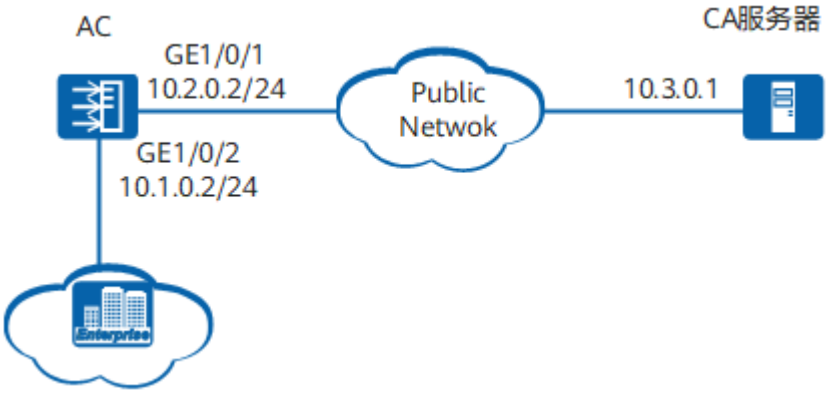
27.11.14.2 配置通过 SCEP 协议自动为 PKI 实体申请本地证书示例

组网需求

如图27-48所示，某企业在网络边界处部署了AC作为出口网关，AC向公网上的CA服务器在线申请本地证书。

用户希望通过简单快捷的方式为PKI实体申请本地证书，申请成功后能自动将证书导入到设备内存中，而且证书过期时，能自动更新证书。此时，可以配置通过SCEP协议自动为PKI实体申请本地证书实现上述需求。

图 27-48 配置通过 SCEP 协议自动为 PKI 实体申请本地证书组网图



说明

本举例只列出了申请证书时AC侧的相关配置，CA服务器的部署和配置请参见相关产品手册。这里的CA服务器以Windows Server 2008自带的“证书服务”，并安装了SCEP插件为例进行说明。

配置思路

采用如下思路配置通过SCEP协议自动为PKI实体申请本地证书：

1. 配置接口的IP地址及到CA服务器的静态路由，实现AC和CA服务器之间路由互通。

2. 创建RSA密钥对，实现申请本地证书时携带公钥。
3. 配置PKI实体，实现申请本地证书时携带PKI实体信息用来标识PKI实体的身份。
4. 通过SCEP协议申请和自动更新证书，实现自动安装证书，并且证书过期时，能自动更新证书。

数据准备

申请证书前需要以离线方式从CA服务器上获取数字指纹和挑战密码。这里假设数字指纹为“e71add0744360e91186b828412d279e06dcc15a4ab4bb3d13842820396b526a0”和挑战密码为“6AE73F21E6D3571D”。

本文以Windows Server 2008作为CA服务器为例，可以通过登录网页http://*host*:*port*/certsrv/mscep_admin/获得CA证书指纹信息和挑战密码，其中*host*为CA服务器的IP地址，*port*为CA服务器的端口号。

操作步骤

步骤1 配置接口的IP地址及到CA服务器的静态路由。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] interface gigabitethernet 1/0/1
[AC-GigabitEthernet1/0/1] ip address 10.2.0.2 255.255.255.0
[AC-GigabitEthernet1/0/1] quit
[AC] interface gigabitethernet 1/0/2
[AC-GigabitEthernet1/0/2] ip address 10.1.0.2 255.255.255.0
[AC-GigabitEthernet1/0/2] quit
[AC] ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
```

步骤2 创建RSA密钥对。

创建一个2048位的RSA密钥对rsa_scep，并设置为可以从设备上导出。

```
[AC] pki rsa local-key-pair create rsa_scep exportable
 Info: The name of the new key-pair will be: rsa_scep
 The size of the public key ranges from 2048 to 4096.
 Input the bits in the modules:2048
 Generating key-pairs...        ..................+++
......................+++
```

步骤3 配置PKI实体，标识申请证书PKI实体的身份信息。

配置PKI实体为user01。

```
[AC] pki entity user01
[AC-pki-entity-user01] common-name hello
[AC-pki-entity-user01] country cn
[AC-pki-entity-user01] email user@test.abc.com
[AC-pki-entity-user01] fqdn test.abc.com
[AC-pki-entity-user01] ip-address 10.2.0.2
[AC-pki-entity-user01] state jiangsu
[AC-pki-entity-user01] organization
[AC-pki-entity-user01] organization-unit info
[AC-pki-entity-user01] quit
```

步骤4 通过SCEP协议申请和更新证书。

```
[AC] pki realm abc
[AC-pki-realm-abc] ca id ca_root
[AC-pki-realm-abc] entity user01
[AC-pki-realm-abc] fingerprint sha256
e71add0744360e91186b828412d279e06dcc15a4ab4bb3d13842820396b526a0
[AC-pki-realm-abc] enrollment-url http://10.3.0.1:80/certsrv/mscep/mscep.dll ra
```

```
[AC-pki-realm-abc] rsa local-key-pair rsa_scep
[AC-pki-realm-abc] enrollment-request signature message-digest-method sha-384
[AC-pki-realm-abc] password cipher 6AE73F21E6D3571D
```

步骤5 开启证书自动注册和更新功能，指定证书有效期到60%时自动更新并同时更新RSA密钥。

```
[AC-pki-realm-abc] auto-enroll 60 regenerate 2048
[AC-pki-realm-abc] quit
```

申请本地证书时，设备会先获取CA证书并自动安装CA证书，然后再获取本地证书并自动安装本地证书。获取的CA证书和本地证书名称分别为abc_ca.cer和abc_local.cer。

步骤6 验证配置结果。

1. 证书申请成功后，可执行命令**display pki certificate local**查看已经导入内存的本地证书的内容。

```
[AC] display  pki certificate local realm abc
 The x509 object type is certificate:
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            48:65:aa:2a:00:00:00:00:3f:c6
    Signature Algorithm: sha1WithRSAEncryption
        Issuer: CN=ca_root
        Validity
            Not Before: Dec 21 11:46:10 2015 GMT
            Not After : Dec 21 11:56:10 2016 GMT
        Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (2048 bit)
                Modulus:
                    00:94:6f:49:bd:6a:f3:d5:07:ee:10:ee:4f:d3:06:
                    80:59:15:cb:a8:0a:b2:ba:c2:db:52:ec:e9:d1:a7:
                    72:de:ac:35:df:bb:e0:72:62:08:3e:c5:54:c1:ba:
                    4a:bb:1b:a9:d9:dc:e4:b6:4d:ca:b3:54:90:b6:8e:
                    15:a3:6e:2d:b2:9e:9e:7a:33:b0:56:3f:ec:bc:67:
                    1c:4c:59:c6:67:0f:a7:03:52:44:8c:53:72:42:bd:
                    6e:0c:90:5b:88:9b:2c:95:f7:b8:89:d1:c2:37:3e:
                    93:78:fa:cb:2c:20:22:5f:e5:9c:61:23:7b:c0:e9:
                    fe:b7:e6:9c:a1:49:0b:99:ef:16:23:e9:44:40:6d:
                    94:79:20:58:d7:e1:51:a1:a6:4b:67:44:f7:07:71:
                    54:93:4e:32:ff:98:b4:2b:fa:5d:b2:3c:5b:df:3e:
                    23:b2:8a:1a:75:7e:8f:82:58:66:be:b3:3c:4a:1c:
                    2c:64:d0:3f:47:13:d0:5a:29:94:e2:97:dc:f2:d1:
                    06:c9:7e:54:b3:42:2e:15:b8:40:f3:94:d3:76:a1:
                    91:66:dd:40:29:c3:69:70:6d:5a:b7:6b:91:87:e8:
                    bb:cb:a5:7e:ec:a5:31:11:f3:04:ab:1a:ef:10:e6:
                    f1:bd:d9:76:42:6c:2e:bf:d9:91:39:1d:08:d7:b4:
                    18:53
                Exponent: 65537 (0x10001)
        X509v3 extensions:
            X509v3 Subject Alternative Name:
                IP Address:10.2.0.2, DNS:test.abc.com, email:user@test.abc.com
            X509v3 Subject Key Identifier:
                15:D1:F6:24:EB:6B:C0:26:19:58:88:91:8B:60:42:CE:BA:D5:4D:F3
            X509v3 Authority Key Identifier:
                keyid:B8:63:72:A4:5E:19:F3:B1:1D:71:E1:37:26:E1:46:39:01:B6:82:C
5

            X509v3 CRL Distribution Points:

                Full Name:
                  URI:file://\\vasp-e6000-127.china..com\CertEnroll\ca_roo
t.crl
                  URI:http://10.3.0.1:8080/certenroll/ca_root.crl
```

```
            Authority Information Access:
                CA Issuers - URI:http://vasp-e6000-127.china..com/CertEnro
ll/vasp-e6000-127.china..com_ca_root.crt
                OCSP - URI:file://\\vasp-e6000-127.china..com\CertEnroll\v
asp-e6000-127.china..com_ca_root.crt

            1.3.6.1.4.1.311.20.2:
                .0.I.P.S.E.C.I.n.t.e.r.m.e.d.i.a.t.e.O.f.f.l.i.n.e
    Signature Algorithm: sha1WithRSAEncryption
        d2:be:a8:52:6b:03:ce:89:f1:5b:49:d4:eb:2b:9f:fd:59:17:
        d4:3c:f1:db:4f:1b:d1:12:ac:bf:ae:59:b4:13:1b:8a:20:d0:
        52:6a:f8:a6:03:a6:72:06:41:d2:a7:7d:3f:51:64:9b:84:64:
        cf:ec:4c:23:0a:f1:57:41:53:eb:f6:3a:44:92:f3:ec:bd:09:
        75:db:02:42:ab:89:fa:c4:cd:cb:09:bf:83:1d:de:d5:4b:68:
        8a:a6:5f:7a:e8:b3:34:d3:e8:ec:24:37:2b:bd:3d:09:ed:88:
        d8:ed:a7:f8:66:aa:6f:b0:fe:44:92:d4:c9:29:21:1c:b3:7a:
        65:51:32:50:5a:90:fa:ae:e1:19:5f:c8:63:8d:a8:e7:c6:89:
        2e:6d:c8:5b:2c:0c:cd:41:48:bd:79:74:0e:b8:2f:48:69:df:
        02:89:bb:b3:59:91:7f:6b:46:29:7e:22:05:8c:bb:6a:7e:f3:
        11:5a:5f:fb:65:51:7d:35:ff:49:9e:ec:d1:2d:7e:73:e5:99:
        c6:41:84:0c:50:11:ed:97:ed:15:de:11:22:73:a1:78:11:2e:
        34:e6:f5:de:66:0c:ba:d5:32:af:b8:54:26:4f:5b:9e:89:89:
        2a:3f:b8:96:27:00:c3:08:3a:e9:e8:a6:ce:4b:5a:e3:97:9e:
        6b:dd:f0:72

Pki realm name: abc
Certificate file name: abc_local.cer
Certificate peer name: -
```

2. 证书申请成功后，可执行命令**display pki certificate ca**查看已经导入内存的CA证书的内容。

```
[AC] display  pki certificate ca realm abc
 The x509 object type is certificate:
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            0c:f0:1a:f3:67:21:44:9a:4a:eb:ec:63:75:5d:d7:5f
    Signature Algorithm: sha1WithRSAEncryption
        Issuer: CN=ca_root
        Validity
            Not Before: Jun  4 14:58:17 2015 GMT
            Not After : Jun  4 15:07:10 2020 GMT
        Subject: CN=ca_root
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (2048 bit)
                Modulus:
                    00:d9:5f:2a:93:cb:66:18:59:8c:26:80:db:cd:73:
                    d5:68:92:1b:04:9d:cf:33:a2:73:64:3e:5f:fe:1a:
                    53:78:0e:3d:e1:99:14:aa:86:9b:c3:b8:33:ab:bb:
                    76:e9:82:f6:8f:05:cf:f6:83:8e:76:ca:ff:7d:f1:
                    bc:22:74:5e:8f:4c:22:05:78:d5:d6:48:8d:82:a7:
                    5d:e1:4c:a4:a9:98:ec:26:a1:21:07:42:e4:32:43:
                    ff:b6:a4:bd:5e:4d:df:8d:02:49:5d:aa:cc:62:6c:
                    34:ab:14:b0:f1:58:4a:40:20:ce:be:a5:7b:77:ce:
                    a4:1d:52:14:11:fe:2a:d0:ac:ac:16:95:78:34:34:
                    21:36:f2:c7:66:2a:14:31:28:dc:7f:7e:10:12:e5:
                    6b:29:9a:e8:fb:73:b1:62:aa:7e:bd:05:e5:c6:78:
                    6d:3c:08:4c:9c:3f:3b:e0:e9:f2:fd:cb:9a:d1:b7:
                    de:1e:84:f4:4a:7d:e2:ac:08:15:09:cb:ee:82:4b:
                    6b:bd:c6:68:da:7e:c8:29:78:13:26:e0:3c:6c:72:
                    39:c5:f8:ad:99:e4:c3:dd:16:b5:2d:7f:17:e4:fd:
                    e4:51:7a:e6:86:f0:e7:82:2f:55:d1:6f:08:cb:de:
                    84:da:ce:ef:b3:b1:d6:b3:c0:56:50:d5:76:4d:c7:
                    fb:75
                Exponent: 65537 (0x10001)
        X509v3 extensions:
            1.3.6.1.4.1.311.20.2:
```

```
                ...C.A
            X509v3 Key Usage: critical
                Digital Signature, Certificate Sign, CRL Sign
            X509v3 Basic Constraints: critical
                CA:TRUE
            X509v3 Subject Key Identifier:
                B8:63:72:A4:5E:19:F3:B1:1D:71:E1:37:26:E1:46:39:01:B6:82:C5
            X509v3 CRL Distribution Points:

                Full Name:
                  URI:http://vasp-e6000-127.china..com/CertEnroll/ca_root.
crl
                  URI:file://\\vasp-e6000-127.china..com\CertEnroll\ca_roo
t.crl

            1.3.6.1.4.1.311.21.1:
                ...
    Signature Algorithm: sha1WithRSAEncryption
         52:21:46:b8:67:c8:c3:4a:e7:f8:cd:e1:02:d4:24:a7:ce:50:
         be:33:af:8a:49:47:67:43:f9:7f:79:88:9c:99:f5:87:c9:ff:
         08:0f:f3:3b:de:f9:19:48:e5:43:0e:73:c7:0f:ef:96:ef:5a:
         5f:44:76:02:43:83:95:c4:4e:06:5e:11:27:69:65:97:90:4f:
         04:4a:1e:12:37:30:95:24:75:c6:a4:73:ee:9d:c2:de:ea:e9:
         05:c0:a4:fb:39:ec:5c:13:29:69:78:33:ed:d0:18:37:6e:99:
         bc:45:0e:a3:95:e9:2c:d8:50:fd:ca:c2:b3:5a:d8:45:82:6e:
         ec:cc:12:a2:35:f2:43:a5:ca:48:61:93:b9:6e:fe:7c:ac:41:
         bf:88:70:57:fc:bb:66:29:ae:73:9c:95:b9:bb:1d:16:f7:b4:
         6a:da:03:df:56:cf:c7:c7:8c:a9:19:23:61:5b:66:22:6f:7e:
         1d:26:92:69:53:c8:c6:0e:b3:00:ff:54:77:5e:8a:b5:07:54:
         fd:18:39:0a:03:ac:1d:9f:1f:a1:eb:b9:f8:0d:21:25:36:d5:
         06:de:33:fa:7b:c8:e9:60:f3:76:83:bf:63:c6:dc:c1:2c:e4:
         58:b9:cb:48:15:d2:a8:fa:42:72:15:43:ef:55:63:39:58:77:
         e8:ae:0f:34

Pki realm name: abc
Certificate file name: abc_ca.cer
Certificate peer name: -
```

3. 配置证书自动更新功能后，当系统检测到时间已经超过了配置的当前证书有效期的60%之后，就会向SCEP服务器发起证书的更新请求。

   由于配置命令**auto-enroll**时选择了**regenerate**参数，更新时系统会生成新的RSA密钥对去申请新证书。

----结束

配置文件

AC的配置文件

```
#
sysname AC
#
pki entity user01
 country CN
 state jiangsu
 organization
 organization-unit info
 common-name hello
 fqdn test.abc.com
 ip-address 10.2.0.2
 email user@test.abc.com
#
pki realm abc
 ca id ca_root
 enrollment-url http://10.3.0.1:80/certsrv/mscep/mscep.dll ra
 entity user01
 fingerprint sha256 e71add0744360e91186b828412d279e06dcc15a4ab4bb3d13842820396b526a0
```

```
 rsa local-key-pair rsa_scep
 password cipher %^%#\c{UCn\RwO'<$oTEf1Q%rZp"U$(K{GGPvZN(qw,B%^%#
 auto-enroll 60 regenerate
 enrollment-request signature message-digest-method sha-384
#
interface GigabitEthernet1/0/1
 ip address 10.2.0.2 255.255.255.0
interface GigabitEthernet1/0/2
 ip address 10.1.0.2 255.255.255.0
#
ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
#
return
```

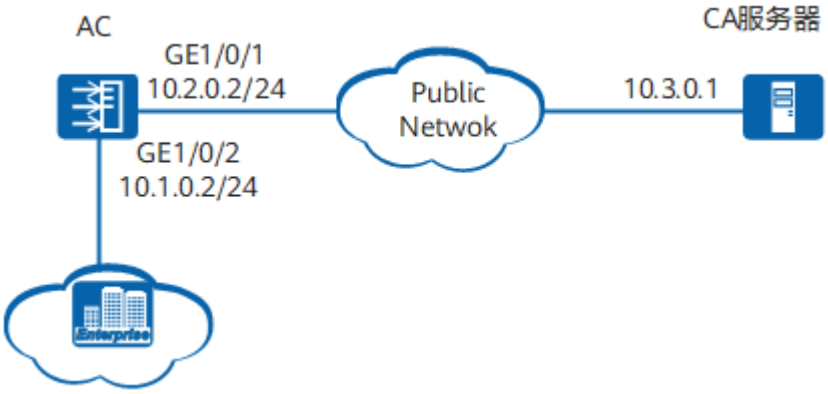
27.11.14.3 配置为 PKI 实体离线申请本地证书示例

组网需求

如图27-49所示，某企业在网络边界处部署了AC作为出口网关，AC向公网上的CA服务器申请本地证书。

用户无法通过SCEP协议在线向CA申请本地证书时，可以通过带外方式为PKI实体离线申请本地证书。

图 27-49 配置为 PKI 实体离线申请本地证书组网图



说明

本举例只列出了申请证书时AC侧的相关配置，CA服务器的部署和配置请参见相关产品手册。这里的CA服务器以Windows Server 2008自带的“证书服务”，并安装了SCEP插件为例进行说明。

配置思路

采用如下思路配置为PKI实体离线申请本地证书：

1. 创建RSA密钥对，实现申请本地证书时携带公钥。
2. 配置PKI实体，实现申请本地证书时携带PKI实体信息用来标识PKI实体的身份。
3. 配置为PKI实体离线申请本地证书，生成本地证书请求文件。
4. 通过带外方式发送本地证书请求文件来申请本地证书，并通过带外方式下载本地证书。

5. 安装本地证书，使得设备可以使用证书来保护通信。

操作步骤

步骤1 配置接口的IP地址及到CA服务器的静态路由。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] interface gigabitethernet 1/0/1
[AC-GigabitEthernet1/0/1] ip address 10.2.0.2 255.255.255.0
[AC-GigabitEthernet1/0/1] quit
[AC] interface gigabitethernet 1/0/2
[AC-GigabitEthernet1/0/2] ip address 10.1.0.2 255.255.255.0
[AC-GigabitEthernet1/0/2] quit
[AC] ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
```

步骤2 创建RSA密钥对。

创建一个2048位的RSA密钥对rsa，并设置为可以从设备上导出。

```
[AC] pki rsa local-key-pair create rsakey exportable
 Info: The name of the new key-pair will be: rsakey
 The size of the public key ranges from 2048 to 4096.
 Input the bits in the modules:2048
 Generating key-pairs...        ..................+++
.......................+++
```

步骤3 配置PKI实体，标识申请证书PKI实体的身份信息。

配置PKI实体为user01。

```
[AC] pki entity user01
[AC-pki-entity-user01] common-name hello
[AC-pki-entity-user01] country cn
[AC-pki-entity-user01] email user@test.abc.com
[AC-pki-entity-user01] fqdn test.abc.com
[AC-pki-entity-user01] ip-address 10.2.0.2
[AC-pki-entity-user01] state jiangsu
[AC-pki-entity-user01] organization
[AC-pki-entity-user01] organization-unit info
[AC-pki-entity-user01] quit
```

步骤4 配置为PKI实体离线申请本地证书。

```
[AC] pki realm abc
[AC-pki-realm-abc] entity user01
[AC-pki-realm-abc] rsa local-key-pair rsakey
[AC-pki-realm-abc] quit
[AC] pki enroll-certificate realm abc pkcs10 filename cer_req
 Info: Creating certificate request file...
 Info: Create certificate request file successfully.
```

已完成配置后，可执行命令**display pki cert-req**查看证书请求文件的内容。

```
[AC] display pki cert-req filename cer_req
Certificate Request:
    Data:
        Version: 0 (0x0)
        Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (2048 bit)
                Modulus:
                    00:a2:db:e3:30:17:8e:f6:2d:2e:64:15:46:51:ad:
                    70:86:dd:32:c4:bb:6b:58:3a:8c:5f:a0:06:a1:e1:
                    56:2e:a4:eb:7e:12:06:05:04:28:b2:6d:64:7a:9c:
                    4f:85:24:c1:aa:b8:99:dc:e9:bb:c4:1e:e2:9d:a0:
                    18:51:1f:ad:b5:2f:60:18:06:8b:c1:cc:6f:32:58:
                    f2:21:2c:16:e8:29:c2:a8:c5:aa:9d:6c:1e:ca:14:
```

```
                fc:7a:e9:bc:07:91:ce:ed:a0:c0:52:d9:0c:e9:ba:
                9b:64:43:e0:9a:3f:c5:d1:2c:86:36:96:6b:4b:4f:
                d4:df:05:d0:4b:41:2c:ec:0a:d7:0e:45:83:ed:cd:
                07:78:40:ed:d5:3d:7f:fe:0f:08:90:04:2e:ac:e5:
                42:b9:81:ea:ec:77:e2:cc:04:6e:e4:63:9f:69:ed:
                60:06:5e:c7:e8:bf:30:57:6a:5d:e0:46:68:d3:ee:
                b0:da:47:24:e3:b6:a5:f3:20:d8:5a:75:92:70:c2:
                a9:a6:97:07:07:0d:1c:94:9a:03:6f:f7:8c:db:6f:
                b7:06:de:51:50:9e:71:fd:86:f3:b5:c9:99:05:bf:
                f1:10:20:28:d3:a6:29:3d:e0:f4:a7:ba:1e:27:85:
                a9:66:fc:a9:90:49:f0:35:f7:d9:6d:06:a2:43:3f:
                18:87
            Exponent: 65537 (0x10001)
        Attributes:
        Requested Extensions:
            X509v3 Subject Alternative Name:
                IP Address:10.2.0.2, DNS:test.abc.com, email:user@test.abc.com
    Signature Algorithm: sha256WithRSAEncryption
         0e:0a:a5:b7:d5:54:11:10:c4:ea:ff:77:da:f9:24:4b:a9:98:
         a1:75:36:08:10:59:60:fa:1a:30:70:2c:b7:f6:5f:5e:31:b7:
         55:a5:7a:26:e5:af:4a:cd:83:c5:f3:90:f3:b9:d5:f9:0a:6d:
         6e:8f:25:b4:ed:95:9c:75:a5:d7:b6:25:fc:8d:39:89:fb:af:
         37:fc:01:7b:09:07:9c:96:7c:fa:28:6d:e2:11:49:a7:95:94:
         ed:26:5b:ca:f8:98:b0:e7:64:7e:dd:2d:75:ff:89:03:b7:0a:
         92:53:25:d4:a1:23:b9:5c:eb:5b:29:1d:8a:92:8f:36:68:7b:
         77:32:bc:48:92:48:84:fa:87:5a:d7:2e:3e:be:d5:6b:e4:df:
         b1:f2:02:35:91:6a:eb:cd:fc:5a:ea:37:85:6c:12:74:5f:a5:
         5c:c0:05:09:cd:34:59:0d:c6:c8:75:ca:1c:18:d6:48:e5:4b:
         e7:8e:e3:ff:25:99:0f:2e:a8:b4:c5:8e:4d:8f:dd:64:c5:1f:
         61:3c:58:21:4f:d5:35:ba:c8:8e:5f:76:41:9f:27:41:0a:94:
         59:2c:59:25:2d:de:60:5c:92:07:ac:8a:a5:7a:ba:75:af:2c:
         82:5f:bb:55:a8:48:49:54:0f:99:54:af:8d:12:4d:4b:7d:8b:
         95:28:ce:dc
```

步骤5 通过Web、磁盘、电子邮件等带外方式将证书申请文件发送给CA服务器，向CA服务器申请本地证书。

本地证书注册成功后，可以通过带外方式下载本地证书abc_local.cer。下载后，可以通过文件传输协议导入到设备的存储介质中。

步骤6 安装本地证书。

```
[AC] pki import-certificate local realm abc pem filename abc_local.cer
 Info: Succeeded in importing file.
```

安装本地证书后，设备就可以使用证书来保护通信。

步骤7 验证配置结果。

执行命令**display pki certificate local**查看已经导入内存的本地证书的内容。

```
[AC] display  pki certificate local realm abc
 The x509 object type is certificate:
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            48:65:aa:2a:00:00:00:00:3f:c6
    Signature Algorithm: sha1WithRSAEncryption
        Issuer: CN=ca_root
        Validity
            Not Before: Dec 21 11:46:10 2015 GMT
            Not After : Dec 21 11:56:10 2016 GMT
        Subject: C=CN, ST=jiangsu, O=, OU=info, CN=hello
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (2048 bit)
                Modulus:
                    00:94:6f:49:bd:6a:f3:d5:07:ee:10:ee:4f:d3:06:
```

```
                80:59:15:cb:a8:0a:b2:ba:c2:db:52:ec:e9:d1:a7:
                72:de:ac:35:df:bb:e0:72:62:08:3e:c5:54:c1:ba:
                4a:bb:1b:a9:d9:dc:e4:b6:4d:ca:b3:54:90:b6:8e:
                15:a3:6e:2d:b2:9e:9e:7a:33:b0:56:3f:ec:bc:67:
                1c:4c:59:c6:67:0f:a7:03:52:44:8c:53:72:42:bd:
                6e:0c:90:5b:88:9b:2c:95:f7:b8:89:d1:c2:37:3e:
                93:78:fa:cb:2c:20:22:5f:e5:9c:61:23:7b:c0:e9:
                fe:b7:e6:9c:a1:49:0b:99:ef:16:23:e9:44:40:6d:
                94:79:20:58:d7:e1:51:a1:a6:4b:67:44:f7:07:71:
                54:93:4e:32:ff:98:b4:2b:fa:5d:b2:3c:5b:df:3e:
                23:b2:8a:1a:75:7e:8f:82:58:66:be:b3:3c:4a:1c:
                2c:64:d0:3f:47:13:d0:5a:29:94:e2:97:dc:f2:d1:
                06:c9:7e:54:b3:42:2e:15:b8:40:f3:94:d3:76:a1:
                91:66:dd:40:29:c3:69:70:6d:5a:b7:6b:91:87:e8:
                bb:cb:a5:7e:ec:a5:31:11:f3:04:ab:1a:ef:10:e6:
                f1:bd:d9:76:42:6c:2e:bf:d9:91:39:1d:08:d7:b4:
                18:53
            Exponent: 65537 (0x10001)
        X509v3 extensions:
            X509v3 Subject Alternative Name:
                IP Address:10.2.0.2, DNS:test.abc.com, email:user@test.abc.com
            X509v3 Subject Key Identifier:
                15:D1:F6:24:EB:6B:C0:26:19:58:88:91:8B:60:42:CE:BA:D5:4D:F3
            X509v3 Authority Key Identifier:
                keyid:B8:63:72:A4:5E:19:F3:B1:1D:71:E1:37:26:E1:46:39:01:B6:82:C
5

            X509v3 CRL Distribution Points:

                Full Name:
                  URI:file://\\vasp-e6000-127.china..com\CertEnroll\ca_roo
t.crl
                  URI:http://10.3.0.1:8080/certenroll/ca_root.crl

            Authority Information Access:
                CA Issuers - URI:http://vasp-e6000-127.china..com/CertEnro
ll/vasp-e6000-127.china..com_ca_root.crt
                OCSP - URI:file://\\vasp-e6000-127.china..com\CertEnroll\v asp-
e6000-127.china..com_ca_root.crt

            1.3.6.1.4.1.311.20.2:
                .0.I.P.S.E.C.I.n.t.e.r.m.e.d.i.a.t.e.O.f.f.l.i.n.e
    Signature Algorithm: sha1WithRSAEncryption
        d2:be:a8:52:6b:03:ce:89:f1:5b:49:d4:eb:2b:9f:fd:59:17:
        d4:3c:f1:db:4f:1b:d1:12:ac:bf:ae:59:b4:13:1b:8a:20:d0:
        52:6a:f8:a6:03:a6:72:06:41:d2:a7:7d:3f:51:64:9b:84:64:
        cf:ec:4c:23:0a:f1:57:41:53:eb:f6:3a:44:92:f3:ec:bd:09:
        75:db:02:42:ab:89:fa:c4:cd:cb:09:bf:83:1d:de:d5:4b:68:
        8a:a6:5f:7a:e8:b3:34:d3:e8:ec:24:37:2b:bd:3d:09:ed:88:
        d8:ed:a7:f8:66:aa:6f:b0:fe:44:92:d4:c9:29:21:1c:b3:7a:
        65:51:32:50:5a:90:fa:ae:e1:19:5f:c8:63:8d:a8:e7:c6:89:
        2e:6d:c8:5b:2c:0c:cd:41:48:bd:79:74:0e:b8:2f:48:69:df:
        02:89:bb:b3:59:91:7f:6b:46:29:7e:22:05:8c:bb:6a:7e:f3:
        11:5a:5f:fb:65:51:7d:35:ff:49:9e:ec:d1:2d:7e:73:e5:99:
        c6:41:84:0c:50:11:ed:97:ed:15:de:11:22:73:a1:78:11:2e:
        34:e6:f5:de:66:0c:ba:d5:32:af:b8:54:26:4f:5b:9e:89:89:
        2a:3f:b8:96:27:00:c3:08:3a:e9:e8:a6:ce:4b:5a:e3:97:9e:
        6b:dd:f0:72

Pki realm name: abc
Certificate file name: abc_local.cer
Certificate peer name: -
```

----结束

配置文件

AC的配置文件

```
#
sysname AC
#
pki entity user01
 country CN
 state jiangsu
 organization
 organization-unit info
 common-name hello
 fqdn test.abc.com
 ip-address 10.2.0.2
 email user@test.abc.com

#
pki realm abc
 entity user01
 rsa local-key-pair rsakey
#
interface GigabitEthernet1/0/1
 ip address 10.2.0.2 255.255.255.0
interface GigabitEthernet1/0/2
 ip address 10.1.0.2 255.255.255.0
#
ip route-static 10.3.0.0 255.255.255.0 10.2.0.1
#
return
```

27.11.15 PKI 常见配置错误

27.11.15.1 获取 CA 证书失败

故障现象

- 通过手工方式获取CA证书，查看设备存储介质中没有下载到CA证书，其失败的原因为通过HTTP方式下载CA证书时配置的不正确。
- 通过SCEP协议获取CA证书，查看设备存储介质中没有下载到CA证书，其失败的原因如下：
  - 获取CA证书的命令未配置。
  - 信任的CA名称配置的不正确或未配置。
  - 证书注册服务器的URL配置的不正确或未配置。
  - 指定的PKI实体未配置。
  - 指纹信息配置的不正确或未配置。
  - 使用的RSA密钥对未配置。
  - TCP连接使用的源接口配置的不正确。

操作步骤

- 通过手工方式获取CA证书

  检查HTTP方式下载CA证书的配置是否正确。如果不正确，请修改相应的内容。详情请参见命令**pki http**。
- 通过SCEP协议获取CA证书
  a. 检查在系统视图下是否已执行命令**pki get-certificate**申请CA证书。

     如果没有，请执行本命令。当申请CA证书相关配置不全时，会提示您配置相应的内容。

b. 检查PKI域下配置的申请CA证书的相关配置是否正确。

可以在任意视图下执行命令**display pki realm**或者在PKI域下执行**display this**查看。

如下所示，这里例举申请CA证书所需的配置。

```
pki realm test
 ca id ca_server   //配置PKI域信任的CA
 enrollment-url http://10.13.14.15:8080/certsrv/mscep/mscep.dll   //配置证书注册服务器的URL
 entity zzz   //指定使用的PKI实体
 fingerprint sha1 7a34d94624b1c1bcbf6d763c4a67035d5b578eaf   //配置对CA证书进行认证时使用的CA证书指纹，从CA服务器上获取
 rsa local-key-pair 8   //指定使用的RSA密钥对
 source interface GigabitEthernet0/0/2   //指定TCP连接使用的源接口（确保该接口为三层接口，且接口下已经配置了IP地址），缺省情况下设备使用出接口作为TCP连接的源接口
```

如果相关配置不正确，请修改相应的内容。详情请参见**27.11.7.1 配置通过SCEP协议为PKI实体申请和更新本地证书**。

----结束

27.11.15.2 获取本地证书失败

故障现象

- 通过手工方式离线获取本地证书，查看设备存储介质中没有下载到本地证书，其失败的原因如下：
  - 指定的PKI实体配置的不正确。
  - 挑战密码配置的不正确或未配置。
  - 通过HTTP方式下载本地证书时配置的不正确。
- 通过SCEP或CMPv2协议获取本地证书，查看设备存储介质中没有下载到本地证书，其失败的原因如下：
  - 执行获取操作之前PKI域中没有CA证书。
  - 指定的PKI实体配置的不正确或未配置。
  - 信任的CA名称配置的不正确或未配置。
  - 证书注册服务器的URL配置的不正确或未配置。
  - 使用的RSA密钥对未配置。
  - TCP连接使用的源接口配置的不正确。
  - 签名证书注册请求消息使用的摘要算法配置的不正确。
  - 挑战密码配置的不正确或未配置。
  - 消息认证码的参考值和秘密值配置的不正确或未配置。
  - 用于证明身份的证书配置不正确。

操作步骤

- 通过手工方式获取本地证书

  a. 检查配置的PKI实体配置是否正确。

  在PKI域下指定的PKI实体，可以执行命令**display pki entity**查看配置的PKI实体信息。

  如果某些内容配置错误，例如PKI实体所属的国家代码配置错误，请修改相应的内容。详情请参见**27.11.6.1 配置PKI实体信息**。

b. 检查挑战密码配置是否正确。

请先确定CA服务器是否要验证挑战密码，如果是，请配置CA服务器的挑战密码，两者要一致。详情请参见命令**pki enroll-certificate**。

c. 检查HTTP方式下载本地证书的配置是否正确。

如果不正确，请修改相应的内容。详情请参见命令**pki http**。

- 通过SCEP或CMPv2协议获取本地证书

a. 检查CA证书是否已导入设备的内存中。

可以执行命令**display pki certificate**查看设备内存中的CA证书。

如果没有请获取CA证书并执行命令**pki import-certificate**将CA证书导入设备的内存中。

b. 检查配置的PKI实体配置是否正确。

在PKI域下指定的PKI实体，可以执行命令**display pki entity**查看配置的PKI实体信息。

如果某些内容配置错误，例如PKI实体所属的国家代码配置错误，请修改相应的内容。详情请参见**27.11.6.1 配置PKI实体信息**。

c. 检查PKI域或者CMP会话下配置的申请CA证书的相关配置是否正确。

- PKI域下

可以在任意视图下执行命令**display pki realm**或者在PKI域下执行命令**display this**查看。

如下所示，这里例举申请本地证书所需的配置。

```
pki realm test
 ca id ca_server   //配置PKI域信任的CA
 enrollment-url http://10.13.14.15:8080/certsrv/mscep/mscep.dll   //配置证书注册服务器的URL
 entity zzz   //指定使用的PKI实体
 rsa local-key-pair 8   //指定使用的RSA密钥对
 password cipher %^%#\1HN-bn(k;^|O85OAtYF3(M4%^%#   //配置SCEP证书申请时使用的挑战密码，与CA服务器一致
 source interface GigabitEthernet1/0/2   //指定TCP连接使用的源接口（确保该接口为三层接口，且接口下已经配置了IP地址），缺省情况下设备使用出接口作为TCP连接的源接口
 enrollment-request signature message-digest-method sha1   //配置签名证书注册请求消息使用的摘要算法，与CA服务器一致
```

如果相关配置不正确，请修改相应的内容。详情请参见**27.11.7.1 配置通过SCEP协议为PKI实体申请和更新本地证书**。

- CMP会话下

可以在CMP会话下执行命令**display this**查看。

如下所示，这里例举申请CA证书所需的配置。

```
pki cmp session cmp
 cmp-request ca-name "C=cn,ST=beijing,L=SD,O=BB,OU=BB,CN=BB"   //配置CA的名称，CA名称中各个字段的顺序必须要和实际CA证书中的顺序保持一致
 cmp-request authentication-cert local.cer   //配置CMPv2请求中用于证明身份的证书，用于更新证书或为其他设备申请证书等
 cmp-request entity user01   //指定使用的PKI实体
 cmp-request server url http://10.3.0.1:8080   //配置CMPv2服务器的URL
 cmp-request rsa local-key-pair rsa  regenerate   //指定使用的RSA密钥对
 cmp-request message-authentication-code 1234 %^%#ZodFBGH[^BkU2(~>[NRBv|#b>se|@I7"'A,llG_B%^%#   //配置消息认证码的参考值和秘密值，与CA服务器一致
```

如果相关配置不正确，请修改相应的内容。详情请参见**27.11.7.2 配置通过CMPv2协议为PKI实体申请和更新本地证书**。

----结束

27.11.16 PKI FAQ

27.11.16.1 CA 证书、本地证书和自签名证书的区别?

CA证书、本地证书和自签名证书的区别如**表27-21**所示。

表 27-21 证书类型

类型	描述	说明
自签名证书	自签名证书又称为根证书，是自己颁发给自己的证书，即证书中的颁发者和主体名相同。	申请者无法向CA申请本地证书时，可以通过设备生成自签名证书，可以实现简单证书颁发功能。 设备不支持对其生成的自签名证书进行生命周期管理（如证书更新、证书撤销等），为了确保设备和证书的安全，建议用户替换为自己的本地证书。
CA证书	CA自身的证书。如果PKI系统中没有多层级CA，CA证书就是自签名证书；如果有多层级CA，则会形成一个CA层次结构，最上层的CA是根CA，它拥有一个CA“自签名”的证书。	申请者通过验证CA的数字签名从而信任CA，任何申请者都可以得到CA的证书（含公钥），用以验证它所颁发的本地证书。
本地证书	CA颁发给申请者的证书。	-

类型	描述	说明
设备本地证书	设备根据CA证书给自己颁发的证书，证书中的颁发者名称是CA服务器的名称。	申请者无法向CA申请本地证书时，可以通过设备生成设备本地证书，可以实现简单证书颁发功能。 **说明** ● 在关闭DNS服务器访问条件下，Chrome等浏览器打开内置Portal认证页面时，浏览器会有安全提示,可以访问认证页面成功。打开DNS服务器访问条件时，可能访问失败。这时候推荐用户尝试使用IE浏览器。 ● 部分终端在连接WIFI网络后，会主动向服务器发送HTTP探测请求报文，探测网络连通性。探测不通时，会校验证书是否为CA证书，导致Chrome等浏览器无法打开内置Portal认证页面。

27.11.16.2 证书支持哪几种格式?

设备支持三种文件格式保存证书，如下表所示。

表 27-22 证书格式

格式	描述	说明
PKCS#12	以二进制格式保存证书，可以包含私钥，也可以不包含私钥。常用的后缀有：.P12和.PFX。	对于证书后缀为.CER或.CRT，可以用记事本打开证书，查看证书内容来区分证书格式。 ● 如果有类似 " -----BEGIN CERTIFICATE----- " 和 " -----END CERTIFICATE----- " 的头尾标记，则证书格式为PEM。 ● 如果是乱码，则证书格式为DER。
DER	以二进制格式保存证书，不包含私钥。常用的后缀有：.DER、.CER和.CRT。	

格式	描述	说明
PEM	以ASCII码格式保存证书，可以包含私钥，也可以不包含私钥。常用的后缀有：.PEM、.CER和.CRT。	

27.11.16.3 如何手工导入证书和 RSA 密钥对?

说明

用户通过设备生成证书请求文件（RSA密钥对已经在设备上生成），并将证书请求文件提供给证书颁发机构（CA），CA只颁发本地证书。用户只需将CA提供的CA和本地证书导入设备内存中，无需导入RSA密钥对。

手工替换CA和本地证书时，请先确保证CA和本地证书未被业务使用，然后再执行命令**pki delete-certificate**删除CA和本地证书。例如删除本地证书：

```
[HUAWEI] pki delete-certificate local realm abc
```

手工导入证书和RSA密钥对的步骤如下所示：

1. 用户已通过Web、磁盘、电子邮件等带外方式将申请证书信息发送给CA申请本地证书。
2. 下载CA提供的CA证书、本地证书和RSA密钥对文件，并通过TFTP等方式上传至设备的存储介质中。

   一般情况下，DER和PEM格式的证书和密钥对文件是分开的，PKCS#12格式的证书和密钥对在同一个文件中。
3. 导入CA证书，如果有多个CA证书，则需导入全部CA证书。

   例如，获取到的CA证书文件名为rootca.pem。

   ```
   <HUAWEI> system-view
   [HUAWEI] pki realm abc
   [HUAWEI-pki-realm-abc] quit
   [HUAWEI] pki import-certificate ca realm abc pem filename rootca.pem
   ```

   导入成功后，查看CA证书的信息。

   ```
   [HUAWEI] display pki certificate ca realm abc
   ```
4. 导入本地证书。

   例如，获取到的本地证书文件名为localcert.pem。

   ```
   [HUAWEI] pki import-certificate local realm abc pem filename localcert.pem
   ```

   导入成功后，查看本地证书的信息。

   ```
   [HUAWEI] display pki certificate local realm abc
   ```
5. 导入RSA密钥对。对于PEM和PKCS#12格式的文件还需要CA提供的RSA密钥对相应的密码。

   例如，获取到的RSA密钥对文件名为local_privatekey.pem，密码为test@123。

   ```
   [HUAWEI] pki import rsa-key-pair abc pem local_privatekey.pem password test@123
   ```

   导入成功后，查看RSA密钥对的信息。

   ```
   [HUAWEI] display pki rsa local-key-pair name abc public
   ```

6. 检查导入的本地证书和RSA密钥对是否匹配，如果没有找到匹配的密钥对，请检查导入的文件是否正确。

```
[HUAWEI] pki match-rsa-key certificate-filename localcert.pem
Info: The file localcert.pem contains certificates 1.
Info: Certificate 1 from file localcert.pem matches RSA key test.
```

27.12 SSL 配置

27.12.1 SSL 概述

概述

SSL协议是在Internet基础上提供的一种保证私密性的安全协议。它能使客户端与服务器之间的通信不被攻击者窃听，并且始终对服务器进行认证，还可选择对客户端进行认证。目前，SSL协议广泛应用于电子商务、网上银行等领域。SSL具有以下优点：

- 提供较高的安全性保证。SSL利用数据加密、身份验证和消息完整性验证机制，保证网络上数据传输的安全性。
- 支持各种应用层协议。虽然SSL设计的初衷是为了解决万维网安全性问题，但是由于SSL位于应用层和传输层之间，它可以为任何基于TCP可靠连接的应用层协议提供安全性保证。
- 部署简单。目前SSL已经成为网络中用来鉴别网站和网页浏览者身份，在浏览器使用者及Web服务器之间进行加密通信的全球化标准。

SSL从以下几方面提高了设备的安全性：

- 通过SSL协议保证合法客户端可以安全地访问服务器，禁止非法的客户端访问服务器。
- 客户端与服务器之间交互的数据需要经过加密和摘要，加密保证了传输的安全性，摘要保证了数据的完整性，从而实现了对设备的安全管理。
- 为设备制定基于证书属性的访问控制策略，对客户端的访问权限进行控制，进一步避免了非法客户对设备进行攻击。

基本概念

- CA（Certificate Authority）

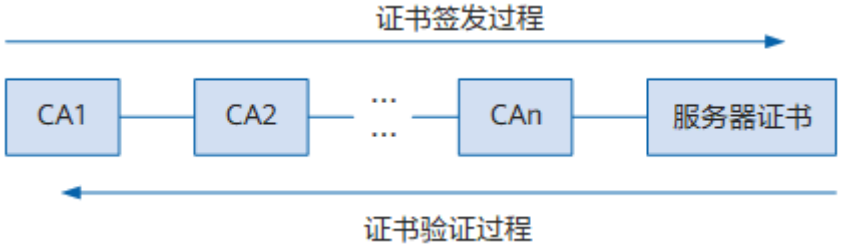
  CA是发放、管理、废除数字证书的机构。CA的作用是检查数字证书持有者身份的合法性，并签发数字证书（在证书上签字），以防证书被伪造或篡改，以及对证书和密钥进行管理。国际上被广泛信任的CA，被称之为根CA。根CA可授权其它CA为其下级CA。CA的身份也需要证明，而证明信息在信任证书机构文件中描述。

  例如：CA1作为最上级CA也叫根证书，签发下一级CA2证书，CA2又可以给它的下一级CA3签发证书，以此下去，最终由CAn签发服务器的证书。

  如果服务器端的证书由CA3签发，则在客户端验证证书的过程从服务器端的证书有效性验证开始。先由CA3证书验证服务器端证书的有效性，如果通过则再由CA2证书验证CA3证书的有效性，最后由最上级CA1证书验证CA2证书的有效性。只有通过最上级CA证书即根证书的验证，服务器证书才会验证成功。

  证书签发过程与证书验证过程如**图27-50**所示。

图 27-50 证书签发过程与证书验证过程示意图



- 数字证书

  数字证书实际上是存于计算机上的一个记录，是由CA签发的一个声明，证明证书主体（证书申请者拥有了证书后即成为证书主体）与证书中所包含的公钥的惟一对应关系。数字证书中包括证书申请者的名称及相关信息、申请者的公钥、签发数字证书的CA的数字签名及数字证书的有效期等内容。数字证书的作用使网上通信双方的身份得到了互相验证，提高了通信的可靠性。

  用户必须事先获取信息发送者的公钥证书，以便对信息进行解码认证，同时还需要CA发送给发送者的证书，以便用户验证发送者的身份。

- 证书撤销列表CRL（Certificate Revocation List）

  CRL由CA发布，它指定了一套证书发布者认为无效的证书。

  数字证书的寿命是有限的，但CA可通过证书撤销过程缩短证书的寿命。CRL指定的寿命通常比数字证书指定的寿命要短。由CA撤销数字证书，意味着CA在数字证书正常到期之前撤销允许使用密钥对的有关声明。在撤销证书到期后，CRL中的有关数据被删除，以缩短CRL列表的大小。

  任何一个证书被废除以后，证书机构CA就要发布CRL来声明该证书是无效的，并列出所有被废除证书的签发者和序列号、CRL的签发日期、证书被撤销的日期、CRL下次发布时间等信息。

  CRL提供了一种检验证书有效性的方式，当终端实体需要验证对端证书合法性时，通常需要检查对端证书的CRL，判断该证书是否被撤销。

协议安全机制

SSL协议提供的安全机制如下：

- 连接的私密性

  SSL利用对称加密算法对传输数据进行加密，并利用密钥交换算法—RSA（Rivest Shamir and Adleman，非对称密钥算法的一种）加密传输对称密钥算法中使用的密钥。

- 身份验证机制

  基于证书利用数字签名方法对服务器和客户端进行身份验证。SSL服务器和客户端通过公钥基础设施PKI（Public Key Infrastructure）提供的机制从CA获取证书。

- 内容的可靠性

  消息传输过程中使用基于密钥的消息验证码MAC（Message Authentication Code）来检验消息的完整性。

  MAC算法是将密钥和任意长度的数据转换为固定长度数据的一种算法。

  - 发送端在密钥参与下，利用MAC算法计算出消息的MAC值，并将其加在消息之后发送给接收端。
  - 接收端利用同样的密钥和MAC算法计算出消息的MAC值，并与接收到的MAC值比较。

如果二者相同，则报文没有改变。否则，报文在传输过程中被修改，接收端将丢弃该报文。

27.12.2 SSL 缺省配置

SSL的缺省配置如表27-23所示。

表 27-23 SSL 缺省配置

参数	缺省值
客户端型SSL策略使用的SSL协议版本	TLS1.2
客户端型SSL策略使用的加密套件	**ecdhe_rsa_aes128_gcm_sha256**和**ecdhe_rsa_aes256_gcm_sha384**
服务器型SSL策略支持的加密套件	**ecdhe_rsa_aes128_gcm_sha256**和**ecdhe_rsa_aes256_gcm_sha384**
保存会话的最大数目和最大时长	缺省情况下，保存会话的最大时长为3600秒，保存会话的最大数目为128。

27.12.3 配置服务器型 SSL 策略

前提条件

PKI域已成功配置。

背景信息

SSL利用数据加密、身份验证和消息完整性验证机制，为基于TCP可靠连接的应用层协议提供安全性保证。应用层协议可以关联服务器型SSL策略，使应用层协议与SSL结合，从而为应用层协议提供安全连接。

图 27-51 AC 作为 SSL 服务器示意图

如图27-51所示，管理员在AC配置服务器型SSL策略后，AC可以作为SSL服务器。在SSL握手过程中，AC使用服务器型SSL策略所设置的SSL参数与SSL客户端之间协商会话参数，并建立会话。

AC作为SSL服务器时，允许SSL客户端对其进行身份验证，但它不具备对SSL客户端进行身份验证的功能。

说明

AC作为SSL服务器时，可以与SSL3.0、TLS1.0、TLS1.1和TLS1.2版本的SSL客户端通信。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**ssl policy** *policy-name* **type server**，创建服务器型SSL策略，并进入服务器型SSL策略视图。

步骤3 执行命令**pki-realm** *realm-name*，配置服务器型SSL策略所使用的PKI域。

缺省情况下，AC没有配置服务器型SSL策略所使用的PKI域。

说明

作为SSL服务器的AC基于PKI域从认证机构CA获取数字证书，以便SSL客户端可以根据数字证书对AC进行身份验证。

AC也支持自身生成自签名证书，但由于设备不支持对该证书进行生命周期管理（如证书更新、证书撤销等），为了确保设备和证书的安全，建议用户替换为自己的证书。

步骤4 （可选）执行命令**version** { **ssl3.0** | **tls1.0** | **tls1.1** | **tls1.2** } *，配置服务器型SSL策略使用的SSL协议版本。

缺省情况下，服务器型SSL策略使用的SSL协议版本为TLS1.2。

说明

推荐使用TLS1.2，其他协议版本存在安全风险。

步骤5 （可选）执行命令**session** { **cachesize** *size* | **timeout** *time* } *，配置保存会话的最大数目和最大时长。

缺省情况下，保存会话的最大时长为3600秒，保存会话的最大数目为128。

步骤6 （可选）执行命令**ciphersuite** { **rsa_3des_cbc_sha** | **rsa_aes_128_cbc_sha** | **rsa_aes_128_sha256** | **rsa_aes_256_sha256** | **ecdhe_rsa_aes128_gcm_sha256** | **ecdhe_rsa_aes256_gcm_sha384** } *，配置服务器型SSL策略支持的加密套件。

缺省情况下，服务器型SSL策略支持的加密套件为**ecdhe_rsa_aes128_gcm_sha256**和**ecdhe_rsa_aes256_gcm_sha384**。

步骤7 （可选）配置SSL连接重协商速率。

当设备遇到重协商攻击时，可通过配置SSL连接重协商速率，减轻重协商对设备造成的攻击。

1. 执行命令**quit**，返回系统视图。
2. 执行命令**ssl renegotiation-rate** *rate*，配置SSL连接重协商速率。

   缺省情况下，SSL连接重协商速率为1次/秒，用户可基于设备CPU的能力适当调整重协商速率。

   此配置对所有SSL策略均生效。

   说明

   如果STA需要重协商，请确保STA支持安全的重协商功能。否则，可能导致STA重协商失败。

----结束

检查配置结果

执行命令**display ssl policy** [*policy-name*]，查看SSL策略的配置信息。

27.12.4 配置客户端型 SSL 策略

前提条件

PKI域已成功配置。

背景信息

SSL利用数据加密、身份验证和消息完整性验证机制，为基于TCP可靠连接的应用层协议提供安全性保证。应用层协议可以关联客户端型SSL策略，使应用层协议与SSL结合，从而为应用层协议提供安全连接。

图 27-52 AC 作为 SSL 客户端示意图

如图27-52所示，管理员在AC上配置客户端型SSL策略后，AC可以作为SSL客户端。在SSL握手过程中，AC使用客户端型SSL策略所设置的SSL参数与SSL服务器之间协商会话参数，并建立会话。

AC作为SSL客户端时，不允许SSL服务器对其进行身份验证，但可以选择对SSL服务器进行身份验证。为了保证通信安全，当AC作为SSL客户端时，请使能基于证书的SSL服务器身份验证。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**ssl policy** *policy-name* **type client**，创建客户端型SSL策略，并进入客户端型SSL策略视图。

步骤3 执行命令**server-verify enable**，使能基于证书的SSL服务器身份验证。

缺省情况下，使能基于证书的SSL服务器身份验证。

步骤4 执行命令**pki-realm** *realm-name*，配置客户端型SSL策略所使用的PKI域。

缺省情况下，AC没有配置客户端型SSL策略所使用的PKI域。

说明

作为SSL客户端的AC基于PKI域从认证机构CA获取CA证书链，以便AC可以根据CA证书链对SSL服务器进行身份验证。

步骤5 （可选）执行命令**version** { **ssl3.0** | **tls1.0** | **tls1.1** | **tls1.2** }，配置客户端型SSL策略使用的SSL协议版本。

缺省情况下，客户端型SSL策略使用的SSL协议版本为TLS1.2。

说明

本步骤所配置的SSL协议版本必须包含在SSL服务器支持的协议版本中。若配置本步骤，请确认SSL服务器支持的协议版本。

推荐使用TLS1.2，其他协议版本存在安全风险。

步骤6 （可选）执行命令**prefer-ciphersuite** { **rsa_3des_cbc_sha** | **rsa_aes_128_cbc_sha** | **rsa_aes_128_sha256** | **rsa_aes_256_sha256** | **ecdhe_rsa_aes128_gcm_sha256** | **ecdhe_rsa_aes256_gcm_sha384** } *，配置客户端型SSL策略使用的加密套件。

缺省情况下，客户端型SSL策略使用的加密套件为**ecdhe_rsa_aes128_gcm_sha256**和**ecdhe_rsa_aes256_gcm_sha384**。

说明

本步骤所配置的加密套件必须包含在SSL服务器支持的加密套件中。若配置本步骤，请确认SSL服务器支持的加密套件。

步骤7 （可选）配置SSL连接重协商速率。

当设备遇到重协商攻击时，可通过配置SSL连接重协商速率，减轻重协商对设备造成的攻击。

1. 执行命令**quit**，返回系统视图。
2. 执行命令**ssl renegotiation-rate** *rate*，配置SSL连接重协商速率。

   缺省情况下，SSL连接重协商速率为1次/秒，用户可基于设备CPU的能力适当调整重协商速率。

   此配置对所有SSL策略均生效。

   说明

   如果STA需要重协商，请确保STA支持安全的重协商功能。否则，可能导致STA重协商失败。

----结束

检查配置结果

执行命令**display ssl policy** [*policy-name*]，查看SSL策略的配置信息。

27.12.5 SSL 配置举例

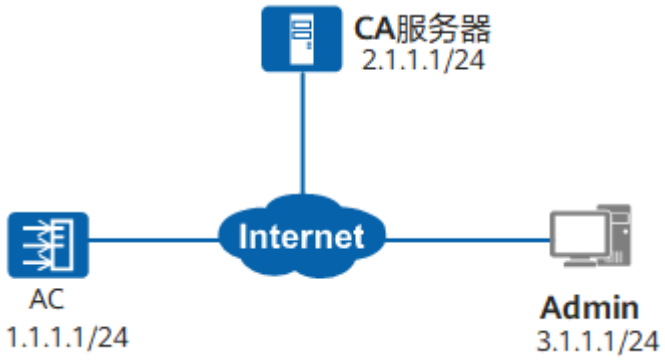
27.12.5.1 配置服务器型 SSL 策略示例

组网需求

如图27-53所示，某企业用户可以利用Web页面访问设备。为了防止传输的数据不被窃听和篡改，实现对设备的安全管理，网络管理员要求用户以HTTPS的方式安全访问设备。

为了满足上述需求，需要把AC配置成为HTTPS服务器，并且该HTTPS服务器关联服务器型SSL策略，以便用户可以利用Web页面安全访问和管理设备。

图 27-53 配置服务器型 SSL 策略示意图



配置思路

采用如下的配置思路：

1. 配置PKI，包括PKI实体和PKI域。
2. 配置服务器型SSL策略。
3. 配置HTTPS服务器。

说明

请确保AC、PC和CA服务器之间路由可达。

操作步骤

步骤1 配置PKI

配置PKI实体。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] pki entity users
[AC-pki-entity-users] common-name hello
[AC-pki-entity-users] country cn
[AC-pki-entity-users] state jiangsu
[AC-pki-entity-users] organization huawei
[AC-pki-entity-users] organization-unit info
[AC-pki-entity-users] quit
```

说明

实体名和实体通用名如果没有配置为设备的IP地址1.1.1.1，使用HTTPS打开网页的时候会提示“证书不合法”，但这不会影响正常使用。

配置PKI域，并使能证书自动注册和更新功能。

```
[AC] pki realm users
[AC-pki-realm-users] entity users
[AC-pki-realm-users] ca id ca_root
[AC-pki-realm-users] enrollment-url http://2.1.1.1:8080/certsrv/mscep/mscep.dll ra
[AC-pki-realm-users] fingerprint sha2
7bb05ada0482273388ed4ec228d79f77309ea3f47bb05ada0482273388ed4ec2
[AC-pki-realm-users] auto-enroll regenerate
[AC-pki-realm-users] quit
```

步骤2 配置服务器型SSL策略

配置SSL策略使用PKI域users，以便AC可以基于该PKI域从认证机构CA获取数字证书。

```
[AC] ssl policy sslserver type server
[AC-ssl-policy-sslserver] pki-realm users
```

配置保存会话的最大数目和最大时长。

```
[AC-ssl-policy-sslserver] session cachesize 40 timeout 7200
[AC-ssl-policy-sslserver] quit
```

步骤3 配置HTTPS服务器

配置HTTPS服务器关联的SSL策略为sslserver。

```
[AC] http secure-server ssl-policy sslserver
```

使能AC的HTTPS服务器功能。

```
[AC] http secure-server enable
```

配置HTTPS服务的端口号。

```
[AC] http secure-server port 1278
```

步骤4 验证配置结果

执行命令**display ssl policy sslserver**，查看SSL策略sslserver的配置信息。

```
[AC] display ssl policy sslserver
  ------------------------------------------------------------------------------
  Policy name                          :   sslserver
  Policy ID                            :   1
  Policy type                          :   Server
  Cipher suite                         :   rsa_aes_128_cbc_sha
  PKI realm                            :   users
   Cache number                        :   40
  Time out(second)                     :   7200
  Server certificate load status       :   loaded
  CA certificate chain load status     :   loaded
  Bind number                          :   1
  SSL connection number                :   0
  ------------------------------------------------------------------------------
```

----结束

配置文件

AC的配置文件

```
#
 sysname AC
#
pki entity users
 country CN
 state jiangsu
 organization huawei
 organization-unit info
 common-name hello
#
pki realm users
 ca id ca_root
 enrollment-url http://2.1.1.1:8080/certsrv/mscep/mscep.dll ra
 entity users
 auto-enroll regenerate
 fingerprint sha2 7bb05ada0482273388ed4ec228d79f77309ea3f47bb05ada0482273388ed4ec2
#
ssl policy sslserver type server
```

```
 pki-realm users
 session cachesize 40 timeout 7200
#
 http secure-server port 1278
 http secure-server ssl-policy sslserver
#
return
```

27.13 HTTPS 配置

安全超文本传输协议HTTPS（Hypertext Transfer Protocol Secure）通过SSL提供的数据加密、身份验证和消息完整性验证等安全机制，为Web访问提供安全性保证。

27.13.1 HTTPS 简介

介绍HTTPS的定义、由来和作用。

定义

HTTPS（Secure HTTP）是支持安全套接层SSL（Secure Sockets Layer）协议的HTTP协议。

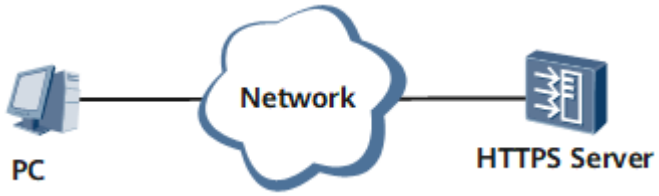
目的

HTTPS通过SSL协议，从以下几方面提高了设备的安全性：

- 通过SSL协议保证合法客户端可以安全地访问设备，禁止非法的客户端访问设备。
- 客户端与设备之间交互的数据需要经过加密，保证了数据传输的安全性和完整性，从而实现了对设备的安全管理。
- 为设备制定基于证书属性的访问控制策略，对客户端的访问权限进行控制，进一步避免了非法客户对设备进行攻击。

如图27-54所示，在作为HTTP服务器的设备上部署服务器型SSL策略，并使能HTTPS服务器功能后，用户可以通过浏览器登录HTTPS服务器，利用Web页面安全管理远程设备。

图 27-54 通过浏览器登录 HTTPS 服务器



27.13.2 配置 HTTPS 服务器

在设备上配置HTTPS服务器功能后，用户可以利用Web页面安全访问远程的设备。

前提条件

确保已完成了服务器型SSL策略的配置，请参看**配置服务器型SSL策略**。

背景信息

用户通过Web页面远程访问作为HTTP服务器的设备时，传统的HTTP会有以下问题：

- 不能使用户对设备进行身份验证。
- 不能保证用户和设备之间数据传输的私密性与完整性。

为了避免HTTP存在的安全方面的缺陷，设备可以作为HTTPS服务器，利用SSL协议的数据加密、身份验证和消息完整性验证机制，保证用户和设备之间数据传输的安全性，这样用户可以利用Web页面安全访问远程的设备。

设备上提供默认的SSL策略，同时Web网页文件中也包含SSL证书，所以用户可以不必再上传证书以及手动配置SSL策略。但为了保证安全性，可以从CA（Certificate Authority）处重新获取有效证书，然后进行手动配置SSL策略。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**http secure-server ssl-policy** *ssl-policy*，配置HTTPS服务器关联的服务器型SSL策略。

缺省情况下，未配置HTTPS服务器关联的服务器型SSL策略。

步骤3 （可选）执行命令**http secure-server port** *port-number*，配置HTTPS服务的端口号。

缺省情况下，HTTPS服务的端口号是443。

步骤4 执行命令**http secure-server enable**，使能设备的HTTPS服务器功能。

缺省情况下，使能设备的HTTPS服务器功能。

----结束

检查配置结果

- 执行命令**display current-configuration**，查看HTTPS服务器的配置信息。

```
<HUAWEI> display current-configuration | include http secure-server
 http secure-server port 1026
 http secure-server ssl-policy user
 http secure-server enable
```

27.13.3 配置举例

介绍HTTPS的配置举例。配置举例中包括组网需求、配置思路、操作步骤等。

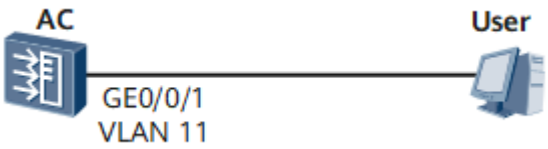
27.13.3.1 配置 HTTPS 服务器示例

组网需求

如图27-55所示，用户通过Web方式访问网关设备AC。

为了防止传输的数据不被窃听和篡改，实现对设备的安全管理，网络管理员要求用户以HTTPS的方式安全访问设备。

图 27-55 配置 HTTPS 服务器组网图



配置思路

采用如下思路在AC上进行配置：

1. 创建VLAN、VLANIF，并配置各接口，使企业用户能够访问设备。
2. 配置服务器型SSL策略并配置缺省的PKI域作为该策略使用的PKI域，无需安装独立的CA服务器。
3. 配置HTTPS服务器功能，保证用户与AC之间数据传输的私密性与完整性。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。
  - 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
  - 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

  配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击？**
- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 创建VLAN并配置各接口

在AC上创建VLAN 11。

```
<HUAWEI> system-view
[HUAWEI] vlan batch 11
```

配置AC连接用户的接口GE0/0/1加入VLAN11。

```
[HUAWEI] interface gigabitethernet 0/0/1
[HUAWEI-GigabitEthernet0/0/1] port link-type access
[HUAWEI-GigabitEthernet0/0/1] port default vlan 11
[HUAWEI-GigabitEthernet0/0/1] quit
```

创建VLANIF11，并为VLANIF11配置IP地址10.1.1.1/24。

```
[HUAWEI] interface vlanif11
[HUAWEI-Vlanif11] ip address 10.1.1.1 24
[HUAWEI-Vlanif11] quit
```

步骤2 配置服务器型SSL策略

配置SSL策略使用PKI缺省域default。

```
[HUAWEI] ssl policy userserver type server
[HUAWEI-ssl-policy-userserver] pki-realm default
```

配置保存会话的最大数目和最大时长。

```
[HUAWEI-ssl-policy-userserver] session cachesize 20 timeout 7200
[HUAWEI-ssl-policy-userserver] quit
```

步骤3 配置HTTPS服务器

配置HTTPS服务器关联的SSL策略为userserver。

```
[HUAWEI] http secure-server ssl-policy userserver
```

配置HTTPS服务的端口号。

```
[HUAWEI] http secure-server port 1278
```

使能AC的HTTPS服务器功能。

```
[HUAWEI] http secure-server enable
  This operation will take several minutes, please wait...
Info:HTTPS server has been started
[HUAWEI] quit
```

步骤4 检查配置结果

执行命令**display ssl policy** *policy-name*，查看SSL策略userserver的配置信息。

```
<HUAWEI> display ssl policy userserver
 ------------------------------------------------------------------------------
  Policy name                    :   userserver
  Policy ID                      :   0
  Policy type                    :   Server
  Cache number                   :   20
  Time out(second)               :   7200
  Server certificate load status :   loaded
  CA certificate chain load status:   loaded
  Bind number                    :   1
  SSL connection number          :   0
  ------------------------------------------------------------------------------
```

当用户在主机user上打开浏览器，输入网址“https://10.1.1.1:1278”后，主机user将以HTTPS的方式访问Web网管页面，用户后续可以利用Web网管页面安全访问和管理AC。

----结束

配置文件

AC的配置文件

```
#
 http server enable
 http secure-server port 1278
 http secure-server ssl-policy userserver
 #
vlan batch 11
#
```

```
pki realm default
 enrollment self-signed
#
ssl policy userserver type server
 pki-realm default
 session cachesize 20 timeout 7200
#
interface Vlanif11
 ip address 10.1.1.1 255.255.255.0
#
interface GigabitEthernet0/0/1
 port link-type access
 port default vlan 11
#
return
```

27.14 Keychain 配置

Keychain是一个集中控制认证算法和认证密钥的应用程序，广泛应用于应用协议的认证中。

27.14.1 Keychain 简介

介绍Keychain的定义和作用。

定义

Keychain是加密规则（key）的集合。它可以为应用程序提供认证功能，在认证过程中，Keychain可以动态地更改认证算法和密钥。Keychain在不中断业务的前提下，通过定期更改认证加密的密钥和算法，提升网络数据传输的安全性。

目的

在网络中，两个应用程序进行通信时，会有一些非法用户试图篡改数据报文或者伪装成认证用户，这样会导致安全问题。为了能识别这些被篡改的报文和伪装的用户，应用程序通过定义认证规则进行信息的认证。一个应用程序可以使用自己独有的认证规则。

然而，长期使用同一个认证规则，容易被非法用户破解。如果由管理员人工修改通信双方的认证规则，将是非常繁琐和复杂的任务，同时，人工修改也容易引入各种问题。此外，如果每个应用程序独立拥有自己的认证规则，当许多应用实例需要配置相同的认证算法时，将会导致数据和配置过程重复。

为了解决上述问题，需要一种能够管理所有认证信息的程序，因而引入了Keychain。Keychain可以集中控制所有的认证过程，并且能够在认证过程中动态更改认证算法和密钥，而不需要人工过多参与。这极大的提高了通信的安全性。

27.14.2 原理描述

介绍Keychain的实现原理。

27.14.2.1 基本概念

Keychain是加密规则（key）的集合。每个规则必须含有以下三个要素：认证算法、认证密钥（加密字符串）、规则的发送/接收时间。其中认证算法和认证密钥用来生成信

息认证码MAC，发送/接收时间表示在这段时间内，能够使用配置的算法和密钥对报文认证后发送/接收。

key

key包含认证信息和活跃时间。认证信息包括认证算法和认证密钥。Keychain支持MD5、SHA1-12、HMAC-MD5、HMAC-SHA1-12、HMAC-SHA1-20等认证算法。应用程序应用Keychain时，也必须支持Keychain里配置的认证算法。认证密钥是一串字符，由用户配置得到。

活跃时间包括发送时间和接收时间。设备上通过设置key的接收和发送活跃时间实现动态变更认证信息。根据key配置的接收时间和发送时间，key可以分为活跃的发送key和活跃的接收key：

- 活跃的发送key：当系统时间处于key配置的发送时间范围内时，该key处于发送活跃状态。应用程序发送报文时，使用此key配置的认证算法和密钥生成发送端的MAC（Message Authentication Code）。
- 活跃的接收key：当系统时间处于key配置的接收时间范围内时，该key处于接收活跃状态。应用程序接收报文时，使用此key配置的认证算法和密钥生成接收端的MAC。

Message Authentication Code

Message Authentication Code，信息认证码，简称MAC，是一串字符。在Keychain的应用中，由设备使用认证算法，对数据报文和认证密钥进行计算得到。

Keychain 的时间模式

Keychain的时间模式是指Keychain中的key按时间工作的方式，包括绝对时间模式和周期时间模式。

绝对时间模式指时间是UTC格式，它表示Keychain只能在一个绝对的时间段内工作。

周期时间模式表示Keychain周期性地在指定时间段内工作。周期时间模式又包括：

- 日周期模式，表示Keychain中的key在每天固定时间段内生效。
- 周周期模式，表示Keychain中的key在每周指定的周几生效。
- 月周期模式，表示Keychain中的key在每月指定的日期生效。
- 年周期模式，表示Keychain中的key在每年指定的月份生效。

一个Keychain只能指定一种时间模式。在Keychain创建时就需要指定时间模式，key的发送和接收时间根据Keychain的时间模式进行配置。

缺省发送 key

如果在某个时间段管理员没有配置key，此时将没有活跃的发送key。在该时间段，应用程序将没有认证的交互。为了避免这种情况，可以配置缺省发送key。在没有其他活跃的发送key时，应用程序将使用缺省发送key作为活跃的发送key。

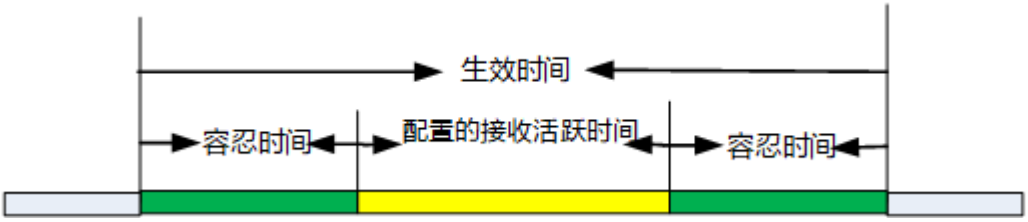
接收容忍时间

当设备上的发送key发生改变时，对应接收端的接收key也必须发生改变。由于时间不同步，在两台设备上的key发生改变时，可能会有时间差。在这段时间内，由于key的

不一致将导致报文丢失。为了避免该情况出现，需要在接收key发生切换时有一个平滑的过渡。这个平滑的过渡时间段称为接收容忍时间。

接收容忍时间只能对接收key有用，可以在每一个Keychain中配置接收容忍时间。配置接收容忍时间后，如图27-56所示，接收key的启动和结束时间都将做相应的延长。

图 27-56 容忍时间生效时间段



TCP kind 和 TCP algorithm-id

TCP应用程序之间通过TCP认证建立连接。对于TCP的认证交互，TCP使用增强的TCP认证选项。

- 不同的厂商使用不同的kind-value值代表增强的TCP认证选项。为了实现不同厂商设备之间的交互，kind-value是可配置的，能根据对端设备的TCP类型进行调整。
- 在TCP的增强认证选项中存在一个algorithm-id字段，该字段用来表示认证算法的类型。由于algorithm-id不是IANA（Internet Assigned Numbers Authority，因特网地址分配组织）统一定义的，不同的厂商之间使用不同的algorithm-id值来代表认证算法。为了实现不同厂商之间的互通，algorithm-id的值与认证算法的对应关系也是可以配置的。

27.14.2.2 非 TCP 应用程序应用 Keychain 的原理

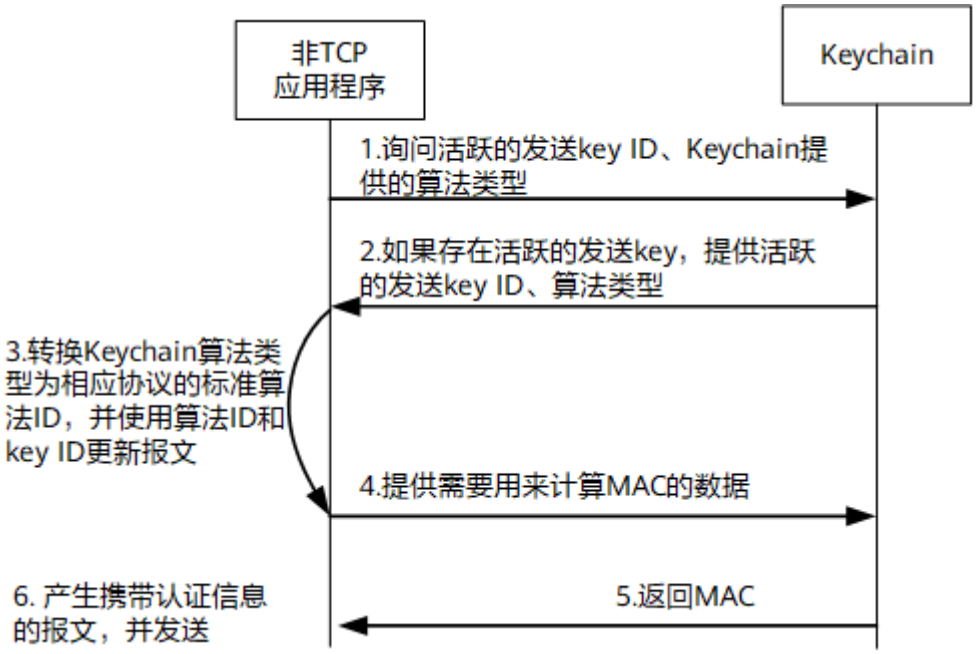
Keychain为应用层协议提供了认证服务。当创建之后，Keychain需要被应用程序使用才能生效。按照不同应用程序应用Keychain进行认证的不同处理流程，可分为非TCP应用程序使用Keychain认证和TCP应用程序使用Keychain认证。

非 TCP 应用程序使用 Keychain 认证发送报文

如图27-57所示，非TCP应用程序使用Keychain发送报文的流程如下：

1. 应用程序询问Keychain的活跃发送key ID和Keychain提供的算法类型。
2. 如果存在活跃的发送key，Keychain模块提供活跃的发送key ID和算法类型；如果没有，应用程序正常发送报文。
3. 应用程序收到活跃发送key ID和算法类型后，将Keychain算法类型转换为相应协议的标准算法ID，并将此算法ID和key ID封装进报文。
4. 应用程序提供需要用来计算MAC（Message Authentication Code）的数据。
5. Keychain模块使用活跃的发送key定义的认证算法和密钥，计算出MAC，并返回MAC。
6. 应用程序产生携带认证信息的报文，并发送出去。

图 27-57 非 TCP 应用程序使用 Keychain 发送报文

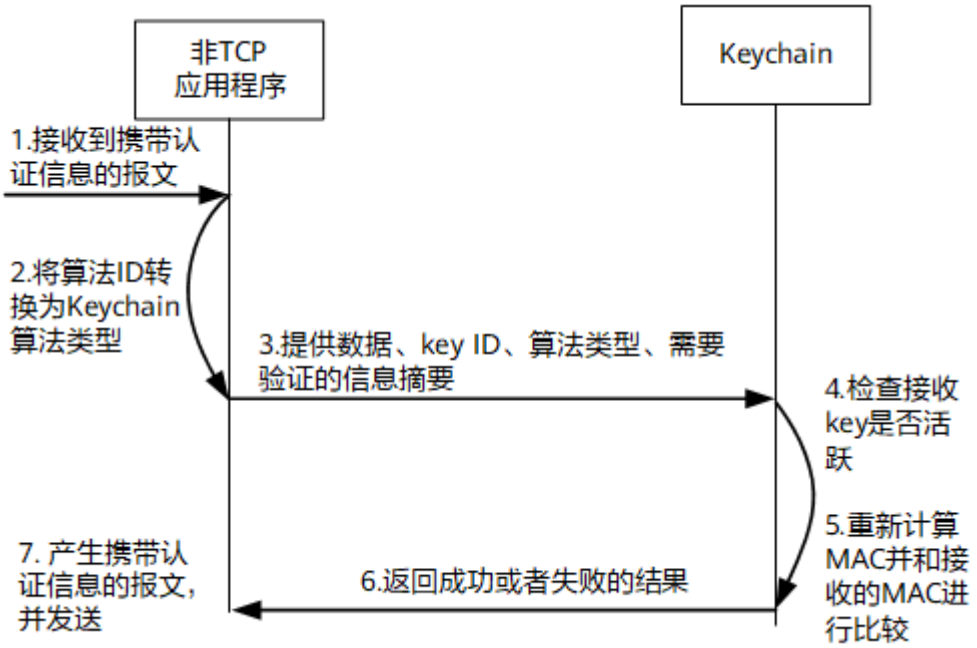


非 TCP 应用程序使用 Keychain 认证接收报文

如图27-58所示，非TCP应用程序接收到报文后的处理流程如下：

1. 接收端接收到携带认证信息的报文。
2. 接收端应用程序将接收的算法ID转换为Keychain算法类型。
3. 接收端应用程序提供数据报文、key ID、算法类型、需要验证的MAC值。
4. Keychain模块根据接收到报文的key的ID，检查本端对应ID的接收key是否活跃。如果不活跃，则返回认证失败消息。
5. 如果对应的接收key活跃，Keychain模块使用此key配置的认证算法和密钥，重新计算MAC，并且比较新生成的MAC和接收到的MAC是否一致。
6. 返回成功消息或者失败消息。
7. 应用程序根据Keychain的认证结果决定接收或丢弃报文。

图 27-58 非 TCP 应用程序使用 Keychain 认证接收报文



说明

IS-IS使用Keychain认证，发送报文时不携带key ID。当接收端收到含认证信息的IS-IS报文时，设备会查看所有活跃的接收key，找一个算法相同的进行校验。

27.14.2.3 TCP 应用程序应用 Keychain 的原理

TCP 应用程序使用 Keychain 认证发送报文

在donica草案中，TCP使用增强的认证选项进行认证交互，增强认证选项的报文格式如图27-59所示：

图 27-59 TCP 增强认证选项格式

Kind	Length	T	K	Alg-id	Res	Key-id
Authentication Data						

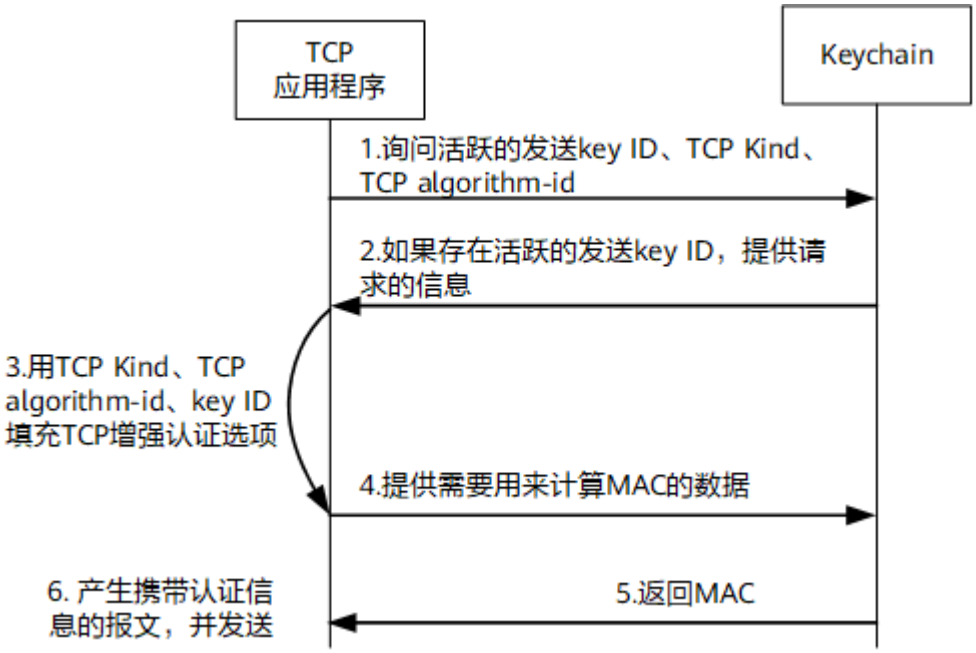
目前该草案还没有标准化，IANA没有统一定义类型（Kind）值和认证算法对应的ID(Alg-id)。各设备商使用不同的取值。为了使不同厂商的设备能够互通，Keychain使TCP类型值和认证算法的ID可以配置和维护。

如图27-60所示，TCP应用程序应用Keychain发送报文的流程如下：

1. 应用程序询问活跃的发送key ID、TCP Kind、TCP algorithm-id。
2. 如果存在活跃的发送key，则Keychain模块提供应用程序请求的信息。
3. 应用程序用TCP Kind、TCP algorithm-id、key ID填充TCP增强认证选项。
4. 应用程序给Keychain模块提供需要用来计算MAC（Message Authentication Code）的数据。

5. Keychain模块根据活跃发送key所配置算法和密钥，计算MAC，并返回MAC值。
6. 应用程序将获取的MAC填充到增强认证选项，将报文发送出去。

图 27-60 TCP 应用程序使用 Keychain 发送报文

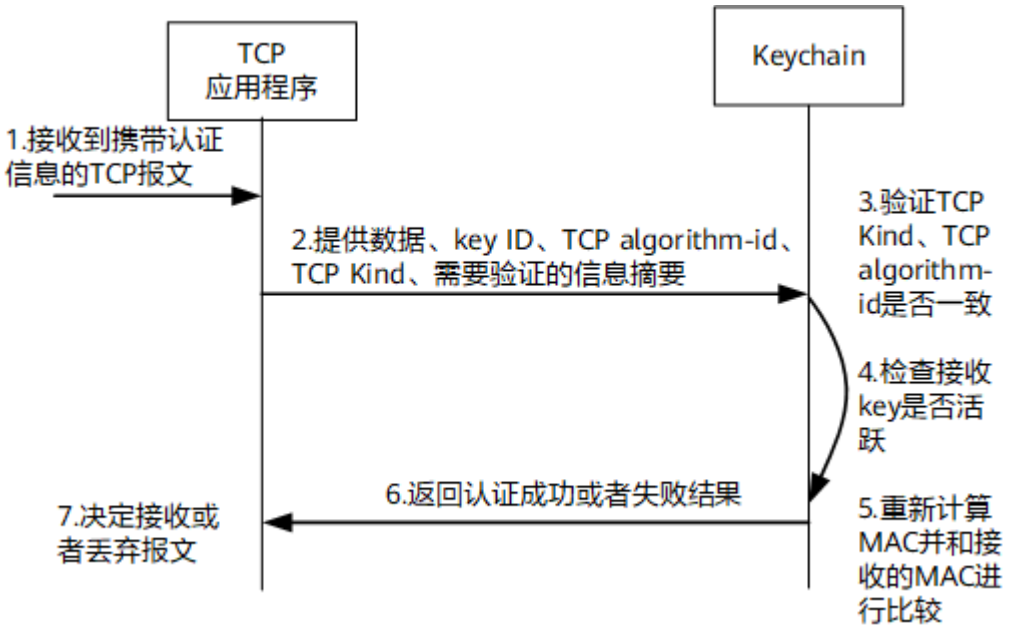


TCP 应用程序使用 Keychain 认证接收报文

如图27-61所示TCP应用程序接收到报文后的处理流程如下：

1. 接收端收到携带认证信息的TCP报文。
2. 接收端向Keychain模块提供数据报文、key ID、TCP algorithm-id、TCP Kind以及需要验证的MAC。
3. Keychain模块检查，接收报文中的TCP类型和算法ID和本端的是否一致。如果不一致，则返回认证失败消息。
4. Keychain模块根据接收到的key ID，检查本端对应ID的接收key是否活跃。如果不活跃，则返回认证失败消息。
5. 如果对应的接收key活跃，Keychain模块根据该接收key配置的认证算法和密钥，重新计算MAC，并且比较新生成的MAC和接收到的MAC是否一致。
6. 返回成功消息或者失败消息。
7. 应用程序根据Keychain的认证结果确认接收或丢弃报文。

图 27-61 TCP 应用程序使用 Keychain 接收报文



27.14.3 配置注意事项

介绍Keychain的相关配置注意事项。

Keychain只是对认证算法和加密密钥的管理，需要具体的应用程序使用Keychain，Keychain才能起作用。

目前设备支持应用Keychain的程序如下：

- RIP
- OSPF
- IS-IS
- BGP

27.14.4 配置 Keychain

配置Keychain，可以实现在不中断连接的情况下，定时更换认证加密的密钥和算法，从而保证应用程序数据传输的安全性。

前置任务

在配置Keychain之前，需完成以下任务：

- 设备上电，自检正常

27.14.4.1 创建 Keychain

背景信息

配置对应用程序进行认证和加密保护时，需要首先创建一个Keychain。另外，如果删除正在使用的Keychain，可能会造成通信的中断，请谨慎操作。

TCP（Transmission Control Protocol）应用程序之间通过TCP认证建立连接。对于TCP的认证交互，TCP使用增强的TCP认证选项。目前，不同的厂商使用不同的kind-value值代表增强的TCP认证选项，使用不同的ID值代表不同的认证算法。当TCP应用程序使用Keychain时，用户必须根据对端的配置，进行相应的配置，以实现不同厂商之间的互通。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**keychain** *keychain-name* **mode** { **absolute** | **periodic** { **daily** | **weekly** | **monthly** | **yearly** } }，创建Keychain，并进入Keychain视图。

步骤3 (可选)配置TCP认证参数

1. 执行命令**tcp-kind** *kind-value*，配置Keychain认证的TCP类型值。
2. 执行命令**tcp-algorithm-id** { **hmac-md5** | **hmac-sha-256** | **hmac-sha1-12** | **hmac-sha1-20** | **md5** | **sha-1** | **sha-256** } *algorithm-id*，配置TCP认证加密算法与算法ID的对应关系。

步骤4 （可选）执行命令**receive-tolerance** { *value* | **infinite** }，配置Keychain的接收容忍时间。

说明

建议用户配置接收容忍时间，这样可以使接收key的启动和结束时间都做相应的延长，以确保不会因为网络上时间不同步而导致报文丢失。

----结束

27.14.4.2 配置 key

背景信息

配置Keychain时，key代表Keychain认证规则，每一个key包括：认证算法、认证加密的密钥、活跃的发送时间、活跃的接收时间，以及该key是否为缺省的发送key。一个Keychain中最多可以有64个key。

同一个Keychain中key必须唯一。不同的Keychain中key ID可以相同。同一Keychain中不能有多个发送key同时生效，否则应用程序无法选择应用哪个发送key进行加密。但是同一Keychain中可以有多个接收key同时生效，接收端会根据接收到的key ID，选择ID相同的活跃的接收key进行解密。

如果发送端的key发生变更，接收端的key也需要变更。由于网络上时钟可能不同步，在接收端和发送端变更key时，有可能存在时间延迟。在延迟的时间范围内会造成数据丢失。为了实现两端key变更时不丢包，可以配置接收容忍时间。接收容忍时间只对接收端的key有效。接收容忍时间将导致接收的起始和终止的时间延长。

如果在某个时间段管理员没有配置key，此时将没有活跃的发送key。在该时间段，应用程序将没有认证的交互。为了避免这种情况，可以配置缺省发送key。任何存在的key都可以被指定为缺省发送key，在一个Keychain中只能有一个缺省发送key。在没有其他活跃的发送key时，应用程序将使用缺省发送key作为活跃的发送key。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**keychain** *keychain-name*，进入Keychain视图。

步骤3 执行命令**key-id** *key-id*，创建key-id，并进入key-id视图。

步骤4 执行命令**algorithm** { **hmac-md5** | **hmac-sha-256** | **hmac-sha1-12** | **hmac-sha1-20** | **md5** | **sha-1** | **sha-256** | **simple** }，配置key采用的认证加密算法。

说明

各个应用程序支持的算法有不同，具体情况如下：

RIP支持MD5和simple；BGP支持MD5；IS-IS支持MD5和simple；OSPF支持MD5、simple和hmac-md5。

步骤5 执行命令**key-string** { [**plain**] *plain-text* | [**cipher**] *cipher-text* }，配置key的认证加密的密钥。

步骤6 配置发送时间。创建Keychain时，选择的时间模式不同，配置发送时间的命令也不同。具体请参考表27-24：

表 27-24 配置发送时间

创建Keychain的模式	配置发送时间的命令
absolute	**send-time** *start-time start-date* { **duration** { *duration-value* | **infinite** } | { **to** *end-time end-date* } }
periodic daily	**send-time daily** *start-time* **to** *end-time*
periodic weekly	**send-time day** { *start-day-name* **to** *end-day-name* | *day-name &<1-7>* }
periodic monthly	**send-time date** { *start-date-value* **to** *end-date-value* | *date-value &<1-31>* }
periodic yearly	**send-time month** { *start-month-name* **to** *end-month-name* | *month-name &<1-12>* }

说明

建议配置NTP（Network Time Protocol），使网络中各设备的时钟保持一致，以避免因为时钟不同步，而产生混乱。

步骤7 配置接收时间。创建Keychain时，选择的时间模式不同，配置接收时间的命令也不同。具体请参考表27-25：

表 27-25 配置接收时间

创建Keychain的模式	配置接收时间的命令
absolute	**receive-time** *start-time start-date* { **duration** { *duration-value* | **infinite** } | { **to** *end-time end-date* } }
periodic daily	**receive-time daily** *start-time* **to** *end-time*
periodic weekly	**receive-time day** { *start-day-name* **to** *end-day-name* | *day-name &<1-7>* }
periodic monthly	**receive-time date** { *start-date-value* **to** *end-date-value* | *date-value &<1-31>* }
periodic yearly	**receive-time month** { *start-month-name* **to** *end-month-name* | *month-name &<1-12>* }

步骤8 （可选）执行命令**default send-key-id**，配置该key为缺省发送key。

----结束

27.14.4.3 配置应用 Keychain

背景信息

配置Keychain之后，需要配置应用程序使用Keychain，否则Keychain不会生效。

该部分以RIP为例介绍应用程序使用Keychain的配置。不同的应用程序使用Keychain时，命令可能不一样，具体请参考表27-26。

表 27-26 支持 Keychain 认证的特性

特性	配置链接
RIP	**rip authentication-mode**
OSPF	**authentication-mode（OSPF）**
IS-IS	**isis authentication-mode**
BGP	**peer keychain (BGP)**

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**interface vlanif** *vlan-id*，进入VLANIF接口视图。

步骤3 执行命令**rip authentication-mode md5 nonstandard** { **keychain** *keychain-name* | { **plain** *plain-text* | [**cipher**] *password-key* } *key-id* }，配置RIP使用Keychain。

----结束

27.14.4.4 检查配置结果

操作步骤

- 执行命令**display keychain** *keychain-name*，查看Keychain的当前配置。
- 执行命令**display keychain** *keychain-name* **key-id** *key-id*，查看key-id的当前配置。

----结束

27.14.5 配置举例

介绍Keychain配置举例。配置示例中包括组网需求、配置思路等。

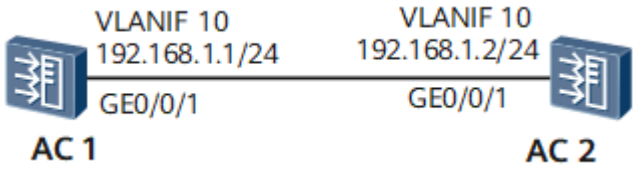
27.14.5.1 配置 RIP 应用 Keychain 认证示例

组网需求

如图27-62所示，网络中AC1和AC2通过RIP-2实现互通。

要求在数据传输过程中，RIP连接始终稳定，不会因为非法用户的攻击而断开连接。

图 27-62 RIP 应用 Keychain 认证组网图



配置思路

为了保证RIP连接稳定，需要保证RIP协议数据能够稳定正确的传输，建议采用认证和加密的方法，保证RIP协议数据传输的安全性。同时为了防止非法用户通过非法手段窃取认证和加密的算法和密钥，建议采用动态更改认证加密算法和密钥的方法实现RIP数据协议传输的安全。综上，采用Keychain协议来保证RIP连接的稳定。

采用如下思路配置Keychain对RIP协议进行保护：

1. 配置RIP基本功能。
2. 配置Keychain功能。
3. 配置RIP应用Keychain。

配置注意事项

- 纯组播报文由于协议要求在无线空口没有ACK机制保障，且无线空口链路不稳定，为了纯组播报文能够稳定发送，通常会以低速报文形式发送。如果网络侧有

大量异常组播流量涌入，则会造成无线空口拥堵。为了减小大量低速组播报文对无线网络造成的冲击，建议配置组播报文抑制功能。配置前请确认是否有组播业务，如果有，请谨慎配置限速值。

- 业务数据转发方式采用直接转发时，建议在直连AP的交换机接口上配置组播报文抑制。
- 业务数据转发方式采用隧道转发时，建议在AC的流量模板下配置组播报文抑制。

配置方法请参见：**如何配置组播报文抑制，减小大量低速组播报文对无线网络造成的冲击?**

- 建议在与AP直连的设备接口上配置端口隔离，如果不配置端口隔离，尤其是业务数据转发方式采用直接转发时，可能会在VLAN内形成大量不必要的广播报文，导致网络阻塞，影响用户体验。
- 隧道转发模式下，管理VLAN和业务VLAN不能配置为同一VLAN，且AP和AC之间只能放通管理VLAN，不能放通业务VLAN。

操作步骤

步骤1 配置RIP基本功能

配置AC1。

```
<HUAWEI> system-view
[HUAWEI] sysname AC1
[AC1] rip 1
[AC1-rip-1] version 2
[AC1-rip-1] network 192.168.1.0
[AC1-rip-1] quit
```

配置AC2。

```
<HUAWEI> system-view
[HUAWEI] sysname AC2
[AC2] rip 1
[AC2-rip-1] version 2
[AC2-rip-1] network 192.168.1.0
[AC2-rip-1] quit
```

步骤2 配置Keychain功能

配置AC1。

```
[AC1] keychain huawei mode absolute
[AC1-keychain-huawei] receive-tolerance 100
[AC1-keychain-huawei] key-id 1
[AC1-keychain-huawei-keyid-1] algorithm sha-256
[AC1-keychain-huawei-keyid-1] key-string cipher hello
[AC1-keychain-huawei-keyid-1] send-time 0:00 2012-3-12 to 23:59 2012-3-12
[AC1-keychain-huawei-keyid-1] receive-time 0:00 2012-3-12 to 23:59 2012-3-12
[AC1-keychain-huawei-keyid-1] quit
[AC1-keychain-huawei] quit
```

配置AC2。

```
[AC2] keychain huawei mode absolute
[AC2-keychain-huawei] receive-tolerance 100
[AC2-keychain-huawei] key-id 1
[AC2-keychain-huawei-keyid-1] algorithm sha-256
[AC2-keychain-huawei-keyid-1] key-string cipher hello
[AC2-keychain-huawei-keyid-1] send-time 0:00 2012-3-12 to 23:59 2012-3-12
[AC2-keychain-huawei-keyid-1] receive-time 0:00 2012-3-12 to 23:59 2012-3-12
[AC2-keychain-huawei-keyid-1] quit
[AC2-keychain-huawei] quit
```

步骤3 配置RIP应用Keychain

配置AC1。

```
[AC1] vlan 10
[AC1-vlan10] quit
[AC1] interface gigabitethernet 0/0/1
[AC1-GigabitEthernet0/0/1] port link-type hybrid
[AC1-GigabitEthernet0/0/1] port hybrid pvid vlan 10
[AC1-GigabitEthernet0/0/1] port hybrid untagged vlan 10
[AC1-GigabitEthernet0/0/1] quit
[AC1] interface vlanif 10
[AC1-Vlanif10] ip address 192.168.1.1 24
[AC1-Vlanif10] rip authentication-mode hmac-sha256 plain admin123 1
[AC1-Vlanif10] quit
```

配置AC2。

```
[AC2] vlan 10
[AC2-vlan10] quit
[AC2] interface gigabitethernet 0/0/1
[AC2-GigabitEthernet0/0/1] port link-type hybrid
[AC2-GigabitEthernet0/0/1] port hybrid pvid vlan 10
[AC2-GigabitEthernet0/0/1] port hybrid untagged vlan 10
[AC2-GigabitEthernet0/0/1] quit
[AC2] interface vlanif 10
[AC2-Vlanif10] ip address 192.168.1.2 24
[AC2-Vlanif10] rip authentication-mode hmac-sha256 plain admin123 1
[AC2-Vlanif10] quit
```

步骤4 验证配置结果

执行命令**display keychain** *keychain-name*命令，查看Keychain中Key-id的当前状态，如下所示：

```
<AC1> display keychain huawei
 Keychain Information:
 ----------------------
 Keychain Name            : huawei
   Timer Mode             : Absolute
   Receive Tolerance(min)  : 100
   TCP Kind               : 254
   TCP Algorithm IDs       :
     HMAC-MD5              : 5
     HMAC-SHA1-12          : 2
     HMAC-SHA1-20          : 6
     HMAC-SHA-256          : 7
     SHA-256               : 8
     MD5                   : 3
     SHA1                  : 4
 Number of Key IDs         : 1
 Active Send Key ID        : 1
 Active Receive Key IDs    : 01
 Default send Key ID       : Not configured

 Key ID Information:
 ----------------------
 Key ID                   : 1
   Key string             : ******
   Algorithm              : SHA-256
   SEND TIMER             :
     Start time           : 2012-03-12 00:00
     End time             : 2012-03-12 23:59
     Status               : Active
   RECEIVE TIMER          :
     Start time           : 2012-03-12 00:00
     End time             : 2012-03-12 23:59
     Status               : Active
```

RIP应用Keychain配置成功后，可以执行命令**display rip** *process-id* **interface verbose**，查看RIP报文的认证方式。以AC1为例。

```
<AC1> display rip 1 interface verbose
 Vlanif10(192.168.1.1)
  State           : UP          MTU    : 500
  Metricin        : 0
  Metricout       : 1
  Input           : Enabled     Output : Enabled
  Protocol        : RIPv2 Multicast
  Send version    : RIPv2 Multicast Packets
  Receive version : RIPv2 Multicast and Broadcast Packets
  Poison-reverse                : Disabled
  Split-Horizon                 : Enabled
  Authentication type           : SHA256 (HMAC - Password)
     Last Sequence Number Sent  : 0x0
  Replay Protection             : Disabled
```

----结束

配置文件

- AC1的配置文件

```
#
 sysname AC1
#
vlan batch 10
#
keychain huawei mode absolute
 receive-tolerance 100
 key-id 1
  algorithm sha-256
  key-string cipher %^%#mFuXI6dJ::pkAA9Q,CAY_v'c/]Yc@@12/<ZkWG3M%^%#
  send-time 00:00 2012-03-12 to 23:59 2012-03-12
  receive-time 00:00 2012-03-12 to 23:59 2012-03-12
#
interface Vlanif10
 ip address 192.168.1.1 255.255.255.0
 rip authentication-mode hmac-sha256 plain admin123 1
#
interface GigabitEthernet0/0/1
 port link-type hybrid
 port hybrid pvid vlan 10
 port hybrid untagged vlan 10
#
rip 1
 version 2
 network 192.168.1.0
#
return
```

- AC2的配置文件

```
#
 sysname AC2
#
vlan batch 10
#
keychain huawei mode absolute
 receive-tolerance 100
 key-id 1
  algorithm sha-256
  key-string cipher %^%#mX(D.9J"7@mCR7Q<'%!D*l5l>L(PSAI:VH.C~%o@%^%#
  send-time 00:00 2012-03-12 to 23:59 2013-03-12
  receive-time 00:00 2012-03-12 to 23:59 2012-03-12
#
interface Vlanif10
 ip address 192.168.1.2 255.255.255.0
 rip authentication-mode hmac-sha256 plain admin123 1
```

```
#
interface GigabitEthernet0/0/1
 port link-type hybrid
 port hybrid pvid vlan 10
 port hybrid untagged vlan 10
#
rip 1
 version 2
 network 192.168.1.0
#
return
```

27.15 URL 过滤

URL（Uniform Resource Locator）过滤可以对用户访问的URL进行控制，允许或禁止用户访问某些网页资源，达到规范上网行为的目的。

27.15.1 简介

介绍URL过滤特性的定义和目的。

定义

URL过滤功能可以对用户访问的URL进行控制，允许或禁止用户访问某些网页资源，达到规范上网行为的目的。

目的

随着互联网应用的迅速发展，计算机网络在经济和生活的各个领域迅速普及，使得信息的获取、共享和传播更加方便，但同时也给企业带来了前所未有的威胁：

- 员工在工作时间随意地访问与工作无关的网站，严重影响了工作效率。
- 员工随意访问非法或恶意的网站，造成公司机密信息泄露，甚至会带来病毒、木马和蠕虫等威胁攻击。
- 在内部网络拥堵时段，无法保证员工正常访问与工作相关的网站（如公司主页、搜索引擎等），影响工作效率。

URL过滤技术可以对用户进行URL访问控制，达到精确管理用户上网行为的目的。

27.15.2 原理描述

通过URL过滤，确定对用户的URL访问请求进行放行或者阻断。

27.15.2.1 URL 格式

URL地址用来完整地描述Internet上的网页或者其他资源的地址。

URL的一般格式为：“protocol://hostname[:port]/path[?query]”。各参数含义如**表27-27**所示。

表 27-27 URL 参数解释

字段	含义
protocol	使用的应用协议，最常用的是HTTP协议。
hostname	Web服务器的域名或者IP地址。
:port	可选，通信端口。各种应用协议都有默认的端口号，如HTTP协议的默认端口为80。当服务器采用默认端口时，URL过滤规则中不用配置端口号。当服务器采用非默认端口时，URL过滤规则中不能省略端口号。
path	由零个或多个“/”符号隔开的字符串，一般用来表示主机上的一个目录或文件地址。
?query	可选，用于给动态网页传递参数。

例如，如图27-63所示，对于“http://www.example.com:8088/news/edu.aspx?name=tom&age=20”：

图 27-63 URL 格式介绍

- http为协议。
- www.example.com为hostname。
- 8088为通信端口。
- news/edu.aspx为path。
- name=tom&age=20为参数部分。

27.15.2.2 URL 匹配方式

URL匹配方式包括前缀匹配、后缀匹配、关键字匹配、精确匹配。

管理员可以在白名单和黑名单中配置URL规则和域名规则，其中URL规则的匹配范围是全部URL，域名规则的匹配范围只是域名（或者IP地址）部分。URL规则和域名规则支持相同的匹配方式，表27-28对几种匹配方式做了简单比较。

表 27-28 URL 匹配方式

匹配方式	定义	条目	匹配结果
前缀匹配	匹配所有以指定字符串开头的URL。	www.example*	匹配所有以www.example开头的URL，如： ● www.example.com ● www.example.com/solutions.do
后缀匹配	匹配所有以指定字符串结尾的URL。	*aspx	匹配所有以aspx结尾的URL，如： ● www.example.com/news/solutions.aspx ● www.example.com/it/price.aspx ● 10.1.1.1/sports/abc.aspx
关键字匹配	匹配所有包含指定字符串的URL。	*sport*	匹配所有包含sport的URL，如： ● sports.example.com/news/solutions.aspx ● sports.example.com/it/ ● 10.1.1.1/sports/

匹配方式	定义	条目	匹配结果
精确匹配	首先判断URL和指定字符串是否匹配，如果未匹配，则去除URL的最后一个目录，再和指定字符串进行匹配；如果还未匹配，则继续去除URL的最后一个目录，再和指定字符串进行匹配。以此类推，直到用域名去匹配指定的字符串为止。	www.example.com	根据匹配规则，以下URL可以匹配www.example.com。 ● www.example.com ● www.example.com/news ● www.example.com/news/en/ 以下URL不会匹配该条目： ● www.example.com.cn/news ● www.example.org/news/www.example.com

27.15.2.3 URL 业务部署

根据无线用户业务数据报文转发方式不同，URL需要部署在不同的网络设备中。

- 隧道转发：AC和AP之间建立CAPWAP隧道集中转发用户数据报文，此时URL业务会部署在AC上。无线用户的业务数据报文在AP上进行CAPWAP封装，经过AP和AC之间的CAPWAP隧道发送到AC上，在AC上解掉CAPWAP封装后对原始的无线用户的业务数据报文进行URL过滤。
- 直接转发：业务数据报文不需要经过AC转发，此时URL业务会部署在AP上。AP收到业务数据报文之后直接对原始用户数据报文进行URL过滤。

27.15.3 应用场景

当企业用户发起HTTP或HTTPS的URL请求时，通过URL过滤功能可以实现对用户的请求进行放行、告警或者阻断。

如图27-64所示，使用URL过滤后：

- 当用户访问合法的网站时，放行此请求。
- 当用户访问非法的网站时，阻断此请求。

URL过滤还可以通过引用时间段或用户/组等配置项，实现针对不同时间段或不同用户/组的请求进行放行或者阻断，达到更加精细化和准确化控制员工上网权限的需求。

根据数据转发方式的不同，将URL过滤功能部署在不同的设备上。

- 隧道转发：业务数据报文会通过CAPWAP数据隧道发送到AC上，此时URL过滤部署在AC上。如图27-64所示。
- 直接转发：业务数据报文不经过AC，直接从AP转发出去，此时URL过滤部署在AP上，如图27-65所示。

图 27-64 隧道转发方式下 URL 过滤的典型应用场景

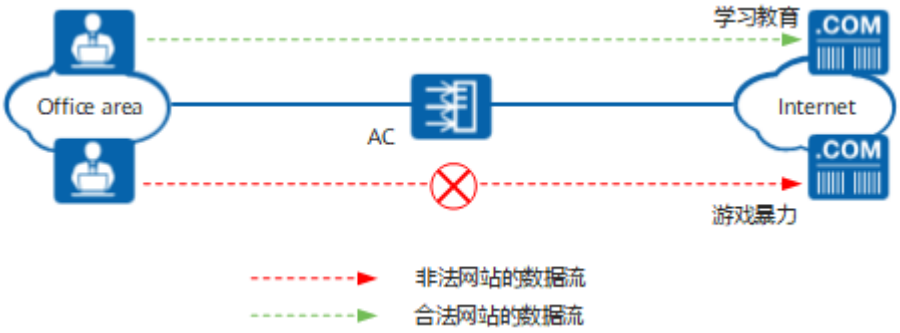
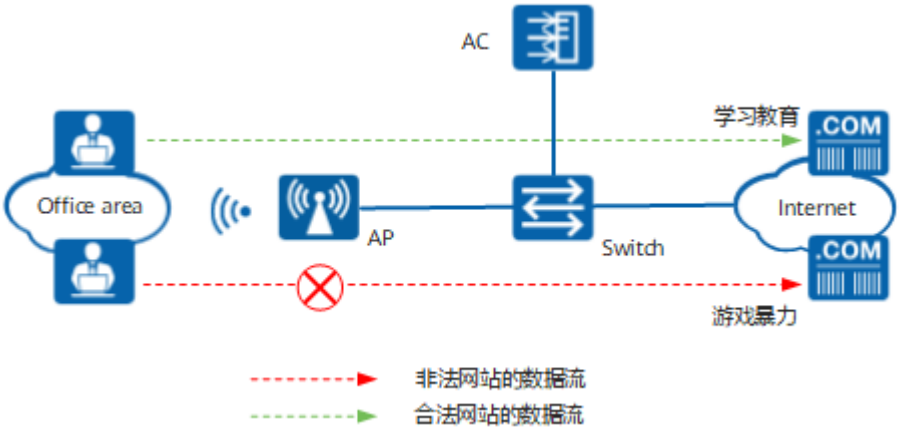


图 27-65 直接转发方式下 URL 过滤的典型应用场景



27.15.4 URL 过滤使用限制和注意事项

配置URL过滤特性之前请先阅读使用限制和注意事项。

HTTPS URL 过滤的加密流量过滤功能使用限制

URL过滤功能只支持过滤HTTP或HTTPS协议的URL请求。当需要过滤HTTPS协议的URL请求时，还需要配置加密流量过滤功能。加密流量过滤功能实现的URL过滤是基于域名级别，不够精确，即通过从客户端Client Hello报文的SNI（Server Name Indication）字段、服务器Certificate报文的CN（Common Name）和SAN（Subject Alternative Name）字段中获取用户访问的网站域名。如果用户使用加密流量过滤功能实现HTTPS URL过滤，请先阅读以下使用限制：

- 在浏览器存在代理的情况下，当用户访问某些网站时，从客户端Client Hello报文的SNI字段、服务器Certificate报文的CN和SAN字段中提取的网站域名可能与实际网站的域名不匹配，这会导致URL过滤功能不生效。例如当用户通过手机的UC浏览器访问优酷网站时，URL过滤功能不生效，通过关闭手机UC浏览器的云加速功能可以解决。
- 当某些网站服务器通过相同的IP地址为多个域名提供服务时，SNI字段可能会包含多个域名，如果URL过滤黑名单只配置了其中一个域名，则无法阻断所有来自这

个网站的流量。例如，用户通过HTTPS访问网站www.example.com，该网站可能有多个域名，例如1.example.com、2.example.com等，如果仅在URL过滤黑名单中配置1.example.com，则不能完全阻断这个网站的流量，通过在黑名单中配置一级域名*.example.com可以解决。

- 当一个证书中有多个URL（即多个网站使用一个证书）时，SAN字段可能会包含多个URL，如果其中一个URL被阻断，会导致这条流量都被阻断，其他的URL也访问不了。
- 如果将某个网站的域名加入URL过滤白名单，则不能保证该网站下的所有内嵌网页都正常访问。例如：当访问网站www.example.com时，如果只配置白名单为www.example.com，则该网站下不是以www.example.com为域名的内嵌网页均不能正常访问，通过将不是以www.example.com为域名的内嵌网页都加入白名单或配置内嵌白名单功能可以解决。
- 由于加密流量过滤功能是通过SSL握手报文实现URL过滤的，客户端尚未发起HTTP请求，因此不支持发送URL推送信息。

URL 过滤其他使用限制

- HTTP协议的默认端口为80、HTTPS协议的默认端口号为443。当服务器采用默认端口时，URL过滤规则中不用配置端口号。当服务器采用非默认端口时，URL过滤规则中不能省略端口号。例如，阻断10.1.1.1的访问，如果服务器使用默认端口80，在URL过滤黑名单中配置为10.1.1.1，就能阻断该访问，不用配置为10.1.1.1：80；如果服务器端口为8080，在URL过滤黑名单中要配置为10.1.1.1：8080，才能阻断该访问。
- URL过滤的加密流量过滤功能仅能处理TLS 1.0及1.0以上版本协议。
- 根据数据转发方式不同，URL过滤需要部署在不同的设备上。
  - 隧道转发：部署在AC上。
  - 直接转发：部署在AP上。仅AP7030DE、AP9330DN、AP4050DE-M、AP4050DE-M-S、AP3050DE、AP4050DE-B-S、AP2051DN-L-S、AP7060DN、AP2051DN-L-S、WA375DD-CE、AP5510-W-GP、AirEngine 5760-10、AP6750-10T、AP3010DN-V2、AP3030DN、AP4030DN、AP430-E、AP4130DN、AP4030DN-E、AP5030DN、AP5030DN-S、AP5130DN、AP9131DN、AP9132DN、AP8130DN-W、AP2051DN、AP2051DN-S、AP2051DN-E、AP5050DN-S、AP2050DN、AP2050DN-E、AP2050DN-S、AP4030TN、AP4050DN、AP4050DN-S、AP4051DN、AP4051DN-S、AP4151DN、AP8050DN、AP8050DN-S、AP8150DN、AP1050DN-S、AP4051TN、AP6052DN、AP7052DN、AP7152DN、AP7052DE、AP8050TN-HD、AP8082DN、AP8182DN、AP4050DN-E、AP4050DN-HD、AP6050DN、AP6150DN、AP7050DE、AP7050DN-E、AP8030DN、AP8130DN、AD9430DN-24、AD9430DN-12支持直接转发方式下的URL过滤功能。
- 在报文来回路径不一致的组网环境中，URL过滤功能不可用。
- URL过滤功能目前不支持过滤在线代理后的URL请求。
- URL过滤特性支持IPv4和IPv6。
- 端口映射功能仅支持IPv4。

URL 过滤注意事项

- URL过滤功能可以对所有URL请求进行过滤，包括用户要访问的网页及该网页内嵌的所有网站链接。一般来说，URL过滤规则针对的是网页自身的URL地址，如需对网页内嵌的网站链接进行管控，请单独配置URL过滤规则。

- URL规则中如果包含字符“#”，则“#”及“#”后面的字符串在匹配时不会生效；用户访问的URL地址中如果包含字符“#”，则“#”及“#”后面的字符串不会送入URL模块进行匹配处理。
- HTTPS协议的URL过滤需要配置模糊匹配方法，才能确保URL黑白名单等功能生效。例如www.huawei.com的模糊匹配方式可以配置为*huawei*。

27.15.5 配置 URL 过滤

27.15.5.1 使能安全引擎

背景信息

在使用URL过滤、入侵防御、反病毒、智能应用控制、升级特征库等安全功能前，需要先开启设备上的安全引擎。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**defence engine enable**，使能设备上的安全引擎。

缺省情况下，安全引擎未使能。

----结束

27.15.5.2 创建攻击防御模板

背景信息

随着网络的不断发展，网络攻击也由单纯的攻击报文转变为报文中存在各种各样的隐藏威胁（例如：木马、蠕虫、病毒等）。创建攻击防御模板后，用户可以实现URL过滤、反病毒、入侵防御等安全功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**defence-profile name** *profile-name*，创建攻击防御模板，并进入攻击防御模板视图。

缺省情况下，没有创建攻击防御模板。

----结束

27.15.5.3 配置 URL 过滤模板

URL过滤模板通过配置黑白名单的控制动作，确定对URL进行放行或阻断。

背景信息

URL过滤黑白名单的应用场景分别如下，请根据需求选择配置：

- 通过配置URL黑名单，阻止用户访问黑名单中定义的URL网站。
- 通过配置URL白名单，允许用户访问白名单中定义的URL网站。

配置了URL过滤功能以后，设备将对URL信息进行如下处理。

1. 将URL信息与白名单进行匹配。
   - 如果匹配白名单，则允许该请求通过。
   - 如果未匹配白名单，则进行下一步检测。
2. 将URL信息与黑名单进行匹配。
   - 如果匹配黑名单，则阻断该请求。
   - 如果未匹配黑名单，则配置的URL过滤功能不起作用，报文按正常流程处理。

操作步骤

步骤1 进入系统视图。

system-view

步骤2 **可选:** 开启加密流量一致性校验功能。

url-filter https-filter consistency-check enable

缺省情况下，关闭加密流量一致性校验功能。

步骤3 创建URL过滤模板，并进入URL过滤模板视图。

profile type url-filter name *name*

步骤4 配置URL过滤模板的描述信息。

description *description*

步骤5 向URL过滤模板中添加黑白名单规则。

add { **blacklist** | **whitelist** } { **url** *url-text* | **host** *host-text* }

步骤6 **可选:** 向URL过滤配置文件中添加referer-host。

add referer-host *host-text*

在访问特定网页时，如果只配置白名单，则该特定网页下其他链接可能不能访问。例如：当访问www.example.com网页时，如果只配置白名单规则为www.example.com，则该网页下不是以www.example.com为域名的其他链接均不能访问。为了解决上述问题，可以配置该命令向URL过滤配置文件中添加referer-host规则，然后将HTTP请求中的referer字段中的域名与referer-host进行匹配，如果匹配则允许该URL请求，用户可以访问该网页下所有的其他链接。

步骤7 **可选:** 关闭HTTP请求中的referer字段中的域名与所有配置的白名单规则进行匹配功能。

undo referer-filter whitelist-all enable

该功能默认开启。使能该功能也可以实现访问特定网页下的其他链接。

步骤8 配置默认动作。

default action { **allow** | **block** | **alert** }

缺省情况下，URL过滤模板的默认动作为**allow**。

当URL未命中黑白名单，AC将执行缺省动作。

步骤9 退回到系统视图，提交模板进行编译。

engine configuration commit

新建或修改URL过滤模板后，配置内容不会立即生效，需要执行**engine configuration commit**命令来激活配置。因为激活过程所需时间较长，建议您完成所有对URL过滤模板的操作后再统一进行提交。

----结束

后续处理

- 在URL过滤模板视图下，重新命名URL过滤模板，并进入新的URL过滤模板视图。

  rename *new-name*
- 在系统视图下，复制已存在的URL过滤模板，并进入新URL过滤模板视图。

  profile type url-filter copy *old-name* [*new-name*]
- 在任意视图下，查看URL过滤模板的信息。

  display profile type url-filter name *name* [**blacklist** [**url** *url-text* | **host** *host-text*] | **whitelist** [**url** *url-text* | **host** *host-text*]]
- 在任意视图下，查看当前URL过滤的统计信息。

  display url-filter statistics
- 在用户视图下，清除URL过滤的统计信息。

  reset url-filter statistics { **blacklist** | **whitelist** | **all** }

27.15.5.4 应用配置

背景信息

配置URL过滤模板后，需要引用到攻击防御模板，然后将攻击防御模板引用到VAP模板、用户组或接口，使应用生效。

操作步骤

步骤1 在攻击防御模板中引用URL过滤模板。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**defence-profile name** *profile-name*，进入攻击防御模板视图。
3. 执行命令**profile type url-filter** *name*，将指定的URL过滤模板引用到攻击防御模板。

   缺省情况下，攻击防御模板未引用URL过滤模板。
4. 执行命令**quit**，返回系统视图。

步骤2 在VAP模板、用户组或接口引用攻击防御模板

- 在VAP模板中引用攻击防御模板

  a. 执行命令**wlan**，进入WLAN视图。

b. 执行命令**vap-profile name** *profile-name*，进入VAP模板视图。
c. 执行命令**defence-profile** *profile-name*，在VAP模板中引用攻击防御模板。
缺省情况下，VAP模板未引用攻击防御模板。

- 在用户组中引用攻击防御模板
  a. 执行命令**user-group** *group-name*，进入用户组视图。
  b. 执行命令**defence-profile** *profile-name*，在用户组中引用攻击防御模板。
  缺省情况下，用户组未引用攻击防御模板。
- 在接口中引用攻击防御模板
  a. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  b. 执行命令**defence-profile** *profile-name*，在接口中引用攻击防御模板。
  缺省情况下，接口未引用攻击防御模板。

----结束

检查配置结果

- 执行命令**display defence-profile** { **all** | **name** *profile-name* }，查看攻击防御模板的信息。
- 执行命令**display references defence-profile name** *profile-name* ，查看攻击防御模板的引用信息。

27.15.6 配置举例

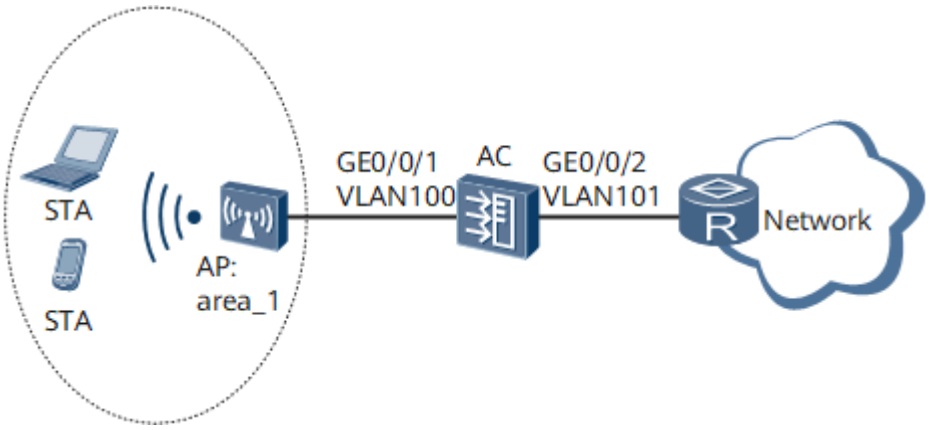
27.15.6.1 配置基于白名单的 URL 过滤

组网需求

如图27-66所示，某公司部署了WLAN网络，现在用户希望通过AC对无线用户访问外部网络的HTTP请求进行URL过滤。

具体需求如下：对员工实行白名单管理，只允许无线用户访问与工作相关的URL（www.example.com/working）和域名（www.example.org），除此之外，其他URL均不允许访问。

图 27-66 基于白名单的 URL 过滤



配置思路

1. 配置WLAN基本业务。
2. 新建URL过滤配置文件，增加白名单URL（www.example.com/working）和域名（www.example.org），并设置过滤默认动作为阻断。
3. 配置攻击防御模板，引用URL过滤模板，实现对URL的访问控制。
4. 配置WLAN业务VAP引用攻击防御模板，使URL过滤功能生效。

操作步骤

步骤1 配置WLAN基本业务，具体配置步骤请参照**9.14.1 配置小型网络WLAN基本业务示例（IPv4网络）**。

步骤2 使能安全引擎，配置URL过滤模板

使能安全引擎。

```
<HUAWEI> system-view
[HUAWEI] sysname AC
[AC] defence engine enable
     It will take several minutes to initialize engine, please wait.
Info: Load the IPS signature database if IPS detection is required after license
 activation.
Info: Load the AV signature database if AV detection is required after license a
ctivation.
Info:Engine has been initialized successfully.
```

创建攻击防御模板，模板名称为“defence_wlan”。

```
[AC] defence-profile name defence_wlan
[AC-defence-profile-defence_wlan] quit
```

配置URL过滤模板“url_wlan”，并添加过滤白名单。

```
[AC] profile type url-filter name url_wlan
[AC-profile-url-filter-url_wlan] description URL filter profile of web access control for wlan.
[AC-profile-url-filter-url_wlan] default action block
[AC-profile-url-filter-url_wlan] add whitelist url www.example.com/working
[AC-profile-url-filter-url_wlan] add whitelist host www.example.org
[AC-profile-url-filter-url_wlan] quit
```

提交配置。

```
[AC] engine configuration commit
```

配置攻击防御模板“defence_wlan”引用URL过滤模板“url_wlan”。

```
[AC] defence-profile name defence_wlan
[AC-defence-profile-defence_wlan] profile type url-filter url_wlan
[AC-defence-profile-defence_wlan] quit
```

步骤3 配置VAP的URL过滤功能

配置VAP模板“wlan-vap”引用攻击防御模板，实现对无线用户的URL过滤功能。

```
[AC] wlan
[AC-wlan-view] vap-profile name wlan-vap
[AC-wlan-vap-prof-wlan-vap] defence-profile defence_wlan
```

步骤4 验证配置结果

配置完成后，VAP下的无线用户可以访问www.example.com/working或www.example.org，其他网址或域名则无法访问。

----结束

配置文件

- AC的配置文件

```
#
 sysname AC
#
profile type url-filter name url_wlan
 description URL filter profile of web access control for wlan
 add whitelist url www.example.com/working
 add whitelist host www.example.org
 default action block
#
 defence engine enable
#
vlan batch 100 to 101
#
dhcp enable
#
defence-profile name defence_wlan
  profile type url-filter url_wlan
#
interface Vlanif100
 ip address 10.23.100.1 255.255.255.0
 dhcp select interface
#
interface Vlanif101
 ip address 10.23.101.1 255.255.255.0
 dhcp select interface
#
interface GigabitEthernet0/0/1
 port link-type trunk
 port trunk pvid vlan 100
 port trunk allow-pass vlan 100
#
interface GigabitEthernet0/0/2
 port link-type trunk
 port trunk allow-pass vlan 101
#
capwap source interface vlanif100
#
wlan
 security-profile name wlan-security
  security wpa2 psk pass-phrase %^%#m"tz0f>~7.[`^6RWdzwCy16hJj/Mc!,}s`X*B]}A%^%# aes
 ssid-profile name wlan-ssid
  ssid wlan-net
 vap-profile name wlan-vap
  forward-mode tunnel
  service-vlan vlan-id 101
  ssid-profile wlan-ssid
  security-profile wlan-security
  defence-profile defence_wlan
 regulatory-domain-profile name domain1
 ap-group name ap-group1
  regulatory-domain-profile domain1
  radio 0
   vap-profile wlan-vap wlan 1
  radio 1
   vap-profile wlan-vap wlan 1
 ap-id 0 type-id 19 ap-mac 60de-4476-e360 ap-sn 210235554710CB000042
  ap-name area_1
  ap-group ap-group1
#
return
```

27.16 升级特征库配置

介绍如何将特征库升级到指定版本。及时更新特征库的版本，可以提高网络安全设备的动态安全防御能力。

27.16.1 简介

升级中心用于提供特征库的升级。升级特征库可以提升设备对入侵行为、病毒、应用识别、恶意域名和IP地址所属地区的检测能力和检测效率。

升级特征库

随着网络中入侵手段、病毒类型和应用类型的不断增加，人们对设备的识别效率和识别能力的需求也在逐步增强。为了使设备可以及时的识别新的应用，防御新的攻击和病毒，人们需要不断更新设备的特征库。特征库包括：

- 入侵防御特征库：入侵防御功能使用的入侵防御签名特征库。
- 反病毒特征库：反病毒功能使用的病毒特征库。
- AC使用的业务感知特征库：AC设备识别应用协议使用的应用特征库。
- AP使用的业务感知特征库：AP设备识别应用协议使用的应用特征库。
- 恶意域名特征库：入侵防御功能使用的恶意域名特征库。

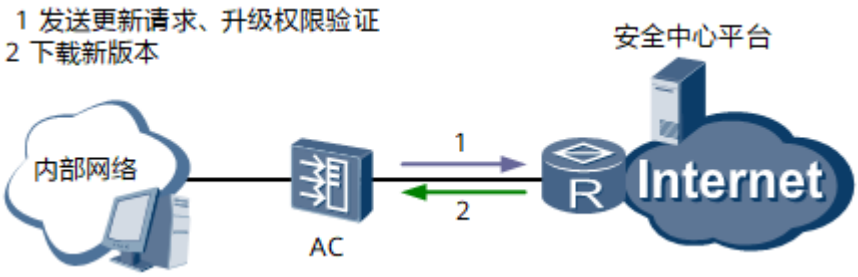
27.16.2 升级场景

介绍AC的升级场景。

AC特征库的升级支持直接升级、通过代理服务器升级和本地升级三种场景，详细说明如下。

直接升级

当AC可以直接通过互联网与升级中心进行通信时，可以采用通过升级中心进行特征库的升级。



此场景下可进行定时升级和立即升级。

- 定时升级：

  AC定期连接升级中心检查是否存在新的特征库版本。如果升级中心存在新版本的特征库，AC会根据设定的时间自动下载并更新本地的特征库。
- 立即升级：

当用户发现网络上出现新的特征库，而AC定时更新时间还没达到，或AC未启用定时更新，此时可以选择立即升级。

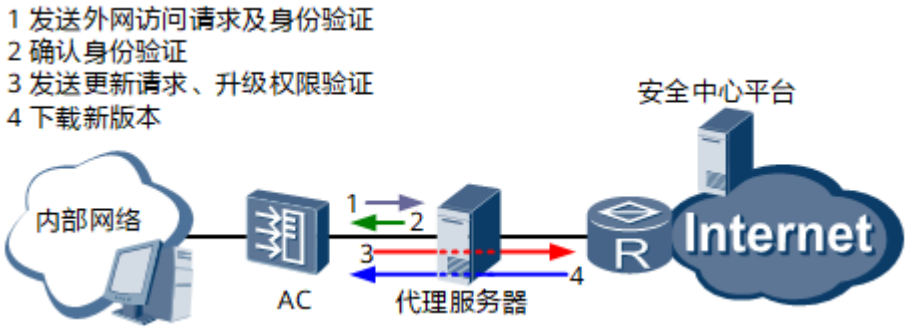
立即升级使用的特征库的下载地址就是定时升级的下载地址，升级流程也与定时升级完全相同，区别在于立即升级不受时间限制，可以在任何时刻执行立即升级动作。

通过代理服务器升级

当AC不能通过Internet直接连接到升级中心时，可以通过代理服务器连接到升级中心进行特征库的升级。

说明

代理服务器的操作系统为Windows时，推荐使用软件CCProxy；代理服务器的操作系统为Linux时，推荐使用软件Squid。代理服务器需要保证开启HTTP协议端口和4种访问方式（PUT、GET、CONNECT和POST）。



AC只支持HTTP代理，因此通过代理服务器升级时需要配置放行HTTP协议的安全策略。 由于HTTP协议存在安全风险，请严格限定安全策略的匹配条件。建议使用本地升级或直接升级方式进行特征库的升级。

此场景下可进行特征库的定时升级和立即升级。

- 定时升级：

  AC定期连接升级中心检查是否存在新的特征库版本。如果升级中心存在新版本的特征库，AC会根据设定的时间自动下载并更新本地的特征库。

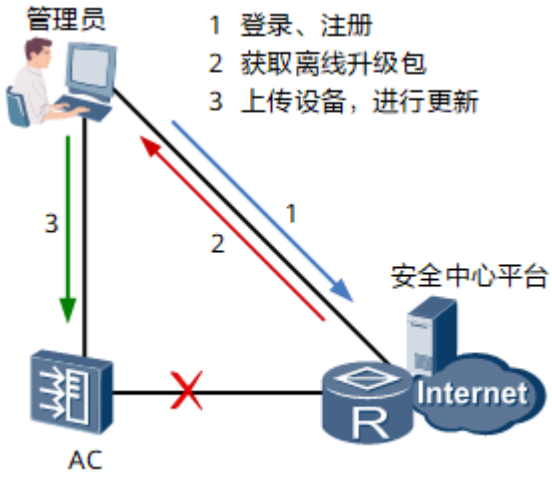
- 立即升级：

  当用户发现网络上出现新的特征库，而AC定时更新时间还没达到，或AC未启用定时更新，此时可以选择立即升级。

  立即升级使用的特征库的下载地址就是定时升级的下载地址，升级流程也与定时升级完全相同，区别在于立即升级不受时间限制，可以在任何时刻执行立即升级动作。

本地升级

当AC与Internet物理隔离，且企业内网没有部署代理服务器时，可以采用本地升级方式。



27.16.3 升级中心使用限制和注意事项

配置升级中心前请先阅读使用限制和注意事项。

使用限制

- 在通过代理服务器升级的场景下，仅支持使用HTTP升级方式，不支持HTTPS升级方式。
- 特征库升级不支持IPv6，即升级服务器的地址不能是IPv6地址。

注意事项

- 设备带有默认版本的入侵防御特征库、反病毒特征库、AP设备使用的业务感知特征库和AC设备使用的业务感知特征库，不带有恶意域名库。
- 设备可直接访问升级中心时，如果设备配置升级方式为HTTPS，则设备会使用HTTPS协议发送升级请求及下载特征库，因此需要配置放行HTTPS协议的安全策略；如果设备配置升级方式为HTTP，则设备会使用HTTP协议发送升级请求，使用FTP协议下载特征库，因此需要配置放行HTTP协议和FTP协议（FTP需要放行21端口和32119端口）的安全策略，以及用于连接FTP数据通道的（协议为TCP、目的端口为10001～15000）自定义服务流量的安全策略。由于HTTP和FTP协议存在安全风险，请严格限定安全策略的匹配条件。
- 如果未配置定时升级时间，则AC缺省在22：00～07：59之间随机选择一个时间作为每天进行定时升级的时间。您可以根据自己网络情况自由选择定时升级的时间，避免与实际业务抢占网络资源。
- 如需进行立即升级操作，请充分考虑网络环境的实时状态，避免与实际业务抢占网络资源。立即升级启动后，若因为网速太慢而影响AC的业务性能时，可以进行终止升级的操作。

27.16.4 升级特征库

介绍通过CLI方式升级特征库的方法。

27.16.4.1 使能安全引擎

背景信息

在使用URL过滤、入侵防御、反病毒、智能应用控制、升级特征库等安全功能前，需要先开启设备上的安全引擎。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**defence engine enable**，使能设备上的安全引擎。

缺省情况下，安全引擎未使能。

----结束

27.16.4.2 升级前准备

特征库升级前请做好相应的准备工作，保证特征库升级成功完成。

检查根目录剩余空间

升级特征库前，需要确认设备根目录的剩余空间是否满足条件。各特征库升级所需空间如下表所示。

特征库	空间
反病毒特征库（AV-SDB）	ACU2和AC6800V设备需要不少于65MB的空间，其他设备需要不少于8MB的空间。
恶意域名库	≥1MB
入侵防御特征库（IPS-SDB）	≥5MB
AC使用的业务感知特征库（SA-SDB）	≥5MB
AP使用的业务感知特征库（APSA-SDB）	≥2MB

检查当前升级状态

特征库升级不能并行操作，因此在特征库升级前，请确认当前的升级状态是否为空闲。只有升级状态为空闲时，才能进行升级操作。

具体操作如下：

步骤1 执行命令**display update status**查看当前特征库的升级状态。

```
<HUAWEI> display update status
  Current Update Status: Idle.
```

以上显示信息中，**Idle**表示处于空闲状态，可以进行升级操作。否则不能进行升级操作，请耐心等待并重复执行上述命令直至状态显示为**Idle**，才能进行升级操作。

----结束

检查特征库版本信息

升级特征库前，请确认待升级特征库的版本信息，确认是否需要升级。

具体操作如下：

步骤1 执行命令**display version** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** } *，查看待升级特征库的版本信息，从而确定是否需要升级。

查看反病毒特征库的版本信息。

```
<HUAWEI> display version av-sdb
AV SDB Update Information List:
-----------------------------------------------------------------
  Current Version:
    Signature Database Version    : 2016090600
    Signature Database Size(byte) : 28032
    Update Time                   : 08:34:03 2016/09/07
    Issue Time of the Update File : 00:00:33 2016/09/07

  Backup Version:
    Signature Database Version    : 2016090100
    Signature Database Size(byte) : 26752
    Update Time                   : 07:18:56 2016/09/02
    Issue Time of the Update File : 20:11:40 2016/09/02

  Download Version:
    Signature Database Version    :
    Signature Database Size(byte) : 0
-----------------------------------------------------------------
```

----结束

27.16.4.3 选择新下载特征库的生效方式

特征库升级支持仅下载和下载并安装两种方式。

背景信息

特征库升级支持两种方式：

- 仅下载：选择特征库升级后，系统定时或立即下载特征库，但不安装。你需要手动进行确认安装。
- 下载并安装：选择特征库升级后，系统定时或立即下载特征库，并自动完成安装。

缺省情况下，系统采用下载并安装的方式进行特征库的升级。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**update confirm** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** } **enable**，开启特征库安装确认开关。

----结束

后续处理

如果您想恢复到系统默认的升级方式时，可执行如下步骤：

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**undo update confirm** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** } **enable**，关闭特征库安装确认开关。

27.16.4.4 定时升级

配置定时升级后，AC会在某指定时间自动下载特征库。

前提条件

- 设备可访问升级服务器或可通过代理服务器访问升级服务器。
- 设备可直接访问升级中心时，需要配置安全策略满足以下要求：
  - 源安全区域为Local。
  - 当在线升级方式选择HTTP时，放行HTTP和FTP（FTP需要放行21端口和32119端口）协议，其中HTTP用于AC与升级中心交互，FTP用于下载特征库文件（连接FTP控制通道）。
  - 当在线升级方式选择HTTP时，放行自定义服务流量，协议为TCP，目的端口为10001～15000（用于连接FTP数据通道）。
  - 当在线升级方式选择HTTPS时，放行HTTPS协议。
- 通过代理服务器访问升级中心时，需要配置安全策略满足以下要求：
  - 源安全区域为Local。
  - 放行HTTP协议，使AC可与代理服务器交互。

操作步骤

步骤1 配置升级中心。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**update server** { **domain** *domain-name* | **ip** *ip-address* } [**port** *port-number*]，配置升级中心的相关信息。

   默认域名为“sec.huawei.com”。

   缺省情况下，HTTP协议的端口号为80，HTTPS协议的端口号为443。

步骤2 **可选:** 执行命令**update download-server aging-time** *age-time*，配置下载服务器的老化时间。

缺省情况下，下载服务器的老化时间为7天。

如果下载服务器正常，并在下载服务器的老化时间内，无需重新获取下载服务器的地址。当达到下载服务器的老化时间或下载服务器异常时，需要重新获取下载服务器的地址。通过该命令可以调整下载服务器的老化时间。

说明

下载服务器的老化时间仅对HTTPS升级方式生效，对HTTP升级方式不生效。

步骤3 **可选:** 执行命令**update online-mode** { **http** | **https** }，配置直接升级的在线升级的模式。

缺省情况下，直接升级的在线升级模式为HTTPS，设备会使用HTTPS协议发送升级请求及下载特征库。

说明

HTTP升级方式存在风险，推荐使用HTTPS升级方式。如需使用HTTP升级方式，请严格限定安全策略的匹配条件。

步骤4 **可选:** 配置代理服务器。

AC通过代理服务器连接升级中心时需要执行此步骤。

1. 执行命令**update proxy enable**，开启特征库代理升级功能。
2. 执行命令**update proxy** { **domain** *domain-name* | **ip** *ip-address* } [**port** *port-number*] [**user** *user-name* [**password** *password*]]，配置代理服务器的域名（或IP地址）和用户名及密码。

步骤5 **可选:** 配置DNS服务器。

1. 执行命令**dns resolve**，启用DNS服务器的域名解析功能。
2. 执行命令**dns server** *ip-address*，配置DNS服务器的IP地址。

步骤6 **可选:** 指定在线升级请求报文的源IP地址。

- 执行命令**update host source** *interface-type interface-number*，指定接口的IP地址作为在线升级请求报文的源地址。
- 执行命令**update host source ip** *ip-address*，指定在线升级请求报文的源地址。

当管理员不指定在线升级请求报文的源IP地址时，系统将根据升级服务器的IP地址查找路由，并使用出接口的IP地址作为升级请求报文的源地址。

当接口下存在多个IP地址时，建议通过命令**update host source ip** *ip-address*直接指定升级请求报文的源地址，并确保AC可以收到响应报文。否则，可能无法正常在线升级。

步骤7 执行命令**update schedule** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** } **enable**，开启特征库定时升级功能。

缺省情况下，开启特征库定时在线升级功能。

步骤8 配置特征库定时升级的时间。

update schedule [{ **daily** | **weekly** { **Mon** | **Tue** | **Wed** | **Thu** | **Fri** | **Sat** | **Sun** } } *time*]

update schedule { **av-sdb** | **cnc** | **ips-sdb** } { **hourly** *minute* | { **daily** | **weekly** { **Mon** | **Tue** | **Wed** | **Thu** | **Fri** | **Sat** | **Sun** } } *time* }

update schedule { **apsa-sdb** | **sa-sdb** } { **daily** | **weekly** { **Mon** | **Tue** | **Wed** | **Thu** | **Fri** | **Sat** | **Sun** } } *time*

请根据网络的实际情况选择定时升级的时间，避免与实际业务抢占网络资源。

下面为各特征库升级时间的建议值，请根据网络的实际情况进行调整：

- 入侵防御特征库：每周升级一次
- 反病毒特征库：每天升级一次
- AC使用的业务感知特征库：每周升级一次
- AP使用的业务感知特征库：每周升级一次
- 恶意域名特征库：每天升级一次

说明

定时升级启动后，若因为网速太慢而影响AC的业务性能时，可以执行命令**update abort**终止特征库升级的操作。等待网络环境改善后再执行命令**update online** { **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** }，继续下载最新版本的特征库。

步骤9 **可选:** 特征库下载完成后，执行命令**update apply** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** }，安装新下载的特征库版本。

----结束

后续处理

定时升级时可能会由于某些原因导致升级失败，系统将定时重试升级，管理员可以手动调整定时重试的时间间隔。

- 在系统视图下，设置定时升级的特征库下载重试时间间隔。缺省值是3600秒。

  update schedule retry-download interval *interval-value*
- 在系统视图下，设置定时升级的特征库加载重试时间间隔。缺省值是3600秒。

  update schedule retry-load interval *interval-value*

27.16.4.5 立即升级

如果您希望在定时升级周期到来前执行升级，可以执行立即升级。

前提条件

- 设备可访问升级服务器或可通过代理服务器访问升级服务器。
- 设备可直接访问升级中心时，需要配置安全策略满足以下要求：
  - 源安全区域为Local。
  - 当在线升级方式选择HTTP时，放行HTTP和FTP（FTP需要放行21端口和32119端口）协议，其中HTTP用于AC与升级中心交互，FTP用于下载特征库文件（连接FTP控制通道）。
  - 当在线升级方式选择HTTP时，放行自定义服务流量，协议为TCP，目的端口为10001～15000（用于连接FTP数据通道）。
  - 当在线升级方式选择HTTPS时，放行HTTPS协议。
- 通过代理服务器访问升级中心时，需要配置安全策略满足以下要求：
  - 源安全区域为Local。
  - 放行HTTP协议，使AC可与代理服务器交互。

背景信息

立即升级使用的特征库下载地址就是AC定时升级设置的服务器地址或者代理服务器地址，升级流程也与定时升级完全相同，区别在于立即升级不受时间限制，根据管理员需要可以在任何时刻执行升级动作。

操作步骤

步骤1 **可选:** 执行命令**update online-mode** { **http** | **https** }，配置直接升级的在线升级的模式。

缺省情况下，直接升级的在线升级模式为HTTPS，设备会使用HTTPS协议发送升级请求及下载特征库。

说明

HTTP升级方式存在风险，推荐使用HTTPS升级方式。如需使用HTTP升级方式，请严格限定安全策略的匹配条件。

步骤2 **可选:** 执行命令**update download-server aging-time** *age-time*，配置下载服务器的老化时间。

缺省情况下，下载服务器的老化时间为7天。

如果下载服务器正常，并在下载服务器的老化时间内，无需重新获取下载服务器的地址。当达到下载服务器的老化时间或下载服务器异常时，需要重新获取下载服务器的地址。通过该命令可以调整下载服务器的老化时间。

说明

下载服务器的老化时间仅对HTTPS升级方式生效，对HTTP升级方式不生效。

步骤3 **可选:** 指定在线升级请求报文的源IP地址。

- 执行命令**update host source** *interface-type interface-number*，指定接口的IP地址作为在线升级请求报文的源地址。
- 执行命令**update host source ip** *ip-address*，指定在线升级请求报文的源地址。

当管理员不指定在线升级请求报文的源IP地址时，系统将根据升级服务器的IP地址查找路由，并使用出接口的IP地址作为升级请求报文的源地址。

当接口下存在多个IP地址时，建议通过命令**update host source ip** *ip-address*直接指定升级请求报文的源地址，并确保AC可以收到响应报文。否则，可能无法正常在线升级。

步骤4 执行命令**update online** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** }，立即升级特征库。

说明

立即升级启动后，若因为网速太慢而影响AC的业务性能时，可以执行命令**update abort**终止特征库升级的操作。等待网络环境改善后再继续下载最新版本的特征库。

步骤5 **可选:** 执行命令**update apply** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** }，安装新下载的特征库版本。

当新下载特征库版本的生效方式为下载并安装时，不需要执行此命令。选择新下载特征库版本的生效方式请参见**27.16.4.3 选择新下载特征库的生效方式**。

----结束

27.16.4.6 本地升级

当设备无法访问升级中心时，可以在本地手动升级特征库。

前提条件

进行本地升级前需要管理员获得升级文件，并通过SFTP、FTP或TFTP方式将升级文件上传至AC的存储器中。

操作步骤

步骤1 下载升级文件。

1. 登录华为安全中心（isecurity.huawei.com），选择“特征库升级 > 特征库升级”。
2. 选择对应的产品类型、产品系列、产品名称和产品版本。
3. 点击待升级特征库对应的页签。
4. 下载特征库文件。

   点击右侧的下载图标，在弹出的“详细信息”页面下载特征库文件。

   部分特征库文件提供了辅助文件以供参考，用于进一步描述特征库或版本变更内容。

   - 业务感知特征库的辅助文件：

     文件“SA-SDB_Classified Application Protocol ID_*x.x*.xls”中提供中英文双语对照，描述了AC或AP支持的应用大类、应用小类、软件信息、应用信息以及应用承载信息。

     文件名称中的“*x.x*”表示版本，对应不同的特征库版本。请按照设备上实际支持的内容，查看对应的辅助文件。
   - 入侵防御特征库的辅助文件：描述IPS签名的增加、删除和修改情况，并对签名的漏洞信息进行描述。
   - 反病毒特征库的辅助文件：描述发生变化的病毒家族信息。

步骤2 将升级包从PC上传到AC的存储器中。

说明

升级包放在AC存储器中哪个目录下都可以，一般建议放在根目录下。

特征库文件为.zip格式，无需解压缩，直接上传到AC即可。

步骤3 执行命令**system-view**，进入系统视图。

步骤4 执行命令**update local** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** } **file** *filename*，进行本地升级。

----结束

27.16.4.7 版本回退

当前使用的特征库出现故障时（如出现误报、系统性能下降），可以采用版本回退的方式将当前的特征库恢复至前一个版本。

背景信息

版本回退只能回退一个版本，多次回退将在当前版本和可回退版本之间循环切换。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**update rollback** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** }，回退特征库的版本。

----结束

27.16.4.8 恢复默认版本

当特征库升级出现异常时，可将特征库恢复到默认版本后再进行升级操作。

背景信息

须知

特征库恢复到默认版本后，特征库的回退版本和下载版本对应的特征库文件将被删除，因此请慎用这个功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**update restore sdb-default** { **apsa-sdb** | **av-sdb** | **ips-sdb** | **sa-sdb** }，恢复特征库为默认版本。

----结束

27.16.4.9 验证与检查

介绍升级特征库后的验证与检查操作。

验证结果

升级特征库后，可执行如下操作检查配置结果：

操作	命令
查看引擎的运行状态和特征库的版本信息	**display engine information**
查看升级配置信息	**display update configuration**
查看在线升级使用的接口和源地址配置	**display update host source**
查看升级的状态	**display update status**

操作	命令
查看引擎和特征库的版本信息	**display version** { **apsa-sdb** | **av-sdb** | **cnc** | **ips-sdb** | **sa-sdb** } *
查看特征库升级的信息	**display update information all-sdb**

27.17 入侵防御配置

入侵防御是一种安全机制。设备通过分析网络流量来检测入侵，并通过一定的响应方式实时地中止入侵行为。

27.17.1 简介

介绍入侵防御特性的定义和目的。

定义

入侵防御是一种安全机制，通过分析网络流量，检测入侵（包括缓冲区溢出攻击、木马、蠕虫等），并通过一定的响应方式，实时地中止入侵行为，保护企业信息系统和网络架构免受侵害。

优势

入侵防御是一种既能发现又能阻止入侵行为的新安全防御技术。通过检测发现网络入侵后，能自动丢弃入侵报文或者阻断攻击源，从根本上避免攻击行为。入侵防御的主要优势有如下几点。

- 实时阻断攻击：设备采用直路方式部署在网络中，能够在检测到入侵时，实时对入侵活动和攻击性网络流量进行拦截，将对网络的入侵降到最低。
- 深层防护：新型的攻击都隐藏在TCP/IP协议的应用层里，入侵防御能检测报文应用层的内容，还可以对网络数据流重组进行协议分析和检测，并根据攻击类型、策略等确定应该被拦截的流量。
- 全方位防护：入侵防御可以提供针对蠕虫、病毒、木马、僵尸网络、间谍软件、广告软件、CGI（Common Gateway Interface）攻击、跨站脚本攻击、注入攻击、目录遍历、信息泄露、远程文件包含攻击、溢出攻击、代码执行、拒绝服务、扫描工具、后门等攻击的防护措施，全方位防御各种攻击，保护网络安全。
- 内外兼防：入侵防御不但可以防止来自于企业外部的攻击，还可以防止发自于企业内部的攻击。系统对经过的流量都可以进行检测，既可以对服务器进行防护，也可以对客户端进行防护。
- 不断升级，精准防护：入侵防御特征库会持续的更新，以保持最高水平的安全性。您可以从升级中心定期升级设备的特征库，以保持入侵防御的持续有效性。

27.17.2 原理描述

入侵防御通过完善的检测机制对所有通过的报文进行检测分析，并实时决定允许通过或阻断。

入侵防御实现机制

入侵防御的基本实现机制如下：

1. 重组应用数据

   AC首先进行IP分片报文重组以及TCP流重组，确保了应用层数据的连续性，有效检测出逃避入侵防御检测的攻击行为。

2. 协议识别和协议解析

   AC根据报文内容识别多种常见应用层协议。

   识别出报文的协议后，AC根据具体协议分析方案进行更精细的分析，并深入提取报文特征。

   与传统AC只能根据IP地址和端口识别协议相比，大大提高了对应用层攻击行为的检测率。

3. 特征匹配

   AC将解析后的报文特征与签名进行匹配，如果命中了签名，则进行响应处理。

   签名的匹配顺序可参考**入侵防御对数据流的处理**。

4. 响应处理

   完成检测后，AC根据管理员配置的动作对匹配到签名的报文进行处理。

   对报文的响应处理流程请参见**图27-68**。

签名

入侵防御签名用来描述网络中攻击行为的特征，AC通过将数据流和入侵防御签名进行比较来检测和防范攻击。

AC的入侵防御签名分为两类：

- 预定义签名

  预定义签名是入侵防御特征库中包含的签名。预定义签名的内容是固定的，不能创建、修改或删除。

  每个预定义签名都有缺省的动作，分为：

  - 放行：指对命中签名的报文放行，不记录日志。
  - 告警：指对命中签名的报文放行，但记录日志。
  - 阻断：指丢弃命中签名的报文，阻断该报文所在的数据流，并记录日志。

- 自定义签名

须知

建议只在非常了解攻击特征的情况下才配置自定义签名。因为自定义签名设置错误可能会导致配置无效，甚至导致报文误丢弃或业务中断等问题。

自定义签名是指管理员通过自定义规则创建的签名。新的攻击出现后，其对应的攻击签名通常都会晚一点才会出现。当用户自身对这些新的攻击比较了解时，可以自行创建自定义签名以便实时地防御这些攻击。另外，当用户出于特殊的目的时，也可以创建一些对应的自定义签名。自定义签名创建后，系统会自动对自定义规则的合法性进行检查，避免低效签名浪费系统资源。

自定义签名的动作分为阻断和告警，您可以在创建自定义签名时配置签名的响应动作。

签名过滤器

由于设备升级特征库后会存在大量签名，而这些签名是没有进行分类的，且有些签名所包含的特征本网络中不存在，需过滤出去，故设置了签名过滤器进行管理。管理员分析本网络中常出现的威胁的特征，并将含有这些特征的签名通过签名过滤器提取出来，防御本网络中可能存在的威胁。

签名过滤器是满足指定过滤条件的集合。签名过滤器的过滤条件包括：签名的类别、对象、协议、严重性、操作系统等。只有同时满足所有过滤条件的签名才能加入签名过滤器中。一个过滤条件中如果配置多个值，多个值之间是“或”的关系，只要匹配任意一个值，就认为匹配了这个条件。

签名过滤器的动作分为阻断、告警和采用签名的缺省动作。签名过滤器的动作优先级高于签名缺省动作，当签名过滤器的动作不采用签名缺省动作时，以签名过滤器设置的动作为准。

各签名过滤器之间存在优先关系（按照配置顺序，先配置的优先）。如果一个入侵防御模板中的两个签名过滤器包含同一个签名，当报文命中此签名后，设备将根据优先级高的签名过滤器的动作对报文进行处理。

例外签名

由于签名过滤器会批量过滤出签名，且通常为了方便管理设置为统一的动作。如果管理员需要将某些签名设置为与签名过滤器不同的动作时，可将这些签名引入到例外签名中，并单独配置动作。

例外签名的动作分为告警和放行。

例外签名的动作优先级高于签名过滤器。如果一个签名同时命中例外签名和签名过滤器，则以例外签名的动作为准。

例如，签名过滤器中过滤出一批符合条件的签名，且动作统一设置为阻断。但是员工经常使用的某款自研软件却被拦截了。观察日志发现，用户经常使用的该款自研软件命中了签名过滤器中某个签名，被误阻断了。此时管理员可将此签名引入到例外签名中，并修改动作为放行。

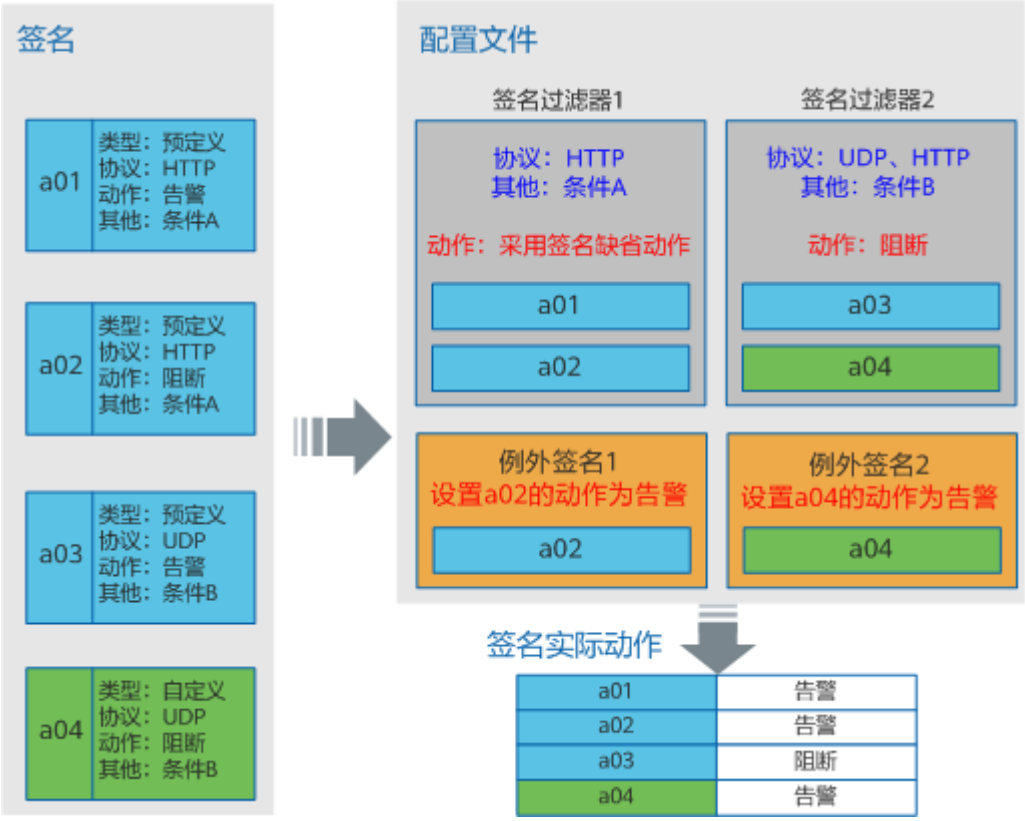
入侵防御对数据流的处理

入侵防御模板包含多个签名过滤器和多个例外签名。

签名、签名过滤器、例外签名的关系如图27-67所示。假设设备中配置了3个预定义签名，分别为a01、a02、a03，且存在1个自定义签名a04。模板中创建了2个签名过滤器，签名过滤器1可以过滤出协议为HTTP、其他项为条件A的签名a01和a02，动作为使用签名缺省动作。签名过滤器2可以过滤出协议为HTTP和UDP、其他项为条件B的签名a03和a04，动作为阻断。另外，2个模板中分别引入1个例外签名。例外签名1中，将签名a02的动作设置为告警；例外签名2中，将签名a04的动作设置为告警。

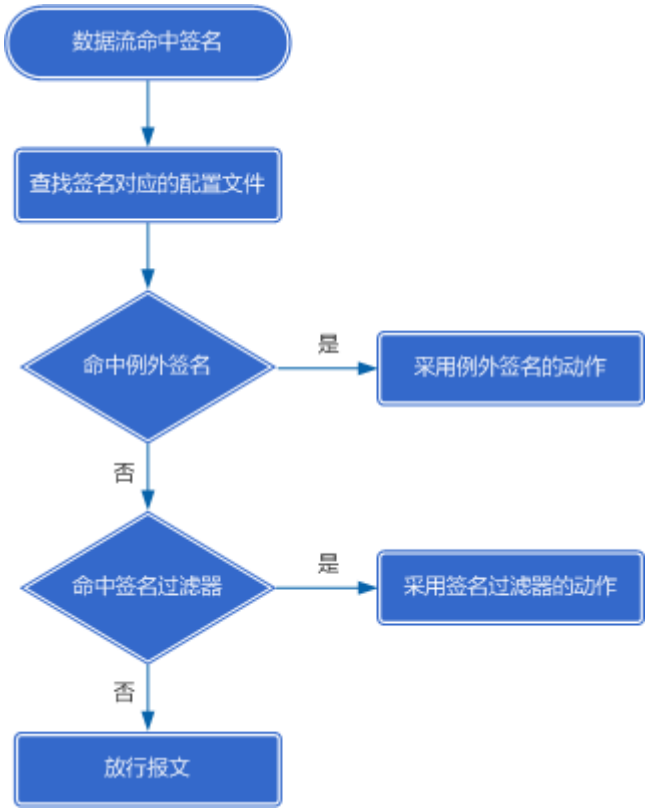
签名的实际动作由签名缺省动作、签名过滤器和例外签名的动作共同决定的，参见图27-67中的“签名实际动作”。

图 27-67 签名、签名过滤器、例外签名的关系



当数据流命中的攻击防御模板中包含入侵防御模板时，设备将数据流送到入侵防御模块，并依次匹配入侵防御模板引用的签名。入侵防御对数据流的通用处理流程请参见图27-68。

图 27-68 入侵防御对数据流的处理



说明

当数据流命中多个签名，对该数据流的处理方式如下：

- 如果这些签名的实际动作都为**告警**时，最终动作为告警。
- 如果这些签名中至少有一个签名的实际动作为**阻断**时，最终动作为阻断。

当数据流命中了多个签名过滤器时，设备会按照优先级最高的签名过滤器的动作来处理。

检测方向

当配置引用了入侵防御模板的攻击防御模板时，攻击防御模板的方向是会话发起的方向，而非攻击流量的方向。

27.17.3 入侵防御使用限制和注意事项

配置入侵防御特性之前请先阅读使用限制和注意事项。

使用限制

- 入侵防御特性支持IPv4和IPv6。
- 直接转发方式不支持入侵防御功能。隧道转发方式下，同一AP下的无线二层用户之间在进行交互时，该功能不生效。

注意事项

- 入侵防御特征库升级之后，如果原有预定义签名在新的特征库中已经不存在，则该签名涉及的所有配置信息将不会生效。

- 在逐流负载分担组网环境下，支持入侵防御功能，但检测率会有所下降。
- 在报文来回路径不一致的组网环境中，可能无法有效检测到网络入侵。
- 自定义签名和预定义签名没有优先级，当流量同时命中自定义签名和预定义签名时，最终动作以最为严格的签名为准。例如，自定义签名动作为告警，预定义签名动作为阻断，当流量同时命中该自定义签名和预定义签名时，最终动作为阻断。
- 流量命中默认动作为放行的签名时，设备不会记录日志、不会进行命中统计。此外，针对默认动作为放行的签名配置的例外签名不会生效。

27.17.4 配置入侵防御

配置入侵防御功能时，首先要升级入侵防御特征库或定义自定义签名，然后创建入侵防御模板，并将符合特定条件的签名引入到入侵防御模板中。最后将入侵防御模板应用到攻击防御模板中。

27.17.4.1 使能安全引擎

背景信息

在使用URL过滤、入侵防御、反病毒、智能应用控制、升级特征库等安全功能前，需要先开启设备上的安全引擎。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**defence engine enable**，使能设备上的安全引擎。

缺省情况下，安全引擎未使能。

----结束

27.17.4.2 升级特征库

设备出厂时，可能存在不满足实际场景的情况，例如：特征库能力小、或者特征库过时等。建议设备启动后立即升级入侵防御特征库和恶意域名特征库，并请在运维过程中及时更新这两个特征库，使设备更好防御网络中的威胁。

升级前准备

升级入侵防御和恶意域名特征库之前请做好如下准备工作，保证升级成功完成。

- **检查根目录剩余空间**

  升级入侵防御和恶意域名特征库前，需要确认设备根目录的剩余空间是否满足条件，入侵防御和恶意域名特征库升级所需空间如下表所示。

特征库	空间
入侵防御特征库（IPS-SDB）	≥5MB
恶意域名库	≥1MB

具体操作如下：

a. 在用户视图下，执行命令**dir**查看根目录的剩余空间。

```
<HUAWEI> dir
Directory of sdcard:/

  Idx  Attr     Size(Byte)  Date        Time(LMT)  FileName
    0  -rw-         8,208  May 05 2016 17:50:47   AC.pat
                         ........
   56  drw-             -  May 13 2016 15:25:17   update
   57  -rw-       828,686  Apr 16 2016 10:04:37   url.so
   58  -rw-         1,511  May 12 2016 11:44:41   vrpcfg.zip

1,975,380 KB total (393,452 KB free)
```

b. 如果剩余空间不足，需要删除无用文件。在用户视图下，执行命令**delete**删除CF卡中的无用文件。

说明

执行带**/unreserved**参数的**delete**命令后，文件将被直接删除，不能恢复。

- **检查当前升级状态**

  特征库升级不能并行操作，因此在特征库升级前，请确认当前的升级状态是否为空闲。只有升级状态为空闲时，才能进行升级操作。

  具体操作如下：

  a. 执行命令**display update status**查看当前特征库的升级状态。

```
<HUAWEI> display update status
 Current Update Status: Idle.
```

  以上显示信息中，**Idle**表示处于空闲状态，可以进行升级操作。否则不能进行升级操作，请耐心等待并重复执行上述命令直至状态显示为**Idle**，才能进行升级操作。

- **检查特征库版本信息**

  升级入侵防御和恶意域名特征库前，请确认入侵防御和恶意域名特征库的版本信息，确认是否需要升级。

  具体操作如下：

  a. 执行命令**display version** { **ips-sdb** | **cnc** }，查看待升级特征库的版本信息，从而确定是否需要升级。

```
<HUAWEI> display version ips-sdb
IPS SDB Update Information List:
-----------------------------------------------------------------
 Current Version:
   Signature Database Version    : 2016042310
   Signature Database Size(byte) : 653281
   Update Time                   : 16:15:13 2016/05/14
   Issue Time of the Update File : 17:31:13 2016/04/23

 Backup Version:
   Signature Database Version    : 2016042704
   Signature Database Size(byte) : 568481
   Update Time                   : 16:12:23 2016/05/14
   Issue Time of the Update File : 13:14:59 2016/04/27
-----------------------------------------------------------------
IPS Engine Information List:
-----------------------------------------------------------------
 Current Version:
   IPS Engine Version            : V200R002C20SPC015S001
   IPS Engine Size(byte)         : 4270561
   Update Time                   : 16:15:13 2016/05/14
   Issue Time of the Update File : 10:39:25 2016/05/14
```

```
Backup Version:
  IPS Engine Version          : V200R002C20SPC012
  IPS Engine Size(byte)        : 3145728
  Update Time                 : 16:12:23 2016/05/14
  Issue Time of the Update File : 19:45:45 2016/04/27
-----------------------------------------------------------------
```

背景信息

入侵防御和恶意域名特征库支持在线升级和本地升级两种升级方式：

- 在线升级

  当AC可以直接通过升级中心进行通信，或者AC可以通过代理服务器与升级中心进行通信，此时可采用在线方式对入侵防御和恶意域名特征库进行升级。

  在线升级又分为两种方式：

  - 定时升级

    AC定期连接升级中心检查是否存在新的入侵防御和恶意域名特征库版本。如果升级中心存在新版本的入侵防御和恶意域名特征库，AC会根据设定的时间自动下载并更新本地的入侵防御和恶意域名特征库。

  - 立即升级

    当用户发现网络上出现新的入侵防御和恶意域名特征库，而AC定时更新时间还没达到，或AC未启用定时更新，此时可以选择立即升级。

    立即升级使用的入侵防御和恶意域名特征库的下载地址就是定时升级的下载地址，升级流程也与定时升级完全相同，区别在于立即升级不受时间限制，可以在任何时刻执行立即升级动作。

- 本地升级

  当AC与Internet物理隔离，且企业内网没有部署代理服务器时，可以采用本地升级方式。

关于特征库升级场景的详细说明请参见**27.16 升级特征库配置**。

在线升级

使用在线升级方式时，如果AC可直接访问升级中心，需要在AC上配置放行HTTP协议和FTP协议的安全策略；如果AC通过代理服务器访问升级中心，需在AC上配置放行HTTP协议的安全策略。

步骤1 配置升级中心。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**update server** { **domain** *domain-name* | **ip** *ip-address* } [**port** *port-number*]，配置升级中心的相关信息。

   默认域名为“sec.huawei.com”。

步骤2 **可选:** 配置代理服务器。

AC通过代理服务器连接升级中心时需要执行此步骤。

1. 执行命令**update proxy enable**，开启特征库代理升级功能。
2. 执行命令**update proxy** { **domain** *domain-name* | **ip** *ip-address* } [**port** *port-number*] [**user** *user-name* [**password** *password*]]，配置代理服务器的域名（或IP地址）和用户名及密码。

说明

如果代理服务器配置了域名，则必须配置DNS来解析域名，具体操作请参见**步骤3**。

步骤3 **可选:** 配置DNS服务器。

1. 执行命令**dns resolve**，启用DNS服务器的域名解析功能。
2. 执行命令**dns server** *ip-address*，配置DNS服务器的IP地址。

步骤4 **可选:** 指定在线升级请求报文的源IP地址。

- 执行命令**update host source** *interface-type interface-number*，指定接口的IP地址作为在线升级请求报文的源地址。
- 执行命令**update host source ip** *ip-address*，指定在线升级请求报文的源地址。

当管理员不指定在线升级请求报文的源IP地址时，系统将根据升级服务器的IP地址查找路由，并使用出接口的IP地址作为升级请求报文的源地址。

当接口下存在多个IP地址时，建议通过命令**update host source ip** *ip-address*直接指定升级请求报文的源地址，并确保AC可以收到响应报文。否则，可能无法正常在线升级。

步骤5 选择定时升级或立即升级。

说明

定时升级或立即升级启动后，若因为网速太慢而影响AC的业务性能时，可以执行命令**update abort**终止特征库升级的操作。等待网络环境改善后再执行命令**update online** { **ips-sdb** | **cnc** } 继续下载最新版本的特征库。

- 定时升级
  a. 执行命令**update schedule** { **ips-sdb** | **cnc** } **enable**，开启特征库定时升级功能。
  b. 执行命令**update schedule** { **ips-sdb** | **cnc** } { **hourly** *minute* | { **daily** | **weekly** { **Mon** | **Tue** | **Wed** | **Thu** | **Fri** | **Sat** | **Sun** } } *time* }，配置特征库定时升级的时间。

     建议入侵防御特征库每周升级一次、恶意域名库每天升级一次，请根据网络的实际情况进行调整。
- 立即升级

  执行命令**update online** { **ips-sdb** | **cnc** }，下载最新版本。

----结束

本地升级

进行本地升级前需要管理员获得升级文件，并通过SFTP、FTP或TFTP方式将升级文件上传至AC的存储器中。

步骤1 下载升级包。

从安全中心平台（isecurity.huawei.com）下载特征库，具体下载升级包的步骤请参见升级中心。

步骤2 将升级包从PC上传到AC的存储器中。

说明

升级包放在AC存储器中哪个目录下都可以，一般建议放在根目录下。

特征库文件为.zip格式，无需解压缩，直接上传到AC即可。

步骤3 执行命令**system-view**，进入系统视图。

步骤4 执行命令**update local** { **ips-sdb** | **cnc** } **file** *filename*，进行本地升级。

----结束

版本回退

当前使用的特征库出现故障时（如出现误报、系统性能下降），可以采用版本回退的方式将当前的特征库恢复至前一个版本。

版本回退只能回退一个版本，多次回退将在当前版本和可回退版本之间循环切换。

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**update rollback** { **ips-sdb** | **cnc** }，将特征库的版本回退到可回退版本。

----结束

27.17.4.3 创建攻击防御模板

背景信息

随着网络的不断发展，网络攻击也由单纯的攻击报文转变为报文中存在各种各样的隐藏威胁（例如：木马、蠕虫、病毒等）。创建攻击防御模板后，用户可以实现URL过滤、反病毒、入侵防御等安全功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**defence-profile name** *profile-name*，创建攻击防御模板，并进入攻击防御模板视图。

缺省情况下，没有创建攻击防御模板。

----结束

27.17.4.4 配置签名

签名中包括网络入侵的某些特征。设备将接收的数据流和入侵防御签名进行比较，当数据流内容和入侵防御签名匹配时，表示该数据流存在威胁。

查看预定义签名内容

预定义签名的内容不能被修改，但可通过查看内容来得知其所检测的入侵的特征，方便后续进行配置。

- 查看所有预定义签名的信息。

  display ips-signature pre-defined [**associated**] [**application** { *application-name* | **all** } | **category** { *category-name* | **all** } | **os** { **all** | **android** | **ios** | **unix-**

like | **windows** | **other** } * | **protocol** { *protocol-name* | **all** } | **severity** { **information** | **low** | **medium** | **high** } * | **state** { **disabled** | **enabled** | **retired** } | **target** { **server** | **client** | **both** }] *

- 查看特定预定义签名的信息。

  display ips-signature *ips-signature-id*

----结束

配置预定义签名状态

预定义签名的状态分为启用、禁用和过时。对于状态为启用或禁用的预定义签名，管理员可以批量修改它们的状态，也可以单独修改某个预定义签名的状态。状态为过时的预定义签名已经失效，管理员不可以修改其状态，特征库中保留该签名是为了方便查看历史信息。

说明

只有根系统下支持配置预定义签名状态。

配置预定义签名的状态后，需要使用命令**engine configuration commit**提交配置才能生效。

- 在系统视图下设置所有预定义签名的状态为启用。

  ips signature-state enabled
- 在系统视图下设置所有预定义签名的状态为禁用。

  ips signature-state disabled
- 在系统视图下设置特定预定义签名的状态。

  ips signature-state signature-id *signature-id* { **enabled** | **disabled** }

----结束

配置预定义签名动作

每一个预定义签名都有缺省的动作，动作分为放行、告警和阻断。当用户希望对预定义签名的动作做定制化修改时，可以使用该配置，该配置可以修改单个或者全部的预定义签名的动作。

说明

只有根系统下支持配置预定义签名动作。

配置预定义签名的动作后，需要使用命令**engine configuration commit**提交配置才能生效。

- 在系统视图下配置对全部预定义签名的动作进行修改。

  ips signature-action alert

  说明

  配置该命令可以将全部预定义签名的动作修改为告警，但不能修改为全部放行和全部阻断。全部放行可以通过**ips signature-state disabled**命令实现。

- 在系统视图下配置对单个预定义签名的动作进行修改。

  ips signature-action signature-id *signature-id* { **allow** | **alert** | **block** }

----结束

修改预定义关联签名

AC默认情况下提供了预定义关联签名，可使用**display ips-signature pre-defined associated**命令查看当前支持的预定义关联签名。

当预定义关联签名的检查项信息不能满足实际需求时，管理员可以对预定义关联签名的检查项信息进行修改。

说明

只有根系统下支持修改预定义关联签名。

步骤1 在系统视图下配置预定义关联签名。

ips associated pre-defined signature-id *signature-id* { **threshold** *threshold-value* | **interval** *interval-value* | **correlateby** { **source** | **destination** | **source-destination** } } *

步骤2 在系统视图下提交配置。

engine configuration commit

修改预定义关联签名后，配置内容不会立即生效，需要执行提交操作来激活。因为激活过程所需时间较长，建议您完成所有对预定义关联签名的操作后再统一进行提交。

----结束

配置自定义签名

报文命中签名后，设备对报文的处理方式请参见入侵防御对数据流的处理。

步骤1 在系统视图下创建自定义签名。

ips signature-id *signature-id*

步骤2 **可选:** 配置自定义签名的名称。

name *name*

步骤3 **可选:** 配置自定义签名的描述信息。

description *description*

步骤4 配置自定义签名的基本特征。

配置项	命令
配置自定义签名检测目标	**target** { **both** | **client** | **server** }
配置自定义签名的协议	**protocol** *protocol-name*
配置自定义签名的威胁等级	**severity** { **high** | **medium** | **low** | **information** }

配置项	命令
配置自定义签名的动作	**action** { **alert** | **block** | **allow** }

步骤5 创建自定义签名的规则。

rule name *name*

步骤6 配置自定义签名规则的参数。

配置项	命令
基本信息	
配置自定义签名规则的检查范围	**scope** { **flow** | **message** | **packet** }
配置自定义签名规则的检查顺序	**check** { **sequential** | **random-order** } **说明** 建议一般情况下不要选择**sequential**。因为选择**sequential**后，匹配顺序更严格，有可能导致有些入侵没有按顺序命中的情况下被当做非入侵而被放过；按顺序检查的模式对检测类型是数值比较的情况无效（包括：equal，gthan，lthan，noequal）。
检查项	
配置自定义签名规则的检查项（IPS检测模式为默认模式）	**condition** [*condition-id*] **field** *field-name* **operate** { **equal** | **gthan** | **lthan** | **noequal** } **value** *value-content* [**direction** *direction* | **qualifier http-method** *http-method*] * **condition** [*condition-id*] **field** *field-name* **operate pmatch value** *value-content* [**offset** { *offset-value* | **begin** }] [**depth** *depth-value*] [**direction** *direction* | **qualifier http-method** *http-method*] * **说明** 当检测字段为DNS.Query.Name和NETBIOS.NS.Queries.Name时，字段值中不允许出现连续的“.”字符。另外，DNS.Query.Name和NETBIOS.NS.Queries.Name检测字段的值不支持缩写，配置时需要输入完整的名称。例如，DNS.Query.Name字段需要匹配huawei123.com，配置时必须输入huawei123.com，不能输入类似huawei123.c这样的名称缩写。 仅如下款型不支持该功能： ● AirEngine 9700-M、AC6508、AirEngine 9700S-S、AC6507S

配置项	命令
配置自定义签名规则的检查项（IPS检测模式为增强模式）	**condition value** *text* 自定义签名规则的检查项配置使用IPS第三代引擎语法，IPS第三代引擎语法在保留已有语法检测精度的情况下，大幅提高了处理效率，同时可以兼容业界常见的语法，具有更好的开放性。关于IPS第三代引擎语法的介绍请参见**IPS第三代引擎语法规则**。 **说明** 仅如下款型支持该功能。 • AirEngine 9700-M、AC6508、AirEngine 9700S-S、AC6507S
高级信息	
配置自定义签名规则检查的源IP地址	**source-ip** { [**ipv4**] *start-ipv4-address* [*end-ipv4-address* | *ipv4-mask-length*] | **any** }
配置自定义签名规则检查的源端口	**source-port** { *start-port end-port* | **any** }
配置自定义签名规则检查的目的IP地址	**destination-ip** { [**ipv4**] *start-ipv4-address* [*end-ipv4-address* | *ipv4-mask-length*] | **any** }
配置自定义签名规则检查的目的端口	**destination-port** { *start-port end-port* | **any** }

步骤7 在系统视图下提交配置。

engine configuration commit

创建或修改自定义签名后，配置内容不会立即生效，需要执行提交操作来激活。因为激活过程所需时间较长，建议您完成所有对自定义签名的操作后再统一进行提交。

----结束

配置自定义关联签名

对于自定义关联签名，只能配置一条rule，在rule中只能配置一条关联检查项信息。

如果某个自定义签名被配置为关联签名，则需要先取消该签名的关联关系，然后才能删除该自定义签名。对于预定义签名，其状态必须为启用状态，才能被配置为关联签名。

步骤1 在系统视图下创建自定义关联签名。

ips signature-id *signature-id*

步骤2 **可选:** 配置自定义关联签名的名称。

name *name*

步骤3 **可选:** 配置自定义关联签名的描述信息。

description *description*

步骤4 创建自定义签名的规则。

rule name *name*

步骤5 配置自定义关联签名的检查项信息。

condition associated signature-id *signature-id* [**threshold** *threshold-value* | **interval** *interval-value* | **correlateby** { **source** | **destination** | **source-destination** }] *

步骤6 在自定义关联签名视图下配置基本特征。

配置项	命令
配置自定义关联签名的威胁等级	**severity** { **high** | **medium** | **low** | **information** }
配置自定义关联签名的动作	**action** { **alert** | **block** | **allow** }

步骤7 在系统视图下提交配置。

engine configuration commit

创建或修改自定义关联签名后，配置内容不会立即生效，需要执行提交操作来激活。因为激活过程所需时间较长，建议您完成所有对自定义关联签名的操作后再统一进行提交。

----结束

IPS 第三代引擎语法规则

IPS第三代引擎语法主要由报文基本信息部分和待检测项部分组成，报文基本信息部分用flow字段表示，待检测项部分可以使用content字段进行特征串匹配或者使用pcre字段进行正则匹配。这几个字段的含义如下：

- **flow**

  flow用来指定检测的方向，检测的范围等基本信息。

  例如，**flow: from_server, session;**表示检测来自于服务端的请求，检测范围为会话。

- **content**

  content用来指定需要检测的特征串。

  例如：**content: “helloworld”; nocase; offset: 100; depth: 20;**表示从TCP/UDP Paylaod的第100字节开始，最多匹配20字节，在这个范围内，匹配“helloworld”特征串，且不区分大小写。

- **pcre**

  pcre表示使用正则表达式检测报文的特征串。格式为：**pcre: “/<regex>/[options][extend]”;**其中，<regex>为正则串，[options]为附加项，[extend]为扩展语法。

  例如，**pcre: "/alert\(.*\)/iAG";**表示从数据开头匹配，以“alert(”开头，“)”结尾的字符串，不区分大小写，并使用贪婪模式（i表示不区分大小写，A表示字符串必须从数据开头匹配，G表示使用贪婪模式）。

IPS第三代引擎语法规则示例：**flow: from_client, message; pkt_data; content:”/index.html”; http_uri; fast_pattern; content:”test”; nocase; http_user_agent; urilen:>512; pcre:” /id=[0-9]{5,10}/Ui”;**其含义为：

- **flow: from_client, message;**表示检测从客户端发出的请求，检测的范围是消息。
- **pkt_data;**表示检测的内容为流量。
- **content:”/index.html”; http_uri; fast_pattern;**表示HTTP头部的URI字段内容与“/index.html”特征串进行匹配。“fast_pattern”用来修饰content特征串，表示该特征串的威胁特征最为明显，会在预过滤过程中优先匹配。
- **content:”test”; nocase; http_user_agent;**表示HTTP头部的User-Agent内容与“test”特征串进行匹配，且不区分大小写。
- **urilen:>512;**表示URI的长度大于512时，才能命中该签名规则。
- **pcre:” /id=[0-9]{5,10}/Ui”;**表示通过正则匹配的方式检查URI字段是否匹配pcre规则，且不区分大小写(U表示URI字段，i表示不区分大小写)。

如果以上条件都匹配，则表示报文命中了此签名规则。

以上仅简单介绍了IPS第三代引擎语法的基础内容，并给出简单示例。关于更详细的语法介绍、支持的语法、字段以及各个字段的含义请参见在线语法手册。

27.17.4.5 配置入侵防御模板

管理员可在入侵防御模板中配置签名过滤器来过滤含有某些特征的签名，并设定动作来对匹配这些特征的威胁进行阻断或放行。也可以直接将签名引入到例外签名中，并为其专门设定动作。

背景信息

设备缺省存在多个入侵防御模板以适用于不同的应用场景，如表27-29所示。缺省的入侵防御模板可以查看，复制或直接被攻击防御模板引用，但是不可以修改或删除。

说明

通过命令**display profile type ips name** *name*可以查看到缺省模板中的配置信息。通过命令行配置攻击防御模板引用缺省模板时，需要输入完整的模板名称（如**default**），否则无法成功引用。如需查看配置结果，可以使用命令**display current-configuration**，在显示信息中可查看到攻击防御模板引用了缺省模板，但是缺省模板自身的配置信息并不显示。

表 27-29 缺省入侵防御模板

模板名称	对象	严重性	操作系统	应用程序	协议	威胁类别	动作	应用场景
video_surveillance	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	DNS、HTTP、FTP、TELNET、SSH、RTSP、SSL、UDP、TCP	全部	采用签名的缺省动作	该模板适用于当设备部署在视频监控的场景。
strict	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	全部	全部	阻断	该模板适用于需要设备阻断所有命中签名的报文场景。
web_server	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	DNS、HTTP、FTP	全部	采用签名的缺省动作	该模板适用于当设备部署在Web服务器前面的场景。

模板名称	对象	严重性	操作系统	应用程序	协议	威胁类别	动作	应用场景
file_server	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	DNS、SMB、NETBIOS、NFS、SUNRPC、MSRPC、FILE、TELNET	全部	采用签名的缺省动作	该模板适用于当设备部署在File服务器前面的场景。
dns_server	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	DNS	全部	采用签名的缺省动作	该模板适用于当设备部署在DNS服务器前面的场景。
mail_server	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	DNS、IMAP4、SMTP、POP3	全部	采用签名的缺省动作	该模板适用于当设备部署在Mail服务器前面的场景。

模板名称	对象	严重性	操作系统	应用程序	协议	威胁类别	动作	应用场景
inside_firewall	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	除**TELNET**和**TFTP**之外的协议	全部	采用签名的缺省动作	该模板适用于当设备部署在防火墙里面的场景。
dmz	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	除**NETBIOS**、**NFS**、**SMB**、**TELNET**和**TFTP**之外的协议	全部	采用签名的缺省动作	该模板适用于当设备部署在区域前的场景。
outside_firewall	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	全部	除**扫描工具**之外的威胁类别	采用签名的缺省动作	该模板适用于当设备部署在防火墙外面的场景。

模板名称	对象	严重性	操作系统	应用程序	协议	威胁类别	动作	应用场景
ids	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	全部	全部	告警	该模板适用于当设备以IDS（旁路）模式部署时的通用场景。
default	全部	低、中、高	Unix-like、Windows、Android、iOS、Other	全部	全部	全部	采用签名的缺省动作	该模板适用于当设备以IPS（直路）模式部署时的通用场景。

操作步骤

步骤1 在系统视图下创建入侵防御模板。

profile type ips name *name*

步骤2 **可选:** 配置入侵防御模板的描述信息。

description *description*

步骤3 **可选:** 配置攻击取证功能。

collect-attack-evidence enable

说明

- 对于HTTPS流量，攻击取证功能不可用。
- 攻击取证功能仅用于故障定位，由于可能导致系统性能降低，所以请在必要时使用，并在攻击取证完成后关闭该功能。

步骤4 创建IPS签名过滤器。

signature-set name *name*

步骤5 配置IPS签名过滤器。

配置项	命令
将指定检测目标的IPS签名加入IPS签名过滤器中	**target** { **both** | **client** | **server** }
将指定严重性的IPS签名加入IPS签名过滤器中	**severity** { **high** | **medium** | **low** | **information** } *
将指定操作系统的IPS签名加入IPS签名过滤器中	**os** { **android** | **ios** | **unix-like** | **windows** | **other** } *
将指定协议的IPS签名加入IPS签名过滤器中	**protocol** { *protocol-name* &<1-10> | **all** }
将指定分类的IPS签名加入IPS签名过滤器中	**category** { *category-name* &<1-10> | **all** }
配置签名过滤器中的应用名称	**application** { *application-name* &<1-10> | **all** }
配置IPS签名过滤器的动作	**action** { **alert** | **block** | **default** }

步骤6 **可选:** 在入侵防御模板视图下配置例外签名。

exception ips-signature-id *ips-signature-id* [**action** { **alert** \| **allow** }]

步骤7 **可选:** 配置恶意域名检查。

cnc domain-filter enable [**action** { **alert** \| **block** }]

开启域名过滤功能。

域名过滤功能通过恶意域名特征库对域名进行过滤，保证内网主机不会受到恶意域名的侵害。当域名命中恶意域名后，系统会根据管理员设置的动作进行处理，并自动记录威胁日志供管理员后续查看和参考。

在系统视图下，添加例外域名：

cnc domain-filter exception domain-name *domain-name*

如果管理员通过日志发现部分域名不属于恶意域名，可以添加此域名为例外域名。

步骤8 **可选:** 配置关联检测功能。

assoc-check enable

缺省情况下，开启关联检测功能。

步骤9 **可选:** 在入侵防御模板视图下配置协议异常检测。

配置项	命令
检测HTTP流量中是否存在SSH流量	**http ssh-over-http check action** { **alert** | **block** }
检测HTTP报文中是否存在多个Host字段	**http multi-host check action** { **alert** | **block** }
检测HTTP报文中的X-Online-Host字段	**http x-online-host check** { **any** | **blacklist** | **multiple** } **action** { **alert** | **block** } **http x-online-host blacklist** *blacklist*
检测HTTP报文中的X-Forwarded-For字段	**http x-forwarded-for check** { **any** | **whitelist** } **action** { **alert** | **block** } **http x-forwarded-for whitelist ipv4** *ip-address*
检测DNS报文的协议格式是否异常	**dns malformed-packet check action** { **alert** | **block** }
检测DNS报文的查询类型	**dns request-type check** { *start-type* [**to** *end-type*] **action** | **default-action** } { **alert** | **allow** | **block** }
检测DNS域名是否存在异常字符	**dns domain check action** { **alert** | **block** }
检测DNS域名长度是否超长	**dns domain length check** [**max-length** *max-length*] **action** { **alert** | **block** }
检测DNS会话请求次数是否过多	**dns session request-times check** [**max-time** *max-time*] **action** { **alert** | **block** }

步骤10 在系统视图下提交配置。

engine configuration commit

创建或修改入侵防御模板后，配置内容不会立即生效，需要执行提交操作来激活。因为激活过程所需时间较长，建议您完成所有对入侵防御模板的操作后再统一进行提交。

----结束

后续处理

入侵防御模板配置完成后，可以使用如下方式进行调整：

- 在IPS签名过滤器视图使用**rename** *new-name*命令重命名已经存在的签名过滤器。
- 在入侵防御模板视图使用**rename** *new-name*命令重命名已经存在的入侵防御模板。

- 在系统视图下使用**profile type ips copy** *old-name* [*new-name*]命令通过复制已经存在的入侵防御模板来创建新的入侵防御模板。

27.17.4.6 应用配置

背景信息

配置入侵防御模板后，需要引用到攻击防御模板，然后将攻击防御模板引用到VAP模板、用户组或接口，使应用生效。

操作步骤

步骤1 在攻击防御模板中引用入侵防御模板。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**defence-profile name** *profile-name*，进入攻击防御模板视图。
3. 执行命令**profile type ips** *profile-name*，将指定的入侵防御模板引用到攻击防御模板。

   缺省情况下，攻击防御模板未引用入侵防御模板。
4. 执行命令**quit**，返回系统视图。

步骤2 在VAP模板、用户组或接口引用攻击防御模板

- 在VAP模板中引用攻击防御模板
  a. 执行命令**wlan**，进入WLAN视图。
  b. 执行命令**vap-profile name** *profile-name*，进入VAP模板视图。
  c. 执行命令**defence-profile** *profile-name*，在VAP模板中引用攻击防御模板。

     缺省情况下，VAP模板未引用攻击防御模板。
- 在用户组中引用攻击防御模板
  a. 执行命令**user-group** *group-name*，进入用户组视图。
  b. 执行命令**defence-profile** *profile-name*，在用户组中引用攻击防御模板。

     缺省情况下，用户组未引用攻击防御模板。
- 在接口中引用攻击防御模板
  a. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  b. 执行命令**defence-profile** *profile-name*，在接口中引用攻击防御模板。

     缺省情况下，接口未引用攻击防御模板。

----结束

检查配置结果

- 执行命令**display defence-profile** { **all** | **name** *profile-name* }，查看攻击防御模板的信息。
- 执行命令**display references defence-profile name** *profile-name* ，查看攻击防御模板的引用信息。

27.17.4.7 验证与检查

介绍入侵防御特性配置完成后的验证与检查操作。

验证结果

入侵防御特性配置完成后，可执行如下操作检查配置结果：

操作	命令
查看IPS签名信息	**display ips-signature** *ips-signature-id* **display ips-signature** [{ **pre-defined** | **user-defined** } [**associated**]] [**application** { *application-name* | **all** } | **category** { *category-name* | **all** } | **os** { **all** | **android** | **ios** | **unix-like** | **windows** | **other** } * | **protocol** { *protocol-name* | **all** } | **severity** { **information** | **low** | **medium** | **high** } * | **state** { **disabled** | **enabled** | **retired** } | **target** { **server** | **client** | **both** }] *
根据CVE ID查看IPS预定义签名的信息	**display ips-signature cve-id** { *cve-id* | **year** *year* }
根据厂商ID查看IPS预定义签名信息	**display ips-signature vendor-id** *vendor-id*
查看IPS预定义签名的状态	**display ips signature-state**
查看IPS预定义签名动作的配置情况	**display ips signature-action**
查看指定名字的自定义签名规则内容	**display ips signature-id** *signature-id* **rule** { **name** *rule-name* | **all** }
查看域名过滤的所有例外域名	**display cnc domain-filter exception**
查看入侵防御模板的信息	**display profile type ips** [**name** *name* [**signature-set-name** *signature-set-name* | **exception-signature-id** *exception-signature-id*]]

入侵防御特性配置完成后，可执行如下操作查看或清除统计信息：

操作	命令
查看IPS统计信息	**display ips statistics**
查看IPS签名命中次数最多的前N条IPS签名的统计信息	**display ips-signature statistics** *top-number*
查看域名过滤的统计信息	**display cnc domain-filter** { **exception** | **domain-name** *domain-name* } **statistics**

操作	命令
查看命中次数最多的前N个恶意域名的统计信息	**display cnc domain-filter domain statistics** [*topn-number*]
查看CNC库中加载的域名详细信息	**display cnc information**
清除IPS统计信息	**reset ips statistics**
清除IPS签名的统计信息	**reset ips-signature statistics** { **signature-id** *signature-id* | **all** } { **event** | **collect-attack-evidence** | **all** }
清除域名过滤功能的统计信息	**reset cnc domain-filter** { **domain** | **exception** | **domain-name** *domain-name* } **statistics**

27.17.5 配置举例

介绍入侵防御的配置举例。

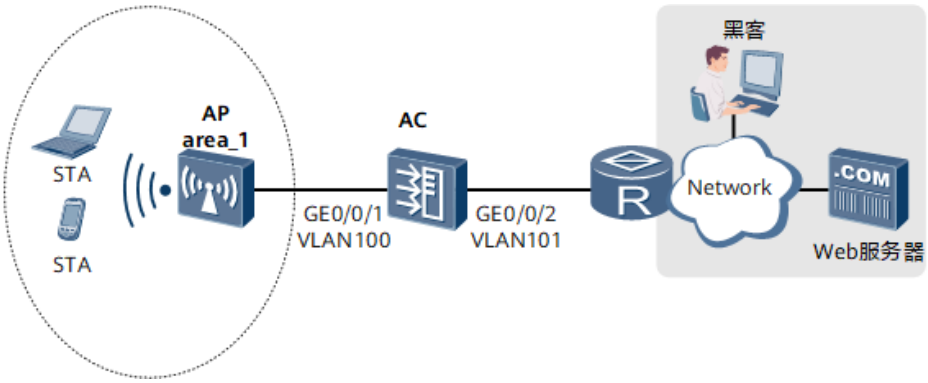
27.17.5.1 配置入侵防御示例

组网需求

如图27-69所示，某企业部署了WLAN网络，内网用户可以访问Internet的Web服务器。现需要在AC上配置入侵防御功能，具体要求如下：

保护内网用户，避免内网用户访问Internet的Web服务器时受到攻击。例如，含有恶意代码的网站对内网用户发起攻击。

图 27-69 入侵防御组网图



配置思路

1. 配置WLAN基本业务。
2. 配置入侵防御模板“profile_ips_pc”，保护内网用户。通过配置签名过滤器来满足安全需要。

3. 创建攻击防御模板“defence_wlan”，并引用入侵防御模板“profile_ips_pc”，保护内网用户免受来自Internet的攻击。
4. 配置WLAN业务VAP引用攻击防御模板，使入侵防御功能生效。

操作步骤

步骤1 配置WLAN基本业务，具体配置步骤请参照**9.14.1 配置小型网络WLAN基本业务示例（IPv4网络）**。

步骤2 使能安全引擎。

```
[AC] defence engine enable
```

步骤3 创建入侵防御模板“profile_ips_pc”，保护内网用户。

```
[AC] profile type ips name profile_ips_pc
[AC-profile-ips-profile_ips_pc] description profile for intranet users
[AC-profile-ips-profile_ips_pc] collect-attack-evidence enable
Warning: Succeeded in configuring attack evidence collection for the IPS functio
n. The function is used for fault locating. This function may deteriorate system
 performance. Exercise caution before using the function.
Attack evidences can be collected only when a log storage device with sufficient
 storage space is available.
After all required attack evidences are collected, disable the function.
Our company alone is unable to transfer or process the communication contents or
 personal data.  You are advised to enable the related functions based on the ap
plicable laws and regulations in terms of purpose and scope of usage. When the c
ommunication contents or personal data are being transferred or processed,  you
are obliged to take considerable measures to ensure that these contents are full
y protected. Continue? [Y/N]: y
[AC-profile-ips-profile_ips_pc] signature-set name filter1
[AC-profile-ips-profile_ips_pc-sigset-filter1] target client
[AC-profile-ips-profile_ips_pc-sigset-filter1] severity high
[AC-profile-ips-profile_ips_pc-sigset-filter1] protocol HTTP
[AC-profile-ips-profile_ips_pc-sigset-filter1] quit
[AC-profile-ips-profile_ips_pc] quit
```

步骤4 提交配置。

```
[AC] engine configuration commit
```

步骤5 创建攻击防御模板“defence_wlan”，引用入侵防御模板“profile_ips_pc”。

```
[AC] defence-profile name defence_wlan
[AC-defence-profile-defence_wlan] profile type ips profile_ips_pc
[AC-defence-profile-defence_wlan] quit
```

步骤6 在VAP模板上引用攻击防御模板“defence_wlan”。

```
[AC] wlan
[AC-wlan-view] vap-profile name wlan-vap
[AC-wlan-vap-prof-wlan-vap] defence-profile defence_wlan
[AC-wlan-vap-prof-wlan-vap] quit
```

步骤7 验证配置结果。

在AC上执行命令**display profile type ips name profile_ips_pc**，查看入侵防御配置文件的配置信息。

```
[AC-wlan-view] display profile type ips name profile_ips_pc
  IPS Profile Configurations:
 ----------------------------------------------------------------------
 Name                          : profile_ips_pc
 Description                   : profile for intranet users
 Referenced                    : 1
 State                         : committed
 AttackEvidenceCollection          : enable

 SignatureSet                  : filter1
```

```
  Target                    : client
  Severity                  : high
  OS                        : N/A
  Protocol                  : HTTP
  Category                  : N/A
  Action                    : default
  Application               : N/A

Exception:
ID      Action                                  Name
---------------------------------------------------------------------
---------------------------------------------------------------------
```

----结束

AC 的配置文件

```
#
 sysname AC
#
profile type ips name profile_ips_pc
 description profile for intranet users
 collect-attack-evidence enable
 signature-set name filter1
  target client
  severity high
  protocol HTTP
#
 defence engine enable
#
vlan batch 100 to 101
#
dhcp enable
#
defence-profile name defence_wlan
  profile type ips profile_ips_pc
#
interface Vlanif100
 ip address 10.23.100.1 255.255.255.0
 dhcp select interface
#
interface Vlanif101
 ip address 10.23.101.1 255.255.255.0
 dhcp select interface
#
interface GigabitEthernet0/0/1
 port link-type trunk
 port trunk pvid vlan 100
 port trunk allow-pass vlan 100
#
interface GigabitEthernet0/0/2
 port link-type trunk
 port trunk allow-pass vlan 101
#
capwap source interface vlanif100
#
wlan
 security-profile name wlan-security
  security wpa2 psk pass-phrase %^%#m"tz0f>~7.[`^6RWdzwCy16hJj/Mc!,}s`X*B]}A%^%# aes
 ssid-profile name wlan-ssid
  ssid wlan-net
 vap-profile name wlan-vap
  forward-mode tunnel
  service-vlan vlan-id 101
  ssid-profile wlan-ssid
  security-profile wlan-security
  defence-profile defence_wlan
 regulatory-domain-profile name domain1
 ap-group name ap-group1
```

```
 regulatory-domain-profile domain1
 radio 0
  vap-profile wlan-vap wlan 1
 radio 1
  vap-profile wlan-vap wlan 1
ap-id 0 type-id 19 ap-mac 60de-4476-e360 ap-sn 210235554710CB000042
 ap-name area_1
 ap-group ap-group1
#
return
```

27.18 反病毒配置

反病毒特性用于保护内网的用户和服务器免受病毒威胁。

27.18.1 简介

介绍反病毒特性的定义和目的。

定义

病毒是一种恶意代码，可感染或附着在应用程序或文件中，一般通过邮件或文件共享等协议进行传播，威胁用户主机和网络的安全。有些病毒会耗尽主机资源、占用网络带宽，有些病毒会控制主机权限、窃取数据，有些病毒甚至会对主机硬件造成破坏。

反病毒是一种安全机制，它可以通过识别和处理病毒文件来保证网络安全，避免由病毒文件而引起的数据破坏、权限更改和系统崩溃等情况的发生。

目的

随着网络的不断发展和应用程序的日新月异，企业用户越来越频繁地开始在网络上传输和共享文件，随之而来的病毒威胁也越来越大。企业只有拒病毒于网络之外，才能保证数据的安全，系统的稳定。因此，保证计算机和网络系统免受病毒的侵害，让系统正常运行便成为企业所面临的一个重要问题。

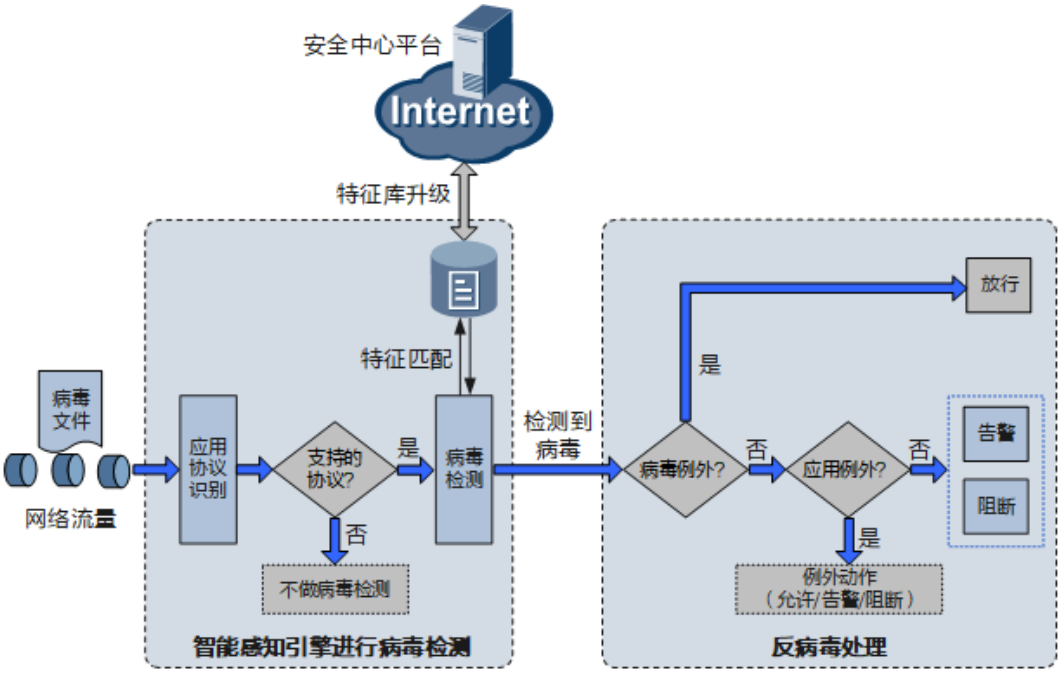
反病毒功能可以凭借庞大且不断更新的病毒特征库有效地保护网络安全，防止病毒文件侵害系统数据。将病毒检测设备部署在企业网的入口，可以真正将病毒抵御于网络之外，为企业网络提供了一个坚固的保护层。

27.18.2 原理描述

介绍反病毒特性的实现原理和处理流程。

AC利用专业的智能感知引擎和不断更新的病毒特征库实现对病毒文件的检测和处理，其工作原理如**图27-70**所示。

图 27-70 反病毒工作原理



智能感知引擎进行病毒检测

AC的病毒检测是依靠智能感知引擎来进行的。流量进入智能感知引擎后：

1. 首先智能感知引擎对流量进行深层分析，识别出流量对应的协议类型和文件传输的方向。
2. 判断文件传输所使用的协议和文件传输的方向是否支持病毒检测。

   AC支持对使用以下协议传输的文件进行病毒检测：
   - FTP（File Transfer Protocol）：文件传输协议
   - HTTP（Hypertext Transfer Protocol）：超文本传输协议
   - POP3（Post Office Protocol - Version 3）：邮局协议的第3个版本
   - SMTP（Simple Mail Transfer Protocol）：简单邮件传输协议
   - IMAP（Internet Message Access Protocol）：因特网信息访问协议
   - NFS（Network File System）：网络文件系统
   - SMB（Server Message Block）：文件共享服务器

   AC支持对不同传输方向上的文件进行病毒检测。
   - 上传：指客户端向服务器发送文件。
   - 下载：指服务器向客户端发送文件。

说明

由于协议的连接请求均由客户端发起，为了使连接可以成功建立，用户在配置攻击防御模板时需要确保将源区域设置为客户端所在的安全区域、将目的区域设置为服务器所在的安全区域。

举例1：trust区域的用户需要从untrust区域的FTP服务器下载文件，此时需要在攻击防御模板配置界面中将trust区域设置为源安全区域，untrust区域设置为目的安全区域，在反病毒配置界面中选择FTP协议的检测方向为下载。

举例2：trust区域的用户需要向dmz区域的SMTP服务器上传邮件，此时需要在攻击防御模板配置界面中将trust区域设置为源安全区域，dmz区域设置为目的安全区域，在反病毒配置界面中选择SMTP协议的检测方向为上传。

3. 病毒检测。

   智能感知引擎对符合病毒检测的文件进行特征提取，提取后的特征与病毒特征库中的特征进行匹配。如果匹配，则认为该文件为病毒文件，并按照模板中的响应动作进行处理。如果不匹配，则允许该文件通过。

   病毒特征库是由华为公司通过分析各种常见病毒特征而形成的。该特征库对各种常见的病毒特征进行了定义，同时为每种病毒特征都分配了一个唯一的病毒ID。当设备加载病毒特征库后，即可识别出特征库里已经定义过的病毒。同时，为了能够及时识别出最新的病毒，设备上的病毒特征库需要不断地从升级中心进行升级。

反病毒处理

当AC检测出传输文件为病毒文件时，需要进行如下处理：

1. 判断该病毒文件是否命中病毒例外。如果是病毒例外，则允许该文件通过。

   为了避免由于系统误报等原因造成文件传输失败等情况的发生，当用户认为已检测到的某个病毒为误报时，可以将该对应的病毒ID添加到病毒例外，使该病毒规则失效。如果检测结果命中了病毒例外，则该文件的响应动作为放行。

2. 如果不是病毒例外，则判断该病毒文件是否命中应用例外。如果是应用例外，则按照应用例外的响应动作（放行、告警和阻断）进行处理。

   应用例外可以为应用配置不同于协议的响应动作。应用承载于协议之上，同一协议上可以承载多种应用。例如，HTTP协议上可以承载163.com的应用，也可以承载yahoo.com的应用。

   由于应用和协议之间存在着这样的关系，在配置响应动作时也有如下规定：

   - 如果只配置协议的响应动作，则协议上承载的所有应用都继承协议的响应动作。
   - 如果协议和应用都配置了响应动作，则以应用的响应动作为准。

   例如，HTTP协议上承载了“163.com”和“yahoo.com”两种应用：

   - 如果只配置了HTTP协议的响应动作为“阻断”，则“163.com”和“yahoo.com”的响应动作也都继承为“阻断”。
   - 如果用户希望对“163.com”这个应用做区分处理，则可以将“163.com”添加为“应用例外”，其响应动作为“告警”。此时，“yahoo.com”的响应动作仍然继承HTTP协议的响应动作“阻断”，而“163.com”的响应动作将使用应用例外的响应动作“告警”。

3. 如果病毒文件既没命中病毒例外，也没命中应用例外，则按照模板中配置的协议和传输方向对应的响应动作进行处理。

   AC对不同协议在不同的文件传输方向上支持不同的响应动作，如下所示。

协议	传输方向	响应动作	说明
HTTP	上传/下载	告警/阻断，默认为阻断。	● 告警：允许病毒文件通过，同时生成病毒日志。 ● 阻断：禁止病毒文件通过，同时生成病毒日志。
FTP	上传/下载	告警/阻断，默认为阻断。	
NFS	上传/下载	告警	
SMB	上传/下载	告警/阻断，默认为阻断。	
SMTP	上传	告警	
POP3	下载	告警	
IMAP	上传/下载	告警	

27.18.3 反病毒使用限制和注意事项

配置反病毒特性之前请先阅读使用限制和注意事项。

使用限制

- 不支持针对断点续传文件的反病毒检测。
- 在IPv6组网中，针对IMAP、SMTP和POP3协议的反病毒功能不可用。
- 直接转发方式不支持反病毒功能。隧道转发方式下，同一AP下的无线二层用户之间在进行交互时，该功能不生效。

注意事项

- 反病毒特征库更新频繁，为保证反病毒功能的有效性，推荐每天升级一次反病毒特征库。
- 在报文来回路径不一致的组网环境中，针对SMTP、POP3和IMAP协议的反病毒功能不可用。

27.18.4 配置反病毒

介绍通过CLI方式配置反病毒的方法。

27.18.4.1 使能安全引擎

背景信息

在使用URL过滤、入侵防御、反病毒、智能应用控制、升级特征库等安全功能前，需要先开启设备上的安全引擎。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**defence engine enable**，使能设备上的安全引擎。

缺省情况下，安全引擎未使能。

----结束

27.18.4.2 升级反病毒特征库

及时升级反病毒特征库可以提升设备对病毒的检测能力和检测效率。

升级前准备

升级反病毒特征库之前请做好如下准备工作，保证升级成功完成。

- **检查根目录剩余空间**

  升级反病毒特征库前，需要确认设备根目录的剩余空间是否满足条件，反病毒特征库升级所需空间如下表所示。

特征库	空间
反病毒特征库（AV-SDB）	ACU2和AC6800V设备需要不少于65MB的空间，其他设备需要不少于8MB的空间。

  具体操作如下：

  a. 在用户视图下，执行命令**dir**查看根目录的剩余空间。

```
<HUAWEI> dir
Directory of flash:/

  Idx  Attr     Size(Byte)  Date        Time(LMT)  FileName
    0  -rw-          8,208  May 05 2016 17:50:47   AC.pat
                            ........
   56  drw-              -  May 13 2016 15:25:17   update
   57  -rw-        828,686  Apr 16 2016 10:04:37   url.so
   58  -rw-          1,511  May 12 2016 11:44:41   vrpcfg.zip

1,975,380 KB total (393,452 KB free)
```

  b. 如果剩余空间不足，需要删除无用文件。在用户视图下，执行命令**delete**删除CF卡中的无用文件。

  说明

  执行带**/unreserved**参数的**delete**命令后，文件将被直接删除，不能恢复。

- **检查当前升级状态**

  特征库升级不能并行操作，因此在特征库升级前，请确认当前的升级状态是否为空闲。只有升级状态为空闲时，才能进行升级操作。

  具体操作如下：

  a. 执行命令**display update status**查看当前特征库的升级状态。

```
<HUAWEI> display update status
 Current Update Status: Idle.
```

以上显示信息中，**Idle**表示处于空闲状态，可以进行升级操作。否则不能进行升级操作，请耐心等待并重复执行上述命令直至状态显示为**Idle**，才能进行升级操作。

- **检查特征库版本信息**

  升级反病毒特征库前，请确认反病毒特征库的版本信息，确认是否需要升级。

  具体操作如下：

  a. 执行命令**display version av-sdb**，查看待升级特征库的版本信息，从而确定是否需要升级。

```
<HUAWEI> display version av-sdb
AV SDB Update Information List:
-----------------------------------------------------------------
 Current Version:
   Signature Database Version    : 2016030400
   Signature Database Size(byte) : 6768274
   Update Time                   : 16:12:23 2016/05/14
   Issue Time of the Update File : 12:01:00 2016/03/04

 Backup Version:
   Signature Database Version    :
   Signature Database Size(byte) : 0
   Update Time                   : 00:00:00 0000/00/00
   Issue Time of the Update File : 00:00:00 0000/00/00
-----------------------------------------------------------------
```

背景信息

反病毒特征库支持在线升级和本地升级两种升级方式：

- 在线升级

  当AC可以直接通过互联网与升级中心进行通信，或者AC可以通过代理服务器与升级中心进行通信，此时可采用在线方式对反病毒特征库进行升级。

  在线升级又分为两种方式：

  – 定时升级

    AC定期连接升级中心检查是否存在新的反病毒特征库版本。如果升级中心存在新版本的反病毒特征库，AC会根据设定的时间自动下载并更新本地的反病毒特征库。

  – 立即升级

    当用户发现网络上出现新的反病毒特征库，而AC定时更新时间还没达到，或AC未启用定时更新，此时可以选择立即升级。

    立即升级使用的反病毒特征库的下载地址就是定时升级的下载地址，升级流程也与定时升级完全相同，区别在于立即升级不受时间限制，可以在任何时刻执行立即升级动作。

- 本地升级

  当AC与Internet物理隔离，且企业内网没有部署代理服务器时，可以采用本地升级方式。

关于特征库升级场景的详细说明请参见**27.16 升级特征库配置**。

在线升级

使用在线升级方式时，如果AC可直接访问升级中心，需要在AC上配置放行HTTP协议和FTP协议的安全策略；如果AC通过代理服务器访问升级中心，需在AC上配置放行HTTP协议的安全策略。

步骤1 配置升级中心。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**update server** { **domain** *domain-name* | **ip** *ip-address* } [**port** *port-number*]，配置升级中心的相关信息。

   默认域名为“sec.huawei.com”。

步骤2 **可选:** 配置代理服务器。

AC通过代理服务器连接升级中心时需要执行此步骤。

1. 执行命令**update proxy enable**，开启特征库代理升级功能。
2. 执行命令**update proxy** { **domain** *domain-name* | **ip** *ip-address* } [**port** *port-number*] [**user** *user-name* [**password** *password*]]，配置代理服务器的域名（或IP地址）和用户名及密码。

   说明

   如果代理服务器配置了域名，则必须配置DNS来解析域名，具体操作请参见**步骤3**。

步骤3 **可选:** 配置DNS服务器。

1. 执行命令**dns resolve**，启用DNS服务器的域名解析功能。
2. 执行命令**dns server** *ip-address*，配置DNS服务器的IP地址。

步骤4 **可选:** 指定在线升级请求报文的源IP地址。

- 执行命令**update host source** *interface-type interface-number*，指定接口的IP地址作为在线升级请求报文的源地址。
- 执行命令**update host source ip** *ip-address*，指定在线升级请求报文的源地址。

当管理员不指定在线升级请求报文的源IP地址时，系统将根据升级服务器的IP地址查找路由，并使用出接口的IP地址作为升级请求报文的源地址。

当接口下存在多个IP地址时，建议通过命令**update host source ip** *ip-address*直接指定升级请求报文的源地址，并确保AC可以收到响应报文。否则，可能无法正常在线升级。

步骤5 选择定时升级或立即升级。

说明

定时升级或立即升级启动后，若因为网速太慢而影响AC的业务性能时，可以执行命令**update abort**终止特征库升级的操作。等待网络环境改善后再执行命令**update online av-sdb**继续下载最新版本的特征库。

- 定时升级
  a. 执行命令**update schedule av-sdb enable**，开启特征库定时升级功能。
  b. 执行命令**update schedule av-sdb** { **hourly** *minute* | { **daily** | **weekly** { **Mon** | **Tue** | **Wed** | **Thu** | **Fri** | **Sat** | **Sun** } } *time* }，配置特征库定时升级的时间。

     建议反病毒特征库每天升级一次，请根据网络的实际情况进行调整。
- 立即升级

  执行命令**update online av-sdb**，下载最新版本。

----结束

本地升级

进行本地升级前需要管理员获得升级文件，并通过SFTP、FTP或TFTP方式将升级文件上传至AC的存储器中。

步骤1 下载升级包。

从安全中心平台（isecurity.huawei.com）下载特征库，具体下载升级包的步骤请参见升级中心。

步骤2 将升级包从PC上传至AC的存储器中。

说明

升级包放在AC存储器中哪个目录下都可以，一般建议放在根目录下。

特征库文件为.zip格式，无需解压缩，直接上传到AC即可。

步骤3 执行命令**system-view**，进入系统视图。

步骤4 执行命令**update local av-sdb file** *filename*，进行本地升级。

----结束

版本回退

当前使用的特征库出现故障时（如出现误报、系统性能下降），可以采用版本回退的方式将当前的特征库恢复至前一个版本。

版本回退只能回退一个版本，多次回退将在当前版本和可回退版本之间循环切换。

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**update rollback av-sdb**，将特征库的版本回退到可回退版本。

----结束

27.18.4.3 创建攻击防御模板

背景信息

随着网络的不断发展，网络攻击也由单纯的攻击报文转变为报文中存在各种各样的隐藏威胁（例如：木马、蠕虫、病毒等）。创建攻击防御模板后，用户可以实现URL过滤、反病毒、入侵防御等安全功能。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**defence-profile name** *profile-name*，创建攻击防御模板，并进入攻击防御模板视图。

缺省情况下，没有创建攻击防御模板。

----结束

27.18.4.4 配置反病毒模板

介绍反病毒特性的配置步骤。

背景信息

AC中存在一个反病毒的缺省配置文件，名称为default。缺省配置文件中已经定义了每种协议在上传或下载方向上的缺省动作，如下所示。缺省配置文件不能被修改和删除。

说明

通过命令**display profile type av name default**可以查看到缺省模板中的配置信息。通过命令行配置攻击防御模板引用缺省模板时，需要输入完整的模板名称（如**default**），否则无法成功引用。

表 27-30 反病毒的缺省模板

名称	协议	上传方向的病毒检测	下载方向的病毒检测	缺省的动作
default	HTTP	开启	开启	阻断
	FTP	开启	开启	阻断
	SMTP	开启	-	告警
	POP3	-	开启	告警
	IMAP	开启	开启	告警
	NFS	开启	开启	告警
	SMB	开启	开启	阻断
攻击取证：未开启 应用例外：未配置 病毒例外：未配置				

AC支持创建自定义配置文件，您可以根据需要，对每种协议应用不同的响应动作。

操作步骤

步骤1 在系统视图下创建反病毒模板。

profile type av name *name*

步骤2 **可选:** 配置反病毒模板的描述信息。

description *description*

步骤3 **可选:** 配置攻击取证功能。

collect-attack-evidence enable

说明

- 对于HTTPS流量，攻击取证功能不可用。
- 攻击取证功能仅用于故障定位，由于可能导致系统性能降低，所以请在必要时使用，并在攻击取证完成后关闭该功能。

步骤4 配置需要检测病毒的协议类型、流量方向以及检测到病毒后的响应动作。

协议	命令
HTTP	**http-detect direction** { **both** | **download** | **upload** } [**action** { **alert** | **block** }]
FTP	**ftp-detect direction** { **both** | **download** | **upload** } [**action** { **alert** | **block** }]
SMTP	**smtp-detect** [**action alert**]
POP3	**pop3-detect** [**action alert**]
IMAP	**imap-detect direction** { **both** | **download** | **upload** } [**action alert**]
NFS	**nfs-detect direction** { **both** | **download** | **upload** }
SMB	**smb-detect direction** { **both** | **download** | **upload** } [**action** { **alert** | **block** }]

步骤5 **可选:** 配置应用例外。

exception application name *name* [**action** { **alert** \| **allow** \| **block** }]

步骤6 **可选:** 配置病毒例外。

exception av-signature-id *av-signature-id* [**action** { **allow** \| **block-source-ip** [**timeout** *timeout*] }]

步骤7 在系统视图下提交配置。

engine configuration commit

创建或修改反病毒模板后，配置内容不会立即生效，需要执行提交操作来激活。因为激活过程所需时间较长，建议您完成所有对反病毒模板的操作后再统一进行提交。

步骤8 **可选:** 在系统视图下开启反病毒日志归并功能。

av log merge enable

开启反病毒日志归并功能后，当短时间内产生多条相同的反病毒日志时，系统会将多条日志归并成一条进行输出。

步骤9 **可选:** 在系统视图下开启提取PE文件完整Hash值。

av extract hash enable

开启提取PE文件完整Hash值后，当AC检测到PE文件中含有病毒，且响应动作为告警或宣告时，反病毒日志中将显示完整的Hash值。

----结束

后续处理

反病毒模板配置完成后，可以使用如下方式进行调整：

- 在反病毒模板视图使用**rename** *new-name*命令重命名已经存在的反病毒模板。
- 在系统视图下使用**profile type av copy** *old-name* [*new-name*]命令通过复制已经存在的反病毒模板来创建新的反病毒模板。

27.18.4.5 应用配置

背景信息

配置反病毒模板后，需要引用到攻击防御模板，然后将攻击防御模板引用到VAP模板、用户组或接口，使应用生效。

操作步骤

步骤1 在攻击防御模板中引用反病毒模板。

1. 执行命令**system-view**，进入系统视图。
2. 执行命令**defence-profile name** *profile-name*，进入攻击防御模板视图。
3. 执行命令**profile type av** *name*，将指定的反病毒模板引用到攻击防御模板。

   缺省情况下，攻击防御模板未引用反病毒模板。
4. 执行命令**quit**，返回系统视图。

步骤2 在VAP模板、用户组或接口引用攻击防御模板

- 在VAP模板中引用攻击防御模板
  a. 执行命令**wlan**，进入WLAN视图。
  b. 执行命令**vap-profile name** *profile-name*，进入VAP模板视图。
  c. 执行命令**defence-profile** *profile-name*，在VAP模板中引用攻击防御模板。

     缺省情况下，VAP模板未引用攻击防御模板。
- 在用户组中引用攻击防御模板
  a. 执行命令**user-group** *group-name*，进入用户组视图。
  b. 执行命令**defence-profile** *profile-name*，在用户组中引用攻击防御模板。

     缺省情况下，用户组未引用攻击防御模板。
- 在接口中引用攻击防御模板
  a. 执行命令**interface** *interface-type interface-number*，进入接口视图。
  b. 执行命令**defence-profile** *profile-name*，在接口中引用攻击防御模板。

     缺省情况下，接口未引用攻击防御模板。

----结束

检查配置结果

- 执行命令**display defence-profile** { **all** | **name** *profile-name* }，查看攻击防御模板的信息。
- 执行命令**display references defence-profile name** *profile-name* ，查看攻击防御模板的引用信息。

27.18.4.6 验证与检查

介绍反病毒特性配置完成后的验证与检查操作。

验证结果

反病毒特性配置完成后，可执行如下操作检查配置结果：

操作	命令
查看反病毒模板的信息	**display profile type av** [**name** *name* [**protocol** | **exception** { **application** | **av-signature-id** }]]
查看反病毒特征库中病毒家族或指定序号的病毒签名	**display av-signature** { *av-signature-id* | **database** }

反病毒特性配置完成后，可执行如下操作查看或清除统计信息：

操作	命令
查看反病毒的统计信息	**display av statistics**
清除反病毒的统计信息	**reset av statistics**

27.18.5 配置举例

介绍反病毒的配置举例。

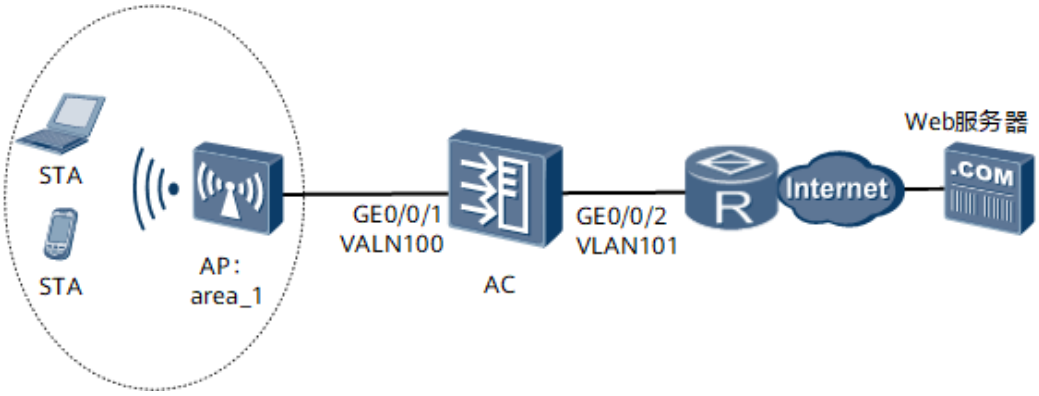
27.18.5.1 配置反病毒示例

组网需求

某公司在网络边界处部署了AC作为安全网关。内网用户需要通过Web服务器下载文件。公司利用AC提供的反病毒功能阻止病毒文件在这些过程中进入受保护网络，保障内网用户和服务器的安全。网络环境如图27-71所示。

其中，用户在通过Web服务器下载某重要软件时失败，排查发现该软件因被AC判定为病毒而被阻断（病毒ID为16424404），考虑到该软件的重要性和对该软件来源的信任，管理员决定临时放行该类病毒文件，以使用户可以成功下载该软件。

图 27-71 配置反病毒组网图



配置思路

1. 配置WLAN基本业务。
2. 配置反病毒模板，针对HTTP设置匹配条件和响应动作，并在该模板中配置病毒ID为16424404的病毒例外。
3. 配置攻击防御模板，引用反病毒模板，实现反病毒功能。
4. 配置VAP模板，引用攻击防御模板，使反病毒功能生效。

操作步骤

步骤1 配置WLAN基本业务，具体配置步骤请参照**9.14.1 配置小型网络WLAN基本业务示例（IPv4网络）**。

步骤2 使能安全引擎，配置反病毒模板。

1. 使能安全引擎。

```
<AC> system-view
[AC] defence engine enable
     It will take several minutes to initialize engine, please wait.
Info: Load the IPS signature database if IPS detection is required after license activation.
Info: Load the AV signature database if AV detection is required after license activation.
Info:Engine has been initialized successfully.
```

2. 创建攻击防范模板，模板名称为“defence_wlan”。

```
[AC] defence-profile name defence_wlan
[AC-defence-profile-defence_wlan] quit
```

3. 配置针对HTTP协议的反病毒模板。由于该反病毒模板只针对HTTP协议进行病毒检测，因此在HTTP协议的病毒检测功能配置完成后，同时关闭其它协议的病毒检测功能。

```
[AC] profile type av name av_http
[AC-profile-av-av_http] http-detect direction download action block
[AC-profile-av-av_http] exception av-signature-id 16424404
[AC-profile-av-av_http] undo ftp-detect
[AC-profile-av-av_http] undo smtp-detect
[AC-profile-av-av_http] undo pop3-detect
[AC-profile-av-av_http] undo imap-detect
[AC-profile-av-av_http] undo nfs-detect
[AC-profile-av-av_http] undo smb-detect
[AC-profile-av-av_http] quit
```

4. 配置攻击防御模板“defence_wlan”引用反病毒模板“av_http”。

```
[AC] defence-profile name defence_wlan
[AC-defence-profile-defence_wlan] profile type av av_http
[AC-defence-profile-defence_wlan] quit
```

步骤3 配置VAP的反病毒功能。

```
[AC] wlan
[AC-wlan-view] vap-profile name wlan-vap
[AC-wlan-vap-prof-wlan-vap] defence-profile defence_wlan
```

步骤4 结果验证

- 当内网用户通过HTTP协议下载带有病毒的文件时，下载连接被阻断。
- 内网用户下载某重要软件（被检测出病毒ID为16424404）不会被阻断。

可以通过EICAR测试文件的方式检查配置是否正确。

1. 构造EICAR测试文件，并进行压缩。

a. 在PC上新建一个“记事本”文件，输入以下内容：

X5O!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*

b. 保存文件时选择文件类型为“所有文件”，文件命名为“EICAR.COM”。

c. 把EICAR.COM文件压缩成文件eicar.zip。

2. 将EICAR测试文件的ID（16424404）加入病毒例外之前，测试HTTP下载方向反病毒是否生效。

   在Web服务器上制作一个包含eicar.zip下载路径的HTML页面。内网用户通过HTTP访问此页面并下载eicar.zip时，下载失败。

3. 将EICAR测试文件的ID（16424404）加入病毒例外之后，测试HTTP下载方向反病毒功能是否生效。

   通过HTTP可以正常传输EICAR测试文件，没有被阻断。

----结束

AC 的配置文件

```
#
 sysname AC
#
profile type av name av_http
 http-detect direction download
 undo ftp-detect
 undo smtp-detect
 undo pop3-detect
 undo imap-detect
 undo nfs-detect
 undo smb-detect
 exception av-signature-id 16424404
#
 defence engine enable
#
vlan batch 100 to 101
#
dhcp enable
#
defence-profile name defence_wlan
  profile type av av_http
#
interface Vlanif100
 ip address 10.23.100.1 255.255.255.0
 dhcp select interface
#
interface Vlanif101
 ip address 10.23.101.1 255.255.255.0
 dhcp select interface
#
interface GigabitEthernet0/0/1
 port link-type trunk
 port trunk pvid vlan 100
 port trunk allow-pass vlan 100
#
interface GigabitEthernet0/0/2
 port link-type trunk
 port trunk allow-pass vlan 101
#
capwap source interface vlanif100
#
wlan
 security-profile name wlan-security
  security wpa2 psk pass-phrase %^%#m"tz0f>~7.[`^6RWdzwCy16hJj/Mc!,}s`X*B]}A%^%# aes
 ssid-profile name wlan-ssid
```

```
 ssid wlan-net
vap-profile name wlan-vap
 forward-mode tunnel
 service-vlan vlan-id 101
 ssid-profile wlan-ssid
 security-profile wlan-security
 defence-profile defence_wlan
regulatory-domain-profile name domain1
ap-group name ap-group1
 regulatory-domain-profile domain1
 radio 0
  vap-profile wlan-vap wlan 1
 radio 1
  vap-profile wlan-vap wlan 1
ap-id 0 type-id 19 ap-mac 60de-4476-e360 ap-sn 210235554710CB000042
 ap-name area_1
 ap-group ap-group1
#
return
```

27.19 IAE 全局配置

介绍IAE（Intelligent Awareness Engine，智能感知引擎）全局性的功能配置，包括国家码、文件解压缩功能和阻断文件断点续传功能等配置。

27.19.1 简介

介绍IAE全局配置功能。

IAE全局配置主要用于指定IAE处理流量或文件的方式，配置结果会影响内容安全功能的检测效果。

IAE全局性的功能配置，包括国家码、文件解压缩功能、阻断文件断点续传功能和远程查询服务等配置。

- 国家码

  配置设备所在的国家，部署在同一区域内的云端服务器将为设备提供多种远程服务（例如用户体验计划等）。

- 文件解压缩功能

  AC支持对压缩文件解压后的内容进行过滤，通过设置不同的解压层数和解压文件大小，AC可以对多重压缩或超大压缩的文件进行监控和处理。

- 阻断文件断点续传功能

  AC支持阻断文件断点续传流量，可以提升设备的检测效率。

- 远程查询服务

  sec.huawei.com可以提供诸多远程服务，例如URL分类信息查询和文件信誉查询等。AC需要正确配置相关参数，才能成功获得远程查询服务。

27.19.2 IAE 全局配置使用限制和注意事项

配置IAE全局配置之前请先阅读使用限制和注意事项。

- IAE引擎的HTTP协议解码仅支持HTTP1.0/HTTP1.1版本，不支持HTTP2.0版本。因此相关内容安全特性均不支持检测HTTP2.0协议的HTTP流量，包括入侵防御、反病毒。
- 最大解压层数和最大解压文件的大小大于设定值会影响反病毒功能的检测结果。

- 缺省情况下，AC放行HTTP或FTP协议的文件断点续传流量。此时，反病毒和入侵防御功能不对该流量进行检测。
- 修改文件解压缩层数的上限值后，多层压缩的恶意文件可能会被AC放过，因为恶意文件的压缩层数超过了设定值。如果增大文件解压层数的上限值，AC的负荷也会相应增加，会对设备性能产生一定影响。所以，合理的设置IAE全局配置参数可以提升设备的检测效率，降低漏检率。一般来说，采用缺省的全局配置参数即可。

27.19.3 配置 IAE 全局配置

介绍通过CLI方式配置IAE全局配置参数的方法。

27.19.3.1 使能安全引擎

背景信息

在使用URL过滤、入侵防御、反病毒、智能应用控制、升级特征库等安全功能前，需要先开启设备上的安全引擎。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**defence engine enable**，使能设备上的安全引擎。

缺省情况下，安全引擎未使能。

----结束

27.19.3.2 配置阻断文件断点续传

AC支持阻断文件断点续传流量，可以提升设备的检测效率。

背景信息

现今很多服务器都支持HTTP和FTP协议的文件断点续传功能，即文件传输失败后，再次传输时可以从文件中间的某个断点开始，而不用从文件头开始。如果采用缺省配置，AC可能会放行从文件中间某个断点开始传输的流量。配置阻断文件断点续传后，AC可以识别出HTTP或FTP协议的断点续传流量并直接进行阻断。

操作步骤

步骤1 进入系统视图。

system-view

步骤2 配置阻断HTTP或FTP协议的文件断点续传。

file-frame breakpoint-resume-blocking protocol { **all** | **http** | **ftp** }

缺省情况下，AC放行HTTP或FTP协议的文件断点续传。

步骤3 提交配置进行编译。

engine configuration commit

配置阻断HTTP或FTP协议的文件断点续传后，配置内容不会立即生效，需要执行**engine configuration commit**命令来激活配置。因为激活过程所需时间较长，建议您完成所有对安全配置文件和全局配置的操作后再统一进行提交。

----结束

27.19.3.3 配置文件解压缩

AC支持对压缩文件解压后的内容进行过滤，通过设置不同的解压层数和解压文件大小，AC可以对多重压缩或超大压缩的文件进行监控和处理。

背景信息

AC基于流的方式检测压缩文件，解压缩和内容安全检测是同步进行的。如果数据流中包含威胁，AC将按照内容安全功能的配置进行处理。如果数据流是安全的，且文件的压缩层数或文件大小超过了设定值，AC将按照超过最大解压层数或最大解压文件大小时的响应动作进行处理：

- 允许：默认动作，不做任何处理，允许文件传输。
- 告警：允许文件传输并记录日志。
- 阻断：阻断文件传输并记录日志。

说明

- 由于设备不支持对NFS协议的阻断，因此当应用为NFS且动作为阻断时，设备将执行告警动作。
- 当应用为IMAP或POP3且动作为阻断时，设备将执行删除附件的动作。

操作步骤

步骤1 进入系统视图。

system-view

步骤2 配置最大解压层数。

file-frame decompress depth *decompress-depth*

缺省情况下，最大解压层数为3层。

步骤3 配置超过最大解压层数时的响应动作。

file-frame decompress depth action { **alert** | **allow** | **block** }

缺省情况下，超过最大解压层数时的响应动作为允许（**allow**）。

步骤4 配置最大解压文件大小。

file-frame decompress size *file-size*

缺省情况下，最大解压文件大小为100M。

步骤5 配置超过最大解压文件大小时的响应动作。

file-frame decompress size action { **alert** | **allow** | **block** }

缺省情况下，超过最大解压文件大小时的响应动作为允许（**allow**）。

步骤6 提交配置进行编译。

engine configuration commit

配置文件解压缩后，配置内容不会立即生效，需要执行**engine configuration commit**命令来激活配置。因为激活过程所需时间较长，建议您完成所有对安全配置文件和全局配置的操作后再统一进行提交。

----结束

27.20 业务与管理隔离配置

通过配置业务与管理隔离，可以提高管理网络的安全性。

背景信息

为提高网络安全性，防止攻击者通过业务网络对设备管理面造成攻击，需要在设备上配置**undo mgmt isolate disable**命令，禁止通过业务口访问设备管理面。例如，Telnet\SSH\HTTP\SNMP等管理协议会被禁止通过业务口接入。

操作步骤

步骤1 执行命令**system-view**，进入系统视图。

步骤2 执行命令**undo mgmt isolate disable**，开启管理面隔离功能。

缺省情况下，设备开启管理面隔离功能。

用户可执行命令**display mgmt interface**，查看设备的管理网口。

----结束

27.21 弱加密算法插件管理

背景信息

缺省情况下，WLAN AC仅支持配置强加密算法。如需配置MD5、DES、SSH1.0和SSL3.0等不安全的算法或协议，需要安装弱加密算法插件。

插件基本信息如**表27-31**所示。

表 27-31 插件基本信息

插件名称	文件名
弱加密算法插件	*AC型号-版本***ENABLEWEAKENCRYPTALGO.mod**

例如，AC6805的配套弱加密算法插件文件名为AC6805-V200R019C00ENABLEWEAKENCRYPTALGO.mod。

注意事项

V200R019C00之前的版本默认支持配置弱加密算法和协议。升级到V2R00R019C00及之后版本时，在未安装插件的情况下，已配置的弱加密算法和协议仍然有效。

说明

安装插件后，仍然推荐使用安全的加密算法和协议。

操作步骤

插件相关的操作方法请参见**4.8 插件管理**。